Support Security Control Management and Implementation in DevSecOps

A thesis submitted in fulfilment of the requirements for
the degree of Doctor of Philosophy

Maysa Sinan
Master of Information Technology - University of Melbourne
Bachelor of Computer Science - University of Jordan
ORCID 0009-0007-8642-8321

School of Computing Technologies
College of Science, Technology, Engineering and Maths
RMIT University
Australia

August, 2025

Declaration

I certify that except where due acknowledgment has been made, the work is that of the author alone; the work has not been submitted previously, in whole or in part, to qualify for any other academic award; the content of the thesis is the result of work which has been carried out since the official commencement date of the approved research program; any editorial work, paid or unpaid, carried out by a third party is acknowledged; and, ethics procedures and guidelines have been followed.

In addition, I certify that this submission contains no material previously submitted for award of any qualification at any other university or institution, unless approved for a joint-award with another institution, and acknowledge that no part of this work will, in the future, be used in a submission in my name, for any other qualification in any university or other tertiary institution without the prior approval of the University, and where applicable, any partner institution responsible for the joint-award of this degree. I acknowledge that copyright of any published works contained within this thesis resides with the copyright holder(s) of those works. I give permission for the digital version of my research submission to be made available on the web, via the University's digital research repository, unless permission has been granted by the University to restrict access for a period of time.

I acknowledge the support I have received for my research through the provision of an Australian Government Research Training Program Scholarship.

Maysa Sinan
School of Computer Technologies
College of Science, Technology, Engineering, and Mathematics
RMIT University

29 August 2025

Acknowledgement

First and foremost, I am deeply grateful to God, the Most Gracious and Most Merciful, for guiding me and blessing me with the strength, health, perseverance, and clarity of mind to complete this thesis.

I am grateful to my supervisor, Prof. Iqbal Gondal, for his academic mentorship and consistent encouragement throughout every stage of this research. His words and belief in me during difficult moments gave me the motivation to persevere and push through.

I am sincerely thankful to my supervisor, Dr. Mojtaba Shahin, for his incredible support and assistance, from swift responses and constructive feedback to his patience in guiding me step by step through publications and literature reviews. I am grateful for his willingness to attend multiple rehearsals with me ahead of my presentations.

I would like to thank the examination committee members for their time and providing valuable comments and suggestions on this thesis.

I am thankful to RMIT University for providing me with the opportunity and resources to pursue this study in an environment of academic excellence.

My heartfelt thanks to my family, especially my children, for their endless love and support. Without your encouragement, this journey would have been far more difficult. Your faith in me has been my greatest motivation.

Dedication

To my beloved father

Though you are no longer with us, your presence has never left me. Every step I took, every milestone I achieved, I did it all with the feeling that you are watching over me from above. Your words about my stubbornness, your strength, and your rigid belief in me continue to guide and inspire me every day in everything I do. I know that if you could see what I have accomplished, you would be proud, and I carry that thought with me always. I feel like the happiest person on earth when someone says that I am a reflection of you, especially when it comes to discipline, consistency, and determination.

To Ammar

My firstborn and my quiet source of inspiration. Your drive to improve, your discipline, and your relentless curiosity reassure me that greatness lies ahead for you. I still remember stealing quiet moments at your desk to work, not just to use space, but to soak up your energy and determination.

To Faisal

My deep thinker, my challenge, and my hope. I have always sought a special way to reach you, and I know that the gifts God placed in you are extraordinary. The moment you fully realize and use the potential within you, you will shake the world in the best of ways. I believe in you with all my heart.

To My Sunshine, Talia

You are my greatest achievement and my little twin. You have been my partner in dreams and crimes as well. Every time we put our heads together, I know we can conquer anything. You are my joy, my strength, and my living reminder that love is the most powerful force in the world.

Contents

Declaration ii

Acknowledgement iii

Dedication iv

List of Figures x

List of Tables xii

Abstract 1

1 Introduction 2
- 1.1 Background . . . 2
- 1.2 Motivation . . . 5
- 1.3 Research Scope and Main Objectives . . . 6
- 1.4 Thesis Contributions . . . 7
- 1.5 Thesis Outline and Publications . . . 9

2 Integrating Security Controls in DevSecOps: Challenges, Solutions, and Future Research Directions 11
- 2.1 Introduction . . . 12
  - 2.1.1 Aim and Contribution . . . 13
- 2.2 **Background and Related Work** . . . 13
  - 2.2.1 Security Controls . . . 13
  - 2.2.2 Standards and Best Practices for Implementing Security Controls . . . 15
  - 2.2.3 DevOps and IEEE 2675-2021 Standards . . . 17
  - 2.2.4 DevSecOps . . . 18
  - 2.2.5 Security Controls with CI/CD Pipelines . . . 19
  - 2.2.6 Existing Reviews on DevSecOps . . . 20
- 2.3 Research Methodology . . . 22
  - 2.3.1 Research Questions . . . 22
  - 2.3.2 Research Strategy . . . 22
  - 2.3.3 Digital Research Databases . . . 23
  - 2.3.4 Inclusion and Exclusion Criteria . . . 23
  - 2.3.5 Data Selection . . . 24
  - 2.3.6 Snowballing Technique . . . 25

2.3.7 Data Extraction . . . 27
2.3.8 Data Synthesis and Analysis . . . 27
2.4 Results and Discussion . . . 28
2.4.1 RQ1: Challenges related to security controls in DevSecOps . . . 28
2.4.2 RQ2: Solutions concerning the challenges related to security controls in DevSecOps . . . 38
2.5 Discussion, Research Gaps and Future Directions . . . 45
2.6 Limitations and Threats to Validity . . . 52
2.7 Conclusion . . . 53

3 Implementing and Integrating Security Controls: A Practitioners' Perspective 55
3.1 Introduction . . . 56
3.2 Background and Related Work . . . 58
3.2.1 Security Controls Maintenance . . . 58
3.2.2 Related Work . . . 59
3.2.3 Security Control and Emerging Trends . . . 61
3.2.3.1 Security Control Integration in AI Applications . . . 61
3.2.3.2 Security Control Integration in Cloud Services . . . 61
3.2.3.3 Security Control Integration in Zero-Trust Models . . . 62
3.3 Methodology . . . 62
3.3.1 Survey Design . . . 62
3.3.2 Potential Participants . . . 64
3.3.3 Data Analysis . . . 65
3.3.4 Validation of Survey Data . . . 66
3.4 Findings . . . 66
3.4.1 Demographics . . . 66
3.4.2 Classification of Security Controls . . . 68
3.4.2.1 In-house vs. outsourced . . . 68
3.4.2.2 Who handles security controls? . . . 68
3.4.2.3 Which types of security controls are implemented? . . . 70
3.4.3 Identification & Execution of Security Controls . . . 71
3.4.3.1 Activities in Security Controls Identification . . . 71
3.4.3.2 When to operate security controls? . . . 72
3.4.3.3 How often are security controls executed? . . . 72
3.4.3.4 Which events would trigger the execution of security controls? . . . 72
3.4.4 Compilation of Security Controls . . . 74
3.4.4.1 Handling evolving security controls . . . 74
3.4.4.2 Complying with regulations and privacy laws . . . 74
3.4.4.3 Practices to improve the effectiveness of security controls . . . 75
3.4.4.4 Security controls in DevSecOps . . . 75
3.4.4.5 Security practices in DevSecOps . . . 76
3.4.5 Validation of Security Controls . . . 77
3.4.5.1 How often to validate security controls? . . . 77
3.4.5.2 Who does security controls validation? . . . 78
3.4.5.3 Activities in security controls validation . . . 79
3.4.5.4 Influencers on security controls . . . 79

3.5 Discussions . . . 80
3.5.1 Analysis of Key Findings . . . 80
3.5.1.1 Security Controls Classification . . . 81
3.5.1.2 Security Controls Identification & Execution . . . 81
3.5.1.3 Security Controls Compilation . . . 82
3.5.1.4 Security Controls Validation . . . 83
3.5.1.5 Security Controls Awareness . . . 84
3.6 Implications . . . 84
3.6.1 Implications for Industry . . . 84
3.6.1.1 Need for Skilled Security Analysts in Governing and Troubleshooting Security Controls . . . 84
3.6.1.2 The Crucial Role of Advanced and Up-to-Date Tools . . . 85
3.6.1.3 The Financial Implication of Implementing Advanced Security controls 86
3.6.1.4 Learning from Past Experiences . . . 86
3.6.2 Implications for Research . . . 86
3.6.2.1 Guiding the Selection of the Right Security Frameworks . . . 86
3.6.2.2 Investigating the priority ranking of continuous security practices . . 87
3.7 Threats to Validity . . . 87
3.7.1 Internal validity . . . 87
3.7.2 External validity . . . 88
3.7.3 Construct Validity . . . 88
3.8 Conclusion . . . 89

4 Towards Resilient Security: A Structured Framework for Security Control Lifecycle Management 91
4.1 Introduction . . . 92
4.2 Background and Related Work . . . 93
4.2.1 Security Controls . . . 93
4.2.2 Security Control Maintenance . . . 93
4.2.3 Related Work . . . 94
4.3 Methodology . . . 95
4.3.1 Focus Group Design (Planning Stage) . . . 96
4.3.2 Potential Participants (Planning Stage) . . . 97
4.3.3 Run Focus Groups (Execution Stage) . . . 98
4.3.4 Data Analysis (Post-Session Stage) . . . 98
4.3.5 Verify Initial Draft . . . 100
4.4 Findings . . . 101
4.4.1 Security Control Identification / Classification . . . 102
4.4.1.1 Inputs . . . 102
4.4.1.2 Activities . . . 103
4.4.1.3 Outputs . . . 104
4.4.2 Security Control Assessment . . . 105
4.4.2.1 Inputs . . . 105
4.4.2.2 Activities . . . 106
4.4.2.3 Outputs . . . 107
4.4.3 Security Control Implementation . . . 108

4.4.3.1 Inputs . . . 108
4.4.3.2 Activities . . . 109
4.4.3.3 Outputs . . . 109
4.4.4 Security Control Verification . . . 110
4.4.4.1 Inputs . . . 110
4.4.4.2 Activities . . . 111
4.4.4.3 Outputs . . . 112
4.5 Discussion . . . 113
4.5.1 Analysis of Key Finding . . . 113
4.5.2 Implications to Practitioners . . . 115
4.5.3 Implications to Researchers . . . 116
4.5.4 The Benefits of our Framework . . . 118
4.5.5 Comparison with Existing Security Models and Standards . . . 119
4.6 Threats to Validity . . . 120
4.6.1 Internal validity . . . 120
4.6.2 External validity . . . 121
4.7 Conclusion . . . 121

5 Framework Verification **123**
5.1 Introduction . . . 123
5.2 Methodology for Framework Validation . . . 125
5.2.1 Member Checking (Individual Interview) . . . 125
5.2.2 Expert Focus Group Discussion . . . 125
5.2.3 Qualitative Data Analysis . . . 126
5.3 Results and Findings . . . 127
5.4 Discussion . . . 128
5.5 Conclusion . . . 129

6 Conclusion and Future Work **130**
6.1 Summary of Findings and Key Contributions . . . 130
6.2 Implications . . . 132
6.2.1 Implications for Industry Practice . . . 132
6.2.2 Implications for Researchers . . . 132
6.3 Limitations . . . 133
6.4 Future Research Directions . . . 133
6.4.1 Enhancing the proposed framework . . . 133
6.4.2 Automation in DevSecOps . . . 134
6.4.3 Cultural and socio-organizational perspectives . . . 134
6.5 Final Reflections . . . 134

Bibliography **136**

Appendix A **172**
List of Publications . . . 172

Appendix B **173**
Survey Instrument . . . 173

What was the purpose of conducting the survey? . . . 173
What did participation involve? . . . 173
What are the possible benfits for you if you take the survey? . . . 174
What are the possible risks for you if you take the survey? . . . 174
What about privacy and confidentiality? . . . 174
How do you give consent to participate in the survey? . . . 174
Contact the Research Team . . . 174
General Information on DevSecOps . . . 174
Demographic Questions: . . . 175
Survey Questionnaire . . . 176

Appendix C **183**
Guide on Conducting the Focus Groups . . . 183
General Information . . . 183
General Questions on Security Controls . . . 183
Questions on Tools and Technologies . . . 184
Questions on Current Practices and Challenges . . . 184
Questions on Security Control Validation . . . 184
Questions on Monitoring security controls for Regulatory and Security Compliance . . . 184
Questions on Directions and Future Opportunities . . . 184
Questions on Security Training and Culture . . . 184
Questions on DevSecOps Methodology . . . 184
Questions on Team Collaboration and Communication . . . 185

Appendix D **186**
Approved Human Ethics Application . . . 186

Appendix E **189**
List of Abbreviations / Acronyms . . . 189

Appendix F **190**

Appendix G **191**

Appendix H **192**

List of Figures

1.1 Categories of Security Controls . . . 3
1.2 The relation between continuous integration, deployment, and security compliance . . . 4
1.3 What is DevOps and How it Works? [1] . . . 5
1.4 The Structural Organization of the Thesis (An Overview of objectives, methodology, and chapter references). . . . 9

2.1 Steps of the study selection process . . . 24
2.2 Applying thematic analysis on a sample of collected data . . . 28
2.3 Solutions (Table 2.9) that address the challenges related to security controls in DevSecOps (Table 2.8), (***SLN**: Solution, ***CH**: Challenge) . . . 46

3.1 Steps of Survey Methodology . . . 65
3.2 Job Positions & Roles of Participants . . . 67
3.3 Respondents vs. years of cybersecurity experience . . . 67
3.4 Are security controls put in place? In-house or outsourced? . . . 68
3.5 Who implements security controls? . . . 70
3.6 Activities involved in Security Control Establishment . . . 72
3.7 When to execute security controls? . . . 73
3.8 How often are security controls executed? . . . 73
3.9 Which events would trigger the execution of security controls? . . . 73
3.10 What security standards/privacy laws do organizations comply with? . . . 75
3.11 Security controls in DevSecOps . . . 77
3.12 Security practices in DevSecOps . . . 78
3.13 How often are security controls being validated in your organization? . . . 78
3.14 Who poses the largest risk to security controls? . . . 79

4.1 The step-by-step methodology used for developing the framework, incorporating data collection, analysis, and validation to ensure reliability and effectiveness. . . . 96
4.2 Applying thematic analysis on a sample of imported transcripts (E.g. Security Compliance and Adhering to Security Standards) . . . 100
4.3 Overview of the Security Control Lifecycle (Classification, Assessment, Implementation, Verification), (***I**: Input, ***ACT**: Activity, ***O**: Output). . . . 102
4.4 Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Identification / Classification** . . . 104
4.5 Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Assessment** . . . 106

4.6 Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Implementation** 108
4.7 Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Verification** 111

5.1 Methodology for Verifying the Proposed Framework 124
5.2 Mapping of Participant Quotes to Codes and Emergent Themes Identified Through Thematic Analysis 127

List of Tables

1.1 Overview of research objectives, corresponding chapters, and the methodologies employed to address them . . . 7

2.1 The survival guide pyramid of James Wickett [2] . . . 12
2.2 Summary of Reviewed Studies on Security Control Implementation in DevSecOps Contexts: ***A**: Discussing the integration of security controls in DevSecOps. ***B**: Examining the challenges associated with implementing security controls in DevSecOps. ***C**: Suggesting solutions and workarounds related to security controls. ***D**: Pinpointing gaps and shortcomings in current DevSecOps security practices. (✓✓) The paper fully covers it, (✓) The paper partially covers it, (N/A) Not Applicable. . . . 21
2.3 Research questions addressed in this chapter . . . 22
2.4 Research string used to extract relevant papers . . . 23
2.5 Number of papers resulted from running Search Engine . . . 25
2.6 Primary papers investigated and used to conduct this SLR (***P**: Paper) . . . 25
2.7 ISO 27001:2022 Classification . . . 29
2.8 Challenges related to security controls in DevSecOps adoption, along with the papers contributed to those challenges (***CH**: Challenge, ***P**: Paper) . . . 35
2.9 Solutions found in literature and related to the challenges enlisted in Table 2.8, relating to security controls in DevSecOps (***SLN**: Solution, ***CH**: Challenge, ***P**: Paper) . . . 43

3.1 A subset of the survey close-ended questions. The complete survey is found in [3]. . . . 63
3.2 Comments raised in the pilot survey and their corresponding solution . . . 64
3.3 Classification of implemented security controls in respondents' organizations . . . 69
3.4 Which practical practices work best to improve the effectiveness of security controls? . . . 76
3.5 What tasks/activities does your organization carry out during the Security Controls Validation process? . . . 80

4.1 A subset of the open-ended questions that were asked in the focus groups . . . 97
4.2 Participants Contributed to the Focus Groups - Demographic Details. (***P**: Participant, ***CX**: Cybersecurity experience in years) . . . 99

5.1 Participants Contributed to member checking and focus groups - Demographic Details. (**CX**: Cybersecurity experience in years) . . . 125
5.2 Sample Questions (aligned with themes) . . . 127

Abstract

The increasing complexity and speed of modern software development have made security integration a critical priority, particularly in DevSecOps environments. Despite the growing adoption of DevSecOps practices, organizations continue to face significant challenges in implementing and managing security controls throughout the software development lifecycle (SDLC). This thesis presents four key contributions to the field of security controls in DevSecOps environments. Firstly, a Systematic Literature Review (SLR) was conducted to investigate the current state-of-the-art body of knowledge to identify the theoretical foundations and the research that has been carried out on security controls in DevSecOps contexts. The SLR investigated vital challenges experienced by organizations in their essential and continuous processes, along with associated solutions and significant implementation roadblocks. Secondly, a comprehensive survey study was carried out to capture the current state of practice, investigating practical aspects and how organizations implement and manage security controls in real-world settings. Third, a series of focus group sessions and in-depth discussions were conducted with security practitioners and subject matter experts to gain deeper insights and practical perspectives on the challenges and best practices in the field. The insights and findings obtained from the SLR and empirical studies (survey, focus groups, and in-depth discussions) have formed the foundational basis for the fourth and primary contribution of this study, which is the development and validation of a governance-based security framework. The framework aims to manage security controls throughout their entire lifecycle in DevSecOps environments. It is particularly valuable for ensuring consistency across the four phases of the security control lifecycle: classification, identification, implementation, and validation. In addition, the proposed framework is designed to be scalable, reliable, and adaptable to diverse organizational contexts. It provides a structured approach and actionable guidance for security practitioners to align essential security practices with business goals, while integrating seamlessly into DevSecOps workflows and maintaining a robust security posture across agile and continuous delivery settings. On the other hand, the proposed framework offers a practical contribution to the IT security field and lays the foundation for future research to address reported issues, practical gaps, and both strategic and operational business needs.

Chapter 1

Introduction

This chapter outlines the motivation, research objectives, and questions that guide this thesis. The subsequent sections detail the key contributions and provide an overview of the thesis structure

1.1 Background

In today's rapidly evolving digital landscape, characterized by the widespread adoption of open systems, organizations have started to undertake comprehensive digital transformation initiatives as a strategic response to maintain competitiveness and foster innovation [4]. As many enterprises strive for agility, innovation, and efficiency, they increasingly rely on interconnected systems and cloud-based applications [5]. Although these technological advancements, openness, and interconnectivity enable significant business benefits, they still present significant security challenges and simultaneously expose organizations to a wide array of cybersecurity threats [6]. The expansion of digital transformation, coupled with the proliferation of access points, has increased the exposure of critical systems and software, making them more susceptible to a broad spectrum of malicious cyberattacks and data breaches [7]. In response to elevated cyber risks, organizations have intensified their focus on the implementation of robust security controls [8]. Their efforts specifically aim to ensure the continuity and resilience of business operations by protecting systems against evolving cyber risks and safeguarding their digital infrastructure, including systems, applications, and organizational data [9] [10].

Recognizing that security controls constitute one of the fundamental pillars of strong and resilient cyber defense frameworks, organizations are increasingly prioritizing the implementation of comprehensive security controls and protective measures [11]. They form the backbone of a comprehensive cyber strategy, acting as the mechanisms that enable organizations to safeguard their organizational assets and digital systems against an increasingly complex and evolving threat landscape [12]. These controls are indispensable in maintaining the confidentiality, integrity, and availability of information [13] [14], while also supporting regulatory compliance and organizational risk management [15]. Without effective security controls, systems become vulnerable to malicious activities, including data breaches, malware infections, and unauthorized access [16]. Ultimately, building robust security controls is essential not only for minimizing the risk of cyber attacks but also for enhancing an organization's cyber resilience, ensuring its ability to anticipate, withstand, and recover from potential security incidents. As illustrated in Figure 1.1, security controls are broadly categorized into main categories, each addressing different aspects of organizational security [17]. **Administrative controls** encompass governance mechanisms such as policies, procedures, and risk assessments [18] [19] [20]. **Technical controls** involve the implementation of technological measures, including firewalls, multi-factor authentication,

and encryption solutions [21] [22]. **Physical controls** refer to tangible security mechanisms, such as surveillance cameras, biometric access systems, and closed-circuit television (CCTV) infrastructure [23]. **Network controls** such as firewalls, Virtual Private Networks (VPNs), and network segmentation that protect communication channels and prevent unauthorized access to networks [24]. **Cloud security controls** employ Identity and Access Management (IAM), encryption, and secure configuration practices to enhance protection in virtualized environments.

Beyond these traditional categories, additional classifications have emerged to address evolving security demands. **Detective controls** are designed to identify and monitor security incidents through intrusion detection systems (IDS) and audit logs. **Human-centric controls** emphasize the role of individuals in the security ecosystem, primarily through user training and awareness programs aimed at fostering secure behavior. **Corrective controls** focus on mitigating the impact of security incidents and facilitating recovery through effective strategies such as incident response planning and disaster recovery procedures. Simultaneously, intrusion detection systems (IDS) assist in the early detection of threats, training and awareness programs promote informed user behavior, and Incident Response Management (IRM) ensures prompt and effective response and recovery in the event of security incidents. **Application security controls** emphasize input validation and secure coding practices, whereas **data security controls**, such as encryption and Data Loss Prevention (DLP), protect data at rest and in transit. **Endpoint Detection and Response (EDR) controls** and antivirus mechanisms strengthen device-level defenses. Finally, adherence to **international security frameworks and standards**, like NIST[1], CIS[2], like ISO 27001[3], along with robust third-party risk management, ensures consistency, accountability, and resilience across all layers of the security architecture [25] [26].

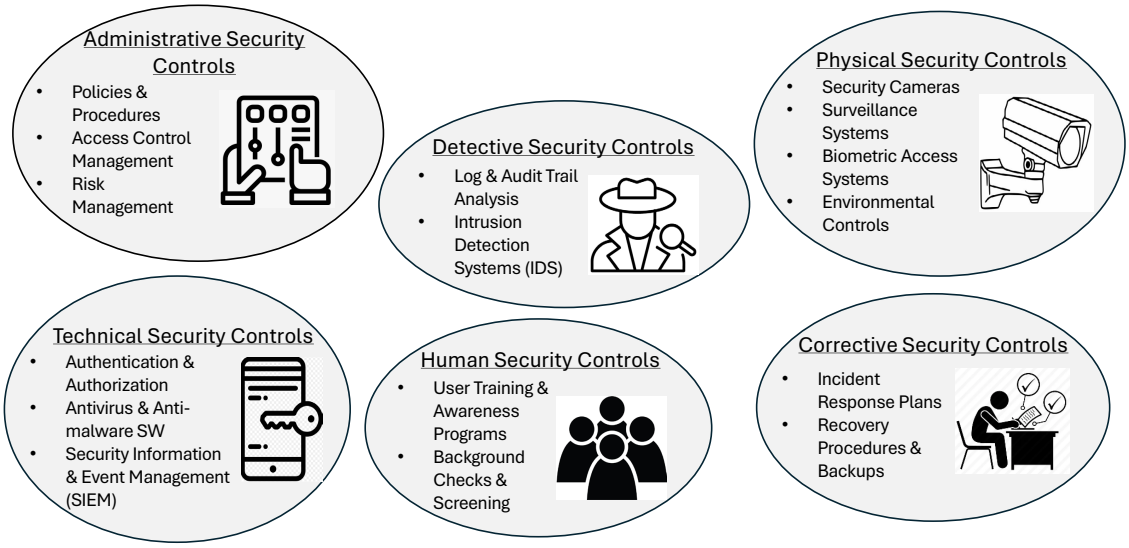

Figure 1.1: Categories of Security Controls

In general, software development teams are under constant pressure to deliver high-quality software rapidly and reliably. This demand has led to the leverage of Continuous Integration (CI) and Continuous Delivery (CD) pipelines to streamline software delivery (Figure 1.2). The CI/CD approach has become a core practice in Agile and DevOps methodologies, enabling developers to detect errors

[1]National Institute of Standards and Technology
[2]Center for Internet Security
[3]The International Organization for Standardization

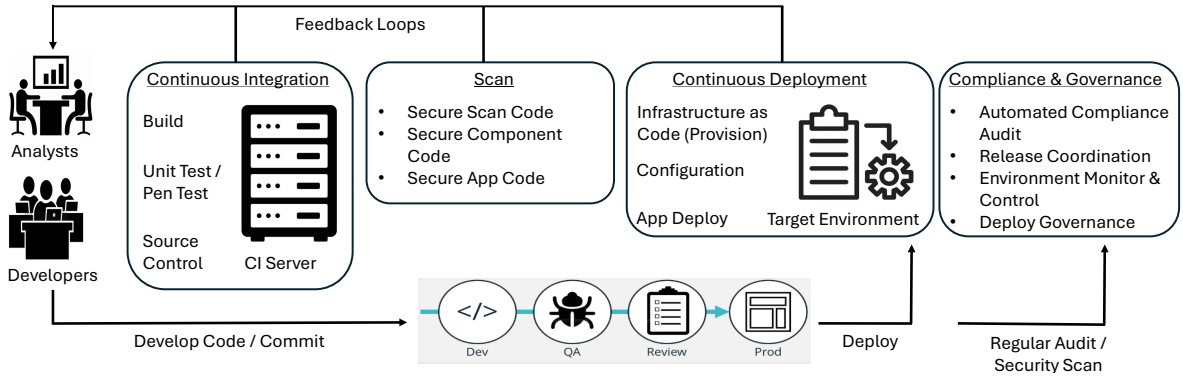

Figure 1.2: The relation between continuous integration, deployment, and security compliance

early, maintain consistent code quality, and optimize release time [27] [28]. It automates building, testing, and releasing software applications, thus introducing new security challenges [29]. As illustrated in Figure 1.2, CI/CD pipelines commonly integrate a variety of security controls using tools such as Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), Software Composition Analysis (SCA), Container Image Scanning, and Infrastructure as Code (IaC) [30] [31]. These tools help detect coding vulnerabilities, insecure third-party libraries, exposed secrets, and misconfigurations early in the development lifecycle [32]. Despite the wide availability of security tools, many organizations struggle to effectively integrate them into their development workflows. Common challenges include performance trade-offs, complex toolchains, lack of standardization, and limited developer awareness of security controls and broader cybersecurity best practices [33].

Traditional security practices, which are often applied manually late in the Software Development Life Cycle (SDLC), are no longer adequate to address the challenges of evolving threat landscapes and the demands of fast-paced, iterative development cycles [34]. In conventional approaches, security checks are conducted only after deployment, leading to increased risk exposure, a surge in supply chain attacks, and insecure dependencies that allow vulnerabilities to go undetected and propagate [35] [36]. In response to these limitations, DevSecOps has emerged as an evolution of DevOps that integrates security into every stage of the development process, embedding it directly within the CI/CD pipeline [37] [38] [39], as shown in Figure 1.3. The DevSecOps methodology is based on three fundamental principles. The first principle, known as "**shifting security to the left**," emphasizes the early integration and application of security controls during the development phase, rather than delaying them until final testing or post-deployment, where they are often overlooked or treated as an afterthought [40] [41] [42]. By embedding security controls directly into CI/CD pipelines and addressing vulnerabilities early in the development stages (design, coding, build), organizations can ensure continuous security while minimizing the cost and complexity of remediation [43] [44]. Consequently, overall code quality is enhanced, and product security is strengthened, all while preserving development speed and agility [45] [46] [47].

Regarding the second principle, "**automation**," it involves leveraging tools and technologies to continuously integrate and automate security tasks such as vulnerability scanning, risk assessment, threat modeling, and static/dynamic code analysis [48]. Automation enables consistent and scalable security practices that complement the speed and agility of DevOps workflows, helping to minimize manual errors, accelerate feedback loops, and ensure that security keeps pace with rapid release cycles [49] [49]. The third principle focuses on proactive "**collaboration**" among cross-functional teams, particularly between developers, operations personnel, and security practitioners to accelerate software

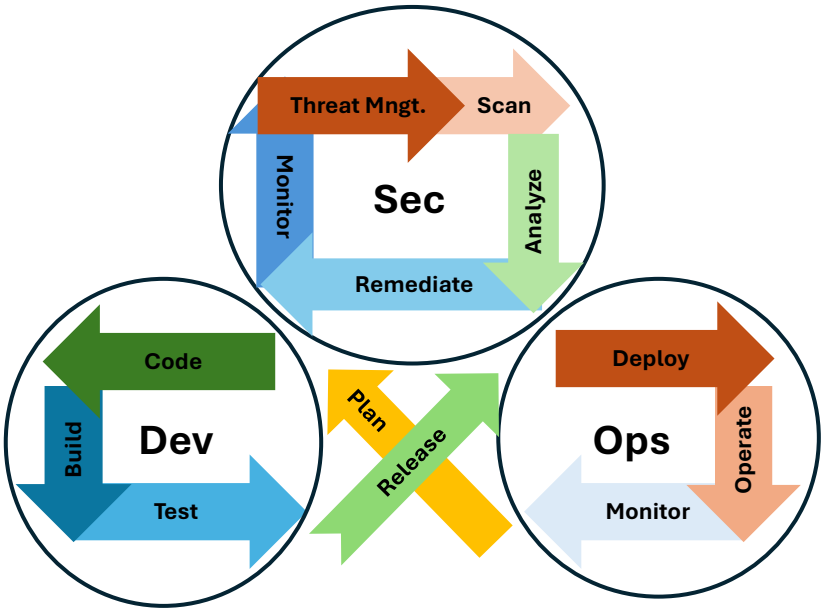

Figure 1.3: What is DevOps and How it Works? [1]

delivery [50]. DevSecOps fosters a culture of security awareness, open communication, and shared accountability in identifying and mitigating vulnerabilities, emphasizing that security is not solely the responsibility of dedicated security teams but a collective duty of all stakeholders involved in the software development process [50] [51]. Consequently, this approach enables organizations to bridge the gap between functionality, performance, and protection [52] [53].

1.2 Motivation

Integrating security into fast-paced development environments and emerging technologies such as DevSecOps practices, AI methods, and Zero Trust Architectures (ZTA), requires cultural transformation, specialized expertise, and investment in modern toolchains. However, security practitioners still encounter several critical challenges when implementing security controls within DevSecOps environments. These include insufficient integration of security mechanisms within agile development pipelines, limited automation and scalability of security testing processes, and cultural resistance from development teams who perceive security measures as impediments to rapid delivery [54] [55]. Furthermore, the absence of unified governance frameworks and the fragmentation of security tools complicate the consistent application and monitoring of controls in continuous integration and deployment workflows [56].

In recent years, both academic and industry communities have increasingly focused on DevSecOps, particularly on identifying the most effective tools, processes, and skill sets required for security practitioners to successfully integrate security into the Software Development Life Cycle (SDLC) [57]. Although substantial research has explored security integration and tooling strategies within DevOps practices [58], the literature still lacks a comprehensive focus on the systematic implementation and governance of security controls. Despite the numerous benefits of adopting DevSecOps and automating security practices within CI/CD pipelines, security practitioners continue to face significant challenges [59] [60]. Such challenges and obstacles extend to process disruptions, tool compatibility, resource

limitations, and cost implications [37] [61] [62]. Addressing these challenges is essential to enable effective and seamless implementation of security controls throughout the various phases of the SDLC [63]. This involves the development of frameworks, best practices, and automation strategies that foster consistent and scalable security integration without disrupting development workflows or delaying project delivery.

Problem Statement: Despite the growing adoption of DevSecOps practices, security practitioners continue to face significant challenges when implementing and integrating security controls into the continuous and fast-paced workflows of modern software development environments. Key obstacles include the difficulty of integrating controls without slowing delivery, limited automation and standardization of security testing, and inconsistent governance and monitoring mechanisms. These obstacles create a tension between rapid development and robust security, which can often hinder the Software Development Lifecycle (SDLC) and lead to friction between development speed and secure practices. This thesis aims to bridge the gap between the theoretical and practical aspects of implementing security controls, and consequently, addresses these challenges by developing a governance framework to guide their seamless integration, automation, and oversight of security controls in DevSecOps environments.

This research is motivated by the need to gain a deeper understanding of the current security landscape within DevSecOps and to identify the prevailing challenges. Based on these insights, it aims to develop a framework or guidance to help security practitioners more effectively integrate security controls into continuous security practices. Addressing this gap is crucial for enhancing cyber resilience, advancing security maturity, and ensuring the sustainability of DevSecOps implementations within complex and dynamic software environments. The significance of this research lies in its potential to tackle the practical difficulties faced by security practitioners in implementing modern security controls. Without addressing these issues sufficiently, or if outdated methods are employed, the effectiveness of integrating security controls may be significantly undermined. This, in turn, can hinder the successful implementation of DevSecOps practices, reducing their intended benefits and obstructing the enforcement of continuous security throughout the development lifecycle.

1.3 Research Scope and Main Objectives

The primary objective of this research is to investigate and enhance the integration of security controls within the implementation of DevSecOps practices. To achieve this, four overarching objectives were formulated and presented in the sequence shown in Table 1.1. The table also indicates the corresponding chapter where each objective is addressed, along with the methodology used to accomplish it. First, examine the current state of security control implementation within the execution of DevSecOps. Therefore, a Systematic Literature Review (SLR) was conducted to enhance the existing body of knowledge on security controls within the practical implementation of DevSecOps practices, with a focus on adopted tools and methodologies. The SLR addressed three research sub-questions and offered an empirical understanding of the real-world challenges encountered by security practitioners when integrating security controls within DevSecOps environments. The impact of these challenges on development workflows, resource allocation, tool effectiveness, and project timelines was examined through thematic and systematic analysis. Based on the findings, the SLR also proposed potential solutions to address these issues and identified key research gaps and limitations.

The second objective was to empirically investigate how security practitioners implement and man-

age security controls within their organizational environments. This objective was addressed through a survey that examined and evaluated real-world practices and security approaches, along with their practical effectiveness. The third objective was to propose a comprehensive security framework that incorporates practical strategies, best practices, and recommendations to improve the implementation of security controls. This framework aims to enable consistent and scalable security assurance while aligning with modern software engineering practices. In the end, we verified the framework to ensure its effectiveness and readiness for deployment in real-world IT environments.

In this thesis, we adopted a multi-method research design to comprehensively achieve these objectives and to ensure a coherent integration of theoretical and empirical perspectives. The SLR was first conducted to achieve Objective 1 (see Table 1.1), as this method provides a rigorous and transparent process for synthesizing existing knowledge, critically evaluating prior studies, and identifying research gaps that define the state-of-the-art. To achieve Objective 2, the online survey was employed because it enables the collection of quantifiable data from a diverse range of professionals, thereby capturing the state-of-practice and examining how organizations practically implement security controls in real-world settings. Finally, to achieve Objectives 3 and 4, the focus groups were conducted with subject matter experts and security practitioners, as this qualitative approach facilitates in-depth discussion, elicits expert insights, and supports the refinement and validation of the proposed governance framework.

Table 1.1: Overview of research objectives, corresponding chapters, and the methodologies employed to address them

High-level Research Objectives	**Chapter#**	**Research Method**
Objective 1. Explore the challenges organizations encounter integrating security controls in DevSecOps, along with associated solutions and gaps.	Chapter 2	Systematic Literature Review (State-of-art)
Objective 2. Empirically investigate how security practitioners implement and manage security controls in real-world settings.	Chapter 3	Online Survey (State-of-practice)
Objective 3. Develop a relaibale and scalable framework providing more opportunities for enhancing the integration of security controls across different phases of the SDLC.	Chapter 4	Focus Groups
Objective 4. Verify the developed framework to ensure its reliability, adaptability, compatibility, and readiness for deployment in the IT industry.	Chapter 5	**(1)** Member-checking **(2)** Focus group with the ITS dept.

1.4 Thesis Contributions

The key contributions of this study are categorized into the following areas.

1. A systematic literature review (SLR) of 45 primary studies that examined security controls within DevSecOps environments, focusing on their integration into CI/CD pipelines and the implementation of continuous security practices (**Chapter** 2).
    - Build a strong foundational understanding in three critical areas: security controls, DevSecOps, and CI/CD pipelines, with particular emphasis on embedding security controls into core continuous security practices.
    - A taxonomy of challenges, issues, and corresponding solutions identified in the literature, aimed at bridging existing gaps and addressing limitations in current practices.

- A set of research gaps and unresolved issues that call for further investigation, as well as critical areas that organizations and researchers must thoughtfully consider to enhance the effective implementation of security controls.

2. A survey study was conducted to capture the current state-of-practice and examine how security practitioners genuinely embed and manage security controls within software development environments (**Chapter** 3).

   - Design and deploy a public online survey via Qualtrics, allowing software practitioners and security analysts to securely and anonymously access and complete the questionnaire.
   - A total of 118 responses were gathered from software practitioners and analysts employed in diverse organizations across multiple sectors, including government, finance, insurance, and telecommunications.
   - The survey findings highlighted the importance of effective and seamless integration for security controls into DevSecOps and CI/CD pipelines, while maintaining the speed and agility of development processes through continuous and automated security practices.
   - It shed light on managing security controls internally through dedicated in-house teams, demonstrating strong internal capabilities and clear ownership of security controls.
   - The survey results reported organizational adherence and security compliance with international standards and privacy regulations, including GDPR[4], PCI DSS[5], ISO 27001[6], APRA CPS[7], and IEC 62443[8].
   - The survey captured the essential role of the complete lifecycle of security controls, encompassing the identification and classification of security risks, followed by the implementation, monitoring, and ongoing validation of security controls.

3. Design a comprehensive framework tailored to the IT industry, intended to provide security practitioners with structured guidance for effectively implementing and seamlessly integrating security controls across organizational processes (**Chapter** 4).

   - The framework was specifically informed by insights and perspectives gathered through focus group discussions with subject matter experts (SMEs) and security analysts, ensuring it addresses their distinct needs and challenges.
   - Not only did the framework facilitate the implementation of security controls, but it also ensured their seamless integration into existing organizational processes and adherence with international security standards and business objectives (e.g. ISO[9], NIST[10], GDPR[11], HPAA[12]).
   - It ensures that essential security practices are properly automated and actively operated to achieve a resilient overall cybersecurity posture within the organization.

[4] General Data Protection Regulation
[5] Payment Card Industry Data Security Standard
[6] The International Organization for Standardization
[7] Australian Prudential Regulation Authority
[8] International Electrotechnical Commission
[9] International Organization for Standardization
[10] National Institute of Standards and Technology
[11] General Data Protection Regulation
[12] Health Insurance Portability and Accountability Act

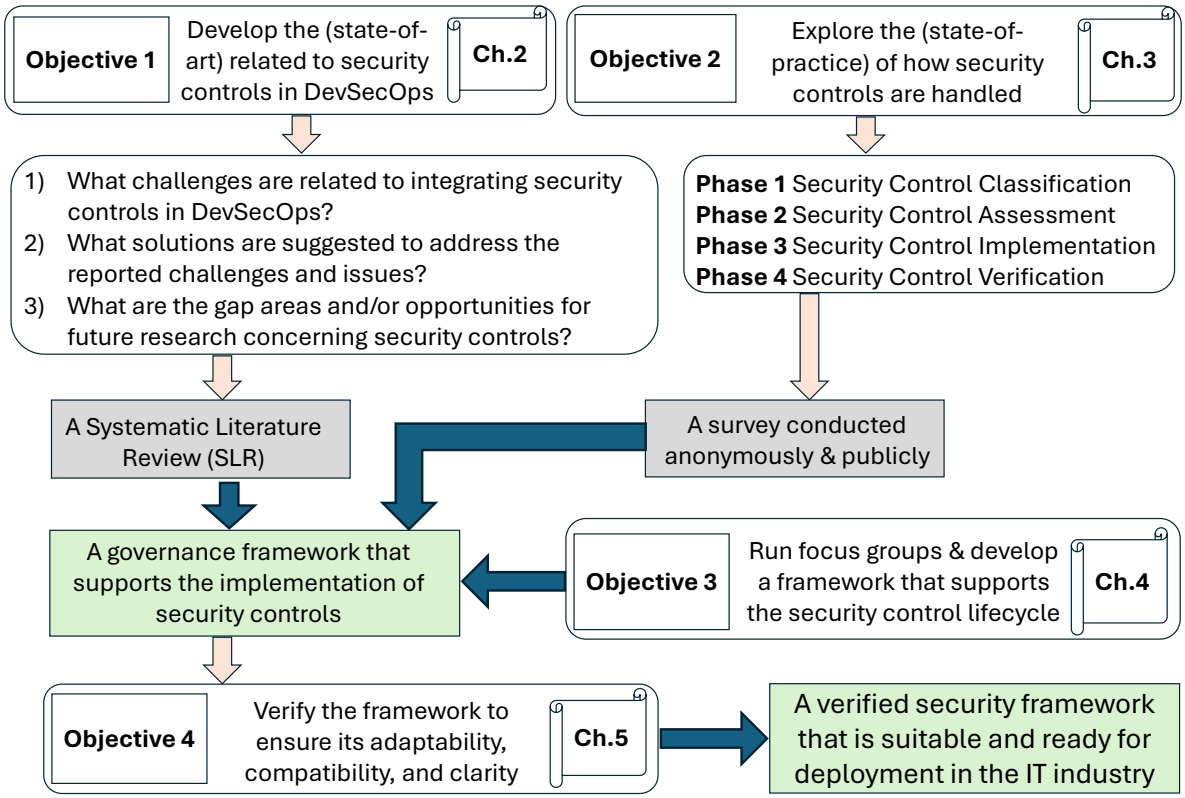

Figure 1.4: The Structural Organization of the Thesis (An Overview of objectives, methodology, and chapter references).

4. Verify and validate the presented framework to assess its adaptability, reliability, and practical suitability for real-world deployment within the IT industry (**Chapter** 5).

    - Conduct member checking to confirm the framework's scalability, compatibility, and readiness for deployment across organizations of varying sizes and sectors, including large enterprises as well as small and medium-sized enterprises (SMEs).
    - An in-depth focus group session was carried out with subject matter experts working in the ITS department of a major governmental university in Australia. The primary objective was to rigorously assess the comprehensiveness of the framework and verify the inclusion of all essential security practices. In addition, participants confirmed its compatibility with both traditional and agile development methodologies, as well as its relevance to emerging technology environments.

1.5 Thesis Outline and Publications

The thesis consists of six chapters. Figure 1.4 illustrates the structure and organization of the chapters that address research questions and primary objectives as follows:

Chapter 1 This chapter introduces the thesis by presenting the research background, defining key terminologies, outlining the motivation and research questions, highlighting the main contributions,

and describing the overall structure of the thesis.

Chapter 2 This chapter addresses three research sub-questions through a systematic literature review (SLR), focusing on the implementation and management of security controls within the context of DevSecOps adoption. It represents the culmination of the state-of-the-art review and the establishment of a theoretical foundation and body of knowledge on the management and handling of security controls within DevSecOps environments. This chapter has been published as [64]:

- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Integrating Security Controls in DevSecOps: Challenges, Solutions, and Future Research Directions*", Journal of Software: Evolution and Process, 2025.

Chapter 3 This chapter describes the empirical investigation conducted through a survey aimed at capturing valuable insights into how security controls are implemented and maintained across organizations of varying sizes and sectors. The chapter systematically outlines the methodology employed to design and administer the survey, followed by a presentation of responses collected anonymously from software practitioners. The findings were critically examined and discussed to derive meaningful conclusions. This chapter has been published as [65]:

- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Implementing and Integrating Security Controls: A Practitioners' Perspective*", Computers & Security, 2025 (**SCImago-Q1**).

Chapter 4 This chapter presents the main contribution of the thesis and details the development of a comprehensive governance framework for security controls. The framework was created with the objective of being scalable, reliable, and practical, serving as a valuable tool to support security practitioners in their operational and security tasks. The framework integrates a broad set of best practices and essential security control activities across all phases of the security control lifecycle, making it both comprehensive and actionable for security analysts and practitioners. It was developed based on a rich set of valuable insights and perspectives gathered through multiple focus groups and in-depth discussions with security practitioners. This chapter has been published and is currently being reviewed.

- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Towards Resilient Security: A Structured Framework for Security Control Lifecycle Management*", International Journal of Information Security.

Chapter 5 This chapter outlines the process undertaken to verify the proposed framework. To ensure its effectiveness and suitability for real-world deployment in the IT industry, the framework was rigorously validated using multiple methods, including focus groups and member checking. This chapter has been submitted to the IEEE TrustCom conference and has been accepted for presentation.

- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Validation of a Governance Framework Supporting Security Controls across Emerging Systems*", the 24th IEEE International Conference on Trust, Security and Privacy in Computing and Communications in China, 2025.

Chapter 6 This concluding chapter wraps up the thesis by synthesizing the key elements, addressing the research questions, and presenting the main contributions. Furthermore, it discusses the broader implications of the findings for both academic research and industry practice, while also highlighting the study's limitations through a critical reflection on its scope and constraints. Finally, it outlines potential directions for future research and closes with a reflection on the study's overall contribution and its significance within the field of cybersecurity.

Chapter 2

Integrating Security Controls in DevSecOps: Challenges, Solutions, and Future Research Directions

This chapter is published and available online:
M. Sinan, M. Shahin, I. Gondal, Integrating security controls in DevSecOps: Challenges, solutions, and future research directions, Journal of Software: Evolution and Process (2025).

Cybersecurity has become a top priority for most organizations to protect their applications. The rapid increase in cyberattacks has necessitated a comprehensive repositioning of how security should be implemented within the software development lifecycle (SDLC). DevSecOps (Development, Security, Operations) is one of the trendy security methodologies and fastest-growing development methods, promoting shared responsibility for security and automating security practices at every step of the SDLC. DevSecOps is a cultural shift that integrates security controls into DevOps pipelines aiming to upscale overall security. Therefore, many organizations started to incorporate security controls within the deployment of DevSecOps through conducting continuous practices, e.g., Automated Security Testing, Infrastructure as Code (IaC), Compliance as Code, and Continuous Monitoring. This chapter aims to organize the knowledge and shed light on challenges concerning security controls during the adoption of DevSecOps, along with associated solutions and remediation workarounds reported in the literature. Further, the chapter aims to provide clear insights into the areas that require further investigation and research in the future. A Systematic Literature Review (SLR) of 45 primary studies was carried out to extract data, and subsequently, the extracted data were analyzed using the Thematic Analysis method. This chapter identifies **19** challenges related to security controls that could be experienced by security practitioners while implementing a DevSecOps model, along with **18** solutions and remediation actions suggested in the literature to address and overcome some of the listed challenges. In addition, some gap areas are identified as opportunities for future research in this domain with the aim of improving the integration of security controls in a DevSecOps environment. Based on findings, this chapter points out the importance of automation in software engineering practices, e.g., continuous automation, continuous delivery, and continuous feedback, to embed security controls at the early stages of the development process.

2.1 Introduction

Cybersecurity has become necessary within the SDLC in response to increasing threats [53]. In traditional delivery methods, IT Service Management (ITSM) supports software applications by developing end-to-end delivery processes, keeping an eye on compliance and adherence to organizational policies [66] [67]. In such models (e.g., waterfall), security controls are an afterthought, limited in scope, and often tackled and tweaked by security teams after Quality Assurance (QA) processes are completed [68]. On the other hand, Software Development as a Service (SDaaS) has become crucial for many organizations due to its flexibility, cost-effectiveness, and the efficiency it brings to the software development process [69]. Moreover, SDaaS allows companies to scale up or down based on project needs, avoiding the high costs associated with recruiting or downsizing staff. It also enables software engineers to stay up-to-date with the latest technologies, ensuring that their projects and applications are developed with best-practices and cutting-edge tools. In the DevSecOps methodology, security analysts progressively integrate and streamline security controls at every phase of the SDLC (from design to build) with minimal disruption [70]. DevSecOps aims to automate continuous security practices in DevOps layers and empower the mantra 'software, safer, sooner' during the delivery process without slowing down deliveries [71]. The hypothesis of enhancing security seamlessly within DevOps activities as agile as possible has contributed to the main concept of DevSecOps [72]. Given this, developers are encouraged to take responsibility and participate in security analysis and discussions related to application infrastructures. They are expected to flag insecure choices, present effective findings, and escalate/share contingency workarounds with DevSecOps engineers for future improvements [73] [74].

DevSecOps and Agile are complementary methodologies that provide the opportunity to left-shift security and build software in tandem with continuous security practices. Such methods require high levels of effective team collaboration to maintain security compliance and accelerated agile work cycles until applications are implemented at customer sites [75]. DevSecOps also highlights the need for knowledge sharing to achieve a superior security culture. Researchers conducted studies on Open Web Application Security Projects (OWASP) to develop reliable approaches such as the survival guide pyramid to overcome the limitations of obsolete security practices that might decrease the benefits of DevSecOps [2], as in Table 2.1.

Table 2.1: The survival guide pyramid of James Wickett [2]

Underpin	**Description**
Defensible	Solid security controls and configuration settings are put in place with consistency
Operational	Transactional data is managed collaboratively with the focus on security awareness and effective interaction between development and operation teams
Situational Awareness	System updates are monitored closely to determine potential cyber attacks and adversary effects
Contradict Measurements	Efficient responses are prompted whilst preventive plans and communication strategies are held.

Security controls in DevSecOps interfaces are indispensable to ensure a robust security posture throughout the Software Development Lifecycle (SDLC). They are essential to protect sensitive data while meeting regulatory and security requirements [76]. Security controls integrated early in the development process help detect and address security weaknesses and vulnerabilities at the initial stages, reducing the cost and effort of fixing them later. On the other hand, they are important to facilitate uninterrupted delivery and execution of continuous practices without compromising overall security

[77]. Integrating security controls into CI/CD pipelines ensures that security-as-code audits are an integral part of the development process [78]. In contrast, immediate feedback on security issues allows software engineers and developers to address issues quickly while maintaining a stable pace of development.

2.1.1 Aim and Contribution

Shifting from conventional methods to DevSecOps and addressing security issues at early stages are declared challenging [79]. It is indispensable for security practitioners to explore existing issues concerning security controls that may arise during the implementation of DevSecOps and hinder the development process. This SLR is designed to provide value not only to software engineers, but also to professionals from related disciplines and roles, including infrastructure engineers, operations engineers, security engineers, and site reliability engineers (SREs). The recommendations related to security controls can address the challenges and opportunities that may arise during the integration of security controls within DevSecOps. This chapter classifies the challenges related to security controls and thematically analyzes the suggested solutions proposed in the literature to address the reported challenges/issues. Security practitioners can use it as a base to conduct further research on implementing security controls, as it explains the research gaps related to building security controls in the continuous operation of DevSecOps. From SLR studies, valuable lessons can be learned to drive innovation and improvements in DevSecOps processes [80].

2.2 Background and Related Work

This section provides the background and summarises the existing review papers concerning security controls in DevSecOps.

2.2.1 Security Controls

Security controls, or security measures, are specific mechanisms/safeguards used to protect organizational assets and systems from cyber-attacks. They are fundamental components implemented to mitigate vulnerabilities in software applications and reduce the impact of security incidents in tandem for better data protection, risk assessments, and security compliance with the guidelines outlined by NIST[1] and ISO 27001[2] frameworks [81] [82]. Security controls are usually customized based upon organizational regulations, risk profiles, and compliance strategies [83] [84], and categorized as follows:

1. *Administrative Controls* that govern security practices and play a critical role in managing information quality within Security Management Systems Enterprises (SMSEs), with alignment to NIST[3] and ISO 27001[4] standards [85]:
   a) Security policies and procedures (e.g., formal documents, organizational guidelines).
   b) Security Education Training Awareness (SETA) to educate employees about security best practices and prevalent threats.
   c) Access Control Policies (ACP) for provisioning and de-provisioning user access requests to systems and data.

[1] National Institute of Standards and Technology
[2] International Organization for Standardization
[3] National Institute of Standards and Technology
[4] International Organization for Standardization

   d) Incident Response Management (IRM) to develop effective response plans and defend quickly against attacks.
   e) Risk Assessments to identify security risks and run periodic evaluations.
2. *Technical Controls* that are implemented through software automation to prevent developers from risky behaviors [86]:
   a) Authentication and Authorization mechanisms to verify user identities and check access requests.
   b) Intrusion Detection/Prevention Systems (IDS/IPS) to monitor, detect, and protect networks from unauthorized access or malicious activities.
   c) Encryption methods to convert data into cipher texts and make information accessible only to authorized users with special decryption keys.
   d) Antivirus and anti-malware functions to detect and remove malicious software.
   e) Patch management to ensure that systems are up-to-date with security.
   f) Security Information and Event Management (SIEM) to perform a real-time security analysis for incidents and events.
3. *Physical Controls* that protect materialistic assets [87]:
   a) Access Control Systems and secure facilitates to restrict entry/access to data centers (e.g., keycards, biometrics).
   b) Install surveillance and monitoring security cameras to detect unauthorized physical access.
   c) Environmental Control Systems to adjust/regulate server temperature, humidity, and fire protection.
4. *Network Security Controls* to protect networks [88]:
   a) Firewall devices to filter/control incoming and outgoing traffic and protect against malicious threats and web-based attacks [89].
   b) Virtual Private Networks (VPNs) to secure remote access and data transmission traffic.
   c) Apply network segmentation to divide the network into segments and isolate and protect sensitive systems.
5. *Application Security Controls* to protect onboarded software applications [90]:
   a) Carry out validation procedures to ensure user inputs are thoroughly checked for vulnerabilities.
   b) Implement manual and automatic code reviews to identify security bugs.
6. *Data Security Controls* like Data Loss Prevention (DLP) and data encryption algorithms to protect data at rest and in-transit modes from unauthorized data sharing and avoid data-breaches [91].
7. *Cloud Security Controls* like Identity and Access Management (IAM), setting up configuration rules and installing encryption methods to improve user authentication, authorization, and access control within cloud-based systems [92].
8. *Endpoint Security Controls* like Endpoint Detection and Response (EDR) and antivirus software mechanisms installed to monitor data and transactions against malware infections, and fasten/secure individual devices (computers, mobile devices) [93] [94].
9. *Security Control Guidelines* like complying with NIST or CIS Cybersecurity Framework and/or ISO27001 [95].
10. *Third-Party Risk Management* to manage/support security controls with third parties and partners with regular access to systems [96].

2.2.2 Standards and Best Practices for Implementing Security Controls

Security controls are implemented as part of an organization's Information Security Management System (ISMS) to ensure compliance with legal requirements, support business continuity, and reduce risks to the Security Triad (Confidentiality, Integrity, Availability: CIA). Due to their significant role in helping organizations to manage and to protect information assets, **ISO 27001:2022** framework identifies 93 security controls and classifies them into 4 control groups [97]. **Organizational controls**; 37 controls covering areas like information security policies, governance, risk management, and business continuity [98]. **People controls**; 8 controls relating to training, roles, responsibilities, and user access management [99]. **Physical controls**; 14 controls addressing the physical security of assets, secure areas, and environmental threats. **Technological controls**; 34 controls concerning technical mechanisms like cryptography, access controls, and system monitoring [100].

Development of suitable security environment in the organizations is essential to ensuring seamless integration of security controls [101]. Some security vulnerabilities result from unplanned activities and random workarounds, resulting in complex codes and inevitable bugs. Therefore, developers are advised to continuously conduct code refactoring and follow security procedures to protect applications from being vague or goofy [102]. Security analysts use techniques like "Code Refactoring" to apply changes to the software without changing the visible behavior. According to Fowler, when software engineers apply code refactoring relentlessly, they stimulate better comprehensive design ideas, resulting in enhanced resilience and software recovery [103]. Afterward, white-box and black-box testing is done to handle any unclear patterns resulting from the software refactoring process [104]. Implementing security controls requires a holistic approach that includes a set of secure development practices to stay compliant with security standards and industry frameworks, ensuring that organizations meet both legal and operational security requirements [105]. Below are some of the best practices categorized into different aspects of security control implementation:

1. *Risk Analysis and Assessment.* A proper risk assessment helps to prioritize security controls. Hence, it is crucial to understand the risks and threats before implementing the security controls [106].
   a) Regular Risk Assessments: Identify risks and vulnerabilities to understand which assets need protection and evaluate the severity of potential threats.
   b) Identify Data and Systems: Classify data based on sensitivity (e.g., public, private, confidential), allowing appropriate security controls to be applied based on the risk.
   c) Threat modeling: Simulate potential threats and malicious attacks to identify security gaps within the organization's security posture.
2. *Apply Authentication and Authorization Techniques.* The following key components are implemented to manage user access controls to systems and software applications [107]:
   a) Multi-Factor Authentication (MFA), (e.g. passwords, tokens, biometric verification), to reduce unauthorized access and the risk of compromised credentials.
   b) Role-Based Access Control (RBAC), to limit user permissions based on their job functions and responsibilities.
   c) Strong Password Policies like using complex, unique passwords and enforcing regular password changes.
3. *Data Encryption Methods.* Encrypting data is essential to protect sensitive data stored on servers, databases, or cloud environments in rest mode, transit, and run-time. Further, software practitioners must ensure that the data transmitted over networks (e.g., emails, web traffic) is always

encrypted using secure protocols such as TLS/SSL[5] [108] [109].

4. *Security Monitoring and Incident Response Management.* Continuous monitoring and the ability to respond quickly to incidents and cyber attacks are crucial for mitigating the damage.
   a) Use security information and event management (SIEM) systems to monitor suspicious activities, generate alerts, and provide real-time threat detection [110].
   b) Deploy Intrusion Detection and Prevention Systems (IDS/IPS) to monitor network traffic for unusual patterns and automatically block suspicious activities.
   c) Develop a solid Incident Response Plan that outlines how to detect, respond to, and recover from cyber-attacks.
   d) Enable regular log and audit to maintain audit trails and utilize them to investigate potential breaches and identify new threats.
5. *Compliance and Regulatory Adherence.* Security practitioners should conduct security audits frequently to assess the effectiveness of implemented security controls and ensure compliance with legal, industrial requirements and security standards [111], like GDPR[6], ISO 27001[7], or NIST[8].
6. *Security Training and Awareness.* Organizations should always ensure that their users and team members are well-informed about security controls and best practices since human errors are hard to control, especially in the security area [112].
   a) Conduct regular security training for all employees and team members, focusing on common cyber attacks like phishing, insider threats, and social engineering.
   b) Test employees' abilities to enhance security awareness and detect phishing attempts through phishing simulations.
   c) Foster a strong security culture where employees feel responsible and empowered to report suspicious activities.

To achieve a comprehensive security control implementation, security practitioners often utilize a combination of the following standards depending on organizational requirements, business industry, and geographic region:

1. *ISO/IEC 27001[9], Information Security Management Systems (ISMS)*: To establish security requirements, identify access controls, and determine supplier relationships, in tandem with focusing on confidentiality, integrity, and availability (CIA).
2. *NIST[10], Cyber Security Framework (CSF)*: To manage incident response and security risks, comprising of the five core functions (Identify, Protect, Detect, Respond, and Recover).
3. *CIS Controls (Center for Internet Security)*: To provide easy-to-implement guidelines and prioritize the best cyber practices for small and medium-sized businesses (SMBs), in critical areas like inventory management, data protection, and incident response.
4. *GDPR (General Data Protection Regulation)*: To primarily mandate security controls for protecting personal data.
5. *COBIT (Control Objectives for Information and Related Technologies)*: To offer a governance framework to manage and align IT goals with business objectives.

[5] Transport Layer Security and Secure Sockets Layer
[6] General Data Protection Regulation
[7] International Organization for Standardization 27001
[8] National Institute of Standards and Technology
[9] International Organization for Standardization and the International Electrotechnical Commission
[10] The National Institute of Standards and Technology

2.2.3 DevOps and IEEE 2675-2021 Standards

DevOps is a methodology comprising of a set of practices that combines software development (Dev) and IT operations (Ops) to streamline all phases within the SDLC. It promotes a culture of collaboration between development and operations teams to enable faster, more reliable, and automated delivery of projects and software applications development [113]. In addition, DevOps is used to increase an organization's agility and abilities to deliver high-quality software applications efficiently while meeting user expectations. It is basically used to break down the traditional practices between these teams, emphasizing continuous integration, continuous delivery (CI/CD), and automated essential and repetitive tasks like testing and rapid feedback [114]. As a consequence, DevSec ensures that code changes are automatically tested and ready for production release, thus allowing faster and more reliable deployment. Further, DevOps ensures that applications are continuously monitored, and the teams are consistently able to detect issues in real-time and implement solutions before they impact users [115].

The IEEE 2675-2021 Standard is designed to provide directions and useful guidance on building and maintaining secure and reliable software systems using DevOps practices. It provides a comprehensive framework that focuses on integrating security, reliability, and scalability into each phase within the software development lifecycle (SDLC), ensuring that applications and software systems remain resilient even as they evolve. In addition, this model outlines the best practices and principles for developing and maintaining IT systems within the context of DevOps [116], offering the following key benefits [117]:

1. *System Security.* Integrating and embedding security controls across the entire software development lifecycle (SDLC).
2. *System Reliability.* Ensuring that applications and systems are resilient even during disruptions and failures.
3. *System Scalability.* Ensuring that software systems can handle the market expansion and growth in demand.
4. *Quality Assurance.* Implementing continuous practices like testing, monitoring, and verification procedures to maintain high-quality systems.

By leveraging DevOps practices and methodologies in conjunction with the IEEE 2675-2021 Standard, software teams can build systems that are secure, resilient, and scalable in response to IT changes and adversity.

1. *Access Control.* Use Role-Based Access Control (RBAC) to ensure that only authorized personnel have access and can modify systems [118].
2. *Continuous Integration (CI).* Implement CI pipelines ensures that code changes are automatically maintained and tested [119].
3. *Continuous Deployment (CD).* Deploy applications and embed rollback mechanisms automatically in various environments (e.g., staging, production) to ensure a smooth deployment process using infrastructure-as-code (IaC) tools [120].
4. *Automated Security Testing and Static Application Security Testing (SAST).* Use tools like Checkmarx[11] to ensure consistent builds with validation, version control, and artifact management [119].
5. *Security Hardening.* Apply security hardening practices (e.g. vulnerability scanning, minimal

[11] https://checkmarx.com/cxsast-source-code-scanning/

base images and image signing) to ensure all components and dependencies are verified against vulnerabilities and managed securely using package managers.

6. *Monitoring and Alerting.* Set up real-time monitoring for both security events and performance metrics using security information and event management (SIEM) tools [121].

2.2.4 DevSecOps

DevSecOps is an extension of DevOps that integrates security practices into DevOps [41]. While DevOps emphasizes collaboration between development (Dev) and operations (Ops) teams to improve the efficiency, speed, and quality of software delivery, DevSecOps incorporates security controls as a core element of the Software Development Lifecycle (SDLC), rather than dealing with security as a separate process at the end [122].

DevSecOps aims to rectify software and resolve issues as soon as they emerge before they become complex or expensive to fix in production sites [123]. In the DevSecOps context, security controls are used consistently [124], and security practices (e.g., threat modeling and risk analysis) are automated by engaging security experts in the development process [125]. This makes security a shared responsibility between teams (development, security, operations) rather than segregating security into a separate silo [126]. Stimulating effective collaboration between teams on multiple levels provides an opportunity to work on different issues, e.g., service level agreements with customers, capacity management, and resource availability for applications [2]. DevSecOps does not mean replacing security with development and/or operations or expecting development and/or operations users to become security specialists. Likewise, there is no expectation for security experts to become developers and/or operational users [127]. However, DevSecOps is still a necessary approach used to upgrade overall security within an organization based on four fundamentals; **(i) culture** acquired from working collaboratively with security teams to build/manage security controls [71], **(ii) automation** for security practices is essential to follow up with user feedback and keep up both pace and agility achieved by DevOps in former instances [128], **(iii) measurements** are important to detect real-world threats and track vulnerabilities throughout the SDLC allowing teams to re-validate and assess the reliability of applications [129], **(iv) sharing** knowledge and DevOps frameworks to build security controls based upon clear contents, perceptible user feedback and lessons learned from past experiences [130] [131].

DevSecOps has resulted from the many attempts to mitigate/overcome security problems and upgrade security to a higher and centralized position in the SDLC by executing the following processes [132]:

1. *Security Shift Left:* DevSecOps shifts security "left," meaning security controls are integrated from the beginning of the software development lifecycle (SDLC). Security tools, checks, and practices are embedded early in the development (coding) phase to identify vulnerabilities and risks sooner, ensuring the code is securely written/tested and resolution time is reduced [133].

2. *Enable zero-trust frameworks:* This approach is based on using security orchestration to promote authentication and authorization, enforcing automated responses and dynamic endorsement for access requests.

3. *Automate testing for access requests:* Automated testing for access requests within every sprint involves integrating access control verification into the CI/CD (Continuous Integration/Continuous Deployment) pipelines to ensure that security controls, such as role-based access control (RBAC) and permissions, are thoroughly validated during each development cycle. This is essential for

agile environments and rapid development cycles that may introduce several security vulnerabilities.

4. *Enable security scanning for vulnerabilities:* This approach allows developers and software engineers to work without the need to rewrite the code if sudden issues arise. This exercise involves integrating processes to automatically identify potential security weaknesses before, during, and after the software releases. It includes static code analysis, dynamic application testing, dependency scanning, and infrastructure vulnerability assessments [54].

5. *Deploy code changes in small patterns and deliver in iterations:* Small, frequent deployments allow teams to quickly identify bugs, security vulnerabilities, or performance issues in new code changes. Consequently, end-users and stakeholders provide real-world feedback when new features or updates are released iteratively, enabling developers to respond and adjust errors quickly [134]. This technique is crucial for agile methodologies and referred to as 'incremental development' or 'continuous delivery', bringing several benefits to the development teams and overall security.

6. *Empower developers to prioritize code:* This significantly enhances both individual productivity and team efficiency by giving developers more autonomy and decision-making power regarding which technical tasks to prioritize and focus on. They are more likely to address technical issues and refactor inefficient code because they see the long-term impact, taking more ownership of the quality and sustainability of code. As a result, they would feel a greater sense of responsibility for the success or failure of the project, leading to higher commitment and accountability [135].

7. *Seek security compliance:* Carrying out regular security reports and automated validations is a proactive approach to maintaining security compliance, improving the organizational security posture, and building trust with stakeholders. These reports support better decision-making, increase accountability, and help ensure that the organizations remain compliant with evolving security standards and regulatory requirements [136].

Building DevSecOps practices in line with ISO/IEC 12207:2017 security standards creates a strong synergy between agility and standardization. This results in a more robust software development process, combining the flexibility and speed of DevOps with the comprehensive processes of ISO/12207 [137]. ISO/IEC 12207:2017 ensures that organizations meet international security standards and regulatory requirements, especially where strict compliance is necessary. Moreover, DevSecOps practices help automate and streamline compliance processes while maintaining reliable alignment with the ISO standards, ensuring both reliability and scalability for high-quality systems and mission-critical projects.

2.2.5 Security Controls with CI/CD Pipelines

Continuous Integration (CI) is a composite process of aggregating code into a complete product. At the same time, Continuous Delivery (CD) is the process in which the code is checked for errors and iteratively reviewed to perform changes / updates before being released to the customer site [138]. Developers may find CI/CD processes tedious as they may prolong the project timeline, risks and costs [139]. Static Application Security Testing (SAST) and Dynamic Application Security Testing (DAST) can be used into CI/CD pipelines to further enhance security-by-design controls [139] [140]. Also, the Infrastructure as Code (IaC) paradigm can be leveraged to embed security controls within CI/CD pipelines, enabling automated configuration processes [141]. Integrating security controls into

CI/CD workflows requires skilled teams to automate security practices in various development phases without affecting project timelines [139]. This approach supports critical activities such as incident response management, vulnerability scanning, and troubleshooting, allowing the detection, analysis, and prioritization of bugs based on their potential impacts [142]. Conversely, this process can introduce significant challenges related to security compliance and adherence to organizational regulations, often stemming from ineffective communication between developers and operators [143].

2.2.6 Existing Reviews on DevSecOps

This SLR's contribution and findings of existing reviews are described in Table 2.2. Former research discussed challenges in DevSecOps concerning tools, people, or processes. There is no discussion/debate on issues concerning security controls in DevSecOps. For example, Rajapakse et al. discussed the challenges of DevSecOps adoption and introduced them in themes (people, practices, tools, infrastructure) along with the solutions suggested for enlisted challenges [54]. Furthermore, Hvardand and Ricardo described the benefits of DevSecOps practices and explained the best approaches to mitigate the occurrence of risks [144]. According to Sánchez-Gordón and Colomo-Palacios [40], effective cooperation and sharing the responsibility of security between teams are considered to be the core of DevSecOps as software engineers need to work collaboratively on security and manage risk properly. They also pointed out the importance of automating security practices within DevOps pipelines in tandem with agility to achieve reliable security [150].

Another Multivocal Literature Review (MLR) by Rafi et al. [145] provided a definition for data heterogeneity and described the key problem of integrated software environments that hinders data assessment and quality. They suggested implementing specialized adaptors to share artifacts that could be accessed from different domains throughout the development process. On the other side, they emphasized the obligation of understanding the data structure in heterogeneous environments. The same authors have conducted another SLR [146], where they classified DevSecOps principles (culture, automation, measurement, sharing) and pointed out how disseminated environments make it difficult for security analysts to operate security practices from different perspectives (processing, execution, testing). They stated problems that would lead to improper threat assessment, like inconsistent policy designs, poor performance measures, and lack of adequate channels to monitor team coordination during the development phase. In another SLR of [147], the authors discussed how some organizations started implementing DevSecOps practices without adequate preparation, resulting in massive failures in penetration testing. Software errors also happen due to a lack of configuration settings and ineffective management of operational inspection and user feedback.

Chiari et al. conducted a survey on static security analysis for Infrastructure as Code (IaC) scripts [149]. The authors discussed failure criteria for performance analysis to identify inefficient configuration from monitored parameters. They also highlighted the benefits of applying static analysis in IaC scripts to let developers and admins automate applications without requiring expensive or time-consuming repair for isolated and/or defective infrastructures. Another SLR was published by Ramaj et al. in 2022 [148]. Their paper shed light on issues related to security compliance during the implementation of DevSecOps. The authors recommended that developers should consider security regulations and accessibility frameworks when building, testing, and deploying software solutions. Further, lack of security awareness is one of the major reasons that could hamper DevSecOps adoption and delay the implementation of security controls into CI/CD pipelines.

Table 2.2: Summary of Reviewed Studies on Security Control Implementation in DevSecOps Contexts: ***A**: Discussing the integration of security controls in DevSecOps. ***B**: Examining the challenges associated with implementing security controls in DevSecOps. ***C**: Suggesting solutions and workarounds related to security controls. ***D**: Pinpointing gaps and shortcomings in current DevSecOps security practices. (✓✓) The paper fully covers it, (✓) The paper partially covers it, (N/A) Not Applicable.

Title	**Focus**	**Year**	**A**	**B**	**C**	**D**
Challenges and solutions when adopting DevSecOps: A systematic review [54]	(1) This SLR presents an overview of key studies to address research questions. (2) DevSecOps-related challenges are determined and categorized in aspects (people, practices, tools, infrastructure). (3) Solutions are formulated along with the mapping with enlisted challenges based on what was found in primary studies.	2021	✓	✓	✓	✓
DevSecOps: A Multivocal Literature Review [144]	(1) This paper indicates how DevSecOps works effectively by integrating modern security methods. (2) It gives a comprehensive overview of how DevSecOps could possibly be implemented in a way that benefits from continuous and automated improvement practices. (3) The book describes the benefits of DevSecOps and the difficulties an organization might experience when operating DevSecOps.	2017	✓	✓	N/A	N/A
Security as Culture: A Systematic Literature Review of DevSecOps [40]	(1) This SLR focuses on the concept of collaboration and sharing the responsibility of security between teams. (2) It points out how DevSecOps allows the automation of security practices in an agile manner within DevOps pipelines. (3) DevSecOps requires a seamless security integration in tandem with velocity and reliability. (4) Effective collaboration on security is much needed as software engineers need to manage objectives and risk analysis.	2020	✓	N/A	N/A	N/A
Multicriteria based decision making of DevOps data quality assessment challenges using fuzzy TOPSIS [145]	(1) Heterogeneity and diversity of components can results in problems during the assessment of data quality. (2) Integrating security controls across data components is another challenge. (3) Invalid data and missing information are major impediments to DevSecOps adoption.	2020	✓	✓	N/A	✓
Prioritization based taxonomy of DevOps security challenges using PROMETHEE [146]	(1) This study focuses on security manual testing and configuration issues. (2) Threat modelling issues and lack of teamwork between security, development, and operation teams are addressed. (3) Developers may resist embedding security controls as it could slow down the deployment proceeding. (4) Inconsistent security policies and complex design templates were spotted. (5) Deficiency of testing measures and performance criteria used for security.	2020	✓	✓	N/A	✓
Toward successful DevSecOps in software development organizations: A decision-making framework [147]	(1) Poor processes of penetration testing. (2) Inadequate deployment parameters and configuration settings used in security controls and compliance. (3) Issues in monitoring and tracking systems resulting in delayed feedback.	2022	✓	✓✓	N/A	N/A
Holding on to Compliance While Adopting DevSecOps: An SLR [148]	(1) Security Compliance is assorted in three taxonomies: initiation, management, and technicalities. (2) Security is reviewed as a non-functional process. (3) Different levels of security awareness can impact the pipeline activities. (4) Container images should be regularly scanned to detect vulnerabilities. (5) Compliance assessment is discussed regardless of the operation mode of executed security controls.	2022	✓	✓	N/A	N/A
Static analysis of infrastructure as code: a survey [149]	(1) Insufficient infrastructure-as-code (IaC) patterns would lead to classification problems and bad-quality code associated with bugs and compilation errors. (2) Hardware machines require new data sets to represent diverse samples and parameters.	2022	✓	✓	N/A	N/A
This SLR	(1) Challenges related to security controls during the DevSecOps adoption. The issues are categorized per ISO 27001:2022 standards for clearer insights into their causes, trying to avoid/rectify them. (2) Introduce the solutions as suggested in the literature and related to security controls trying to address the previously enlisted challenges. (3) Propose opportunities for future research/gap areas to support the integration of security controls in DevSecOps environments.	2024	✓✓	✓✓	✓✓	✓✓

2.3 Research Methodology

Systematic Literature Reviews (SLRs) are recognized as a prominent research method in Evidence-Based Software Engineering (EBSE) for collecting data and analyzing bodies of evidence [151] [152]. Therefore, we decided to carry out an SLR to gain a deep understanding of security controls in DevSecOps following the methodology proposed by Kitchenham and Charters [153]. To this end, the study adheres to the guidelines outlined in [151] and is structured to present the following sections: (i) formulation of research questions (RQ) (see Table 2.3), (ii) search strategy, (iii) inclusion and exclusion criteria, (iv) quality assessment criteria, (v) snowballing procedures, (vi) data extraction, and (vii) data synthesis and mapping.

2.3.1 Research Questions

We outlined the research questions and the motivation (purpose) behind each question in Table 2.3. Meanwhile, papers were searched and filtered. The process is described in the following sections.

Table 2.3: Research questions addressed in this chapter

RQ	Description	Purpose/Motive
RQ1	What challenges related to integrating security controls in DevSecOps are reported in the literature?	For those organizations who plan to adopt DevSecOps practices, security practitioners are advised to be aware of potential challenges concerning security controls and explore possible issues at the early stages of the SDLC [154] [62]. However, obstacles and impediments concerning security controls during the implementation of DevSecOps have not been precisely investigated. There are not enough peer-reviewed sources or significant bodies of up-to-date academic literature that thematically analyze and reconcile problems associated with the integration of security controls in DevSecOps. Hence, this research question aims to address this specific gap.
RQ2	What solutions are reported in the literature to address the issues associated with security controls in DevSecOps?	Security practitioners are interested in exploring and learning best practices, guidelines, and modern frameworks concerning the integration of security controls in DevSecOps [155]. This field has not been thoroughly discussed in the current DevSecOps research. Knowledge of what precautions/activities of security practitioners can solve and/or overcome security controls-related issues at an early stage. Addressing this question helps developers learn from past DevSecOps experiences and scrutinize why some practices fail.
RQ3	What are the gap areas and/or opportunities for future research concerning security controls in the domain of DevSecOps?	This RQ aims to identify gaps and opportunities for future research. Further, we will explicitly highlight the shortcomings and areas where security controls lack and/or fail to operate properly while carrying out DevSecOps practices.

2.3.2 Research Strategy

In relation to the focus of this chapter and in accordance with the guidelines established by Kitchenham and Charters [156], our search string is structured into three components. The first section targets cybersecurity-related terms (e.g., Security, Cyber), the second focuses on the most commonly used term for DevSecOps, along with other interchangeable variations (e.g., SecDevOps, CyberDevOps). The final section captures terms associated with controls, encompassing related concepts (e.g., settings, standards, guidelines). Ultimately, all authors contributed to the development of the search string, reviewed it, and confirmed the final version after several iterations, as shown in Table 2.4.

Table 2.4: Research string used to extract relevant papers

("security" OR "cyber" OR "cybersecurity") AND ("DevOps" OR "DevSecOps" OR "SecDevOps" OR "CyberDevOps") AND ("control" OR "standard" OR "governance" OR "compliance" OR "regulation" OR "audit" OR "safeguard" OR "measure" or "countermeasure" OR "assessment" OR "evaluation" OR "strategy" OR "appraisal" OR "criteria" OR "setting" OR "requirement" OR "logistic" OR "category" OR "controller" OR "mechanism" OR "instruction" OR "objective" OR "rule" OR "setup" OR "set-up" OR "regulate" OR "restriction").

2.3.3 Digital Research Databases

Given the considerable overlap among digital research databases, we selected five prominent and widely used databases in software engineering and cybersecurity research (Scopus, IEEE[12] Xplore, Science Direct, ACM[13] Digital Library, Springer Link), to identify relevant papers for this research [157]. Next, pilot searches were conducted on the selected databases to confirm that the relevant papers were selected. Note that digital databases have unique syntax or search capabilities. Therefore, we customized the search string to use the full potential of the databases' search capabilities to get more relevant and accurate paper retrieval. Certain databases may support regular expressions and/or Boolean operators, while other repositories utilize specific commands for phrase searching. For instance, we tailored the search string to align with specific syntaxes, such as 'continuous,' to enhance the quality of the results.

2.3.4 Inclusion and Exclusion Criteria

The following inclusion and exclusion criteria was applied to target relevant studies and remove irrelevant papers, duplicates, or any grey literature.

Inclusion criteria:

1. The article should specifically address the research objective or address one of the research questions.
2. The article should tackle one or more of DevOps or DevSecOps stages on top of integrating security controls in continuous security practices.
3. The article should discuss solutions or challenges that might be experienced while implementing and managing security controls in DevSecOps.
4. The article must be written in English and formatted as full-text articles.
5. The article must be published from 2012 to 2024 without restriction on publication place or venue.

Exclusion criteria:

1. Articles that are not related to DevSecOps in cybersecurity or not peer-reviewed, like presentations or calls for papers (CFP).
2. Articles that do not provide information about challenges or solutions for handling security controls in DevSecOps.
3. Secondary studies (e.g., surveys and literature reviews)
4. Articles are written in any language other than English.
5. Articles cannot be accessed or downloaded.

[12] Institute of Electrical and Electronics Engineers
[13] Association for Computing Machinery

2.3.5 Data Selection

While conducting this SLR, we followed a systematic approach to select relevant papers to ensure the reliability and accuracy of our research. We worked collaboratively to ensure the selection process was accurate, comprehensive, and aligned with the study objectives. This strategy also helped to produce precise, consistent, and unbiased datasets. At the start, we drafted the inclusion and exclusion criteria based on the research objectives and methodology. The criteria were interpreted and refined to confirm they were comprehensive and consistently understood. Subsequently, the articles were screened according to the agreed criteria, and the titles and abstracts were reviewed independently to ensure that only relevant articles and key studies were carried forward to the next round. Full-text reviews and quality assurance were conducted to thoroughly investigate the papers selected in the previous step, ensuring that all included papers met the review criteria and that no critical studies were missed. Throughout this process, the research team held discussion sessions to reconcile differing perspectives, resolve conflicts, and achieve a final consensus. Moreover, critical documentation related to decisions, criteria changes, and justifications was shared with the co-authors and incorporated into the supplementary materials.

Figure 2.1 shows the study selection process. In the first step, the search terms were applied to query the aforementioned databases in September 2023, with the results being matched solely to the titles, abstracts, and keywords of the papers. Table 2.5 illustrates the number of papers retrieved from the databases at each step. Initially, a total of 952 papers were retrieved, then after removing the duplicates, 248 papers were left. Next, inclusion and exclusion criteria were applied to the titles, abstracts, and keywords of the 248 papers. Of the 248 papers, 138 were excluded in this step, leaving 110 to proceed to the next stage. In the next step, the complete content of the 110 papers was thoroughly reviewed while simultaneously applying the inclusion and exclusion criteria. In some instances, all the terms of the search string were clearly reflected in the title, abstract, or keywords. However, it was challenging to determine whether the article's content was truly aligned with the objectives and research questions of this SLR.

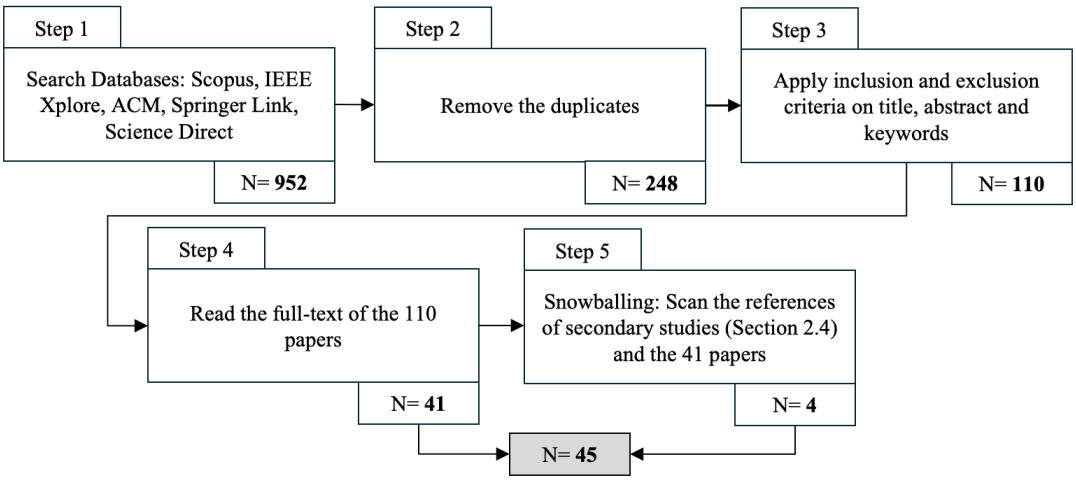

Figure 2.1: Steps of the study selection process

The research team followed the guidelines outlined in [158] and performed the following quality assessment checks to evaluate the papers. First, each paper was thoroughly examined to confirm that one or more of the research questions were being explicitly addressed in the study. Secondly, we checked if the papers were adequately related to our SLR's focus (i.e., security in DevOps or DevSecOps or

continuous practices). The papers were required to clearly describe their findings, contributions, and contexts. For instance, the term 'DevSecOps' appeared in the titles or abstracts of some papers; however, upon reviewing the full text, the content was not sufficiently aligned with DevOps, DevSecOps, or other continuous security practices. As shown in Figure 2.1, 41 papers satisfied all inclusion and exclusion criteria. The selection decisions for each paper, whether included or excluded, were recorded in an Excel spreadsheet at each step. Papers were labeled as 'Yes' (to be included in the next step), 'Maybe' (insufficient information to exclude at this stage), or 'No' (to be excluded in this step). The spreadsheet was later shared with other co-authors to thoroughly review the selected and excluded papers, along with the rationale behind the decisions. In the final stage, various study contexts, findings, and stated claims were thoroughly examined and discussed during weekly meetings until a consensus was reached regarding the selected papers.

Table 2.5: Number of papers resulted from running Search Engine

Databases	**Step 1**	**Step 2**	**Step 3**	**Step 4**
Scopus	321	130	39	23
IEEE Xplore	119	41	27	9
ACM Digital Library	52	26	22	4
Springer Link	429	35	14	3
Science Direct	31	16	8	2
Total No. of Papers	**952**	**248**	**110**	**41**

2.3.6 Snowballing Technique

With the aim to enhance the overall quality and depth of research, backward snowballing was performed to thoroughly explore the references and citations within the 41 primary papers. This process aimed to efficiently capture any relevant studies missed during the initial search and uncover important papers not included in the previous section, following the guidelines and instructions suggested by Wohlin et al. [159]. This technique is essential for uncovering additional relevant literature and key papers that could contribute to the study. The same inclusion and exclusion criteria were applied to select additional papers, ensuring a comprehensive and thorough literature review. However, it was determined that the majority of the papers had already been included in the initial selection process. As a result, only 3 more papers were added using this activity. Subsequently, the snowballing technique was applied once more to the reference lists of the secondary studies listed in Table 2.2 to identify any potentially overlooked relevant papers. Upon screening and reviewing the reference list of the secondary studies, only one paper met the inclusion/exclusion and quality assessment criteria. In conclusion, the total number of relevant papers included in this SLR is 45, as presented in Table 2.6.

Table 2.6: Primary papers investigated and used to conduct this SLR (***P**: Paper)

ID	**Title**	**Citations**
P1	Challenges and Opportunities of DevOps in Cyber-Physical Production Systems Engineering [160]	5
P2	DevOps Capabilities, Practices, and Challenges: Insights from a Case Study [161]	178
P3	Revisit security in the era of DevOps: An evidence-based inquiry into DevSecOps industry [41]	1
P4	A DevOps Framework for Quality-Driven Self-Protection in Web Software Systems [162]	9
P5	Towards a Hypothetical Framework to Secure DevOps Adoption: Grounded Theory Approach [163]	20

Continued on next page

Continued from previous page

ID	Title	Citations
P6	Continuous Compliance: Experiences, Challenges, and Opportunities [164]	10
P7	An Empirical Analysis of Practitioners' Perspectives on Security Tool Integration into DevOps [165]	14
P8	modelling continuous security: A conceptual model for automated DevSecOps using open-source software over cloud (ADOC) [166]	71
P9	Integrating Security with DevSecOps: Techniques and Challenges [167]	31
P10	DevOps for information management systems [168]	71
P11	DevSecOps Approach in Software Development Case Study: Public Company Logistic Agency [169]	2
P12	Mitigating an oxymoron: Compliance in a DevOps environment [170]	15
P13	Microservices: architecture, container, and challenges [171]	35
P14	Continuous Software Engineering and Beyond: Trends and Challenges [172]	325
P15	BP: Security Concerns and Best Practices for Automation of Software Deployment Processes An Industrial Case Study [173]	32
P16	A Unified Framework for Automating Software Security Analysis in DevSecOps [32]	4
P17	Using a Semantic Knowledge Base to Improve the Management of Security Reports in Industrial DevOps Projects [174]	4
P18	Embracing IaC Through the DevSecOps Philosophy: Concepts, Challenges, and a Reference Framework [175]	14
P19	Prioritization Based Taxonomy of DevOps Security Challenges Using PROMETHEE [146]	38
P20	Toward Successful DevSecOps in Software Development Organisations: A Decision-Making Framework [147]	63
P21	Security Impacts of Sub-Optimal DevSecOps Implementations in a Highly Regulated Environment [176]	17
P22	An Advanced DevOps Environment for Microservice-based Applications [177]	11
P23	Beyond Continuous Delivery: An Empirical Investigation of Continuous Deployment Challenges [178]	96
P24	Container and Microservice Driven Design for Cloud Infrastructure DevOps [179]	275
P25	The Top 10 Adages in Continuous Deployment [180]	107
P26	Continuous Delivery Huge Benefits, but Challenges Too [181]	485
P27	BP: Security Concerns and Best Practices for Automation of Software Deployment Processes: An Industrial Case Study [173]	32
P28	Hardening with Scapolite: a DevOps-based Approach for Improved Authoring and Testing of Security-Configuration Guides in Large-Scale Organizations [182]	3
P29	Root-Of-Trust for Continuous Integration and Continuous Deployment Pipeline in Cloud Computing [183]	0
P30	Efficient secure DevOps using process mining and Attack Defense Trees [184]	0
P31	Secure Scale: Exploring Synergies between Security and Scalability in Software Development and Operation [185]	0
P32	Cloud Infrastructure Self Service Delivery System using Infrastructure as Code [186]	2
P33	Migration From DevOps to DevSecOps: A Complete Migration Framework, Challenges, and Evaluation [187]	3
P34	Automated Dependability Assessment in DevOps Environments [188]	2
P35	Challenges and Approaches for the Assessment of Micro-Service Architecture Deployment Alternatives in DevOps [189]	5
P36	From DevOps to DevSecOps is not enough. CyberDevOps: An extreme shifting-left architecture to bring cybersecurity within software security lifecycle pipeline [53]	2
P37	Major Challenges of Systems-of-Systems with Cloud and DevOps - A financial experience report [190]	9
P38	Continuous Validation for Data Analytics Systems [191]	23
P39	Architecture Scheme of DevOps for Cross Network and Multiple Environment Collaboration [192]	2
P40	Understandings of Ethics in DevOps Teams: A Preliminary Investigation [193]	0
P41	Current and Future Challenges of Software Engineering for Services and Applications [194]	68
P42	Self-Service Cybersecurity Monitoring as Enabler for DevSecOps [195]	62
P43	Expanding DevSecOps Practices and Clarifying the Concepts within Kubernetes Ecosystem [196]	3
P44	VeriDevOps: Automated Protection and Prevention to Meet Security Requirements in DevOps [197]	13

Continued on next page

Continued from previous page

ID	Title	Citations
P45	Rethinking Secure DevOps Threat modelling: The Need for a Dual Velocity Approach [198]	4

End of Table

2.3.7 Data Extraction

This section describes the process of collecting and recording relevant data from the 45 primary papers listed in Table 2.6, in accordance with the guidelines provided by Garousi et al. [199] and Kitchenham et al. [200]. The data extraction process was systematically carried out into detailed, standardized Excel spreadsheets, capturing key attributes (e.g., title, keywords, abstract) along with the corresponding data from the selected papers. At first, data subsets (e.g., challenges, solutions, research gaps) were extracted separately for each research question. Subsequently, the completed spreadsheets were shared with co-authors for review to assess progress and address any discrepancies. They collaborated closely to compare results and pinpoint any ambiguities in data interpretation or extraction. Any issues, disagreements, or misinterpretations that arose were addressed and resolved during those discussions. Later, their input and feedback were carefully considered to update the Excel sheets and confirm that key aspects were covered and aligned with the research questions. This process aided in confirming the consistency and accuracy of the extracted data (results), ensuring reliability and thoroughness in tandem with overseeing the tracking progress.

2.3.8 Data Synthesis and Analysis

Thematic Analysis [201] was performed on the extracted data to analyze the results and address the research questions, following the approach outlined by Braun and Clarke [202]. This flexible and iterative process involves researchers systematically revisiting the data, making adjustments, and uncovering meaningful insights and interpretations, to gain a deeper understanding of the data [203] [204]. In the first step, the extracted data was thoroughly reviewed to identify recurring and common patterns, providing a broad context. These patterns were then categorized into three components based on the research questions: challenges, solutions, and research gaps. In each component, they were reviewed again to gain familiarity, give a concise narration, and develop descriptive key points (themes). The extracted themes were reviewed to verify the credibility of the results (e.g., is there sufficient evidence for each theme? Was it referenced in at least 2-3 papers?), following the recommendations of Cruzes and Dyba [205]. The themes were also refined to eliminate redundancy, merge similar themes, or deconstruct complex themes into sub-themes. Subsequently, these sub-themes were used to generate codes with relevant names. Finally, the themes and their corresponding codes were shared with the co-authors for review. Meetings were held to discuss any disagreements or conflicts regarding the generated themes and codes, which were subsequently resolved through a negotiated agreement approach [206].

As an example for analyzing one of the components (challenges), we classified the areas (domains in software engineering) that could be noticeably impacted by the enlisted challenges within building and integrating security controls in DevSecOps, or might have the direct and biggest effect. This classification greatly helped to provide structured views for the challenges and to address them effectively. Figure 2.2 illustrates an example of how the classification was developed, based on the impacted areas outlined below.

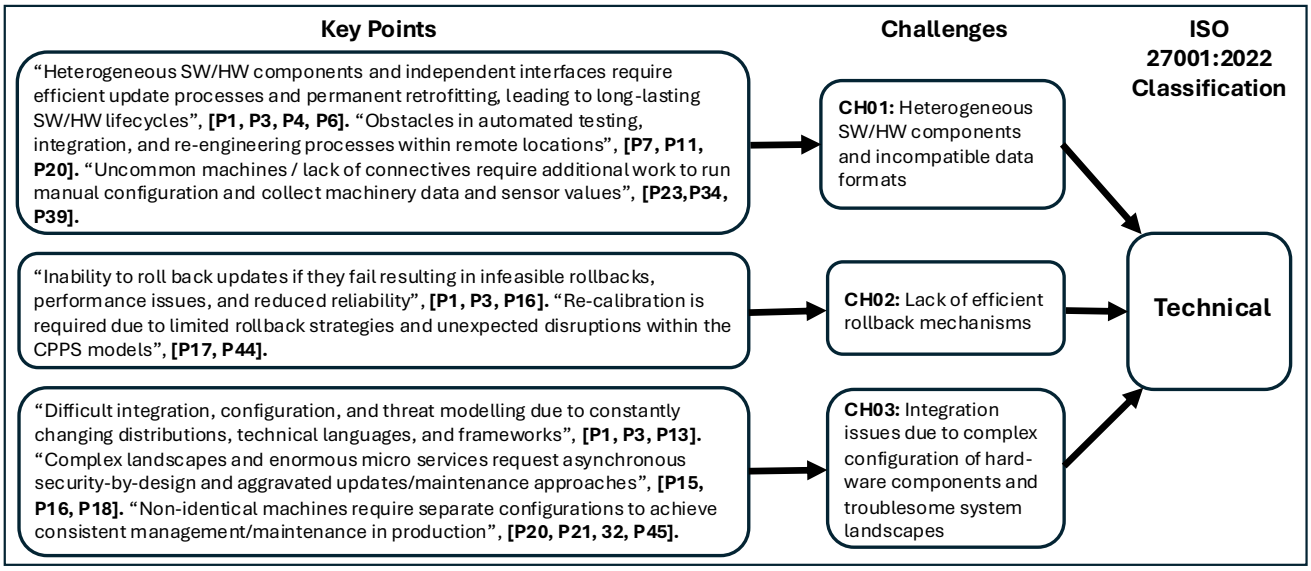

Figure 2.2: Applying thematic analysis on a sample of collected data

1. *Technical Constraints*: issues like system performance, agility, compatibility, limited or inadequate testing environments, or complex integrations of unfamiliar SW/HW components.
2. *Resource Limitations*: staffing, budget, and resource limitations that restrict building or maintaining robust security controls.
3. *Cultural Resistance*: challenges in getting user buy-in, resistance to adopting new security strategies, and cultural resistance within the organization.
4. *Knowledge and Skill Gaps*: lack of experience on cyber threats and latest attacks, leading to difficulties in application designs.

This process led to identifying **19 challenges** (see Table 2.9 in Section 2.4.1), **18 solutions** (see Table 2.8 in Section 2.4.2), and 12 research gaps (see Section 2.5). Subsequently, we conducted the mapping process and linked the 19 challenges with the 18 proposed solutions. Once the initial version of the challenges-solutions mapping was created, it was shared with the co-authors for feedback. Their feedback helped identify conflicts, potential discrepancies, and ambiguities that were resolved later using the negotiated agreement approach [206]. Figure 3 shows the challenges-solutions mapping.

2.4 Results and Discussion

This section presents the results of RQs listed in Table 2.3 based on 45 primary papers in Table 2.6.

2.4.1 RQ1: Challenges related to security controls in DevSecOps

This SLR identified a list of 19 challenges that have affected or may affect the implementation of security controls in DevSecOps (see Table 2.8). At the highest level, they were described, analyzed, and categorized according to the overarching classification outlined in the ISO 27001:2022 Standard, such as organizational challenges (e.g. budget constraints, lack of executive support, etc.), technical challenges (e.g. complexity of HW/SW components, legacy system compatibility, etc), or people-related challenges (e.g. user resistance to integrate security controls, training needs, etc.) [207], as shown in Table 2.7. Table 2.8 also demonstrates some descriptive key points for each challenge, the

application type (general, mission-critical, or safety-critical) in which the challenge could occur, and the papers that discussed and debated on that challenge.

Table 2.7: ISO 27001:2022 Classification

Classification	Examples
Organizational	Policies, roles, responsibilities, and resources required to manage information security.
People	Security awareness, training, and human resource security.
Physical	Protection of physical assets such as buildings, servers, and workstations.
Technical	Access control, encryption, and malware protection to safeguard information systems.

CH01: Heterogeneous SW/HW components and incompatible data formats. The current literature points out some technical challenges concerning the integration of heterogeneous scripts that require managing diverse components and endpoints (e.g., operating system resources, file permissions, logging services, etc.). **[P3, P4]**. The tight coupling between software (SW) and hardware (HW) components from one side and regulatory environments from the other side, requires manual configurations and presents serious obstacles hindering the success of Continuous Delivery (CD) **[P1, P10]**. Furthermore, fixing the problem of inconsistent SW/HW segments and re-engineering the split (fragmentation) between incompatible components are considered troublesome. This resulted from complicated connectives and robust elements in remote locations within development and operation processes **[P20, P23, P26]**. Moreover, outdated security techniques are still used in software design and execution phases, resulting in a serious challenge of aligning with business interests **[P6]**. The main confusion comes from the increasingly sophisticated attacks that cannot be predicted by obsolete techniques at design and run-time phases **[P7, P11]**. On the other hand, providing adequate information and briefings on development purposes is still difficult due to the complexity and dissimilarity found in machines **[P34, P39]**.

CH02: Lack of efficient rollback mechanisms. The inability to roll back updates when they fail would significantly impact the overall performance and reduce software reliability. Furthermore, infeasible rollback mechanisms and limited reporting would not assist the development processes when software updates fail to execute **[P1]**. Conversely, they will negatively impact both the performance and reliability of Cyber-physical Production Systems (CPPS) Engineering **[P3, P16]**. In comparison with Common Data Environment (CDE) practices, continuous delivery (CD) requires sophisticated monitoring solutions and fully automated rollback mechanisms **[P23]**. Because the vast amount of data produced by security activities varies in formats, perspectives, and contents **[P17]**, thus extra data processing and re-calibration activities are certainly needed to turn out unexpected disruptions and downtime errors **[P44]**.

CH03: Integration issues due to complex configuration of hardware components and troublesome system landscapes. Many microservices with frequently changing distributions running on multiple nodes (e.g., physical or virtual machines) would result in complicated hardware modeling, tricky integration, and more communication disruptions **[P1]**. Non-identical machines require separate configurations to achieve consistent modularization in production phases **[P3]**. Due to the reason that microservices are created and destroyed dynamically, there is a lack of correspondence and proper resemblance between microservices and associated system nodes **[P16]**. A bunch of asynchronous interactions is required to connect microservices with complicated call chains, resulting in adding complexity to system configurations, inconsistent environmental settings, and runtime failures as

well **[P13, P15]**. On top of all, developers find it difficult and troublesome to understand evolving system components thoroughly (in-depth), especially with the increasing complexity of applications **[P18]**. This will impede and hinder the scalability of threat modelling. Therefore, threat modelling is considered a bottleneck due to the need for significant time to execute properly **[P20]**. In addition, diverse substructures and infrastructures make manual processes quite burdensome depending on the application phase (e.g., development, testing, integration, or production). They require complex integration and asynchronous practices to perform operational transactions **[P21, P32]**. Since there are many components in cloud infrastructures (e.g., database, network, storage, etc.), where each component is instantiated in multiple instances to engage extra elements to properly function and manage infrastructures resources (e.g., multiple virtual routers) **[P45]**.

CH04: Indispensable costs needed to move into DevSecOps. Increased costs are required for dynamic interfaces like short-term hardware modularization, ever-changing architectures, elements and infrastructure-as-code (IaC) patterns **[P1]**. Frequent software updates and security constraints must be included at the architectural level of software development, which in turn will increase both complexity and cost **[P3]**. Also, expansion costs are needed for other major activities, such as simulation, procurement, variable data integration, and improving quality objectives like memory caches for performance **[P22]**. In contrast, individuals will regularly request additional funds to fix data disruptions, backtracking issues, and potential damage to machinery during production schedules. Consequently, there will always be a challenge of not being able to spend shared funds among teams effectively **[P41]**.

CH05: Lengthy and time-consuming activities slowing down the implementation of DevSecOps. DevSecOps adoption involves lengthy delays and heavy workloads to perform automated security testing **[P2, P3]**. Moreover, manual inspections and security scans need extensive scanning time that significantly impacts the overall execution time of CI/CD pipelines as many false-positive results need to be fixed and rectified at the end of the scanning process **[P8, P13]**. Due to the massive number of false-positive delays within a software release, developers eventually lose trust in tools' abilities to give accurate and reliable visualization of the software development process **[P14, P16]**. Development schedule slippage and critical time issues will impede the fulfillment of the requirements leaving the organization in constant struggles with data streamlining between CI/CD pipelines. For that reason, the incapacity to achieve and sustain the desired performance in the development phase causes work delays **[P21, P23]**. Besides, multiple code-batching activities are needed for code reviews within short time intervals to keep up with technical complexities, resulting in unsatisfactory response times and slowing down the whole process **[P25, P41]**. Within the DevSecOps environment, CI/CD pipelines are mainly created for testing purposes and addressing issues in operation mode **[P2]**. Incorporating security practices simultaneously during three phases (development, testing, production) might end up with counterproductive consequences as it could lower the developmental pace of applications in production mode **[P3]**. If developers are given access to the production environment to fix vulnerabilities and rectify security issues, then there will be significant time loss due to delivery failures and continuous security practices in DevSecOps pipelines. In such cases, software engineers and developers usually disable applications in production site **[P15, P21]**. On the other side, some security activities like threat modelling require highly skilled engineers to conduct detailed analysis which makes it hard to maintain the pace of software development and align with business needs at the same time **[P25]**. Conducting threat modelling for each application in each iteration is a slow process that could lead to slow implementations and increased risks of not achieving DevSecOps goals as well **[P39]**. Additionally, the physical isolation of multiple architects and lack of capabilities decelerate

DevSecOps processes and result in long development lifecycles **[P45]**.

CH06: Multi-disciplines and conflict management. Effective collaboration and cooperation among individuals could be challenging as some developers find it difficult to work in a connected group rather than independently **[P1]**. People cannot be put together and expected to work due to the fact that they initially differ in cultures and skill sets **[P2]**. Based on surveys and consultation sessions held with different teams **(development, operation, security)**, there could be concerns about how groups differ in their aspects (perspectives). For example, security analysts focus on advanced cybersecurity detection by inspecting traces and application log files, while developers focus on continuous monitoring and building up the code **[P3]**. Conflicts and disputes normally happen because development teams prefer fast pace coding and changing applications frequently, whereas security teams promote stability and resilence of applications against cyber attacks **[P9]**. It is exhausting to integrate security controls and adopt new methodologies after developers are already done with customizing applications and systems to suit customer requirements and business features **[P10]**. They find it hard to return to the development phase and fix errors where security was overlooked **[P19]**. Alternatively, team assembly and resource allocations in late stages of the project require deep analysis and staff assessment even with a mutual agreement to integrate security functions in the product and take into account the critical milestones of the project itself **[P20, P24]**. Each team has its own organizational interests, competing goals, work methods, and perceived areas of control. Hence, it is highly expected to observe resistance, stress and other social issues among development and operation teams **[P26]**. Moreover, it becomes more challenging if there are no organizational guidelines to comply with in resolving issues and problems **[P33]**. Correspondingly, having many balls in the air would lead to disagreements and/or burnouts **[P37]**. Although DevSecOps benefits are generous and abundant, yet there is a bit of confusion with no consensus about cyber objectives as some existing literature published unclear information about security trendy techniques in DevSecOps **[P40]**.

CH07: Lack of DevSecOps skillsets and automation competences. The fundamental knowledge of when/where software practitioners should embed and integrate security controls into DevOps layers within the development phase, is a significant necessity for employing automation and carrying out continuous security practices **[P3]**. Therefore, it has always been a huge challenge for organizations to provide high-quality training to employees and retain staff who have relevant skills and experience **[P16]**. This challenge relates to recruiting new individuals and retaining current staff **[P21]**. In some instances of unexpected incidents and operational problems, developers are still incapable of attending emergency and incident calls because they do not possess the required capabilities in automation, monitoring and other continuous security practices **[P2, P8]**. Some companies still think of upskilling and enhancing the competencies of existing staff, mainly in automation, as the "bottleneck" of DevSecOps adoption **[P17, P23]**. Typically, security teams comprise data administrators who supervise database tables and manage access requests. They monitor daily transactions, report data statistics, and resolve abnormalities and/or malicious activities **[P23]**. Nonetheless, the number of security analysts who are expert in DevSecOps is still low in the industry **[P27]**.

CH08: Lack of knowledge and experience in continuous security practices. The steep learning curve of software developers who need to learn advanced security techniques and gain new competences to work on new procedures, is quite a big challenge. They are requested to know exactly when and where to utilize security practices and integrate them into CI/CD pipelines, requiring urgent assistance from cybersecurity teams **[P2]**. Lack of security capabilities and DevSecOps competencies

can lead the inexperienced engineers take more time to explore security tools and become familiar with continuous security practices **[P9]**. Although developers are keen to learn emerging technologies, but the challenge is to arrange enough workshops and high-quality training to keep up with work demands and continuous security practices **[P10]**. Further, it was perceived that not all customers are mature and ready enough to accept continuous software releases **[P23]**. Dealing with demotivated customers, trying to make them change their mindsets to fully adopt DevSecOps and support automated testing practices, it is considered a major work burden **[P35]**.

CH09: Lack of collaboration and effective cooperation. Adopting DevSecOps requires software engineers to familiarize themselves with security teams (e.g. risk and incident response), and cooperatively work against cyber attacks and uncertainties **[P1, P2]**. Poor techniques and inadequate channels used to monitor teamwork and collaboration among divisions will result in serious communication issues hindering the implementation of DevSecOps **[P5, P19, P22, P25]**. DevSecOps execution is marked in danger whenever issues in transparency and collaborative culture rise up **[P33, P40, P41, P43]**.

CH10: Separation of roles, uncertain responsibilities, and unsteered assignments. Staff burnouts, shifted responsibilities, and segregation lines of business make the management of security controls tricky and challenging. Some business divisions may not interact efficiently, and instead, they will resist the adoption of continuous practices and new security methods, which will eventually result in slow upskilling and slack training **[P1]**. Moreover, lack of role definitions and unclear responsibilities result in organizational challenges and conflicts among individuals **[P2, P3]**. changing responsibilities and turnovers caused by DevSecOps adoption can lead to misunderstandings about who is in charge of carrying out continuous security practices **[P6]**, leaving the organization in need to re-engineer the organizational structure of security roles along with associated responsibilities cohesively and rationally **[P10, P27]**. Consequently, sharing of knowledge between teams and business divisions would relatively become daunting and exhausting **[P10]**.

CH11: Unclear security scope and unreliable, erratic input from stakeholders. Within the shift-to-left paradigm and pushing security to the left of the SDLC, many changes are pointed out by the QA (Quality Assurance) team and release managers requiring to start with incomplete parameters **[P8]**. Unreliable input and delayed user feedback will eventually lead to inadequate risk analysis and poor workarounds without the ability to calculate the impacts of sudden attacks. Such risk issues could end up with isolation and destructive impacts on overall security and result in not achieving DevSecOps main objectives **[P14]**. Implementing DevSecOps practices requires applying Infrastructure as code (IaC) patterns, which make it difficult to utilize data and switch between software versions due to unexpected changes in security requirements. However, it is still hard to confirm the validity of collected data and determine whether the acquired security approaches were worth the cost or not **[P16, P17]**. Starting the requirement phase with incomplete input and vague information leads to time-consuming activities and difficulties in replicating errors as well **[P18, P20]**. In addition, security domain constraints and strict controls require further risk analysis and extra verification proceedings before each release, which can result in dividing the process into lengthy contingency plans and slowing down the execution of CPPS and other automatic security practices. Further, a large number of complicated software components require enormous prototype-builds **[P24, P30, P31]**. Therefore, software engineers try to rely on manual quality checks and consult with stakeholders to clarify the scope and requirements to particularly operate in DevSecOps context **[P35, P42]**.

CH12: Security-by-design challenges within lengthy build/release phases. The security-by-design model embodies a strategic approach to building digital applications with reliable security, emphasizing threat modeling, risk assessment, and integrating preemptive security measures within every stage in the SDLC from inception to deployment **[P1]**. Security-by-design adheres to a set of rules and principles shaping up a core philosophy of security that includes prioritizing prevention over reaction and embodying a culture of continuous monitoring and improvement **[P3]**. One challenge of security-by-design is the misconception that security can be postponed, plus, retrofitting security controls onto existing systems is complex and costly, requiring contemporary maintenance and safety prerequisites **[P32]**. Also, evolving threat landscapes and current IaC patterns based on different tools and paradigms require continuous vigilance and adaptation **[P21]**. Addressing these challenges is integral to successfully implementing security-by-design principles and ensuring the long-term security of digital systems **[P39]**.

CH13: Runtime consistency issues. Connectivity problems at runtime make it hard to prioritize security issues in remote infrastructures, while customers' old-fashioned techniques do not have the ability to adhere to security in tandem with agile **[P1]**. Such dependencies are numerous and restrictive, thus making it almost impossible to adopt DevSecOps simultaneously with agility and speed **[P2, P3]**. To maintain both agility and speed of DevSecOps adoption, collaboration is required between developers, operations teams, and security professionals **[P22]**. Current security tools also need to be embedded and incorporated within DevOps layers in many instances of the SDLC **[P24]**. Moreover, runtime naming conventions in paths and configuration files, like including special characters, lead to failure in the CI/CD execution and, consequently, more difficulties during security bug fixes **[P33]**.

CH14: Resistance to change and coordination problems in Change Release Management. Working in the end-to-end system of systems (SoS) environments leads to resistance, impediments, and slow execution of DevSecOps practices **[P1, P2, P5]**. Some individuals may resist the integration process of security controls and/or ignore following up with the Change Management of product releases **[P10, P19, P37]**.

CH15: Lack of automated testing and performance measures. Complex software environments need rigorous simulations and automatic testing due to the digital twins created in isolated environments. More serious issues and failures in user acceptance tests are prone to happen because of the absence of automatic testing for software applications before being delivered to the customer site **[P1]**. Research studies indicate that a large number of software iterations is spent on running regression tests and interpreting results of manual checks **[P15]**. Human intervention and assessment involved in user acceptance tests could bring more value and increase confidence in code quality **[P27]**. Lack of access control and poor simulation will result in simulation issues, thus worsening the deployment process and bringing potential changes on a regular basis **[P23]**. Security requirements must be checked and tested before delivering applications in production environments. In the case of indirect provisioning for access requests, developers reach out to operation teams to get a formal confirmation for each release at the customer site **[P28]**.

CH16: Insufficient geographical distribution. DevSecOps concepts are not fully understood by the managing boards, therefore, developing efficient organizational structures for the teams is difficult **[P2, P3]**. Dysfunctional geographic locations for developers, security, and operations teams can result

in poor and unsatisfactory communication **[P25, P41]**.

CH17: Inconsistent security policies and lack of rigorous compliance controls. Lack of rigid security controls and coding standards leads to serious problems like delivering unreliable applications **[P3]**. In traditional processes, security compliance regimes usually restrict access to production servers to developers and testers only, which in turn hinders the process of continuous delivery (CD) **[P8, P9]**. Some software engineers may ignore the controls of security compliance and take shortcuts to speed up the development process, leaving their systems open to exploitation **[P21, P26]**. They believe, implementing security measures towards the end of development is another challenging milestone. Thus, they continually try to overlook and pass over **[P35, P39]**. Furthermore, there are incompatible problems about how the sprint planning is negatively affected rather than ensuring security compliance **[P12, P14]**. Therefore, new roles and artifacts must be added to the project scrum to support complying with security compliance and regulations at the end of each sprint**[P18]**. On the other side, ethical issues and lack of collaboration increase the risk of inefficient security compliance. Also, some regulations and security measures can be overlooked instead of being thoroughly integrated within the SDLC **[P43]**.

CH18: Complex and weak design cause issues in performance and resilience. Overall security posture cannot be improved nor rectified with ambiguous designs or inconsistent requirements **[P1, P2]**. Discrepant design of policies and performance measures, along with inconsistent security strategies and guidelines, will result in serious mitigation problems **[P5, P6]**. For those instances related to access provisioning, keeping inactive users leads to serious problems in mitigation. Therefore, access to systems and applications should be revoked automatically for invalid and unidentified users **[p18, P27]**. There are different security insights and perspectives about access requests during the mitigation process due to the fact that inactive users are not removed immediately **[P37, P43]**. Additionally, non-functional requirements (NFRs) of legacy systems create complications in security controls during their integration with DevSecOps practices. They require continuous scanning with several tools within the CI/CD pipelines **[P3, P4, P8]**, thus extending the CI execution time and increasing the complexity of configuring other continuous processes.

CH19: Patching mechanisms are not available to detect new vulnerabilities. In Security Content Automation Protocols (SCAP), extensible configuration methods are used to define data inputs using machine-formatted checklists in open vulnerability and assessment languages **[P8, P28]**. Numerous vulnerabilities that cannot be identified, prioritized, or fixed may appear within relocation processes and running system patches **[P29, P43]**.

Table 2.8: Challenges related to security controls in DevSecOps adoption, along with the papers contributed to those challenges (***CH**: Challenge, ***P**: Paper)

ISO 27001:2022 Classify	Challenge	Key Points	App. Types	Papers
Technical	CH01: Heterogeneous SW/HW components and incompatible data formats	• Heterogeneous SW/HW components and independent interfaces require efficient update processes and permanent retrofitting, leading to long-lasting SW/HW lifecycles. • Obstacles in automated testing, integration, and re-engineering processes within remote locations. • Uncommon machines and lack of connectives require additional work to run manual configuration and collect machinery data and sensor values. • More tasks are needed to identify security controls leaving developers with puffed workloads and incomprehensive documentation.	General	P1, P3, P4, P6, P7, P10, P11, P20, P23, P26, P34, P39
Technical	CH02: Lack of efficient rollback mechanisms	• Inability to roll back updates if they fail resulting in infeasible rollbacks, performance issues, and reduced reliability. • Re-calibration is required due to limited rollback strategies and unexpected disruptions within the CPPS models.	Mission-critical	P1, P3, P16, P17, P44
Technical	CH03: Integration issues due to complex configuration of hardware components and troublesome system landscapes	• Difficult integration, configuration, and threat modelling due to constantly changing distributions, technical languages, and frameworks. • Complex landscapes and enormous micro services request asynchronous security-by-design and aggravated updates/maintenance approaches. • Non-identical machines require separate configurations to achieve consistent management/maintenance in production.	Mission-critical	P1, P3, P13, P15, P16, P18, P20, P21, P32, P45
Organizational	CH04: Indispensable costs needed to move into DevSecOps	• Increased cost required for modularization, procurement, integration and variable tests. • Extra cost to fix disruptions and potential damage of machinery during production schedules. • Inability to spend shared funds effectively.	Mission-critical	P1, P3, P41

Continued on next page

Continued from previous page

ISO 27001:2022 Classify	Challenge	Key Points	App. Types	Papers
Technical	CH05: Lengthy and time-consuming activities slowing down the implementation of DevSecOps	• Time loss due to manual testing, code reviews, and delivery failures in mechanics functionalities. • Lack of capabilities and appropriately skilled staff would delay the development process. • Physical isolation of multiple architectures results in long development cycles.	General	P2, P3, P8, P13, P14, P15, P16, P21, P23, P25, P39, P41, P45
People	CH06: Multi-disciplines and conflict management	• Difficult to unify individuals of different cultures and backgrounds to work in collaborative groups. • Unclear understanding of objectives, expectations, and limitations of SoS (system of systems) context. • Managing directors do not fully understand DevSecOps concepts. • Social issues between development and operation teams.	General	P1, P2, P3, P9, P10, P20, P24, P26, P33, P37, P40
People	CH07: Lack of DevSecOps skillsets and automation competencies	• Need to recruit staff with DevSecOps skills to cope with cyber attacks, or retain the staff who have relevant security experience. • Teams are not ready to be on calls for operational problems because of not possessing automation skills. • The false perception of considering automation as the "bottleneck" of DevSecOps adoption.	General	P2, P3, P8, P16, P17, P21, P23, P27
People	CH08: Lack of knowledge and experience in continuous security practices	• Need to prepare workshops and high-quality training programs to keep developers updated with continuous security practices and trendy techniques. • Deal with stubborn or demotivated customers trying to change their mindsets and convince them to fully adopt continuous security practices.	General	P2, P9, P10, P23, P35
People	CH09: Lack of collaboration and effective cooperation	• Collaboration and transparency issues, complicating the involvement of security practitioners and putting DevSecOps progress at risk. • Poor techniques to monitor collaboration among team members	General	P1, P2, P5, P25, p33, P40, P41, P43
People	CH10: Separation of roles, uncertain responsibilities, and unsteered assignments	• Unclear role definitions result in conflicts and misunderstandings about work responsibilities and assignments. • Vague tasks and assignments would lead to a High volume of staff turnovers, burnouts, and shifted responsibilities. • Unsteered assignments result in many challenges in Knowledge sharing and expert acquaintance. • Slowing down the process of up-skilling the staff and improving their cyber capabilities, as they would resist change or improve in such environments.	General	P1, P2, P3, P6, P10, P27

Continued on next page

Continued from previous page

ISO 27001:2022 Classify	Challenge	Key Points	App. Types	Papers
Organizational	CH11: Unclear security scope and unreliable, erratic input from stakeholders	• Unreliable and erratic input leads to isolated infrastructure-as-code (IaC) patterns and complicated data utilization. • Inconstant user feedback leads to poor risk analysis and destructive impacts on security. • Hard to know requirements and feedback upfront, hence, frequent data reviews are needed to assist security and decision-making.	General	P8, P14, P16, P17, P18, P20, P24, P30, P31, P35, P42
Technical	CH12: Security-by-design challenges within lengthy build/release phases	• Embedding security controls requires maintenance and safety prerequisites. • Lack of stable platforms and ever-evolving threat landscapes cause many issues impacting both security and productivity.	Safety-critical	P1, P3, P21, P32, P39
Organizational	CH13: Runtime consistency issues	• Connectivity problems make it hard to prioritize security issues in remote infrastructures. • Customer systems are unable to adhere to security in tandem with agile.	Mission-critical	P3, P33
Organizational	CH14: Resistance to change and coordination problems in Change Release Management	• Ignore/Overlook Change Management in security • Conduct end-to-end system of systems (SOS) leads to resistance and slow adoption of DevSecOps. • Impossible to release new versions quickly and safely	Mission-critical	P1, P2, P5, P10, P37
Technical	CH15: Lack of automated testing and performance measures	• Extended landscapes need automatic testing due to digital twins created in isolated environments. • Potential issues may come up due to the lack of performance measures during manual security testing.	Mission-critical	P1, P15, P23, P27, P28
Organizational	CH16: Insufficient geographical distribution	• Incorrect geographic distribution for dev/sec/ops teams. • Hard to achieve DevSecOps visions due to distinct objectives across teams.	General	P2, P3, P25, P41
Organizational	CH17: Inconsistent security policies and lack of rigorous compliance controls	• Lack of strict compliance and consistent code standards lead to mitigation problems. • Ethical issues in legal compliance lead to reduced integrity and weak privacy. • DevOps professionals ignore security controls and take shortcuts to speed up the delivery. • Complex and ambiguous design of compliance controls, along with repetitive security guidelines, create big security challenges.	General	P3, P8, P9, P12, P14, P18, P21, P26, P35, P39, P43

Continued on next page

Continued from previous page

ISO 27001:2022 Classify	Challenge	Key Points	App. Types	Papers
Technical	CH18: Complex and weak design cause issues in performance and resilience	• Non-functional requirements (NFRs) add complexity to security controls and negatively impact the scalability. • Performance issues of legacy resources complicate the DevOps folding due to security audit failures. • Security controls need to be scanned continuously within CI/CD pipes. • Discrepant design of policies and regulations leads to poor performance and issues in scalability assessment.	General	P1, P2, P3, P4, P5, P6, P8, P18, P27, P37, P43
Technical	CH19: Patching mechanisms are not available to detect new vulnerabilities	• Difficult to identify/fix bugs that appear within relocation processes. • Failed patches ending up with code of 43% errors.	Mission-critical	P8, P28, P29, P43

End of Table

2.4.2 RQ2: Solutions concerning the challenges related to security controls in DevSecOps

This section presents a list of solutions found in the literature to address the security control-related challenges within the DevSecOps environment (see Table 2.9).

SLN01: Design automated processes and enable advanced analytic capabilities. Automating processes is vital to ensure virtual machine compliance with security policies, providing flexible customization and the ability to override when required. This is carried out by executing Cyber-Physical Production Systems (CPPS), which utilize analytic capabilities and link conceptual models to store transformed data sources in wider repositories **[P1]**. Security practitioners must thoroughly work on designing DevSecOps processes and make them compatible with complex CPPS models. They aim to automate testing, maintain stability, and achieve continuous and efficient functioning of security practices **[P28]**. Furthermore, developers have started to integrate several technologies like the Internet of Things (IoT), data analytics, and metadata storage in accordance with typical objectives of machine Learning, Application Programming Interface (API) integration, and data processing **[P6]**. In addition, researchers must work in parallel with development teams to discuss security problems that could arise within complex structures **[P39]**.

SLN02: Add scalability to threat modeling by carrying out multi-cloud techniques and employing digital twins. Scalability is essential to ensure that threat modeling adapts to changing requirements, complexity, and the evolving nature of software systems. To achieve this, software engineers seek continuous feedback, perform continuous integration and continuous delivery (CI/CD), reusing threat libraries through different releases to apply and monitor changes in the production site. First, they set clear scope and security objectives for threat modeling efforts and use structured methodologies to document results. Subsequently, they leverage automation and prioritize threats

based on their impacts. This is called integrating couplings of threat models into CI/CD pipelines to incorporate security in design and development phases **[P1]**. In addition, software engineers are advised to apply digital twins in pairs and link them with simulation tools and real-time data sources to optimize the assembly process and skip restrictive/slow routines. Digital twins perform continuous monitoring of virtual physical prototypes. In contrast, the simulation tools are crucial for improving resolution times and mitigating risks, as well as achieving the appropriate planning in various phases and preventing financial breakdowns during the SDLC. Another solution is to use contract-based designs to continuously specify functional and/or non-functional constraints in the design and run-time phases. In these instances, security analysts apply extra rules among services to define potential interactions and behaviors **[P11]**. Another solution is to implement multi-cloud methods and integrate tool chains with hierarchy-restricted file formats. Multi-cloud methods help operate and manage multiple cloud computing environments simultaneously. Their primary goal is to enhance flexibility, improve overall cloud security, and reduce vendor lock-ins, aiming to optimize application management and resource allocation. On the other side, involving flexible tool chains offers several benefits like improved consistency, easy adoption, efficient compliance, and long-term stability **[P32]**.

SLN03: Coordinate work groups in software engineering to identify main goals, challenges, and domain inter-dependencies. Cross-functional teams to work together and collaboratively brainstorm to provide various benefits to the development process and software engineering as a whole, such as knowledge sharing, diverse perspectives, and accountability **[P37]**. The main goal is to conduct focus groups that work in tandem with team-related ethics to automate user feedback, collect essential documentation, and improve their learning to keep knowledge alive and consistent with reality **[P40]**.

SLN04: Establish effective budgeting and financial management. Engineers are requested to develop comprehensive financial plans and allocate budget portions to security controls, continuous practices, SW/HW modularization, and other security expenses **[P1]**. They can regularly review and adjust budgets to fulfill security and financial objectives in accordance with changing circumstances **[P3]**.

SLN05: Execute security-by-design approaches. These approaches are essential for building secure and resilient applications in complex landscapes. Destination locations are predefined and verified to match host services requirements **[P37]**. By integrating security into every phase of the software development lifecycle (SDLC), organizations can reduce risks of security breaches and minimize potential impacts of incidents **[P5]**. Another solution is to automate infrastructure-as-code (IaC) processes from design to runtime by carrying out metadata indicators (e.g., OPC-UA, MQTT). They are used to collect/store data in heterogeneous data lakes (repositories), taking into account simulation analysis **[P20]**. Developers can start using effective tools like 'Chef Roles' to assign configuration endpoints and utilize compliance scripts **[P6]**. Additionally, research suggests continuous compliance frameworks where security compliance rules are managed and automated in a flexible and timely manner. Continuous compliance aims to support overrides, customize requirements, and provide real-time reports on security posture **[P18]**. Furthermore, security practitioners are recommended to apply subsequent monitoring to detect abnormalities and react at early stages **[P43]**.

SLN06: Add scalability feature to Threat Modelling. Scalability is essential to help companies assess/mitigate security risks in an efficient manner **[P16]**. Integrating scalable frameworks within

automated practices enables developers to better address security risks associated with application complexity **[P18, P24]**. This proactive approach builds resilient systems that react against security threats as they expand and evolve **[P28]**. On the other side, security practitioners conduct Threat modelling to address scalability concerns like STRIDE, DREAD, CAPEC, and AI Ops (Artificial Intelligence for IT Operations) that utilize Natural Language Processing (NLP) to review blacklist definitions and deal with the negative effects of configurations **[P45]**.

SLN07: Conduct the concepts of ethical factors (EFs) and ethical barriers (EBs). Developers must understand deployment cycles along with associated challenges. Similarly, deployment teams must understand SDLC-related obstacles. Both teams should be attentive to prevalent security attacks and the consequences of not considering security controls in design phases. They are advised to carry out regular reviews and development assessments with ethical factors (EFs) and ethical barriers (EBs) to locate where security should be rectified and improved **[P40]**.

SLN08: Establish security-by-design principles in all phases to integrate security at early stages in the SDLC. In the light of DevSecOps deployment, the aim is to build a solid security foundation and minimize vulnerabilities from the very beginning throughout the development process **[P1]**. Executives prioritize security requirements from top to bottom and simultaneously educate developers on security up-to-date practices **[P16]**. They will start using model-based frameworks and digital twins to test settings and address security challenges through workshops and group sessions **[P17]**. They conduct automated practices (e.g., integration, testing, virtual deployment) to explore Model-Based Engineering (MBE) and fix rollback failures **[P35]**.

SLN09: Manage risk effectively and carry out IaC orchestration at run-time to achieve integrity and coherency in IaC Execution Manager (IEM). Orchestration is crucial to configure properly and provision IaC patterns, thus working seamlessly to support the whole system **[P17]**. It refers to aligning IaC patterns with configuration and deployment parameters, then including infrastructure states in software codes (server, storage, network) to manage resource provisioning and access requests subsequently **[P18]**. On the other side, software engineers are advised to automate user feedback and execute risk management efficiently. In risk management, software engineers use structured frameworks to identify, assess, and mitigate risks while ensuring compliance with regulatory and internal governance requirements. They later report results in log files and await to obtain input from stakeholders via automated user feedback. This step would significantly reduce the need for periodic data collection efforts **[P1]**. Automation allows real-time feedback collection and enables organizations to respond quickly to cyberattacks and emerging issues. Generally speaking, automated systems ensure that data collection and feedback analysis are carried out consistently and efficiently. This promotes timely decisions and improves data consistency and accuracy, reducing errors and bias associated with manual processes **[P14]**. Another solution suggests running automatic testing before different releases to perform cross-validation and achieve better integration and rollouts **[P18]**. In modern software engineering, automatic testing is an essential component of CI/CD pipelines for enabling teams to test code changes automatically once integrated into databases and ensuring reliable delivery to production **[P28]**. Engineers deploy IaC scripts like Canary Sandbox Environment (CSE) and BizDev to conduct dynamic testing **[P38]**.

SLN10: Apply the approach of compliance sprints and effective collaboration among cross-functional divisions. Compliance sprints refer to a new initiative within the organization aiming to

accelerate and prioritize compliance contexts during limited time frames. This examination involves evaluating processes, controls, and basic documentation to identify security cracks and areas of non-compliance **[P35]**. Some organizations run compliance sprints to quickly assess their current compliance regulations with specific criteria. They also involve intensive training programs and communication campaigns to educate engineers about compliance requirements and best security practices. Furthermore, if significant compliance violations are spotted, they initiate a compliance sprint immediately to investigate incidents, conduct root cause analysis, and take corrective actions to prevent further violations **[P44]**. In DevSecOps, effective collaboration is crucial and should be complemented with automation and other practices like continuous testing and threat modelling. Therefore, all organizations are advised to improve collaboration and effective cooperation among agile and security teams. By doing this, they eventually build a robust security posture, and cross-functional divisions will cooperate and work together, ensuring security is handled as a shared responsibility **[P33]**.

SLN11: Implement VeriDevOps to apply continuous integration and delivery for security requirements. The main concept of VeriDevOps is to comply with security standards (e.g., ISA, IEC) by applying root cause analysis for security breaches and implementing protection mechanisms (e.g., network firewalls, vulnerability detection) **[P16]**. Security professionals should reconfigure intelligent traffic monitors to avoid immediate danger and ensure system perimeters are consistent **[P17]**. They execute remediation methods on code and design upgrades using parsers within the KB (Knowledge Base) **[P38]**. Patching parsers are used to identify external human input (e.g., false positive identification), duplicate findings, and KB changes. This allows analysts to revise and recalculate contradictory information, ensuring consistent deployments **[P44]**.

SLN12: Utilize CyberDevOps architectures. CyberDevOps involves integrating security into DevOps layers following hypothetical components like Security as Code, Infrastructure as Code (IaC), Role-Based Access Control (RBAC), Incident Response Management and SETA (Security, Education, Training, Awareness) methods **[P28]**. CyberDevOps frameworks allow developers to redo composite analysis and carry out vulnerability assessments **[P36]**.

SLN13: Utilize advanced analysis practices like quality assurance and intrusion detection. In cybersecurity, advanced analysis is used to detect vulnerabilities, respond to cyberattacks, and protect systems and networks. Further inspections often involve sophisticated software tools, statistical methods, programming languages like Python, and machine learning algorithms to process and analyze large and complex databases. The main purpose is to extract actionable insights, make data-driven decisions, and solve complex problems before they get harder or more expensive to fix **[P1]**. Quality Assurance (QA) and Intrusion Detection are prevalent analysis practices used to ensure both the quality and reliability of software. QA activities prevent defects/issues from occurring and ensure that delivered products meet customer expectations and predefined quality standards. Network Intrusion Detection (NID) refers to distinguishing malicious activities and responding to unauthorized transactions within networks. Enforcing NID practices and Access Requests Control is crucial as it helps organizations protect their digital assets and revoke invalid and/or unidentified access requests. They detect and alert abnormalities that might compromise the Security Triad of data (confidentiality, integrity, availability) **[P15]**.

SLN14: Apply change management effectively in all sprints. Change management helps address concerns and resistance points of stakeholders to obtain consent and buy-ins. Managing changes

emphasizes transparent team communication to reduce confusion and/or misunderstandings. This will also ensure that employees are in the loop and have adequate information about changes to start preparing with essential resources and training if needed. Ultimately, change management speeds up adopting DevSecOps processes as it builds capabilities to adapt to applied changes and seize new opportunities quickly **[P37]**.

SLN15: Split testing phase securely into sub-phases using digital twins. Digital twins are consolidated within inner/outer CPPS loops to bridge phases and align data in comprehensive views, resulting in improving integration and synchronization **[P1]**. Further, software engineers conduct regular reviews and validation processes on current user names and identifiers (IDs) to ensure they have valid authentication and data access. This endorsement process is important to confirm current users remain accurate, up-to-date, and compliant with security standards and organizational regulations **[P15]**.

SLN16: Perform Software Composition Analysis (SCA). In modern software engineering, SCA is an important practice that uses third-party components extensively. It helps developers balance the leveraged benefits of open-source software and associated risks. Eventually, SCA helps organizations handle and mitigate risks associated with supply-chains as their software heavily depends on open-source and third-party components **[P8]**. On the other hand, Extensible Configuration Mechanisms (XCCDF) are suggested to incorporate new features and/or functionalities without altering core databases **[P28]**. Applying XCCDF mechanisms and plug-in extensions improves modularization, scalability, and flexibility of system configuration **[P29]**. Format checklists and system-on-chip elements are used in Trusted Computing Technologies (TCT) and open languages to isolate services before addressing security issues in the attempt to protect traffic over different access points **[P43]**.

SLN17: Apply container scans and key protection mechanisms. Research has suggested modern state-of-the-art approaches like applying container scans, key protection mechanisms, and entity attestations (container, virtual machine, hosting nodes). Data will be scanned and processed in all phases within the SDLC (storage, transit, execution) **[P43]**. DevSecOps engineers are encouraged to obtain operational data by utilizing Application Performance Management (APM) and leverage on technologies in terms of speed and accuracy to achieve better productivity.

SLN18: Carry out Security Orchestration. Security Orchestration is a cybersecurity practice that includes automation and integrating security practices to respond to and mitigate cyberattacks efficiently. The Security Orchestration, Automation, and Response (SOAR) Approach aims to streamline Incident Response (IR) processes and reduce the time required for detecting, investigating, and remediating attacks. Further, the SOAR approach enables effective team coordination and repetitive automation for tasks within a single platform **[P16]**. Security orchestration enhances the organization's ability to respond to security incidents in a rapid and coordinated manner, prioritize incidents, and reduce the risk of human error. Software engineers must comply with Application Systems Control and Audit (ASCA) guidelines every six months to ensure that systems are robust and reliable, in addition to adherence to two-level approval techniques which confirm that only relevant users have access to systems and organizational data **[P27]**.

Table 2.9: Solutions found in literature and related to the challenges enlisted in Table 2.8, relating to security controls in DevSecOps (***SLN**: Solution, ***CH**: Challenge, ***P**: Paper)

Solution	Challenges	Solution Description	Papers
SLN01	CH01	• Design automated processes and allow analytic capabilities by executing CPPS models. • Careful design for DevOps processes to consider compatibility and put up with CPPS complexity and diversity. • Ensure continuous and efficient functioning of practices while maintaining security without affecting the project timeline or productivity. • Enable automated testing specification and execution within DevSecOps. • The Research Team should closely work with development teams to control problems of composite structures.	P1, P6, P28, P39
SLN02	CH03	• Add scalability feature to threat modelling and carry out multi-cloud techniques and shadowing systems. • Employ digital twins to simulate and jump-start the automatization within the development and operation phases. • Perform HW/SW couplings and link the digital twins with actual data to optimize the assembly process. • Implement rigid chains that use hierarchy-limited file formats to reduce the need for integration. • Apply contract-based designs and extra rules to specify functional/non-functional constraints and identify potential interactions among components.	P1, P11, P32
SLN03	CH06	• Organise work groups to clearly identify main goals, challenges, and interdependencies. • Conduct focus groups to collect testimonies and provide clear documentation about user feedback with the aim of keeping knowledge vital and consistent. • Perform fast modelling and continuous feedback to adapt and monitor changes in production.	P37, P40
SLN04	CH04	• Conduct budget management for software development and hardware modularization.	P1, P3
SLN05	CH03	• Execute security-by-design procedures to identify destination locations and confirm they match host requirements. • Automate the IaC process from design to runtime. • Carry out metadata indicators (e.g., OPC-UA, MQTT) to collect machinary data and store it in heterogeneous repositories, taking into account the simulation analysis. • Implement DevSecOps techniques with borderlines to filter and authenticate data. • Enforce compliance scripts and utilize the "chef role" tool based on configuration settings on endpoints. • Apply subsequent monitoring and continuous compliance frameworks to detect abnormalities, support overrides, and customs requirements.	P5, P6, P18, P20, P37, P43

Continued on next page

Continued from previous page

Solution	Challenges	Solution Description	Papers
SLN06	CH03, CH05	• Establish unified frameworks to automate security integration (tools and procedures). • Generate integration artifacts into DevOps pipelines. • Execute blacklist definitions to deal with the negative effects of secure configurations. • Apply a set of AI Ops (Artificial Intelligence for IT Operations) based on Natural Language Processing (NLP) for application logs.	P16, P18, P24, P28, P45
SLN07	CH09	• Use ethical factors (EFs) and barriers (EBs) to resolve issues promptly. • Carry out regular reviews for development processes to identify areas where security needs to be fixed.	P40
SLN08	CH11	• Establish security-by-design principles to meet security requirements throughout the CPPS life cycle. • Utilize digital twins to apply testing in secure settings. • Establish automated integration and explore MBEs to support self-testing and roll-back of failed updates. • Leverage model-based frameworks and focus groups to tackle security challenges.	P1, P16, P17, P35
SLN09	CH11, CH12	• Execute risk management competently to report results. • Automate user feedback to obtain input from stakeholders. • Run automated testing through different releases to perform cross-validation and achieve better integration and rollouts. • Carry out orchestration at run-time to achieve coherent IEM (IaC Execution Manager). • Deploy IaC tools like Canary Sandbox Environment (CSE) and BizDev to test dynamic properties.	P1, P14, P17, P18, P28, P38
SLN10	CH13, CH17	• Run compliance sprints for security standards to improve collaboration between agile and security teams. • Boost effective collaboration among developers, security practitioners, and the operations team.	P33, P35, P44
SLN11	CH02, CH17	• Use VeriDevOps for secure continuous integration and delivery. • Implement protection mechanisms (e.g., firewalls) and comply with security standards (e.g., ISA/IEC) during vulnerability detection. • Examine system designs to apply root-cause analysis for security breaches. • Identify remediation methods on code as patches/upgrades at the design level. • Use a parser within the KB (Knowledge Base) to apply repeated validation to monitor changes, identify contradictory information, and ensure a consistent KB deployment.	P16, P17, P44

Continued on next page

Continued from previous page

Solution	Challenges	Solution Description	Papers
SLN12	CH08	• Propose CyberDevOps architecture to integrate security within DevOps • Revise composition software analysis to deal with security settings and involve vulnerability assessment.	P28, P36
SLN13	CH09, CH10	• Utilize advanced analysis practices, such as quality assurance and intrusion detection, while enforcing access control policies. • Implement mitigation by revoking invalid and unidentified access requests.	P1, P15
SLN14	CH14	• Apply change management to deliverable sprints • Determine pre-approved changes beforehand to achieve desired agility.	P37
SLN15	CH15	• Securely split the testing phase into sub-phases using the bridging twins in inner/outer CPPS loops. • Carry out regular user reviews (re-validation processes) to ensure all users have valid access and authentication.	P1, P15
SLN16	CH19	• Perform software composition analysis (SCA) to identify vulnerabilities. • Use Extensible Configuration Mechanisms (XCCDF) to tailor applications. • Run Trusted Computing Groups (TCG) and Trusted Computing Technologies (TCT) to address issues through system-on-chip advancements. • Isolate services and protect the traffic over-allocated access points.	P8, P28, P29. P43
SLN17	CH18	• Apply container scans and key protection mechanisms for data in all phases (storage, transit, execution). • Conduct entity attestation (container, virtual machine, hosting nodes).	P43
SLN18	CH18	• Perform Security Orchestration, Automation, and Response (SOAR) technologies during the implementation process to coordinate and automate practices within a single platform. • Apply Application Systems Control and Audit-ability (ASCA) rules to ensure robust and reliable systems. • Apply two-level approval techniques to confirm that only relevant users can access applications and organizational data.	P16, P27

End of Table

2.5 Discussion, Research Gaps and Future Directions

Research gaps play a crucial role in driving the research progress and advancement of knowledge about security controls in the DevSecOps domain. They also reveal areas where further investigation is needed. This section discusses the gap areas for future research on security controls within DevSecOps. It uses uses the findings from **RQ1** and **RQ2** to clearly address **RQ3**, providing a detailed analysis of research gaps and future opportunities in DevSecOps research. The mapping of the SLR results,

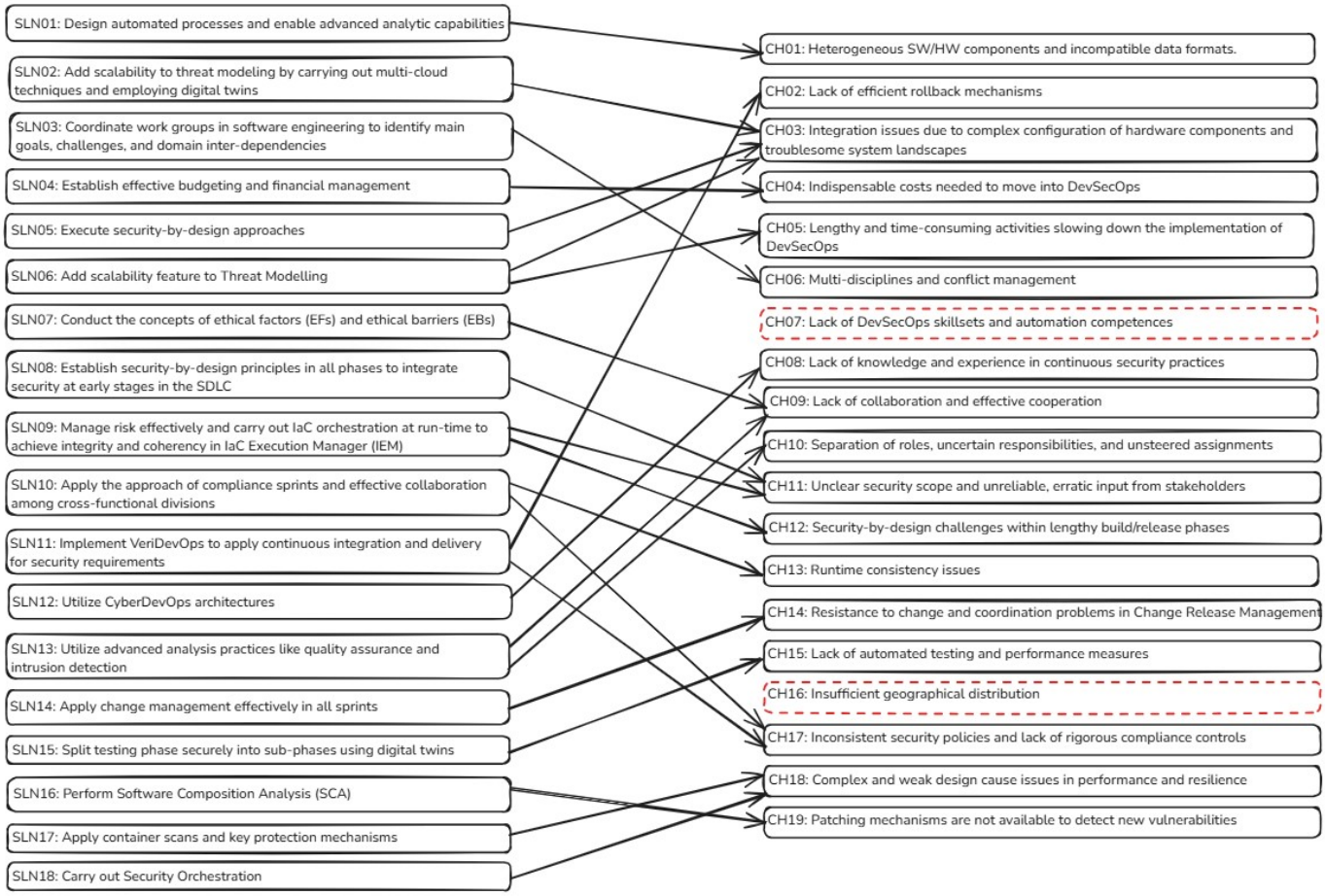

Figure 2.3: Solutions (Table 2.9) that address the challenges related to security controls in DevSecOps (Table 2.8), (***SLN**: Solution, ***CH**: Challenge)

presented in Figure 2.3, is provided to allow readers to comprehensively understand the connections between the reported challenges, proposed solutions, and identified research gap areas.

Continuous Compliance Monitoring (CCM). The findings of this SLR show a growing emphasis on Continuous Compliance Monitoring (CCM) as a critical component of efficient security control management. Security controls are usually implemented to ensure systems are reliable, secure, and compliant with regulatory requirements. However, the static nature of traditional compliance assessments fails to address the dynamic and evolving threat landscape. This gap underscores the significance of CCM [208]. CCM facilitates real-time evaluation of security controls, ensuring they remain effective and compliant across systems and dynamic IT environments. By automating the monitoring process, CCM provides continuous visibility into the state of security controls, helping organizations identify and address deviations before they expand and escalate into significant risks [209]. For instance, tools such as Security Information and Event Management (SIEM) platforms and compliance automation solutions are pivotal in implementing CCM by integrating compliance checks into daily operations [210].

Continuous Compliance Monitoring plays a vital role in ensuring that organizations meet regulatory requirements, internal security standards, and industry-specific requirements on an ongoing basis,

using automation and real-time monitoring tools. The importance of CCM spans various dimensions, including risk management, regulatory adherence, protecting organizational reputation, and enhancing business agility [211]. Several studies report the challenges concerning security compliance and adherence with regulatory requirements **[CH17, CH18]**. Consequently, the following research gaps persist in this area and revolve around technological, methodological, and regulatory challenges:

- Interchange of Compliance Tools: More research is needed on how standardized frameworks can be developed for better interoperability between different compliance monitoring systems.
- Scalability and Performance Issues: More research is required to develop scalable components that can handle large-scale and real-time compliance monitoring across distributed systems.
- Integration of AI/ML for Predictive Compliance: More research is needed on how AI/ML (Artificial Intelligence/Machine Learning) models can be trained to predict compliance failures before they happen, to reduce risk exposure.
- Regulatory Alignment: Organizations face increasing pressure to comply with standards such as ISO 27001 [14], NIST CSF [15], and GDPR [16]. CCM ensures continuous alignment with these requirements, reducing the risk of fines and penalties. However, there's a need to study automated mechanisms to update and adapt CCM systems as regulations change, without requiring costly manual updates.
- Resilience and Adaptability: Further investigation is required to inspect the adaptive CCM mechanisms that could quickly adjust to changing environments without introducing extra security risks.

Despite the benefits, implementing CCM is not without challenges. Several studies highlight the complexity of integrating CCM tools into existing security systems, particularly in hybrid or multi-cloud environments [212] [213]. Additionally, there is a need for standardized metrics to measure the effectiveness of CCM in managing security controls. Future research should focus on developing frameworks that address these challenges, emphasizing interoperability, automation, and scalability [214].

Automated Security Testing (AST). This SLR underscores the increasing adoption of Automated Security Testing (AST) as a crucial practice for ensuring the robustness and effectiveness of security controls. Automated Security Testing refers to using scripts and tools to identify vulnerabilities, validate security controls, and ensure that systems meet security standards and compliance requirements in an efficient and scalable manner [215]. Compared to manual testing practices, AST significantly enhances both the speed and accuracy of the testing process [216].

Automated Security Testing (AST) is significant to ensuring robust cybersecurity in several ways. For example, AST practices can consistently scan complex architectures, interconnected components, and third-party integrations in modern software systems, as they identify vulnerabilities faster and more efficiently [217]. In addition, automated testing provides immediate feedback to developers during the development process, allowing them to fix vulnerabilities as they are introduced. This real-time feedback is crucial to maintain security throughout the software development lifecycle (SDLC) [218]. Manual testing can sometimes miss critical issues due to human fatigue, especially in complex and/or repetitive testing scenarios. In contrast, automated tools perform tests systematically and accurately, reducing the risk of missing potential security gaps. With the rise of agile and DevOps practices, AST practices allow continuous security checks without slowing down the development process, ensuring

[14] International Organization for Standardization
[15] National Institute of Standards and Technology - Cybersecurity Framework
[16] General Data Protection Regulation

that security does not lag behind rapid development efforts. Automating Security Testing reduces the cost of manual labor and time spent on repetitive testing tasks. Over time, it could also lower the total cost of security management by identifying and mitigating vulnerabilities earlier in the development process, which is often less expensive than fixing issues post-deployment [219]. Despite all these benefits, Automated Security Testing (AST) is not without limitations. For example, it may not always detect sophisticated attacks or complex flaws that require human intuition. Although **[CH15]** discussed the lack of automated security testing, the literature has not debated enough on how to technically verify and validate the effectiveness of implemented processes and tools used in Automated Security Testing, e.g. static analysis, dynamic analysis, and container scanning. Therefore, additional research is needed to evaluate process effectiveness, improve tool accuracy, and develop hybrid approaches that effectively combine manual and automated testing.

While AST offers numerous advantages, the integration of AST tools into complex, multi-cloud environments remains a significant challenge and technical hurdle. This review highlights some key challenges that need to be addressed. For this reason, future research should explore advanced approaches and new methods, such as AI-driven testing, to enhance the precision and flexibility of AST practices [220]. Furthermore, there is a need for industry standards and frameworks to guide the selection and deployment of AST tools, confirming their effectiveness in diverse organizational contexts.

Security Awareness and Training. Security Awareness and Training are critical for the organization's overall cybersecurity strategy, as they directly address one of the most significant vulnerabilities and major risks in any security system, which is human errors. Many security violations and malicious breaches result from human mistakes, such as using weak passwords, mishandling sensitive data, or falling victim to phishing attacks [221]. For this reason, security awareness and educating employees to recognize malicious attacks and common threats, are essential for reducing the risk of cyberattacks by empowering employees with the knowledge and skills needed to recognize, avoid, and respond to threats. By fostering a culture of security, ensuring regulatory compliance, and staying ahead of evolving cyber threats, organizations can protect themselves against costly breaches and safeguard their digital systems and organizational assets as well [112]. As suggested in **[SLN03]**, organizations are advised to invest in training their employees, and follow a proactive, cost-effective strategy that strengthens the human element within the organizational cybersecurity defences. This is a thorough approach to addressing the challenges related to people and employees like **[CH06, CH07, CH08, CH09]**, and improving staff skills and performance. As a result, research should further investigate the positive impacts of security awareness and training programs on development and operation teams in DevSecOps environments.

On the other side, efficient Security Educating and Training Awareness (SETA) methods must be carefully assessed and validated due to their long-term impacts on security culture within organizations, and because current SETA methods may not adequately address evolving threats [222], requiring continuous research to ensure they remain effective. Additional research is required to create more customized SETA programs that accommodate cultural, educational, and demographic diversity, making training more effective across all user groups. Besides, research is needed to explore how people retain and act on security knowledge, the psychological aspects of training, and how to design engaging and retention-boosting programs. In reference to addressing the challenge of incorrect geographic distribution for DevSecOps teams **[CH16]**, organizations should map practical skills and resources in parallel with balancing collaboration, communication and operational efficiency in multiple locations. They are compelled to analyze, assess, and optimize team distribution efficiently to

ensure key security skills are not isolated.

Security Orchestration and Automation. This literature review underlines the growing importance of orchestration and automation in improving the effectiveness of security controls. As organizations grow and face increasingly complex IT infrastructures, including hybrid and multi-cloud environments, the manual management of security controls is no longer practical nor feasible [223]. Orchestration refers to the coordinated management of multiple security tools and processes, while automation involves the execution of tasks without human intervention. Together, these approaches streamline the implementation, monitoring, and enforcement of security controls [224].

Security automation and orchestration are essential components of modern cybersecurity strategies due to their ability to improve efficiency, reduce human error, and speed up threat response [225]. Automation helps reduce the time it takes to respond to cyber threats by automatically detecting, analyzing, and responding to incidents [226]. On the other hand, orchestration involves integrating and incorporating crucial security tools and systematic processes, allowing for automated and smooth workflows. Both automation and orchestration ensure that security incidents are handled consistently and quickly on different platforms [227]. Developers, similar to security analysts, need to genuinely understand the mechanisms of orchestration and automation. They should be aware of obstacles and difficulties that might be experienced during the conduct of automated security practices in DevSecOps pipelines. Such obstacles may lead to low adoption of DevSecOps practices [101]. For this reason, further research is needed to examine the orchestration and automation procedures in DevSecOps interfaces. Moreover, extra investigations are required to validate and evaluate the efficiency of automation processes conducted in Incident Response (IR) management for the sake of responding against security attacks and improving resolution times, as pointed out in challenges **[CH15, CH18]** and solutions **[SLN05, SLN09, SLN12, SLN18]**.

In contrast, several studies highlighted the difficulty of integrating disparate security tools and legacy systems into a unified platform. For example, improperly configured automation workflows can inadvertently introduce risks, such as overprivileged access or misconfigured controls [228]. For this reason, future research should focus on developing standardized frameworks and best practices for secure implementation of orchestration and automation in diverse environments [229]. Moreover, machine learning (ML) and artificial intelligence (AI) applications could contribute to further enhancing the adaptability and intelligence of automated workflows [230] [231].

Security Metrics and Key Performance Indicators (KPIs). Metrics and KPIs provide a quantifiable way to assess how well security controls are functioning. They help to identify whether implemented controls, like firewalls, intrusion detection systems, and encryption methods, are effective in preventing attacks and/or mitigating cyber threats [17]. Moreover, they highlight the areas of risks and vulnerabilities, such as weak password policies and unpatched systems, with the intention of enabling proactive mitigation [232]. Security metrics also allow organizations to align security efforts with business objectives by demonstrating how security controls support business continuity, legal compliance, and customer trust. In contrast, KPIs provide evidence of the return on investment (ROI) for security tools and initiatives, helping to justify budgets and resources allocated in executing security practices [233]. As a result, suggesting security metrics and KPIs in Solution **[SLN05]** addressing Challenge **[CH18]**, researching security metrics and KPIs is highly recommended to ensure that the chosen metrics are meaningful, actionable, and aligned with both security and business goals. By conducting thorough research in several areas like Security Metrics Frameworks and metric types, organizations can develop robust and meaningful security metrics that align with their goals and continuously improve their

cybersecurity posture.

Threat Intelligence Integration. Threat intelligence integration is crucial for enhancing security defense mechanisms. It involves incorporating real-time and contextualized information about cyber threats (such as malware, threat actors, and attack techniques) into organizational security infrastructures. This preemptive approach helps organizations stay ahead of evolving threats [234]. Several challenges relating to security controls in threat integration intelligence are reported in this SLR **[CH03, CH11, CH12]**. However, the documentation limitation concerning this area makes the challenges, even more tricky and problematic **[CH01]**. We have discovered that the main cause for such obstacles is development and use of traditional and old-fashioned security tools for security practitioners only, making it a bit burdensome for developers to learn or even utilize them. As a result, software practitioners find it quite difficult to implement DevSecOps practices within a large range of complex and heterogeneous components **[CH01, CH17, CH05, CH02]**, followed by extra activities within the development process **[SLN02, SLN06, SLN09, SLN11]**. This is considered a serious impediment to DevSecOps adoption, as developers must carry out the burden of security-related tasks. To conclude, this is a good opportunity to explore strategies and well-structured frameworks for integrating threat intelligence, including developers' insights about DevSecOps practices along with their feedback on hazard mitigation plans and Incident Response (IR) Management.

Secure Data Containers. Secure Data Containers play a crucial role in protecting sensitive data, especially in today's digital landscape where data is constantly in transit and stored across various environments like clouds and mobile devices [235]. They allow organizations to isolate, encrypt, and protect organizational data across a range of networks and environments, ensuring compliance, reducing risks, and safeguarding against evolving threats and cyber attacks. In addition, these containers help ensure the CIA Triad (confidentiality, integrity, and availability) of organizational data by providing secure and isolated environments to store and process sensitive information [236]. Some solutions **[SLN12, SLN17]** suggest using data containers to overcome scalability and reliability issues related to managing security controls in DevSecOps pipelines [237]. Developers and software practitioners still need to learn and practice the ideal approaches to appropriately implement data containers to address issues like **[CH18]**. Hence, research must extensively investigate the obstacles and challenges of using data containers to solve security problems and improve runtime applications.

Continuous Feedback. Continuous feedback in software engineering is essential for maintaining high-quality code, enhancing collaboration, and enabling iterative improvements throughout the software development lifecycle (SDLC). In the fast-paced development process, regular feedback fosters a culture of agility, adaptability, and continuous learning [238]. For this reason, many studies reported that continuous feedback should be thoroughly considered and automated as much as possible at early stages within the SDLC [239], as pointed out in Solution **[SLN03]**. Continuous feedback is proposed to instantly collect and understand user feedback **[SLN09]**. However, extra investigation is needed on how to obtain user feedback during the manual conduct of security practices to fit into DevSecOps pipelines. Regarding challenges **[CH06, CH11, CH12]**, the sourced papers did not fully inspect the optimization of feedback mechanisms. Therefore, researchers are advised to explore how to optimize feedback mechanisms for faster vulnerability remediation, analyze the effectiveness of feedback loops in DevSecOps particularly, and improve the overall security generally.

Consensus on Shift-Left Security. Shift-Left Security is a core practice within DevSecOps that

emphasizes incorporating and integrating security controls early in the software development lifecycle (SDLC). Security must be handled from the initial design phases rather than waiting until deployment or after the code is complete [240]. The term "shift-left" comes from the idea of moving security "to the left" in the development timeline, which traditionally placed security controls toward the end of the process [241]. In DevSecOps environments, security becomes a shared responsibility among all members working in the development, operations, and security teams, aiming to ensure that all vulnerabilities are spotted, identified, and addressed as early as possible [40]. As mentioned in Challenge **[CH06]**, there is still no complete consensus about the best practices of DevSecOps due to the confusion and unclear information published in current literature about DevSecOps environments. Consequently, it is of utmost importance for researchers to illustrate the main concepts of DevSecOps along with “security-shift-left” best practices, with the aim of resolving possible conflicts among stakeholders and head managers concerning the implementation of security controls within DevSecOps pipelines.

Need for Socio-technical Studies. Socio-technical studies is a collaborative and multidisciplinary field that examines the interaction between technology, society, and human behavior. They explore how technology influences social systems and how social and cultural factors, in turn, shape the development and use of technology [242]. In these studies, the learning is ultimately based on how the technical systems (e.g. machines, software applications, and infrastructures) and social systems (e.g. people and organizations) are intensely interconnected, and both must be considered together to design effective and sustainable solutions [243]. DevSecOps paradigm is widely recognized as a cultural transformation for organizations concerning the cybersecurity field [244] [54]. As pointed out by people-related challenges **[CH06, CH09, CH10]**, the lack of security skills can result in challenges and obstacles relating to agility, velocity, and integration. As a result, it is a good opportunity to conduct socio-technical studies to foster security-conscious cultures and collaboration among development, security, and operations teams who work on DevSecOps practices.

Security Testing in Multi-Cloud Environments. Security testing in multi-cloud landscapes is essential due to the complexity, diversity, and dynamic nature of such architectures [245]. As organizations increasingly adopt multi-cloud networks and start working with external providers (e.g. AWS, Azure, and Google Cloud), ensuring the security of data and applications has become more challenging [246]. Concerning Challenge **CH03**, obstacles may arise during the automation of security practices within multi-cloud environments [247]. Hence, researchers should pay more attention to demystifying the challenges related to building security controls during the execution of DevSecOps in multi-cloud interfaces. Advanced solutions must be proposed to support and maintain consistent security controls across multi-cloud environments, as referred to in Solution **[SLN02]**.

Incident Response Management in DevSecOps. Incident Response Management is indispensable in cybersecurity and business continuity because it ensures a well-organized and effective approach to detecting, mitigating, and recovering from several security incidents like cyberattacks, data breaches, and/or system failures [248]. Effective and practical incident response plans would certainly narrow the impacts and potential damage caused by such incidents, reduce recovery time, and ensure compliance with security standards and regulatory requirements [249] [250]. Referring to the practices mentioned in **[SLN12, SLN18]**, there is still a need to examine Incident Response (IR) processes to identify gaps in detecting, responding to, and recovering from malicious attacks during the implementation of security controls in DevSecOps. Researchers can investigate how incident response teams can improve

communication skills and Incident Response (IR) capabilities from different perspectives (individuals, teams, organizations), especially in high-stress situations. They can explore and inspect the optimal methods for isolating affected systems while minimizing the impact on operational transactions.

2.6 Limitations and Threats to Validity

Like other surveys and systematic reviews, the findings could be impacted by potential threats combined with poor aggregation of primary studies [149] [148]. Relevant papers or suitable studies might have been missed. However, it is hard to guarantee that all relevant papers were captured in this SLR. We have thoroughly examined the risks to validity with the aim of addressing potential internal/external risks and enhancing both the credibility and reliability of the findings, thereby providing more accurate and meaningful insights to mitigate threats as much as possible. Due to limitations in research databases, narrow digital libraries, and search methodologies [158], we took multiple precautions to mitigate the risk of incomplete or biased literature coverage. We developed a thorough search strategy to include multiple libraries and source databases using a combination of wide-ranging synonyms, keywords, and related terms. Despite this, we acknowledge that one limitation of this literature review could be the potential incompleteness of the search string. While we aimed to use comprehensive and well-defined search terms, it is possible that certain relevant studies and papers were not captured due to the exclusion of alternative terms, keywords, or specific synonyms that might have been used by other researchers and missed out in this SLR. Further, we were keen to record every step and document the search process to ensure the replicability and transparency of data.

Bias resulting from picking up relevant papers by implementing inclusion/exclusion criteria normally differs due to subjective judgments, and may affect literature reviews [251]. To reduce this effect, a study approach (protocol) was developed first to identify the research questions, search procedures, and inclusion/exclusion criteria [158]. The main objective of this approach was to increase the consistency in data collection and extraction procedures [252]. All stages (e.g., study selection, data extraction) of this SLR were shared among all authors to review and provide their feedback. We mainly conducted the data extraction process using data extraction spreadsheets. All related spreadsheets and work statements were shared with other authors to access and verify whenever needed. Regular meetings were held between authors to evaluate the progress and assess the outcome of each stage in this SLR. They confirmed and cross-checked the completion of paper selection, data extraction, and data analysis processes [251]. On the other side, we developed standardized spreadsheets for data extraction to handle inaccurate and/or inconsistent data collection and conducted multiple meetings to review and resolve data discrepancies. We also carried out pilot testing and ran several searches on prevalent databases and selected sources for the final primary papers. Further, the search string was improved in a set of iterations to capture relevant papers. Subsequently, the snowballing technique was carried out to capture more papers and explore the primary lists of other secondary studies reported in Table 2.2. Undertaking those activities initially resulted in duplicates and redundant articles, however, they noticeably reduced the chance of missing out on any relevant papers [252] [159]. Nevertheless, there is a risk of bias caused by not performing forward snowballing and neglecting those papers that could be identified through citation tracking. The paper selection might be limited to those prevalent or easily accessible papers.

To maintain a high standard of quality and integrity for our review, we included only peer-reviewed articles to ensure that the findings were based rigorously on research and evaluated by subject matter experts. In contrast, gray literature often lacks this formal evaluation process, leading to inconsistencies in reliability and credibility. Also, gray literature may not be accessible or uniformly indexed in

some instances, making it difficult to include in SLRs. The scope of this review emphasized theoretical and empirical studies to align with our research objectives, which are less addressed in the gray literature. To support replicability and transparency toward achieving the study goals, we included only the sources that provide detailed methodologies on security controls and DevSecOps practices. On the other side, gray literature often includes information and insights not published in traditional papers and academic journals, like white papers, conference proceedings, and government publications. Many sources of gray literature usually come from security practitioners and industry professionals, making the acquired information more valuable and aligned with practical applications. Given these advantages of gray literature, including its ability to provide comprehensive coverage, real-world relevance, and a reduction in publication bias, we recognize its significant value in ensuring inclusive insights and expanding the scope of our research. We aim to conduct a broader future review and include gray literature, addressing new knowledge gaps and capturing additional hands-on practices and emerging trends.

2.7 Conclusion

In this chapter, we conducted an SLR on 45 primary studies, which led to the following findings.

- This SLR captures 19 security controls-related security challenges and 18 solutions to address those challenges. Researchers are recommended to thoroughly consider other challenges and/or solutions within well-defined themes and proper categorization. Moreover, developers should conduct contingency plans and flexible workarounds to take appropriate actions to reduce the impacts of security issues when integrating security controls in DevSecOps.
- The focus area devised from this SLR is supporting security controls in DevSecOps. Current methods have a lot of deficiencies that would certainly hinder the integration of security controls/measures within CI/CD pipelines. Therefore, research for key studies on new methods to promote speedy deployments and rapid integration for security controls within DevSecOps pipelines is a current requirement.
- It is difficult to fully incorporate security controls in DevSecOps using outdated techniques. These techniques hinder the adoption of DevSecOps as they are unable to automate security practices. This is a tricky issue, considering automation is a major pillar in DevSecOps. Hence, further research is required to support automation in continuous security practices within CI/CD pipelines. Security practitioners need to know how to mitigate issues of manual security testing and reduce negative impacts when adding automation to security practices particularly. Thereby, key studies are needed to explore suitable trade-offs and maintain the objective symmetry of both agility and DevSecOps.
- This SLR introduces some staff-related challenges like conflict management and communication issues among individuals. Although collaboration and cultural factors are critical for DevSecOps adoption, they are not investigated enough in the current literature. This fact brings up a strong recommendation to conduct up-to-the-minute research exploring socio-technical studies concerning staff working in DevSecOps. New research should explore more key studies where security practitioners faced social issues due to people problems (e.g., grudges, negative conversations, misconceptions, or stereotypes between departments). Consequently, security analysts will get a better opportunity to understand how such issues were previously handled and mitigated. Eventually, they will greatly benefit from such research to reduce multi-disciplinary problems and obtain a list of valuable lessons learned from past experiences.
- DevSecOps is developed based on shifting security to the left and integrating security controls at

the early stages of SDLC to ensure code is securely written/tested and reduce resolution time for cyberattacks. This SLR highly recommends shifting security to the left and executing continuous scanning for security practices to sustain a solid security posture throughout the deployment cycle.

In conclusion, the suggested solutions provide a practical foundation for implementing and integrating robust security controls within the continuous practices of DevSecOps pipelines. By addressing the key challenges such as automation, scalability, and real-time responsiveness, those approaches and solutions would genuinely enable security practitioners to enhance overall security posture without compromising the agility and efficiency that continuous delivery demands. The integration of these security controls fosters a solid and stable culture of proactive security, aligning development, operations, and security teams toward a unified goal of delivering secure and resilient software. This alignment not only mitigates risks effectively but also empowers these teams to collaborate and embed security controls seamlessly into their workflows, ultimately supporting the realization of secure, high-performing systems in dynamic environments. As this chapter provides an overview of the state-of-art and described the systematic literature review conducted to examine existing approaches for integrating and implementing security controls in DevSecOps environments, the next chapter investigates the state-of-practice and explores how such controls are genuinely implemented in real-world DevSecOps environments and organizational contexts.

Chapter 3

Implementing and Integrating Security Controls: A Practitioners' Perspective

This chapter is published and available online:
M. Sinan, M. Shahin, I. Gondal, Implementing and integrating security controls: A practitioners' perspective, Computers & Security (2025) [65].

Security controls are indispensable in today's technology-driven world for their essential role in protecting applications and systems in many organizations. They help to manage the organizational controls to ensure confidentiality, integrity and access to vital infrastructure and data (e.g., software applications, financial records, personal information, intellectual property, etc) by ensuring that only authorized and trustworthy users have privileged access. Further, integrating security controls within the Software Development Lifecycle (SDLC) is imperative for detecting application deficiencies and preventing potential breaches that could result in financial losses and expose the systems to external and/or internal threats. They reduce the exploitation risk by identifying and patching vulnerabilities in applications and networks within the organization. The SLR findings and foundational background presented in the previous chapter (Chapter 2) revealed that current research places significant emphasis on understanding and conceptualizing security controls. However, these insights also highlight the need to examine how such controls are applied in real-world contexts through empirical investigation. To explore and obtain in-depth practical information, a practitioner-based survey was conducted with 118 software practitioners to further explore how security controls are technically implemented, managed, and validated within organizational environments. The survey covers the four phases of the security controls lifecycle, including classifying, identifying, implementing, and validating security controls to understand the best practices and essential activities in each process. The results indicated that most respondents recognized the critical importance of understanding security requirements before integrating appropriate controls in each software release. We highlighted the key factors that influence the selection and identification of security controls, including user group considerations, risk management practices, and organizational requirements. It appeared that security practitioners utilize a wide range of security controls that are broadly classified into six categories, where administrative and technical controls come first. With this emphasis and awareness, they could align their responses with practical and contextual factors driving effective security control implementation. Furthermore, the findings showed that most organizations rely on internal departments to implement and maintain security controls in conjunction with continuous security practices throughout the different phases of the SDLC. In

contrast, only 36% of respondents utilize automated testing tools for monitoring, while 52% cite insufficient security training as a major obstacle. The survey highlighted the need to hire skillful security practitioners who possess a diverse range of cybersecurity skills, enabling them to govern security controls and handle troubleshooting with poise and professionalism, taking advantage of lessons learned in past experiences. In addition, the results also demonstrated the need for employing up-to-date tools and carrying out a list of best practices, to implement security controls and improve their effectiveness to up-level overall security posture. Those results emphasize the need for enhanced training programs and advanced tools to streamline security control integration.

3.1 Introduction

Security controls are defined as the measures put in place to protect software applications and systems from threats, vulnerabilities, and unauthorized access. They play a fundamental role in ensuring the confidentiality, integrity, and availability (CIA) of information and shaping the practices the security practitioners take to protect their organizations [253]. They are significant in protecting sensitive data, preventing data breaches, and mitigating risks. Furthermore, they greatly contribute to security compliance and adhere to security standards and organizational regulations [254] [255]. Thereby, the lack of security controls and/or their improper implementation would put data confidentiality, integrity, and availability all at risk [256]. As a result, software practitioners and security analysts are strongly advised to understand and systematically prioritize security controls before implementing them based on risk-related practices [257]. Simultaneously, security controls must be thoroughly integrated and aligned with security standards and regulatory requirements (e.g., ISO 27001[1], NIST[2], CIS[3], etc.). These security guidelines and standards perform a fundamental role in leveraging cybersecurity and upgrading the organizational regulations that help in protecting sensitive data and responding against evolving threats [260].

Integrating security controls in parallel with continuous security practices is a significant factor in enhancing the overall security posture. Conversely, security controls still struggle to operate in conjunction with continuous testing, continuous monitoring, and security-by-design principles [261] [262]. Therefore, it is essential for software practitioners to have the sufficient skills and knowledge required to embed security controls into their systems and mitigate the emerging challenges associated with the implementation process [263] [264]. Actually, security analysts still lack the required experience and knowledge to perform the job, resulting in poor and improper implementation [265] [266]. For this reason, it is highly recommended to learn the challenges associated with implementing intelligent security controls, and develop comprehensive metrics and/or benchmarks to verify and assess security controls that could evolve based on threat intelligence, risk assessment, and other environmental changes [267] [268]. Those intelligent security controls are crucial as they refer to advanced controls that leverage tools and applications relating to artificial intelligence (AI) and machine learning (ML). They go beyond traditional rule-based practices by adapting to new threats, learning from incidents, and making real-time security decisions. They will also be used in automation and analytics to detect, prevent, and respond to cyber threats more effectively.

Over the past years, the research focused on international security frameworks such as ISO/IEC

[1] International Organization for Standardization 27001, [258]
[2] National Institute of Standards and Technology [259]
[3] Center for Internet Security

27001[4], NIST SP 800-53[5], and CIS Controls[6]. However, there is a lack of standardized metrics and methodologies for measuring the effectiveness and maturity of security controls [269]. Although existing studies have covered the technical aspects of specific controls like access management and encryption, several critical gaps remain unaddressed, limited research has explored the practical challenges and analyzed how organizations integrate security controls into broader business processes. There is insufficient empirical data on how they effectively adopt best practices in implementing security controls in real-world scenarios. Hence, it became difficult to examine the awareness level and explore the issues experienced throughout the SDLC. By synthesizing data and responses collected from diverse industries, this survey provides actionable insights into best practices and emerging trends, offering a straightforward roadmap for more effective implementation of security control.

The SLR insights explained in Chapter 2, indicated a gap in empirical evidence concerning how these controls are genuinely operated in practice. Building on the foundational understanding and background knowledge, this chapter presents an empirical investigation through a survey aimed at exploring how organizations practically establish, manage, and operationalize security controls. We carried out an online survey with 118 software practitioners and security analysts to understand the prevalent practices and security activities performed while identifying and implementing security controls. More specifically, we sought the practitioners' perspectives on identifying, implementing, and validating security controls during continuous practices. Furthermore, this survey sheds light on the most essential security activities and best practices practitioners carry out to integrate and implement security controls throughout the Software Development Lifecycle (SDLC). It also emphasized the fundamental skills and requisite security certificates that should be possessed by the security practitioners who are expected to work on security controls.

This survey found that software practitioners are aware of the importance of understanding security requirements before implementing security controls. They categorize security controls (e.g., preventive, detective, corrective, etc.) based on each security control's fundamental responsibilities. However, they sometimes aggregate typical types and merge them in a way that supports their applications. Our survey pointed out the major phases of Security Controls Lifecycle including the execution phase, where software practitioners conduct essential practices like threat modeling, penetration testing, and risk assessment to determine the most suitable controls for their systems. They do their best to ensure security controls adhere to strategic objectives, industry-specific standards, and national security frameworks like NIST[7], ISO/IEC 27001[8].

Based on this survey, security controls are frequently reviewed to check their effectiveness, especially after responding to malicious attacks or major organizational restructuring. A set of key performance indicators (KPIs) is utilized to measure the effectiveness of security controls and confirm they meet security requirements. Systematic reports are automatically generated to summarize the outcomes resulting from the verification process, which will be shared later with stakeholders reporting the areas that need to be improved. Many organizations have also started to provide security awareness training programs for their current staff to ensure the proper execution of security controls.

In this chapter, Section 3.2 summarizes the background knowledge and related work about security controls providing a foundational understanding of existing literature about the field of security controls. Section 3.3 thoroughly describes the methodology and key elements we addressed in conducting this survey to ensure that our approach is clear, replicable, and well-justified. Next, we explain the sur-

[4]International Organization for Standardization and the International Electro-technical Commission
[5]National Institute of Standards and Technology Special Publication
[6]Center for Internet Security
[7]National Institute of Standards and Technology
[8]International Organization for Standardization/International Electrotechnical Commission

vey results in a well-articulated findings Section 3.4, including the key insights and perceptions derived from the survey responses. Later, we discuss and communicate our reflection and interpretation of the findings in Section 3.5, highlighting the survey objectives. In addition, we underpin the significance and implications of the results in Section 3.6. Potential limitations of the survey design and findings are outlined in Section 3.7, demonstrating the transparency and credibility of the study. The Conclusion Section 3.8 synthesizes the main elements of the survey's contribution, relevance, and potential studies for future research.

3.2 Background and Related Work

3.2.1 Security Controls Maintenance

Security controls are indispensable for ensuring and maintaining a solid level of confidentiality, integrity, and availability of organizational data and resources [270]. They are generally categorized into multiple types based on their main purpose and role in protecting systems from sophisticated data breaches, unauthorized access, physical damage, or even robbery [271] [272]. As an example, security monitoring systems, Security Information and Event Management (SIEM) [273], Incident Response (IR) and contingency plans [274], and Security Education Training and Awareness (SETA) [275]. The lack of persistent security controls and/or improper implementation exposes organizations to many severe consequences and wide-ranging impacts affecting them in various aspects. In addition, prioritizing security controls is crucial for protecting organizations against cyber ransomware threats and maintaining a positive resilience and trustworthy reputation in the market and current digital landscapes [276].

Data Breaches: Without adequate security controls in place, organizations are more vulnerable to cyber-attacks and likely exposed to data breaches, resulting in unauthorized (malicious) access and illegitimate transactions to sensitive information, e.g., financial records, customer profiles, employee information, and data of intellectual properties [16].

Compliance Violations: Failure to adequately implement solid security controls can result in non-compliance with legal requirements and industry regulations, such as GDPR[9], HIPAA[10], and PCI DSS[11]. Failure to demonstrate compliance with security standards would also result in legal penalties, fines, and sabotage of business operations and regulatory relationships [277].

Disruption of Transactions & Operations: Most security incidents are usually caused by a shortage of technical controls that disrupt business processes, resulting in critical damage to the infrastructure and reduced productivity. Inadequate security controls can likely sabotage resilience and disrupt business continuity, impeding daily transactions and service delivery [278].

Financial Losses & Security breaches arouse significant expenses and financial costs relating to forensic investigations, incident responses, regulatory fines, and remediation and fixing procedures. Financial implications may extend to long-term revenues and/or shareholder values [279].

Reputational Harm: Operational disturbances would certainly tarnish the organization's reputation and affect the normal flow of business activities with customers, leading to deep dissatisfaction, decreased customer loyalty, and contract cancellations as well. Cyber breaches and data leaks weaken the trust and confidence level among customers, especially if their services are affected. This could also result in business/brand damage, negative publicity, and diminished market values [280].

[9] General Data Protection Regulation
[10] Health Insurance Portability and Accountability Act
[11] Payment Card Industry Data Security Standard

Long-Term Destructive Business Impacts & Loss of Intellectual Property (IP): Insufficient security controls lead to loss of intellectual property (IP), trade business secrets, and ownership technologies. Lame security controls can have enduring repercussions on organizations' profitability and sustainability in the market, thus reducing innovation and competitiveness vibes within different departments, especially R&D (Research and Development) [281].

Legal actions & Regulatory Scrutiny: Cyber incidents caused by inefficient security measures usually entail problematic investigations and enforcement of actions/audits by governing authorities.

Cyber Ransomware & Online Extortion: Organizations lacking solid security controls (safeguards) are more prone and susceptible to cybercrimes and ransomware online attacks [282]. Generally, hackers exploit weak and vulnerable systems and get remote control to disrupt daily transactions, covert them into botnets, and encrypt sensitive data, demanding ransom payments for decoding algorithms.

3.2.2 Related Work

This section investigates relevant literature concerning security controls and their basic processes (implementation, validation, and maintenance). Stafford and his research team highlighted the importance of the roles and responsibilities of security controls, thus putting extra effort into selecting and identifying the appropriate security controls upon the completion of any security risk assessment [283]. They discussed a set of 10 internal security controls that are included in ISO 17799[12] and should be implemented as the basis for security risk assessment. This process was indispensable to mitigate the risks resulting from improper risk assessment and/or un-methodical security analysis.

In another paper, Almeida and Respício considered the selection of security controls and pointed out the necessity of relying on well-established and international standards for information security (e.g., ISO/IEC[13] 27001:2013, ISO/IEC 27002:2013) [284]. It is extremely important to first define the relationship between vulnerabilities/threats and generic security controls before commencing the process of selecting and establishing security controls. Based on this concept, they developed an optimized model that uses the standards of ISO/IEC 27001, supporting software practitioners in detecting security weaknesses and identifying vulnerabilities. After the process of vulnerability identification, developers must select and establish a proper subset of security controls to ensure effective contingency plans and adequate mitigation for reported vulnerabilities within sufficient time and lower costs.

Moreover, Khajouei et al. conducted a usability study to discuss and understand the challenges of identifying and selecting information security controls in organizations [285]. Their approach included running a fuzzy analyser to prioritize and select security controls based on their effective managerial domains, objectives, and roles in maintaining data security. They demonstrated a fuzzy Analytical Hierarchy Process (AHP) as the main method to specify the main objectives of security controls and the local weights of managerial domains. The fuzzy AHP was used to prioritize and select internal security controls while implementing ISO 27001 security standards at the same time. Meanwhile, there are some authors who put a lot of effort into sustaining and supporting the decision-making processes when it comes to identifying security controls.

Bettaieb et al. studied the difficulties that security analysts have to claim and compete during the elaboration of security requirements [286]. One of the most noticeable problems was filtering and sifting security controls before the development process. Further, determining which security controls were significant and relevant to organizational security requirements yet had been missed. They built their assessment with a reasonable level of precision. Eventually, the authors presented

[12] International Organization for Standards 17799

[13] International Organization for Standards/ International Electrotechnical Commission

an ML (Machine Learning) approach that helps security analysts identify relevant security controls efficiently, plus reducing the possibility of ignoring or overlooking any important controls. In year 2022, Wibowo and Ramli studied the relationship between security controls and their impacts on the Security Risk Assessment (SRA) from multiple aspects [287]. They provided a comprehensive and systematic investigation for security controls about all risk phases, including identification, analysis, evaluation, maintenance, and risk acceptance. They also mentioned some maturity gaps relating to security controls in the domain of governance frameworks, risk assessment, bug detection, and risk management to follow up with incident response and contingency plans.

On the other side, Hamed pointed out the importance of internal security controls to ensure financial performance sustainability [288]. He mapped his study with the implementation of e-accounting systems along with their influences on business transactions, productivity, and financial performance. Hamed tested his results using a set of statistical methods (e.g. Cronbach Alpha, One Sample tests, etc). Moreover, several studies have explored topics closely related to our research, particularly those discussing the validation process of security controls and the procedures for assessing the effectiveness of internal security controls, as pointed out by Angelini et al. in [289]. Papazov et al. debated how to correctly and frequently structure the process of verifying security controls according to the best practices resulting from risk management/analysis and in tandem with the standards outlined by NIST SP 800-100 [290]. Ultimately, the authors suggested automated approaches to apply frequent validations on security controls and carry out a dynamic risk assessment to support risk analysis and recovery management faster and methodically. Those methods were built based on attack charts to estimate the consequences of attack patterns and further reckon the possibility for them to occur.

Other researchers have also provided guidelines and instructions to assist organizations in planning and conducting security controls, including administrative policies and technical and network controls. Bettaieb et al. worked comprehensively and used machine learning to assist with the selection of security controls during security assessment [291]. They presented practical recommendations for implementing and managing security controls related to continuous practices. On top of all, their results suggested the key elements of security testing and the technical assessment of controls. They conducted their reviews with a close eye on network security testing guidelines from one side and advanced security techniques from the other side, including benefits, recommendations, and limitations of use. Other papers have proposed new methodologies to apply quantitative analysis for security controls. Jillepalli et al. suggested Cyberspace Security Econometrics System (CSES) models that involve quantitative indications to measure security performance and reliability [292]. The special characteristic of those models is that they account for the necessity of each security requirement and deal with every piece of specification as a new function, whether it matches the interests of stakeholders or not. Their study introduced the fundamentals and competencies of the CSES model, including input/output parameters required for the assessment.

Moreover, some studies suggested self-assessment frameworks to publish and validate security controls in cloud environments along with their associated capabilities and facilities. Mishra et al. developed a model to verify and evaluate security controls in cloud environments [293]. Their model gives the ability to select cloud services according to competences and publishing suppliers. In addition, the researchers debated the challenges of verifying the trustworthiness of security controls and whether those controls are satisfactorily fulfilled as per the providers' request. To solve this challenge, they introduced a formalized taxonomy in the form of the trust properties that should be captured by security controls. Given the increasing complexity of cyberattacks and the crucial role of security controls within organizations, security practitioners can no longer rely on manual methods to ensure security. Our analysis of the papers mentioned above shows a lack of in-depth discussions on important

elements like the best practices and challenges associated with implementing and integrating security controls. They did not sufficiently address the critical aspects like approaches, methodologies, and issues from the practitioners' perspectives. This omission left a noticeable gap in understanding the practical hurdles and solutions necessary for effective implementation. For this reason, we decided to conduct this survey to comprehensively discuss those points and enhance the understanding of the challenges, complexities, and practicalities of implementing effective security controls. It highlights the most efficient insights, dynamic security frameworks, and resilience-based training that can assist in designing more resilient and secure software applications. The findings derived from this survey can thus serve as a valuable resource for security analysts and software practitioners, helping to enhance their response capabilities and workforce preparedness, thus strengthening organizational security.

3.2.3 Security Control and Emerging Trends

As IT environments evolve, security controls emerge and develop to function proactively with such environments and technologies (e.g., AI applications, cloud services, zero-trust models), supporting their agility and complexity. The following sections examine the dynamic integration of security controls in advanced and emerging technological ecosystems.

3.2.3.1 Security Control Integration in AI Applications

Integrating security controls with AI-powered interfaces demands a fusion of customized security techniques to align with AI features [294]. Security practitioners review security controls, keeping them suitable and seamlessly integrated with AI interfaces. For example, they adopt AI-specific threat modeling and address risks like adversarial input and model poisoning. They also identify AI-specific vulnerabilities to defend against emerging threats [295]. Since AI systems rely on data quality and accuracy, security analysts enforce input validation and adversarial training to ensure data integrity, fortify models, and resist adversarial attacks [296]. They enhance identity access management (IAM), multi-factor authentication (MFA), and role-based access controls (RBAC) by continuously verifying users through behavioral patterns, preventing unauthorized access and ensuring compliance with privacy-preserving AI techniques. In addition, data encryption secures sensitive information processing without compromising functionality or compliance [297].

3.2.3.2 Security Control Integration in Cloud Services

Embodying security controls in dynamic cloud environments comes with unique challenges. Software practitioners firstly address those challenges to ensure that security controls remain agile, updated, and well integrated with the unique cloud demands (e.g., Cloud Security Posture Management (CSPM), Cloud Workload Protection Platform (CWPP)), which support real-time monitoring, configuration, and incident response [298] [299]. In addition, developers utilize threat intelligence and Security Information and Event Management (SIEM) to get better visibility for centralized logs resulting from multiple cloud-native tools [300]. They implement automated scans and infrastructure as code (IaC) tools such as Terraform[14] and AWS Cloudformation[15] to enforce security compliance and check for misconfigurations and/or excessive permissions on cloud deployments [301].

[14] https://www.terraform.io/
[15] https://aws.amazon.com/cloudformation/

3.2.3.3 Security Control Integration in Zero-Trust Models

Security controls are upgraded to align with zero-trust models that require a focus on continuous user verification, limited access controls, and contextual awareness [302]. Zero-trust models are designed based on the principle of "never trust, always verify", meaning no user/device is trusted by default, regardless of location [303]. Software engineers are requested to review current controls to align with zero-trust models [304]. They build resilient and flexible security models that minimize risk and improve visibility, ensuring continuous access control. They also enforce multi-factor authentication (MFA), just-in-time (JIT), and least-privilege access controls across multiple administrative points to add additional security layers [305] [306]. By doing this, they confirm that only privileged access is granted, and users have the minimum access to perform their roles. Temporary sessions are granted only when needed and automatically revoked after task completion. The encryption functions are enforced in transit and rest mode [307]. On the other hand, software engineers hold regular sessions to promote zero-trust practices (e.g., adaptive authentication, least privilege access), helping employees understand and support these initiatives [308]. They also carry out automated practices such as security assessment and incident response plans to respond to security incidents promptly, isolate suspicious users or devices, and generate warning alerts for security teams [309].

3.3 Methodology

Typically, obtaining information in a structured way to harmonize the understanding of current industry practices and future directions can lead researchers to conduct impactful and translational research. To this end, an online survey was conducted to uncover how organizations establish and monitor security controls on their systems and software applications. The following sections describe how the survey was designed and conducted after obtaining ethical approval from our university to conduct the research survey and involve human responses. Figure 3.1 shows an overview of the steps of the survey design and execution.

3.3.1 Survey Design

The survey was designed using the guidelines proposed in [310] and was hosted on the Qualtrics platform. It took approximately 8-10 minutes to complete the survey. The survey was available online from 01 April to 31 May 2024. We designed the survey questions based on the literature review and the authors' experience to assess the knowledge in implementing and validating security controls. The survey questions were designed to provide clear insights into the levels to which security controls are classified. A subset of them is listed in Table 3.1. Other authors reviewed the survey questions and provided their feedback. In the survey introduction (Section 3.1), we summarized our goals to the potential participants and defined the eligibility criteria for participation. To enhance the reliability of our survey, we incorporated well-defined questions designed to comprehensively address all phases of the security controls life cycle, including the associated practices, approaches, and methods. The survey consists of 27 questions, including 20 compulsory (must be answered). All questions were closed-ended except for one, which was open-ended, and the participants had the chance to share their feedback and suggestions with the survey author.

- **Demographics:** The survey included 4 demographic questions about the participants' job positions, the industry they work in, and the cyber security certificates they obtained to gain a competitive advantage in their careers. Where necessary, we also allowed the participants to select multiple

responses for the questions and enter their choice in blank fields if the answer options did not apply to them.

- **Classification of Security Controls:** We had 8 questions to understand the types of security controls currently implemented in the industry (e.g., *"which of the following physical security controls do you employ in your organization?"*.
- **Identification & Execution of Security Controls:** Our survey also consists of 4 questions that sought the participants' perceptions on the identification and implementation process of the security controls (e.g., *"when does your organization execute security controls?"*).
- **Compilation of Security Controls:** There were 5 questions to explore how security controls are normally established to achieve compliance in the organizations (e.g., *"Which cybersecurity regulations and privacy laws does your organization comply with?"*).
- **Validation of Security Controls:** Validating security controls can ensure that they are providing desired deterrence against identified security threats. For this purpose, five questions focused on the validation process of security control (e.g., *"how often are the controls validated in your organization?"*).

Table 3.1: A subset of the survey close-ended questions. The complete survey is found in [3].

Q1. Has your organization put in place security controls and measures to monitor security breaches? If yes, then how? (Select all that apply)
Q2. Security controls are categorized into several types: administrative, technical, physical, human, detective, and corrective controls. Which of the following administrative security controls do you employ in your organization? (Select all that apply).
Q3.Which of the following detective security controls do you employ in your organization? (Select all that apply).
Q4. During the process of identifying security controls, which of the following points/activities did you consider according to the organization's preferences? (Select all that apply).
Q5. What are your plans to handle evolving security controls in the next 12 months? (Select all that apply).
Q6. Which Cybersecurity regulations and privacy laws does your organization comply with? (Select all that apply).
Q7.Which of the following practices have helped in improving the effectiveness of controls in your organization? (Select all that apply).
Q8. Which security practices have you utilized during the implementation of DevSecOps? (Select all that apply).
Q9.How often are the controls validated in your organization?

Pilot Study. Before starting the survey, we conducted a pilot study to identify and resolve the logistical and technical problems. The survey was initially shared with a small, selective group of security experts (participants). Their contribution and feedback were used to verify and refine the quality of the survey design and questions. Their input and comments significantly contributed to reviewing the questions, ensuring proper navigation between pages, and improving the main survey. The research team followed a strategic plan to select potential participants whose insights and contributions could be valuable in shaping the survey. We selected 11 participants who held different roles, such as security analysts, developers, and software practitioners, and had experience implementing security controls. Subsequently, formal invitation emails were sent to the participants. Six respondents completed the survey. Three invitees emailed us, indicating they could not complete the survey due to the lack of required knowledge in the security controls area.

In summary, the pilot study indicated that no issues were found with the presentation of the survey, as the participants did not face any technical problems or difficulties while navigating between pages and/or moving across the questions. Conversely, they raised a few concerns and suggestions enlisted

in Table 3.2. Those concerns were considered and addressed before distributing to a larger number of participants.

Table 3.2: Comments raised in the pilot survey and their corresponding solution

Comments	Solution
The survey questionnaire is a bit lengthy	Although the survey consists of 27 questions, including demographic and primary questions, the length of a survey is usually measured in terms of the time spent to answer all questions. As advertised in our survey, filling out the questionnaire takes 8-10 minutes. However, the questions were revised and edited to appear briefer and more concise to reduce the expected time-frame required to answer the questionnaire.
The first demographic question (Q1), which inquires about the industry in which the participant works, didn't include the option of 'Retail Business'	Although we included the option 'others' as one of the answers and a free-text where the participant can enter a new answer in case his/her response wasn't enlisted. The answer list of (Q1) was changed to include the option of 'Retail Business'.
The punctuation of question (Q13) was not clear nor well-formulated, causing confusion and some misunderstandings	The question (Q13) was re-formulated immediately and re-phrased to convey the meaning of the original inquiry.

3.3.2 Potential Participants

The key goal was to target the right participants who could contribute to the study with their knowledge and practical experience. Based on this understanding, we identified our participants by considering the factors, e.g., their expertise level, demographic locations, and experience in security controls. To help this, we designed a flyer that effectively helped communicate with the target audience and encourage participation. We used several recruitment strategies to employ potential participants for our study. We ensured that all recruitment methods complied with ethical guidelines and data protection regulations outlined by the ethics application. The research team utilized their professional networks to recruit participants and elicit a diverse range of responses about security practices that are currently being implemented within organizations. At the high-level, the employed recruitment strategies can be classified into the following:

- **Public Networks**: We publicly advertised our survey on social media platforms like LinkedIn, cybersecurity-relevant WhatsApp groups, and cybersecurity forums, where potential participants may be members. Moreover, the authors posted a detailed message on LinkedIn along with the flyer, and the positive reactions from the network were used to contact the participants. The flyer effectively helped to communicate the survey purpose successfully as it included the hyperlink to the questionnaire. To highlight the value of the survey, we enclosed information about ethics approvals associated with the survey. This recruitment strategy resulted in 5% of response rates.
- **Direct Invitations**: In this strategy, we directly invited potential practitioners to participate in the survey. The list of potential practitioners was compiled from the research team's professional networks. The direct invitations were sent through email or LinkedIn messaging. We also encouraged a prompt participation and called some participants to swiftly take action and contribute to the survey by simply adding a friendly statement that shows our appreciation and how their feedback is valuable and important. *E.g. "We value your feedback – please take a few minutes to complete the survey!"*. After a week, follow-up reminders were sent to the practitioners. This strategy obtained 95% of the survey responses.

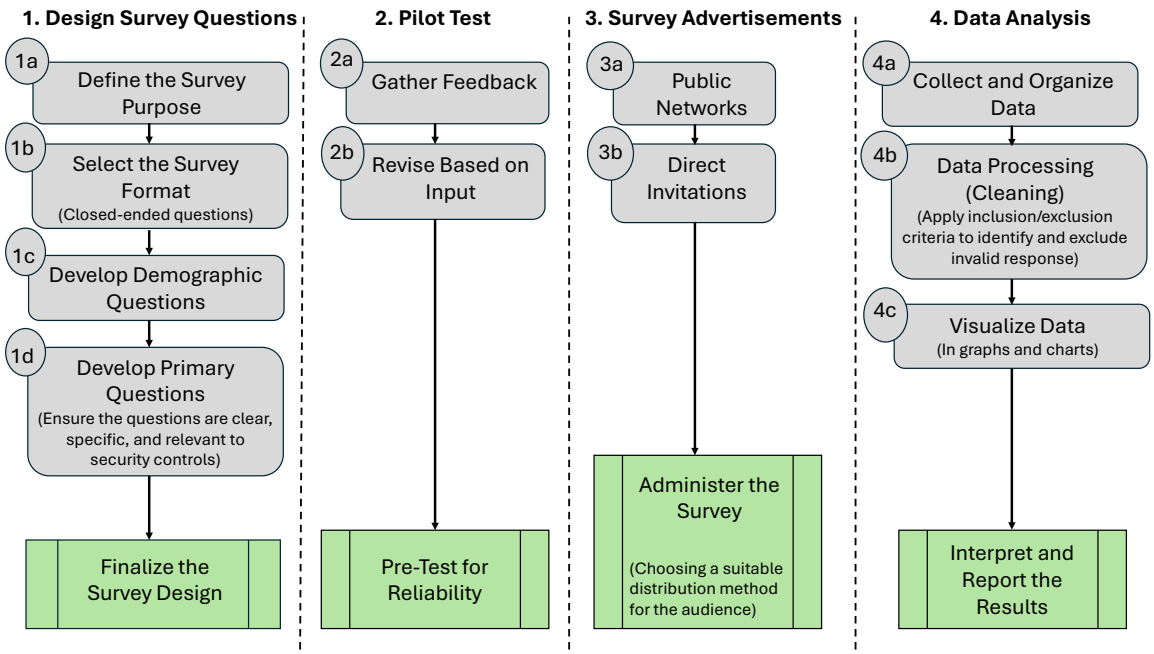

Figure 3.1: Steps of Survey Methodology

3.3.3 Data Analysis

We received 197 responses in total from the above-mentioned recruitment strategies. The responses were analyzed and captured in a spreadsheet. Next, a data processing was performed to identify invalid responses from 197 responses. This step was essential to confirm the relevance and suitability of the samples for the study.

- Incomplete Submissions: Our analysis shows that some participants started the survey and answered some of the questions (e.g., demographic questions) but did not submit the survey. One reason behind this may be that the respondents felt they were not the right people to participate in the survey. 21% of the participants (n=41) completed the demographic questions only.
- Response Time: Given that approximately 10 minutes were needed to complete the survey, we inspected the time taken to fill out the survey by the participants. More specifically, if the responses were submitted too quickly (less than 2 minutes), these responses were identified as invalid as they indicated a lack of attention or automated replies.
- Inconsistent Responses: Respondents might provide inconsistent and contradictory answers concerning security controls, which indicates misunderstanding, confusion, or lack of attention to the survey questions. For example, some participants might declare they have in-house security controls capabilities while reporting contracts with outer vendors for control management in later questions.
- Incoherent Responses: When respondents gave feedback that does not make sense or is irrelevant to security controls in any way. This could happen due to providing irrelevant feedback, random answers, or deliberate attempt to misrepresent.

Applying the above-mentioned criteria to the 197 responses, we identified 79 as invalid. All invalid data was later dismissed and excluded from the survey results, yielding 118 valid responses and reliable data samples. We used descriptive statistics to analyze 118 valid responses because the survey questions were largely closed-ended (e.g., multiple-choice questions) [310]. For many questions, the participants

were able to enter their own answers through the 'Other' field.

3.3.4 Validation of Survey Data

The findings presented in this chapter are primarily derived from data collected on the implementation of security controls in real-world DevSecOps environments. Although the survey yielded valuable insights, it was essential to verify the accuracy and reliability of the data before using it as the basis for developing the framework presented in the next chapter (Chapter 4). As the data could be subject to discrepancies, biases or inconsistent interpretations of survey questions; therefore, a systematic validation process was undertaken. First, the survey findings were carefully examined to ensure they were conceptually robust, aligned with DevSecOps principles and accurately reflected the intended research constructs. To ensure data reliability, internal consistency analyses was undertaken, involving a systematic examination of response patterns to detect incomplete, inconsistent, or anomalous data, thus strengthening the trustworthiness of the survey results. To further contextualize the findings, the research team conducted semi-structured discussions to corroborate the survey results with insights and observations obtained from industry practitioners. Collectively, these activities strengthened the credibility of the empirical findings and provided a robust foundation for the framework developed in the subsequent chapter (Chapter 4), ensuring it is both evidence-based and practically relevant.

3.4 Findings

This section presents the findings of our survey. We categorize the results into five sections, namely Demographics, Classification of Security Controls, Identification & Execution of Security Controls, Compilation of Security Controls, and Validation of Security Controls), detailed below.

3.4.1 Demographics

Domain: Among all respondents, 14% were employed in the cybersecurity industry, 19% in the banking and financial sector, 20% in IT consulting organizations, and 10% in governmental and educational sectors, with the remaining participants distributed across other industries such as telecommunications, healthcare, insurance, and retail.

Role: As displayed in Figure 3.2, most respondents (42 out of 118) were project managers and had multiple primary areas of responsibility from project management and application supervision. Twelve participants are technical consultants, and 26 respondents are managing directors and vice presidents. Sixteen security practitioners and DevOps engineers contributed to our survey. On the other hand, architects and instructors also completed the survey.

Experience: Figure 3.3 shows the number of participants along with their years of practical experience in cybersecurity. It was found out that many participants (n=79) had more than five years of experience in cybersecurity.

Certificates: Further, the results show that 14% of respondents are CEH[16] and CGEIT[17], while 15% of respondents hold advanced certificates in cybersecurity like CISM[18], CISSP[19], CISO[20], and

[16]Certified Ethical Hackers
[17]Certified in the Governance of Enterprise IT
[18]Certified Information Security Manager
[19]Certified Information Systems Security Professional
[20]Chief Information Security Officer

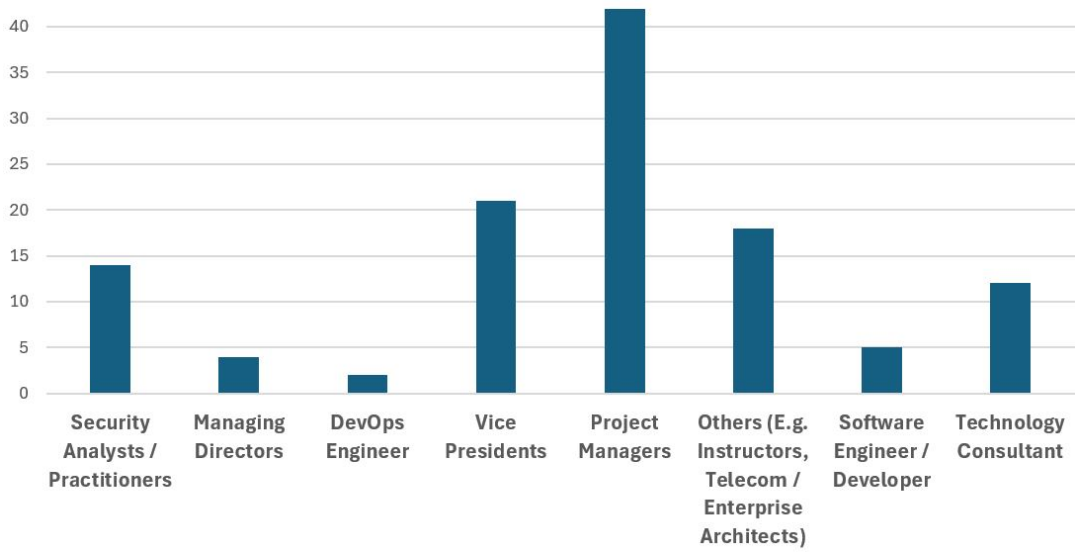

Figure 3.2: Job Positions & Roles of Participants

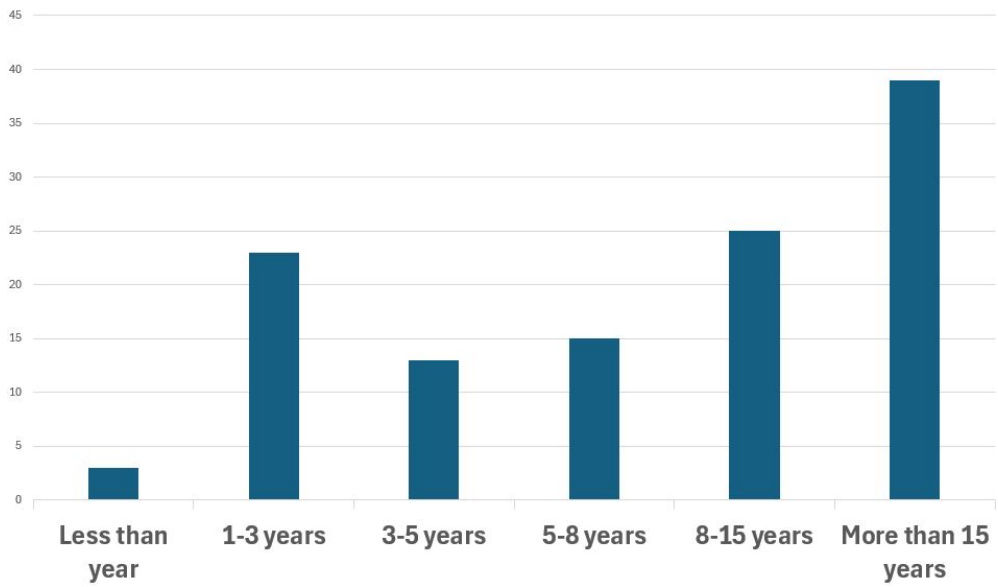

Figure 3.3: Respondents vs. years of cybersecurity experience

CISA[21]. The remaining 49% of participants hold equivalent certifications in security and networking, such as CCIE[22], GCSP[23], and ISC2[24]. It was also observed that 22% of the participants possessed multiple certifications in the field of cybersecurity.

[21] Infrastructure Security Agency
[22] Cisco Certified Internetwork Expert
[23] Geneva Center for Security Policy
[24] International Information System Security Certification Consortium

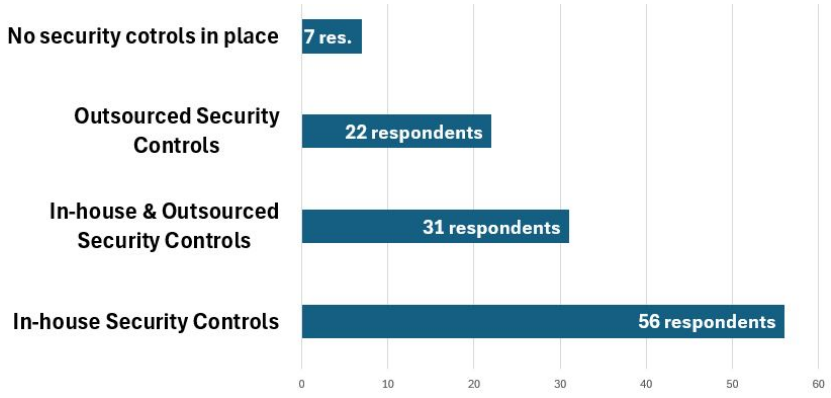

Figure 3.4: Are security controls put in place? In-house or outsourced?

3.4.2 Classification of Security Controls

Classification of security controls refers to the process of categorizing and structuring security controls based on certain criteria to effectively protect information systems and organizational data. Security controls are typically classified in several ways based on their main purpose, nature, functionality, or implementation. At the outset of the survey, questions regarding the establishment and classification of security controls were posed to assess how these controls are implemented within organizations. Understanding the effectiveness of existing security controls is crucial to determining whether they are adequately positioned to detect and monitor cyberattacks and breaches.

3.4.2.1 In-house vs. outsourced

In this survey, the participants could specify whether the implemented security controls were in-house specified or outsourced by third parties or external providers, as illustrated in Figure 3.4. 47% of the respondents implement and handle security controls in-house, pointing out the in-house capabilities and self-sufficiency in managing security controls. In contrast, 26% of the respondents stated that their in-house departments still collaborate with external service providers to build and maintain security controls, taking advantage of their expertise in conducting specific security practices. Figure 3.4 also shows that 19% of the respondents indicated that their organizations totally rely on external service providers to manage security controls and deal with cybersecurity situations.

3.4.2.2 Who handles security controls?

The participants were asked to specify the departments responsible for tracking and handling security controls in their organizations. Figure 3.5 shows that 25 out of 118 respondents mentioned that the IT Security Department is responsible for security controls. 14 respondents pointed out that security controls are managed by the Security Operations Center (SOC). In contrast, 11 respondents said that both IT Security Department and Security Operations Center (SOC) are responsible for implementing, tracking, and managing security controls in their organizations. Based on respondents' answers, Figure 3.5 also indicates how some organizations rely on multiple internal departments to collaborate effectively and work together on supporting/preserving implemented security controls, e.g., Incident Response (IR) Department, Risk Department, Compliance and Governance Department.

Table 3.3: Classification of implemented security controls in respondents' organizations

Category	Description of security controls & Main purpose	%
Administrative	**Policies & Procedures**: Establish security policies and guidelines to govern how employees should handle data and access systems.	81%
	Access Control Management: Manage access requests to systems and data through account provisioning, de-provisioning, and user access reviews.	80%
	Security Awareness Training: Educate employees about security practices and their responsibilities for safeguarding data and organizational assets.	75%
	Incident Response Management: Develop remediation plans and effective workarounds to respond to security incidents and breaches.	62%
Technical	**Authentication**: Verify user identities and provide convenient access to systems and resources using passwords or multi-factor authentication (MFA) mechanisms.	83%
	Antivirus & Anti-malware Software: Install up-to-date antivirus software to scan systems against malicious viruses and/or malware functions.	78%
	Firewalls: Implement security devices to filter network traffic, and control incoming/outgoing traffic with the aim of preventing unauthorized access.	72%
	Access Control Lists (ACLs): Configure permissions and restrictions on files and directories.	66%
	Patch Management: Ensure that software and systems are kept up to date with the latest security updates.	64%
	Vulnerability Scanning: Identify and assess vulnerabilities in systems and applications.	61%
	Intrusion Detection & Prevention Systems (IDS/IPS): Monitor network traffic for suspicious activities and take action to block and/or alert potential threats.	59%
	Encryption: Protect organizational data by transferring it into unreadable formats that can only be decrypted by authorized logins.	58%
	Security Information & Event Management (SIEM): Collect and analyze login files to detect security incidents.	53%
Physical	**Surveillance Systems**: Employ cameras and monitoring equipment to monitor and record physical access.	70%
	Environmental Controls: Maintain safe physical environments to protect your hardware, such as temperature and humidity control, fire suppression, and backup power systems.	65%
	Biometric Access Systems: Use fingerprint or retina scans for physical access control.	54%
Human	**User Training & Awareness Programs**: Educate employees about security trendy methods, best practices, and the importance of their roles in maintaining a strong security posture.	79%
	User Account Management: Properly manage user accounts including provisioning, de-provisioning, and enforcing password policies.	76%
	Background Checks & Screening: Ensure that individuals who are hired for positions with access to sensitive information undergo security checks.	64%
Detective	**Log and Audit Trail Analysis**: Review transactional logs and audit activities to detect unauthorized proceedings.	85%
	Intrusion Detection Systems (IDS): Monitor for signs of unauthorized access or attacks	64%
Corrective	**Risk Management Plans**: Implement security controls based on security organizational needs and solid risk assessments.	72%
	Incident Response Plans: Execute remediation procedures and workarounds that quickly respond to security incidents and data breaches.	68%
	Recovery Procedures and Backups: Implement strategies to recover organizational data and create secure backups for systems in case of data loss, breaches, or system compromise.	67%
	Maintain the CIA (Confidentiality, Integrity, Availability) Triad: Establish specific controls to maintain the security principles for data and information systems	58%

Figure 3.5: Who implements security controls?

3.4.2.3 Which types of security controls are implemented?

Several categories of security controls need to be implemented in an organization: administrative, technical, physical, human, detective, and corrective controls. Through a multi-choice question, we asked the participants which activities they do for each type of security control.

(1) *Administrative Security Controls:* As disclosed in Table 3.3, many participants (81%) said that their respective organizations had implemented administrative security controls by establishing and circulating 'Policies & Procedures' to govern how employees should handle data and access systems. Around 80% of respondents indicated using 'Access Control Management' (ACM), like implementing account provisioning, de-provisioning, and user access reviews. Furthermore, 75% of the respondents indicated that their respective organizations have already started to run 'Security Awareness Training' to educate employees about security practices and their responsibilities for safeguarding data and organizational assets. 73 out of 118 respondents referred to using Incident Response Management (IRM) to develop remediation plans and effective workarounds to respond to security incidents and breaches. Conversely, only 4 respondents enlisted other unmethodical and random approaches to admin security controls in their organizations, that were not included in the question list.

(2) *Technical Security Controls:* As shown in Table 3.3, the majority of participants (83%) indicated carrying out authentication mechanisms like passwords or multi-factor authentication (MFA) to verify user identities and provide convenient access to systems and resources. Multi-Factor Authentication (MFA) mechanisms enhance security by requiring users to provide multiple forms of verification to prove their identity. These mechanisms typically fall into primary categories; knowledge-based mechanisms (passwords or pins, security questions), possession-based mechanisms (hardware tokens, software tokens), and inherence-based mechanisms (facial or voice recognition, fingerprint scanning). 78% of participants said that their respective organizations protect and scan their systems against malicious viruses and/or malware functions by installing up-to-date antivirus software onto their computers and servers. 85 out of 118 respondents declared they implement firewalls to filter network traffic and control incoming/outgoing traffic to prevent unauthorized access. 64% of respondents use Patch Man-

agement to ensure that their systems are kept updated with the latest security updates. At the same time, 53% of participants mentioned that their respective organizations utilize Security Information and Event Management (SIEM) to collect and analyze login files to detect security incidents.

(3) *Physical Security Controls:* 70% of respondents employ surveillance systems, like cameras and monitoring equipment, to monitor and record physical access in their organizations, especially to server rooms.

(4) *Human Security Controls:* 79% of respondents indicated that their respective organizations have started User Training and Awareness Programs to educate employees about security detection/ mitigation/ prevention methods, best practices, and the importance of their roles in maintaining a strong security posture.

(5) *Detective Security Controls:* It also appeared that most respondents (100 out of 118) performed the intrusion detection by conducting Log/Audit Trail Analysis methods and reviewing transactional logs and audit activities.

(6) *Corrective Security Controls:* 72% of respondents use Risk Management Plans to implement security controls based on security organizational needs and risk assessments. On the other side, 68% of respondents indicated that their respective organizations implement Incident Response Plans to execute remediation procedures and workarounds that quickly respond to security incidents and data breaches.

Key Findings 1: Approximately 47% of the respondents handle security controls internally by in-house departments, demonstrating their self-sufficiency and internal capabilities in this domain. Others collaborate with external providers to develop and maintain security controls. Additionally, 80% of the respondents utilize access control management in account provisioning, de-provisioning, and conducting user access reviews. In contrast, 75% provide security awareness training programs to educate employees on security practices and their responsibilities in protecting data and organizational assets.

3.4.3 Identification & Execution of Security Controls

Identification of security controls involves determining which security controls are needed based on specific security needs, organizational requirements, and cyber threats. This process generally includes Security Requirements Analysis, Risk Assessment, and Security Control Selection. On the other hand, the execution of security controls involves the actual implementation and integration of the identified security controls within the system or the organization's environment.

3.4.3.1 Activities in Security Controls Identification

Through the survey, we asked participants about the activities and best practices they usually carry out during the identification of security controls. As shown in Figure 3.6, 70 participants pointed out that they clearly specify the ownership for security controls and assign specific practitioners to manage security controls. Further, 69 participants said they provide meaningful descriptions of controls when identifying security controls to ensure they are effectively understood and verified. 67 respondents perform essential security activities, such as risk management, vendor actions/controls, projects/business initiatives, and regulatory/structural changes, during the identification of security controls.

Figure 3.6 also shows that the majority of participants specify the essential parameters of security controls (e.g., input parameters, occurrence parameters, and place of execution) during the process of identifying security controls. As most of the survey questions included the 'Other' option, six participants entered their own unique answers in a text box at the end of the answer choice list. They

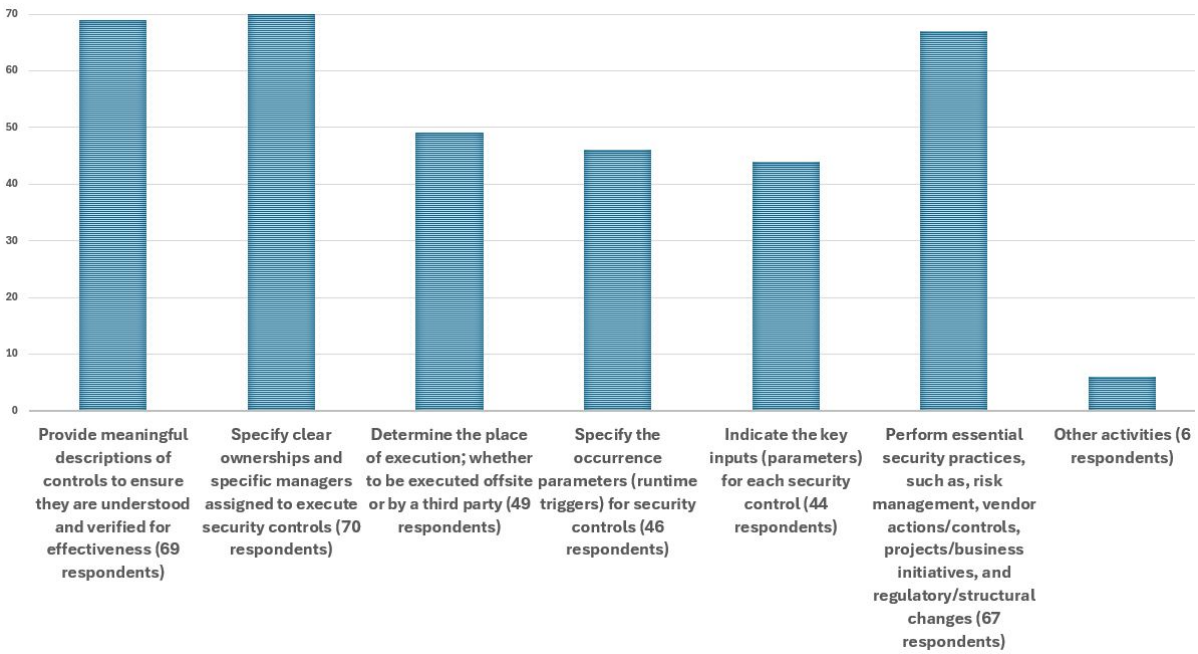

Figure 3.6: Activities involved in Security Control Establishment

indicated that they first conduct Security Risk Assessments (SRAs) to help discover security gaps and identify vulnerabilities. Later, they utilize those SRAs to build security controls from multiple perspectives (processes, people, tools) and integrate and align them with organizational preferences. Before commencing the process of Security Controls Implementation, security controls will be reviewed and checked by the Security Review Board (SRB) to confirm their proper functioning of patching, addressing security gaps, and mitigating threats.

3.4.3.2 When to operate security controls?

Figure 3.7 illustrates that 36% of respondents reported that their respective organizations establish security controls at the start of the software applications requirements phase. While 31% establish security controls at the design phase, the rest (24%) identify security controls during the run-time phase. A small percentage (9% of respondents) said their organizations consider security controls within all aforementioned phases of the software lifecycle.

3.4.3.3 How often are security controls executed?

According to the survey results, 37% of respondents said that security controls are executed monthly, as illustrated in Figure 3.8. In contrast, 24% of respondents pointed out that their respective organizations run security controls quarterly, while 14% carry out a semi-annual control execution. Five participants only reported that their respective organizations execute security controls once a year.

3.4.3.4 Which events would trigger the execution of security controls?

As Figure 3.9 shows, 36% of participants said that security controls are usually triggered during the automation process, with the occurrence of predefined events like submitted forms or received emails. On

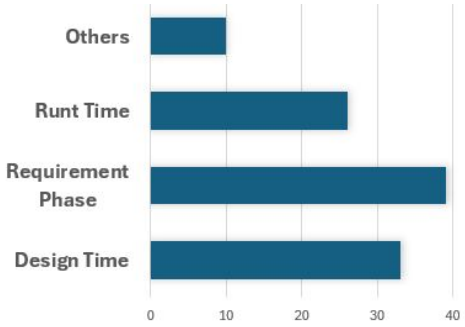

Figure 3.7: When to execute security controls?

Figure 3.8: How often are security controls executed?

the other side, 25% of participants indicated that security controls are triggered in their organizations with the occurrence of special events like clicking a button or placing a message in the queue. 14% of the participants indicated that security controls are triggered due to the updates in database systems which result in automatic actions. Eleven respondents said that security controls are triggered during the execution of predefined cloud services, such as uploading files into clouds and/or serverless architectures. Lastly, only three participants said that their respective organizations have security controls associated with IoT (Internet of Things) devices and sensor readings. For instance, a thermostat device will trigger the associated security controls to heat up the systems whenever the temperature falls below certain thresholds.

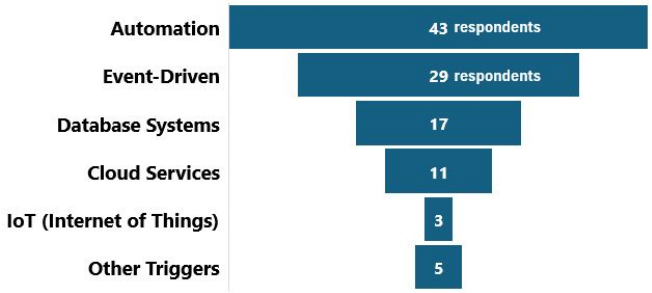

Figure 3.9: Which events would trigger the execution of security controls?

Key Findings 2: Many practitioners explicitly determine the ownership of security controls and designate dedicated individuals or teams to oversee and manage them. Almost 60% provide clear and meaningful descriptions for security controls to ensure they are effectively understood and verified. Furthermore, 67 out of 118 respondents carry out essential security activities like risk management to address security and regulatory requirements.

3.4.4 Compilation of Security Controls

Compilation of security controls refers to the procedure of gathering, organizing, and documenting a comprehensive set of security controls the organization employs to protect assets, data, and information systems. Standardization and compliance with security standards and regulatory requirements are considered to be the main purposes of this compilation process. Compilation of security controls is also used as a reference to ensure that all mandatory controls are properly identified, implemented, and effectively maintained.

3.4.4.1 Handling evolving security controls

Through a multi-choice question, we asked the practitioners what practices they plan to employ to handle evolving security controls in the next twelve months. Our results showed that 42% of participants utilize additional measures to compile evolving security controls. However, 25% of participants indicated that external vendors provide them with out-of-door software programs to handle security controls. 47% of respondents reported that they audit and self-assess their evolving security controls by boosting security awareness among the IT staff and improving their capabilities through SETA (Security, Education, Training, Awareness) methods to help them become security experts. On the other hand, 22% chose to partner with managed service providers and get out-sourced security analysis, whereas 19% of respondents decided to extend their current contracts with vendors and get further assistance in managing security controls. Finally, 20% of the survey respondents claimed that they do not have any systematic procedures or plans in place to handle evolving security controls in the next 12 months, nor did they know if such procedures existed in the first place.

3.4.4.2 Complying with regulations and privacy laws

Figure 3.10 illustrates what regulations and privacy laws the participants' organizations comply with and the percentage of participants who selected each law. After analyzing the survey results, it appears that 27% of participants indicated that their organizational security controls strongly comply with the General Data Protection Regulations (GDPR). Moreover, 25% of participants said that their respective organizations consider the security standards outlined by (Payment Card Industry Data Security) whenever they need to manage or identify new security controls. 19% of participants declared that their respective organizations follow the standards outlined by (Data Availability & Transparency Act) to compile and manage security controls. However, 9% of respondents assured that their organizations comply with other national regulations and enforcement policies like the New South Wales Education Standards Authority, ISO27001, APRA CPS234, and IEC-62443 controls. Nevertheless, 31% of participants were not sure about what security regulations their organizations comply with.

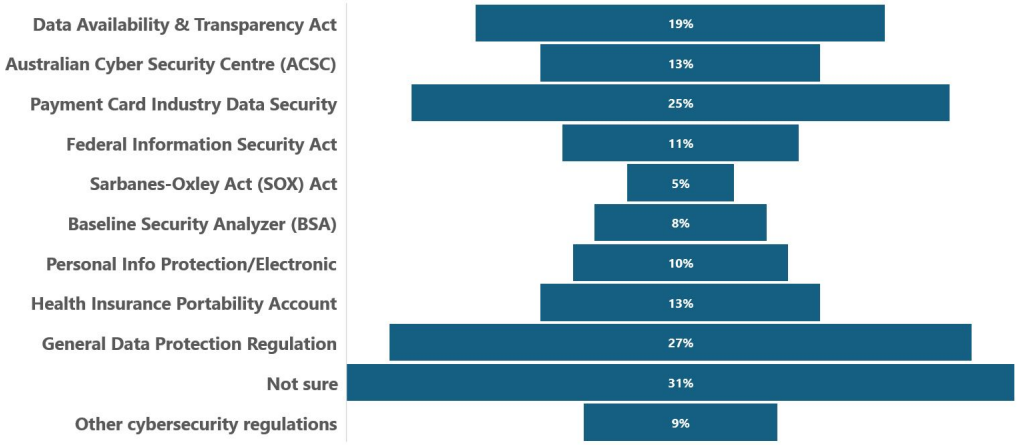

Figure 3.10: What security standards/privacy laws do organizations comply with?

3.4.4.3 Practices to improve the effectiveness of security controls

According to Table 3.4, the majority indicated that they conduct security testing and security analysis-related practices. More specifically, 52% of participants execute penetration testing and vulnerability scanning to ensure the effect of security controls in detecting vulnerabilities, whereas 15% of respondents said that they carry out red-team exercises and play the role of ethical hackers in an attempt to breach security controls and address more vulnerabilities. With reference to practices relevant to Incident Response Management (IRM), 40% of the respondents confirmed having solid Incident Response (IR) plans to demonstrate the security controls that simulate incidents and attacks properly. Additionally, 26% of respondents use Incident Response (IR) metrics, like Mean-Time-to-Detect (MTTD) and Mean-Tim-to-Respond (MTTR) values, to indicate the efficiency of implemented security controls. 51% of respondents assured that they started carrying out User Awareness Training to improve security competencies in identifying and reporting attacks.

3.4.4.4 Security controls in DevSecOps

Given that DevSecOps has become a widely adopted methodology in the industry, we were interested in knowing how organizations build and implement security controls in the context of DevSecOps. Within the survey, we asked the participants about the approaches they carry out to build security controls and their adopted strategies to improve the overall security in DevSecOps. As shown in Figure 3.11, 45% of the respondents said that their respective organizations helped their staff get certified in advanced security programs and acquire essential security skills and competencies. On the other hand, 33% still believe that partnering with external providers is the best and quickest approach to providing the organization with skillful security analysts and resources. 32% of participants indicated that their respective organizations completely rely on independent software vendors to provide advanced security software. 21% of the respondents said that their organizations hired a new staff specialized in firewalls and cloud security. Only 25 respondents (out of 118) were not sure about the security controls that ought to be implemented in DevSecOps environments.

Table 3.4: Which practical practices work best to improve the effectiveness of security controls?

Category	Description of the practice	%
Security Testing	- Execute penetration testing and vulnerability scanning to ensure the effect of controls in detecting vulnerabilities.	52%
	- Engage in red team exercises where ethical hackers attempt to breach controls to address vulnerabilities.	15%
Security Assessment	- Run/Monitor patch management to assure the proper execution of security patches	39%
	- Conduct Security Information and Event Management (SIEM) analysis to provide valuable insights into security incidents	36%
Incident Response	- Manage User Awareness Training to improve security competences in identifying and reporting attacks	51%
	- Be ready with solid Incident Response (IR) plans to demonstrate the controls that simulate incidents and attacks properly	40%
	- Perform post-incident analysis after the occurrence of attacks to decide lessons learned	35%
	- Track security metrics and key performance indicators (KPIs) like incident reduction rates and false positives/negatives	27%
	- Use Incident Response (IR) metrics like Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR). E.g., low MTTD/MTTR values indicate the efficiency of controls	26%
Network Security	- Apply firewall rules and network segmentation to control the traffic	54%
	- Carry out intrusion detection and network security monitoring to uncover suspicious activities and anomalies	33%
Security Compliance	- Apply regular reviews and audit access controls like authentication mechanisms and user access permissions to ensure only authorized users have access	55%
	- Conduct security audits and regular assessments to identify areas where controls may need refinement	31%
	- Generate security control validation reports and share the results with managers and stakeholders	26%
	- Conduct regular compliance audits to verify that controls align with regulatory requirements and industry standards, e.g., ISO 27001, GDPR, HIPAA	24%

3.4.4.5 Security practices in DevSecOps

DevSecOps helps organizations ensure security controls are properly addressed by integrating best practices. By performing essential practices like Automated Security Testing, Infrastructure as Code (IaC) Security, Continuous Monitoring, Automated Security Testing, and Shift-Left Security (as shown in Figure 3.12), organizations can reduce vulnerabilities and address various security issues in early stages within the SDLC, to prevent their recurrences as much as possible. This process is extremely important to mitigate the potential impacts of vulnerability exploitation and reduce any conflict between the development, operation, and security teams. Figure 3.12 shows that 40% of respondents conduct Continuous Planning to address and tackle security controls. 37% of respondents carry out Automated Deployment, while 32% conduct Continuous Delivery. Moreover, 24% perform Security Continuous Integration (SCI) and 35% apply Automated Monitoring. Further, 22% of respondents indicated that they carry out Threat Intelligence & Investigation, while only 19% started utilizing SETA (Security/Education/Training/Awareness) methods.

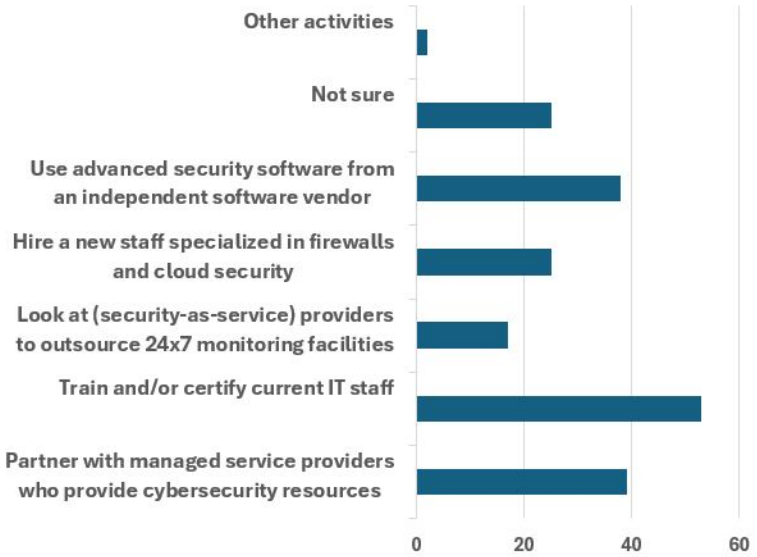

Figure 3.11: Security controls in DevSecOps

Key Findings 3: The survey emphasizes the global security regulations and privacy laws observed by the participants' organizations. 27% of participants reported compliance with GDPR regulations, while 25% emphasized prioritizing the security standards defined by PCI DSS when identifying new security controls. Meanwhile, 9% confirmed compliance with other national regulations and enforcement frameworks, including ISO 27001, APRA CPS 234, and IEC-62443.

3.4.5 Validation of Security Controls

Validation of security controls refers to the process of ensuring that the implemented security controls are functioning properly, addressing risks effectively, and satisfying the organization's security requirements. A regular and thorough validation process is an essential maintenance aspect of security management that involves a combination of reviewing, testing, and verifying implemented security controls to confirm important factors. For example, **reliability** (they can reliably detect, prevent, and quickly respond to security incidents), **effectiveness** (they perform effectively and work as intended in protecting organizational assets against evolving threats and vulnerabilities), **compliance** (they comply with security standards and regulatory requirements), and **improvement** (identify the areas that need to be improved in the existing security controls). While running this survey, we asked participants to estimate the processes of verifying and endorsing implemented security controls in their organizations.

3.4.5.1 How often to validate security controls?

More than half of respondents (52%) conduct regular validation procedures to ensure that current security controls are implemented, maintained and used correctly to perform the designated activities and reduce the risk of security attacks. Many of them (40% of participants) do this procedure monthly. Other respondents said their respective organizations validate and check their security controls quarterly or semi-yearly, as illustrated in Figure 3.13.

Figure 3.12: Security practices in DevSecOps

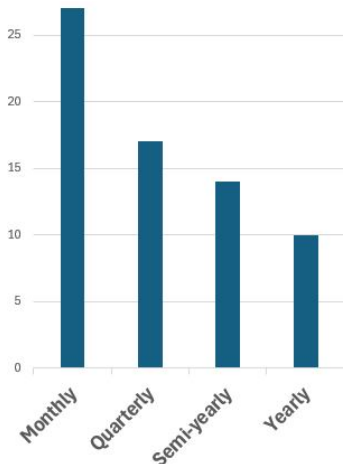

Figure 3.13: How often are security controls being validated in your organization?

3.4.5.2 Who does security controls validation?

For those organizations who carry out regular assessments for implemented security controls, the majority (82% of participants) depend on in-house administrative departments to manage and handle security controls in their organizations. 25% of participants declared they utilize Client Services Centres (e.g., help-desks, technical support departments) to follow up with security controls. In contrast, the other 25% do a self-auditing process for security controls and procedures in each division. Only seven respondents said they hire external third parties and independent audit organizations to perform those

assessment procedures.

3.4.5.3 Activities in security controls validation

The survey results in Table 3.5 show that respondents had the opportunity to thoroughly explain the process of security control validation, and make a list of essential tasks and exercises to be carried out. The majority confirmed they first understand the scope, main objectives, and the expected outcome from each security control during the process of security control validation. On the other hand, 75% of the respondents said they review all the documentation related to security controls, including standards and guidelines as per industrial regulatory requirements. Also, 67% of respondents start carrying out vulnerability assessment, code management, and penetration tests to determine weaknesses and areas of malfunctions. Furthermore, 44% generate reports summarizing the findings of the security control validation process and sharing these findings with managers and other stakeholders. However, only 34% of participants indicated that their organizations enforce continuous improvement and use the received feedback after each validation session. Moreover, 36% of participants apply continuous monitoring and track the performance of implemented security controls using security information and event management (SIEM) and intrusion detection systems (IDS). SIEM excels in centralized management and log correlation, while IDS focuses on real-time network or system monitoring. Correlating IDS detections within SIEM's broad data pools would improve the accuracy and relevance of threat detections, thus enabling detailed understanding and mitigation of attacks. By leveraging these powerful security mechanisms, organizations can effectively detect, analyze, and respond to cybersecurity threats, ensuring robust protection.

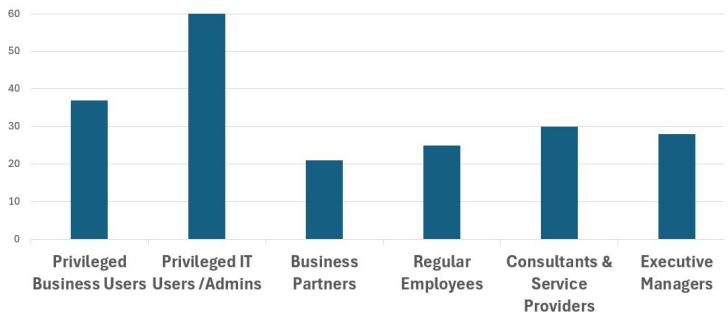

Figure 3.14: Who poses the largest risk to security controls?

3.4.5.4 Influencers on security controls

Finally, the participants were asked to indicate the user groups that have the most significant impact on current security controls or may potentially put security controls at risk. Figure 3.14 shows the percentages of respondents who answered the question and identified the associated groups. For instance, 30% of participants said that privileged IT users and administrators have the biggest effect on current security controls, while 15% pointed out that consultants and service providers largely affect current security controls. However, it appeared that business partners (11%) have the least impact on current security controls.

Table 3.5: What tasks/activities does your organization carry out during the Security Controls Validation process?

Category	Description of the task	%
Security Testing	- Understand the scope, main objective and expected outcome of each control in alignment with organizational security policies.	70%
	- Carry out vulnerability assessment, code management and penetration tests to determine weaknesses and areas of malfunctions.	67%
	- Apply continuous monitoring to track the performance of controls through security information and event management (SIEM) and intrusion detection systems (IDS).	36%
Security Assessment	- Review the documentation related to security controls including procedures, standards, and guidelines as per industrial regulatory requirements.	75%
	- Review the implementation of each control including configuration checks, access control lists, and network diagrams.	62%
	- Keep all security documentation up to date and version-controlled.	64%
	- Generate summary reports for the results of Security Controls Validation process and share the findings with managers and other stakeholders.	44%
	- Enforce continuous improvement and use the feedback received after each validation session.	34%
Incident Response	- Develop remediation workarounds to address issues and respond to vulnerabilities.	51%
	- Revise the effectiveness of Incident Response (IR) plan.	43%
Audit & Security Compliance	- Ensure all individuals are aware of cybersecurity and always compliant with security policies.	48%
	- Ensure that security controls comply with security standards and align with industrial regulatory requirements (e.g., GDPR, HIPAA, ISO 27001).	46%

Key Findings 4: Over half of the respondents regularly perform validation procedures to ensure that security controls are properly implemented and maintained to carry out designated activities and minimize security risks. The majority of participants rely on in-house administrative departments to support and oversee security controls within their organizations. Only a few engage external audit firms to carry out the validation process.

3.5 Discussions

This chapter presents the findings of a survey on how organizations implement and manage security controls. In the following subsections, we reflect on the key findings and discuss the results to uncover underlying issues and identify the gaps, strengths, and areas for improvement relating to security controls and associated practices.

3.5.1 Analysis of Key Findings

After reviewing and investigating the survey results, the findings show a positive perspective of the respondents' professionalism and focus on achieving the organizational security targets. They were eager to complete a specific exercise checklist before executing each process within the Security Controls Lifecycle, including Security Controls Identification and Classification, Security Controls Implementation, Security Controls Compilation, and Security Controls Validation. Moreover, this survey opens new opportunities for research discussions.

3.5.1.1 Security Controls Classification

The findings in Section 3.4.2 emphasize a clear preference for managing access controls internally, with nearly half of the organizations relying on in-house teams. This underscores the crucial role of human participation in cybersecurity, demonstrating self-sufficiency and expertise in implementing security controls effectively and improving the overall security posture. In contrast, the preference of some organizations to collaborate with external providers suggests a strategic effort to leverage specialized expertise to improve their security posture. Given this, organizations are strongly advised to conduct extensive market research, assess suppliers, vendors, and third parties, and review feedback to ensure partnerships with reputable and highly rated providers. To streamline this process, they may consider establishing a dedicated department focused on research and development, allowing informed decision-making and continuous evaluation of external security partnerships.

On the other side, the survey shows that most organizations now categorize security controls by objectives and operational areas, ensuring secure access, minimizing unauthorized privileges, and strengthening governance. However, developers may design advanced aggregations, combining and configuring controls for enhanced security. Potential bias may arise when innovators and start-ups classify security controls according to strategic goals rather than compliance [311], while those of compliance-driven organizations often prioritize regulations over operational risks [312] [313]. By integrating security controls with human-centric strategies and awareness training programs, organizations educate employees about best security practices and their responsibilities. This would manifestly reduce human error risks, improve security resilience, and cultivate a culture of security.

3.5.1.2 Security Controls Identification & Execution

The survey indicates that the process of identifying security controls begins with the selection of security controls. As illustrated in Section 3.4.3, the results highlighted the importance of understanding security requirements and establishing clearly defined responsibilities for security controls before implementing them in each software release. Practitioners offer clear descriptions of security controls and responsibilities, ultimately improving control effectiveness and fostering better understanding among stakeholders. During the survey, we emphasized the factors that would guide the identification of security controls, such as organizational requirements, risk management, and user groups.

Allocating the ownership and accountability of security controls to dedicated individuals or teams before commencing with the implementation process is necessary to identify decision-makers in times of issues. This improves the enforcement and verification of security controls, ensuring accountability, structured oversight, and transparency in control implementation. However, other respondents indicated that their security controls are built upon pillars (processes, people, tools) after conducting the Security Risk Assessment (SRA), which is reviewed and endorsed under the supervision of the Security Review Board (SRB). In light of implementing different types of security controls (Table 3.3), the survey highlighted key policies and administrative procedures governing data access management while ensuring the CIA Triad (Confidentiality, Integrity, and Availability) for information systems. While designing software, practitioners should always ensure that security controls are strongly aligned with security standards and regulatory requirements outlined in international security frameworks, such as NIST CSF[25], SOC[26], ISO 27001[27] [314] [315]. They also comply with relevant data privacy and se-

[25] National Institute of Standards and Technology | Cybersecurity Framework
[26] Security Operations Center
[27] International Organization for Standardization

curity laws specific to each industry, such as GDPR[28], HIPAA[29], and PCI-DSS[30]. However, the survey shed some light on technical controls, such as encryption techniques, which are essential to protect confidentiality, integrity, and authenticity [316].

Software practitioners usually select a list of proven and widely adopted encryption algorithms, such as AES[31] for symmetric encryption and RSA[32] or ECC[33] for asymmetric encryption. They avoid using outdated or proprietary algorithms as they might contain some vulnerabilities. Due to the frequently evolving encryption standards, many organizations conduct regular audits of encryption implementations to verify compliance with security policies and regulatory standards [317] [318]. These audits include tracking access keys and encryption/decryption functions, monitoring access attempts in log files, and analyzing these logs for abnormalities or suspicious activities [319]. Based on the practices mentioned in Table 3.4, software practitioners utilize those essential activities to implement robust security controls and treat them as an integral part of their operational processes. For example, they engage in risk management and adhere to theoretical models with a strong focus on addressing security threats and regulatory compliance. This proactive approach reflects that security governance extends beyond control implementation to ongoing monitoring, maintenance, and risk mitigation, with the aim of improving organizational resilience [320] [77].

In the context of threat modeling, the results showed that practitioners in large organizations prioritize comprehensive threat modeling, while smaller organizations focus on immediate risks due to limited resources. To address this potential bias, we collected responses from balanced samples of organizations of varying sizes and discussed how the availability of resources could influence the identification process [19]. However, security analysts in high-risk industries (e.g., Fintech companies that deliver innovative financial solutions) may report different challenges compared to conservative sectors (e.g., healthcare) [321] [322]. Software practitioners schedule on-time reviews and continuously run auditing exercises to verify both technical and functional specifications of implemented security controls. The survey indicated that the frequency of these audits (e.g., weekly, monthly, or quarterly) is often determined by the system architecture, and some organizations release new security controls biannually. This highlights that practitioners are well aware of the optimal timing for building and implementing security controls. Integrating security controls early in the software development life cycle (SDLC) enables the detection and resolution of vulnerabilities before they become more complex and costly to address.

3.5.1.3 Security Controls Compilation

By analyzing the survey responses in Section 3.4.4, our study highlights that security compliance and adherence to regulatory requirements are critical factors in shaping the implementation of security controls. Hence, practitioners are strongly encouraged to adopt frameworks and select controls from international frameworks, such as NIST[34], ISO 27001[35], or CIS[36], based on organizational objectives and business requirements [323]. However, they can always navigate complex regulations and tailor

[28] General Data Protection Regulation
[29] Health Insurance Portability and Accountability Act.
[30] Payment Card Industry Data Security Standard
[31] Advanced Encryption Standard
[32] Rivest-Shamir-Adleman
[33] Elliptic Curve Cryptography
[34] National Institute of Standards and Technology
[35] International Organization for Standardization
[36] Center for Internet Security

their controls to meet their risk landscapes and comply with industry-specific standards. For example, adherence to GDPR[37] points out a strong emphasis on data privacy, especially for organizations handling personal information. Similarly, focusing on PCI DSS[38] underscores the priority of securing payment transactions and financial data. Moreover, security controls are structured according to how organizational size and resources impact the thoroughness of control analysis. As an example, practitioners in large enterprises advocate for comprehensive control sets to mitigate a wide range of risks associated with complex infrastructures. However, analysts in smaller organizations usually prefer a minimal, cost-effective subset of controls, emphasizing feasibility over completeness [324].

Conversely, security controls are compiled based on how the practitioner's role influences the emphasis placed on compliance versus operational effectiveness. For instance, a security architect may prioritize controls that strictly align with regulatory requirements, such as GDPR[39] or HIPAA[40]. However, another practitioner may focus on controls that enhance technical robustness and sustainability, potentially de-emphasizing compliance-driven requirements [325] [326]. Furthermore, security controls are usually evaluated based on how past incidents and individual experiences shape the approaches carried out in the compilation process. For instance, security practitioners with experience in organizations previously breached might overemphasize controls targeting similar vulnerabilities. Meanwhile, those without breach history may rely more on general guidance without specific threat emphasis [327] [328].

3.5.1.4 Security Controls Validation

The survey findings in Section 3.4.5 show the proactive approach that organizations adopt to ensure the effectiveness of security controls. The reliance on in-house administrative departments for supporting and overseeing security controls demonstrates a strong internal capability and self-sufficiency in verifying security controls. In contrast, the limited involvement of external audit firms in control validation indicates that most organizations prefer internal management of controls and processes, likely due to confidence in their teams or the need for greater oversight and flexibility. This underscores the importance of organizations investing in skill development, enhancing security expertise, and improving their teams' ability to respond swiftly to security incidents. To accomplish this, organizations must first educate employees on emerging threats and evolving attack techniques, ensuring they are well-prepared to tackle modern cybersecurity challenges.

As shown in Table 3.5, software practitioners adopt top-down approaches and implement effective practices to enhance security controls for safeguarding systems and software applications. The results revealed that more than half of the respondents were perceptive and attentive to the significance of ongoing monitoring and control validation. They perform regular reviews and best security practices to ensure preventive and detective controls are effectively implemented, maintained, and capable of preventing cyberattacks and minimizing risks. Although the practices used to verify security controls are robust and comprehensive, they may vary depending on the availability of tools, internal audits, or third-party inspections [329]. Moreover, validation results are logged and archived to track implemented controls and verify their consistency, compliance, and efficiency in addressing evolving threats and technical upgrades.

The survey also found that practitioners in well-funded organizations utilize automated practices, whereas others rely on manual testing. Therefore, they are encouraged to implement security metrics,

[37] General Data Protection Regulation
[38] Payment Card Industry Data Security Standard
[39] General Data Protection Regulation
[40] Health Insurance Portability and Accountability Act

such as MTTD[41], MTTR[42], and CMMI[43] in Table 3.4, to systematically enhance and optimize security controls. These techniques enable developers to shift from basic, reactive approaches to proactive, evolving controls that effectively withstand emerging threats [330]. Because each industry has unique regulations, operational priorities, and threat landscapes, practitioners consider industry-specific regulators to assess the effectiveness and punctuality of implemented controls. Security regulations and theoretical models include HIPAA[44] and HITRUST[45] in Health Industry, as well as PCI-DSS[46] and FFIEC[47] in Finance Industry [331] [332].

3.5.1.5 Security Controls Awareness

Our study shows that many organizations have already started to invest in their employees and educate them through adequate training to spread cybersecurity awareness. Effective employee training programs will certainly improve their cybersecurity skills and practical competencies in managing security controls. On the other hand, the survey demonstrates rating evidence on whether or not the respondents utilize security controls by implementing DevSecOps layers and continuous security practices. On average, most participants who exhibited the execution of DevSecOps practices have confirmed the implementation of fundamental security controls while performing continuous security practices.

3.6 Implications

In this section, we discuss several implications for research and practice communities, helping practitioners and researchers understand what the findings suggest and how they should influence security controls, policies, or decisions relating to security controls and associated practices.

3.6.1 Implications for Industry

The survey findings provided practical approaches and actionable recommendations that organizations can leverage to address real-world scenarios and challenges in implementing and managing security controls. Here, we include some industry implications to ensure our research is a practical tool that can drive progress and foster innovation within the domain of security controls.

3.6.1.1 Need for Skilled Security Analysts in Governing and Troubleshooting Security Controls

Upon the survey completion, the respondents had the opportunity to reflect on their experience and acknowledge concerning the integration of security controls within the conduct of continuous security practices (e.g., threat modelling, risk analysis, continuous delivery, etc) [333]. They became assertive of the best practices and most effective time to manage and tackle security controls within the SDLC. During the governance of security controls, security practitioners may face some technical problems and/or networks issues, which require immediate troubleshooting to resolve issues as quickly as possible [334]. The survey results showed that the demand for cybersecurity specialists outpaced the growth

[41] Mean Time to Detect
[42] Mean Time to Respond
[43] Capability Maturity Model Integration
[44] Health Insurance Portability and Accountability Act.
[45] Health Information Trust Alliance
[46] Payment Card Industry Data Security Standard
[47] Federal Financial Institutions Examination Council

in aggregate demand across the rest of the occupations. The combination of swelling cyber-attacks and regulatory requirements indicates a further necessity for hiring skillful analysts and security professionals who could practically apply their knowledge and CTA (Call To Action) findings in troubleshooting when unexpected issues arise [335]. The insights and strategies gained from this survey, were established based on diverse practitioner inputs and tailored to variable business needs and organizational contexts (e.g. resource constraints, regulatory requirements, and evolving threat landscapes).

3.6.1.2 The Crucial Role of Advanced and Up-to-Date Tools

The survey results demonstrate the importance of utilizing contemporary tools and technologies, whether the tools are used to execute the security controls and improve their effectiveness (as in Table 3.4, Section 3.4.3), or used during the Security Controls Validation Process (as in Table 3.5, Section 3.4.5). Those tools help organizations safeguard systems and organizational data through the Security Controls Lifecycle, and within the conduct of continuous security practices. As an example, it is important to tightly track and maintain the solutions and tools used in Identity and Access Management (IAM) like SailPoint[48], Okta[49], and Microsoft Azure Active Directory[50]. Such tools are used to assist in verifying user identities and managing/controlling access requests to systems and sensitive data [336]. Additionally, organizations must look after the tools they utilize in Security Information and Event Management (SIEM) to aggregate and analyze activities from different departments, provide real-time security analysis, and generate application alerts. Besides, Intrusion Detection and Prevention Systems (IDPS) tools must be frequently maintained to monitor network traffic for abnormalities and suspicious activities, trying to respond and avoid potential threats. By focusing on practical, evidence-based solutions, the survey equips organizations with the tools needed to enhance their security posture and navigate complex security challenges.

On the other side, the study discusses a comprehensive set of best practices and approaches the security analysts can adopt to mitigate security risks effectively, and overcome common implementation hurdles. For example, it indicates how vulnerability management is important to scan software applications for impairments and weaknesses, helping to prioritize remediation plans and patching efforts [337]. To conclude, vulnerability scanning tools must be extended to open sources and validated to achieve proper vulnerability management and perform successful testing sessions (functional and field testing). On the other side, there are different technologies and tools required in protecting cloud-based resources as most organizations have moved to Cloud Security Solutions recently [338], [339]. To this end, it is highly recommended that security analysts and practitioners obtain accurate, vital, and up-to-date information about clouds-related security tools like AWS Security Hub[51], Microsoft Azure Security Center[52] and Google Cloud Security Command Center[53]. Further, they need to conduct in-depth research on trendy tools like Nikto[54] to assist in running field testing sessions and executing test cases.

[48] https://www.sailpoint.com/
[49] https://www.okta.com
[50] https://azure.microsoft.com/en-au/get-started/azure-portal
[51] https://aws.amazon.com/security-hub/
[52] https://azure.microsoft.com/en-au/explore/security
[53] https://cloud.google.com
[54] https://nikto.com

3.6.1.3 The Financial Implication of Implementing Advanced Security controls

After analyzing the survey results, it appeared that not all organizations, particularly small to medium-sized businesses (SMBs), have the funds and resources to implement advanced or comprehensive security controls. Implementing sophisticated security controls requires dedicated staff and managed services for effective oversight. Consequently, hiring, training, and retaining security professionals are considered costly, especially given the cybersecurity skills shortage. Furthermore, extra expenses and ongoing costs are required to maintain and update security controls. Since security controls usually come with recurring costs (e.g. software updates, subscriptions, licensing fees, and hardware maintenance), these expenses can increase over time, especially when new threats and cyber-attacks demand continual upgrades and patches. As a result, organizations with limited budgets may need to prioritize certain security controls while postponing or forgoing others, which could impact the overall security effectiveness and posture. For instance, they may prioritize essential and perimeter defenses like firewalls and network controls over internal controls such as data loss prevention (DLP) tools. Such limitations can also lead to prioritizing some areas over others or securing specific systems only, potentially leaving some systems or organizational data more vulnerable and exposed. In summary, while security controls are essential, the cost associated with their implementation and maintenance can pose significant limitations. Organizations must balance effective implementation of security controls with cost efficiency, prioritizing controls based on risk and aligning security spending with overall business objectives to avoid financial drawbacks.

3.6.1.4 Learning from Past Experiences

Security practitioners are advised to learn from past projects and run synthetic test cases before running functional and regression testing [340]. This survey helps security practitioners review, revise, and rectify their current practices to ensure the successful implementation of security controls.

3.6.2 Implications for Research

This study contributes to the academic field and identifies directions for future investigations in the area of security controls. The following research implications articulate how the findings verify existing practices or challenge some prevailing assumptions, thus serving the body of knowledge and enriching the academic discourse.

3.6.2.1 Guiding the Selection of the Right Security Frameworks

Typically, security practitioners follow specific security frameworks to guarantee the proper implementation of security controls. However, they may disregard valuable frameworks due to several reasons. One of these reasons is framework overload. The numerous security frameworks available in the IT industry can make the selection of security controls feel daunting [341]. Therefore, practitioners might feel confused and overwhelmed when selecting suitable frameworks within the speedy development process. In some cases, they may prefer to utilize the same frameworks they feel familiar with instead of exploring the appealing features and useful aspects found in modern security frameworks [342]. Eventually, this selection would cause them to overlook essential cyber security controls, resulting in many security gaps and leaving the organization vulnerable to attacks. Another reason that affects their selection of a proper security framework is the lack of comprehensive knowledge of the effective aspects of a security framework. Security practitioners might be experts in certain areas but have a superficial understanding of other crucial areas, resulting in unbalanced implementations for security

controls [343]. Hence, we argue that new research studies should be carried out to develop guidelines that help security practitioners select the right security framework based on their needs and context.

3.6.2.2 Investigating the priority ranking of continuous security practices

By governing a thorough assessment of the best practices and activities enlisted in Table 3.4 (Section 3.4.3) and Table 3.5 (Section 3.4.5), the findings give a body of knowledge on what positively impacts the implementation of security controls. We strongly believe that a prioritization-based ranking for continuous security practices will assist researchers in thinking about the best approaches that would support the implementation and management of security controls in their ongoing and future work. Future work can focus on developing and verifying frameworks that could support this implementation of security controls in tandem with the conduct of continuous security practices that are as agile as possible. Such frameworks should carefully investigate the priority ranking of security practices and map them with fundamental security controls.

3.7 Threats to Validity

Like other survey studies, a number of potential threats might have been introduced during the different stages of our survey (i.e., questionnaire design, execution, data analysis, and reporting the findings) [344]. This section enlists the potential threats and the procedures taken to mitigate those potential threats.

3.7.1 Internal validity

Many participants contributed to this survey and responded to our questionnaire, however, some responses may not have come from the right practitioners. For instance, some practitioners may have possessed poor knowledge or insufficient experience in security controls, or they had little interest in security controls. They may have altered their answers based on their expectations and thoughts rather than providing genuine answers [345]. To mitigate this threat, we developed a well-structured Data Management Plan (DMP) to ensure that the data collected from this survey is handled efficiently, ethically, and securely (see Section 3.3). Further, this DMP helped facilitate high-quality research outcomes and promote data reuse. On the other side, we carried out a systematic strategy to recruit participants carefully and hire security practitioners who genuinely have worked on security controls (see Section 3.3.2).

Another threat to validity may occur due to social bias when the respondents tend to agree with some research statements and/or answer questions in a favorable manner instead of giving truthful answers about how they perform the exercises enlisted in the question [346] [347]. This is similar to acquiescence bias, where the respondents do not reflect their true thoughts but for different reasons [348] [349]. For example, security practitioners usually overemphasize their adherence to best practices and exaggerate their compliance with NIST (National Institute of Standards and Technology). In contrast, developers tend to give opinions revolving around the practical methodologies they operate during the development process. To mitigate this threat, we explicitly highlighted in the survey introduction and invitation emails that all contributions and responses are kept confidential. Also, we emphasized that respondents' identities will not be identified, and participation is voluntary.

Finally, the method we used to assess and exclude invalid survey responses may have limitations [350]. Despite employing well-designed criteria, we cannot guarantee an entirely error-free process. These criteria may have flaws, and some invalid responses might have been erroneously considered.

3.7.2 External validity

Although the survey was open to all practitioners worldwide, most respondents were from the United States, Canada, and the Middle East. We built our findings based on 118 authentic responses after circulating the survey among participants with diverse job positions in the software engineering and IT industry. The target audience was mainly software practitioners who worked in secure software development, practically security controls. They also had different years of professional experience in cybersecurity. For this reason, we acknowledge that the survey findings may not be comprehensive or universally applicable [351] [352]. On the contrary, they could be limited in their applicability and feasibility because the data was obtained from software practitioners with limited cyber experience representing specific surveyed populations. Further, the results cannot be generalized to all software practitioners. Thus, precautions should be taken when attempting to generalize those results [353].

In addition to insufficient years of cyber experience, other factors could influence the findings' relevance, e.g., demographic, geographical settings, and contextual differences [354]. Besides, any limitation in sample size or self-selection bias might restrict the extent to which those results and findings apply globally. Hence, we plan to carry out future research with a broader range of practitioners who work in varying sectors (e.g., banking, telecommunications, and insurance) and possess diverse job positions and seniority levels to increase the generalizability of our results as much as possible.

3.7.3 Construct Validity

As the survey questions are the primary information source for the survey, any ambiguity or transparency in the questionnaire may raise concerns about the construct validity and overall reliability. Although the survey questions were direct, respondents may misinterpret or improperly answer some questions because they may not have fully understood their meaning and purposes [355]. This would result in multiple conclusions or misinterpretations, thus affecting the survey responses adversely. To deal with such threats, the survey questions were designed in a way that supports the participants' working experience, particularly in security controls. The questions were designed based on existing literature and systematic reviews, exploring informative insights and feedback from researchers and practitioners specialized in cybersecurity. A pilot study was also conducted to test the survey design and questionnaire before distributing it to a large population (Section 3.3.1). This process was beneficial in improving the survey, clarifying ambiguous questions, and ensuring representative previews [356].

Furthermore, the authors conducted regular discussion sessions to review and rectify the survey questions, change the order of the questions, capture biased questions, and rephrase the wording to make the questions suitable for diverse software and security practitioners. These strategies helped assess the harmony of the survey as a whole [357]. Another factor that gave rise to misunderstandings is the mixing of terms describing the methodologies and practices conducted during the implementation and validation of security controls. Therefore, participants may mix between practices and processes resulting in further confusion and misinterpreting some terminologies. To reduce this imperilment, we carefully defined the questions by giving brief explanations about included practices and processes. This solution helped the participants gain a consensus, as none of them showed confusion or disagreement. We also included feedback questions and “other" fields in some questions to give them the ability to engage more effectively and reflect more thoughts and perspectives in open-ended text fields. As a result, this survey provided valuable perceptions and insights into participants' experiences with security controls after considering the limitations in construct validity.

3.8 Conclusion

In this study, we present the findings of a survey conducted with 118 software practitioners and security analysts to explore the prevalent practices and activities involved in implementing and integrating security controls. Our study aimed to understand the key security activities and best practices professionals employ to integrate and enforce security controls, in addition to offering valuable insights into the challenges experienced across the SDLC. In general, it contributes to a deep and comprehensive understanding of how security controls are managed with a focus on organizational requirements and data security. One of the key contributions of this survey is to emphasize the importance of software practitioners having a thorough understanding of security requirements before implementing security controls. The findings underscore the significance of categorizing security controls based on their specific functions, such as preventive, detective, and corrective controls. Proper classification before implementation is crucial for developing efficient and compliant security strategies, optimizing resource allocation, and ensuring adherence to regulatory requirements. However, some practitioners may occasionally consolidate these categories to better align with their specific application needs.

Another significant contribution is to identify the critical phases of the Security Controls Lifecycle, outlining activities and best practices to enhance the effectiveness of security controls. During implementation, practitioners carefully engage in threat modeling, risk assessment, and penetration testing to identify weaknesses and areas of malfunctions. According to the survey findings, the improper implementation of security controls could most likely lead to problematic consequences, such as weakness exploitation, unauthorized access, and data breaches. For this reason, organizations are advised to apply continuous monitoring, security information and event management (SIEM), and intrusion detection systems (IDS) to track control performance. Furthermore, practitioners are encouraged to collaborate with business units and integrate security controls seamlessly into application infrastructures. The survey highlights the continuous evaluation of security controls, particularly following malicious attacks or significant organizational changes. Key performance indicators (KPIs) are frequently employed to assess the effectiveness of security controls and ensure their compliance with security requirements. These efforts ensure that security controls align with strategic objectives, industry standards, and national security frameworks such as NIST[55], ISO/IEC 27001[56].

On the other side, systematic reports of evaluation outcomes are crucial for summarizing verification results, identifying gaps, and supporting proactive security improvements. They enable informed decision-making, align security investments with organizational priorities, and ensure regulatory compliance with standards like GDPR[57], and PCI DSS[58]. Over time, these reports measure control effectiveness, foster continuous security enhancement, and refine incident response strategies. As a result, it is highly recommended that organizations implement security awareness training to enhance staff competency and ensure the effective execution of security controls. Overall, this study provides valuable insights into the evolving landscape of security control management, offering a comprehensive understanding of the strategies, challenges, and best practices adopted by software practitioners in securing modern software systems.

Drawing upon the findings from this chapter, which investigated the state of practice and provided insights into how security controls are integrated in real-world DevSecOps environments, and combining these with the outcomes of the literature review presented in Chapter 2, this research now advances in the next chapter toward developing a governance framework (Chapter 4). This framework is in-

[55] National Institute of Standards and Technology
[56] International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC)
[57] General Data Protection Regulation
[58] Payment Card Industry Data Security Standard

tended to guide the effective integration of security controls in DevSecOps settings. Furthermore, it is envisioned to be applicable in broader industrial contexts, assisting security analysts in managing controls within DevSecOps pipelines, as well as in emerging technological domains such as Artificial Intelligence (AI), Zero Trust Architecture (ZTA), and related innovative systems.

Chapter 4

Towards Resilient Security: A Structured Framework for Security Control Lifecycle Management

This chapter has been submitted to the International Journal of Information Security, and is currently under review.

M. Sinan, M. Shahin, I. Gondal, Towards Resilient Security: A Structured Framework for Security Control Lifecycle Management, the International Journal of Information Security, 2025.

The effective integration and consistent management of security controls throughout all phases of the Software Development Life Cycle (SDLC) are essential for protecting organizational assets, ensuring operational continuity, and achieving compliance with regulatory requirements. The survey findings, presented in the previous chapter (Chapter 3), pointed out that organizations continue to encounter significant challenges in practically managing and handling security controls across distributed systems. Such issues and obstacles included a lack of traceability and inconsistent implementation, resulting to hinder the ability to maintain a robust security posture within the evolving nature of cyber threats. Therefore, these challenges and the problems identified through the survey responses (in Chapter 3) underscore the need for a clear governance framework to support the effective implementation of security controls, while maintaining adherence to security and compliance requirements. Such a framework should be traceable and align seamlessly with agile development cultures and toolchains on one hand, and with automated practices and dynamic DevSecOps environments on the other. This chapter presents a comprehensive framework (model) for managing security controls throughout their entire lifecycle. The framework is developed based on data collected through a set of focus groups targeting security practitioners and subject matter experts (SMEs). The objective of the framework is to enhance resilience and facilitate the execution of automated security practices in dynamic IT environments, including code scanning, threat modeling, and risk management. Further, the framework ensures alignment with organizational security objectives, compliance requirements, and international standards, such as NIST SP 800-53[1], ISO 27001[2], and OWASP[3]. It is meant to be deployed within the

[1]National Institute of Standards and Technology Special Publication 800-53
[2]International Organization for Standardization
[3]Open Web Application Security Project

IT industry as a practical tool to assist security practitioners in the implementation and validation of security controls.

4.1 Introduction

In today's fast-paced digital environment, organizations rely heavily on interconnected systems, cloud services, and software applications to run their operations reliably. These technologies, while offering significant benefits, also expose organizations to a wide range of cyber threats, such as data breaches, ransomware, and advanced persistent threats (APTs) [358] [359]. This makes the implementation of robust security controls critical for ensuring the security of systems, software applications, hardware, and sensitive data [360]. Organizations store critical and valuable data for customer information, intellectual property, and proprietary software to support their operations. Therefore, security controls are essential to protect these assets from unauthorized access, theft, or damage [361].

Security breaches usually result in significant financial losses due to data theft, business downtime, legal fines, and reputational damage [362] [363]. This is where the role of security controls becomes crucial as they help identify, assess, and manage risks within the organization's IT environment. By implementing a layered approach to security (i.e., using a combination of preventive, detective, and corrective controls), organizations can effectively mitigate the risks of such incidents and reduce their likelihood or impacts, thus maintaining operational continuity and minimizing potential financial loss [364]. Generally, cyberattacks disrupt an organization's operations and lead to system downtimes, business disruptions, and decreased productivity [365] [366]. At this point, security controls play a vital role in check-and-balance and disaster recovery plans, ensuring that operations can continue in the time of attacks or incidents [367]. On the other hand, many industries are subject to strict regulatory standards (e.g., GDPR[4], HIPAA[5], PCI-DSS[6]) that mandate and dictate the protection of sensitive information and critical data [368]. Implementing robust security controls would allow organizations to maintain security compliance and avoid incurring penalties or financial penalties [369].

With the constant evolution of cyber attacks, security controls must remain flexible and adaptable. Ensuring their compatibility and effectiveness requires continuous assessment and refinement to address emerging risks [370]. Continuous monitoring and improvement, along with automation can play a crucial role in ensuring that security controls can keep pace with emerging threats and vulnerabilities [371], and evolving technologies and security trends, such as DevSecOps, artificial intelligence (AI), machine learning (ML), and zero-trust models [372] [373]. Despite advancements, serious challenges remain prevalent across many organizations, including resource constraints, compliance complexities, knowledge gaps, and the rapid evolution of cyber threats as well [374] [375]. To address these challenges, we propose a security control framework to provide an integrated and structured approach to implement and manage security controls. The findings from the Systematic Literature Review (SLR) outlined in Chapter 2, together with the empirical data obtained through the practitioner-based survey in Chapter 3, played a pivotal role in shaping the development of the proposed framework. The integration of theoretical insights with real-world evidence ensured that the framework is both grounded in existing research and aligned with current industry practices, thereby enhancing its practical relevance and applicability. Moreover, the framework suggested in this chapter, was developed based on three focus groups with 11 practitioners. It aims to streamline security processes and essential practices, ensuring that controls are applied effectively and operate as intended.

[4]General Data Protection Regulation
[5]Health Insurance Portability and Accountability Act
[6]Payment Card Industry Data Security Standard

The rest of the chapter is structured as follows. Section 4.2 provides an overview of the background of security control frameworks and reviews existing work. Subsequently, the methodology employed to gather insights from security practitioners is then outlined in Section 4.3. In Section 4.4, we delve into these findings and elaborate on the key components of our framework, followed by the discussions and implications for security practitioners and researchers in Section 4.5. The potential threats to validity are identified along with the strategies employed to mitigate them in Section 4.6. The chapter concludes with a summary of the key takeaways in Section 4.7 and suggestions for future research in Section **??**.

4.2 Background and Related Work

In the following section, we will provide an overview of the background on security controls and their maintenance within organizations. We will then review the existing literature, discussing and analyzing the frameworks that address security controls.

4.2.1 Security Controls

Security controls serve as protective mechanisms designed to safeguard systems, data, and organizational assets from threats, vulnerabilities, and cyberattacks [376]. They are intended to be adaptable, enabling integration into various system architectures, such as service-oriented, network-based, and distributed systems, and to effectively respond to malicious activities [377] [378]. Security controls play a crucial role in crafting cyber defense strategies and mitigating risks, ensuring the integrity, confidentiality, and availability of information systems [379] [380] [381]. In the context of secure software development, integrating security controls proactively from the early stages of the development lifecycle is essential for addressing potential vulnerabilities before they escalate into costly issues [382, 383]. This approach ensures robust protection without disrupting the development process or project timelines, thereby promoting both security and operational efficiency [17]. International standards and security frameworks, such as NIST SP 800-53[7], ISO 27001[8], and OWASP[9] guidelines, provide structured approaches for enforcing security controls [384] [385]. They highlight the importance of adopting holistic strategies to encompass risk management, continuous monitoring, and other essential security practices [386]. By fully complying with these regulations, organizations would proactively address security challenges and ensure a resilient, compliant, and well-protected infrastructure.

4.2.2 Security Control Maintenance

The effectiveness of security controls depends on their proper implementation, continuous monitoring, and ability to address evolving threats and emerging risks [387]. Achieving a balanced security posture requires organizations to continuously assess and uphold the long-term relevance of existing controls, while strengthening them through strategic policies, enforceable practices, and resilient technical defenses [388, 389]. Security controls are typically evaluated from three key perspectives: management, operational, and technical [390]:

Management Perspective. This focuses on evaluating governance regulations, policies, and security compliance, including security rules, user access policies, risk management (processes and plans),

[7]National Institute of Standards and Technology Special Publication
[8]International Organization for Standardization
[9]Open Web Application Security Project

security awareness training (programs and materials) and adherence to international standards and regulatory frameworks, such as NIST[10], ISO 27001[11], GDPR[12], HIPAA[13] [391].

Operational Perspective. This evaluates the implementation and effectiveness of security controls in daily transactions and day-to-day activities, reviewing user access controls, personnel information security, incident response plans, and physical security controls to ensure that security controls are properly built and enforced [392] [393].

Technical Perspective. Analyzes and evaluates the technical security controls, including encryption algorithms, network firewalls, intrusion detection/prevention systems (IDS/IPS), and system configurations [394] [395]. This is carried out in tandem with vulnerability assessments and code management practices to evaluate their functionality and effectiveness in mitigating cyber threats. These practices provide a proactive approach to maintaining the integrity, reliability, and compatibility of security controls from a technical perspective [396].

4.2.3 Related Work

Existing research presents various security frameworks that focus on regulatory compliance, security controls, and policy enforcement to strengthen organizations' systems, software applications, and cloud security. These frameworks aim to establish a defensive layer against cyber threats by implementing risk mitigation measures, access controls, and compliance-driven security practices. As an example, Ellenberg explores the security challenges associated with cloud computing; and the necessity of implementing robust security controls to mitigate risks and reduce the chance of exposures [397]. This paper introduces a security framework that addresses critical aspects such as governance, risk management, security architecture, access controls, and continuous monitoring. The framework is designed to enhance the security and resilience of cloud-based systems while ensuring compliance with regulatory requirements.

Moreover, Qudus has examined the critical role of cyber governance and security controls in addressing the growing challenges of cybercrime and data privacy on a global scale [375]. This study highlights the need for stronger policy frameworks, adaptive regulations, and international collaboration to counter evolving threats, such as ransomware, data breaches, and nation-state attacks. Qudus suggested joint defense initiatives and the integration of privacy-by-design principles with risk management to improve governance, cyber resilience, and digital security.

This study [398] examines security controls designed to protect Industrial Control Systems (ICS), in response to the growing frequency of cyberattacks targeting critical infrastructure. While, existing research has primarily focused on the unique attributes of ICS to meet their security requirements, there is still a gap in understanding and enhancing security controls specific to these systems. To address this, Youngin and his peers introduced an ICS security control matrix to categorize and analyze security controls from an ICS perspective, address vulnerabilities, and defend effectively against attacks on critical infrastructure. Their findings provided useful insights, for effectively applying security controls at the right locations within ICS environments, refining existing frameworks, and strengthening ICS protection against evolving threats through security improvement and continuous monitoring.

Kanaan et al. [399] highlighted the importance of organizational cyber resilience in ensuring business continuity and growth within the complex threat landscapes. It presented a framework that acts as a guide for organizations to navigate security challenges, foster long-term stability and innovation

[10] National Institute of Standards and Technology Special Publication
[11] International Organization for Standardization
[12] General Data Protection Regulation
[13] Health Insurance Portability and Accountability Act

in interconnected environments. It integrates security policies, resilience testing, and collaborative engagement of designated teams to strengthen the organization's cybersecurity preparedness. Kanaan et al. and their team offered a strategic approach to embedding cyber resilience within digital transformation initiatives, while examining the evolving threats, resource limitations, and ethical considerations throughout the entire process.

On the other side, Loncar et al. conducted a study to explore coding techniques and guidelines to reduce security risks throughout the software development process [400]. They highlighted the significance of secure coding practices by analyzing past attacks and current security vulnerabilities. Their main objective was to tackle the OWASP[14] Top 10 vulnerabilities, which are known as an important resource for improving application security and reducing security risks [401]. Their paper offered practical solutions to common issues such as access control flaws, encryption errors, and injection vulnerabilities, while stressing the importance of adhering to secure coding standards from organizations like OWASP[15], SEI CERT[16], and ISO[17] [402]. Furthermore, this study promoted proactive security mindsets and useful strategies to overcome challenges experienced by developers during the SDLC, including limited security knowledge and resources.

Likewise, Al-Safwani et al. carried a study and designed the Information Security Control Prioritization (ISCP) model to help organizations assess and prioritize critical security controls effectively [333]. This model offered a structured approach to evaluate the effectiveness and cost-efficiency of security controls by leveraging the TOPSIS[18] method. First, they addressed the gaps in current frameworks that often rely on subjective judgments. Later, they emphasized practical and clear guidelines for control analysis and prioritizing vulnerabilities, while ensuring a minimal overlap. This approach enabled organizations to optimize resource allocation and achieve better returns on security investments by focusing on the most critical vulnerabilities.

4.3 Methodology

This chapter aimed to develop a robust and comprehensive framework to support the implementation and integration of security controls throughout the development and deployment phases. To achieve this, we conducted a series of focus groups to seek valuable data and informative insights from security and software practitioners and subject matter experts (SMEs) (i.e., hereafter referred to as practitioners), as illustrated in Figure 4.1. In software engineering, focus groups are commonly used to gather qualitative insights and in-depth perspectives on various aspects of secure software development, such as security requirements, practices, preferences, and challenges [403], [404]. Conducting effective focus groups brings together valuable perspectives and seeks to gather diverse insights into experiences, behaviors, and viewpoints, with a particular emphasis on exploring collaboration challenges and communication barriers encountered by teams throughout the security control lifecycles [405]. This participatory methodology ensured that the framework remains practical, relevant, and rooted in real-world scenarios while also adapting to the evolving needs of organizations [406].

[14] Open Worldwide Application Security Project
[15] Open Worldwide Application Security Project
[16] The Software Engineering Institute | Computer Emergency Response Team
[17] The International Organization for Standardization
[18] Technique for Order Preference by Similarity to Ideal Solution

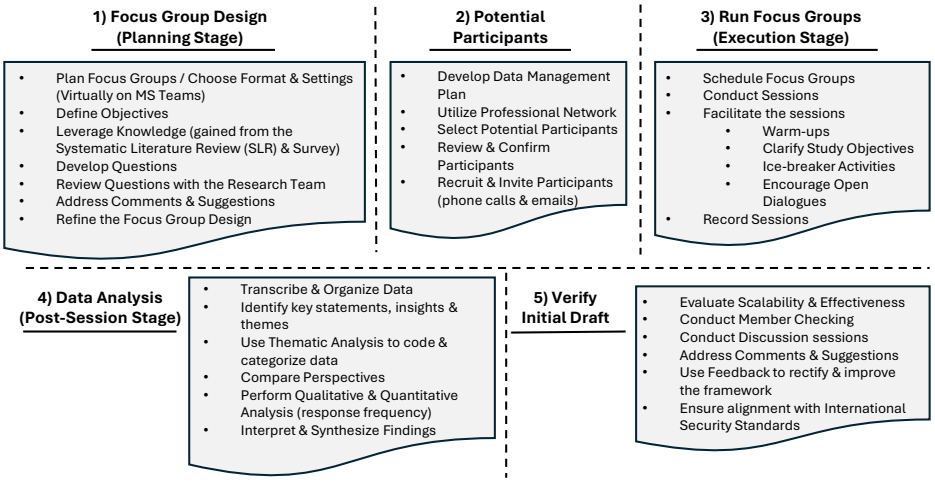

Figure 4.1: The step-by-step methodology used for developing the framework, incorporating data collection, analysis, and validation to ensure reliability and effectiveness.

4.3.1 Focus Group Design (Planning Stage)

The design of the focus groups involved planning, structuring, and facilitating discussions to explore knowledge and exchange perspectives on implementing and managing security controls, following the guidelines proposed in [404] [407]. We recognize that well-crafted questions should align with the main objectives, are fundamental to a successful focus group, ensuring an efficient process, meaningful discussions, and actionable outcomes. For this purpose, a set of open-ended questions was carefully designed to align with the objectives of the study. These questions were informed by a thorough literature review and the authors' expertise in cybersecurity, with a particular focus on security controls [160] [161] [41] [162] [163]. All co-authors actively participated in this process, regularly reviewing the questions and providing feedback.

The questions were carefully structured and clearly articulated to enhance participant comprehension, minimize confusion, and encourage meaningful contributions. Open-ended questions, including "what", "how", and "why" inquiries, were used to explore participants' experiences and perceptions. By doing this, we aimed to obtain detailed insights and a contextualized understanding of the integration of security controls. A subset of the questions used in the focus groups is listed in Table 4.1. The 24 questions in the focus group can be categorized as follows.

- **General Questions**. Five questions help identify and understand the fundamental security controls implemented in each phase of the Software Development Life Cycle (SDLC).
- **Tools and Technologies**. Two questions aim to explore the tools and technologies used for implementing security controls and the criteria considered when selecting them.
- **Current Practices and Challenges**. Six questions aim to understand the best practices, challenges, and mitigation strategies involved in building and integrating security controls. They also explore the availability of the necessary resources and frameworks, along with key lessons learned from past projects to enhance future implementations.
- **Security Control Validation**. Three questions focus on the validation, measurement, and enforcement of security controls within an organization. They explore how security controls are regularly evaluated and improved, the key metrics used to evaluate their effectiveness, and the strategies to

Table 4.1: A subset of the open-ended questions that were asked in the focus groups

Q1. Which security controls do you consider fundamental in your organization? How did you choose them?
Q2. Do you apply the same security controls across all phases (design, development, and deployment) in the SDLC? Do you have a separate list for each phase?
Q3. Which tools and technologies are you currently using to implement security controls?
Q4. Do you have a list of best practices that helped in building and integrating security controls?
Q5. What issues did you encounter while building security controls? How did you mitigate those issues/challenges?
Q6. What did you specifically learn from past projects to ensure the same mistakes don't arise in the future?
Q7. Do you carry out a regular process to validate implemented security controls, whether for the purpose of improving them or addressing new vulnerabilities?
Q8. Do you have any concerns about aligning with NIST standards and other national regulations?
Q9. What is your vision for security controls in case you decide to adopt DevOps practices over the next few years?

ensure that stakeholders and team members remain informed and comply with security requirements.

- **Monitoring Security Controls for Regulatory and Security Compliance**. Two questions aim to understand the processes used to monitor and track security controls to ensure compliance with established security standards and regulatory requirements. They also explore any challenges or concerns related to aligning with frameworks such as NIST[19] and other national regulations, highlighting potential gaps or difficulties in maintaining compliance.
- **Directions and Future Opportunities**. Two questions focus on the future of security controls within an organization, exploring planned improvements and strategic initiatives. They also examine how security controls might evolve if DevSecOps practices are adopted, emphasizing the integration of security within agile development and deployment processes.
- **Training and Culture**. Two questions explore the training programs and resources provided to teams to ensure compliance with security controls. They also aim to understand the strategies in place to cultivate a security-conscious culture within the development and DevOps teams, emphasizing ongoing education and awareness.
- **Collaboration and Communication**. Two questions examine the impact of adopting the DevSecOps methodology on collaboration between development, operations, and security teams within an organization. They also explore the communication channels and tools that are most effective in ensuring that security controls are seamlessly integrated throughout the DevSecOps lifecycle, facilitating collaboration and adherence to security standards.
- **General Knowledge on DevSecOps**. Five questions aim to explore the respondent's understanding and experience with DevSecOps practices, particularly their implementation in the organization. They also assess the perceived importance of DevSecOps in enhancing security control integration and inquire about the recommended tools and technologies to incorporate security into DevOps pipelines. Additionally, the questions seek insights into the evolving role of a DevSecOps engineer within this framework.

4.3.2 Potential Participants (Planning Stage)

We utilized professional networks to recruit participants and elicit a diverse range of contributions about security controls in organizations across various sectors, e.g., banking, insurance, governmental, telecommunications, etc. A diverse group of practitioners was selected, comprising software engineers, security practitioners, and subject matter experts with practical experience in implementing and inte-

[19] National Institute of Standards and Technology

grating security controls across various phases of the SDLC. The key goal was to target the right participants who could participate in the focus groups with their knowledge and practical experience. These individuals possessed the necessary expertise to contribute meaningfully to the discussions. Later, the research team held several meetings to review and discuss the list of potential participants, considering factors such as business unit perspectives, industry diversity, years of experience in cybersecurity (especially in integrating security controls), and geographic locations. After thorough consideration, the list of practitioners was finalized who would be invited to participate in the focus groups.

Later, potential participants were directly contacted via phone calls and emails, inviting them to participate in the focus groups. In the invitation email, we ensured that the participants fully understood the purpose of their contribution, how their feedback would offer valuable insights and perceptions, and how it would ultimately benefit our framework.

To effectively communicate the benefits of participating in focus groups, we developed a data management plan to ensure ethical practices, foster trust, and promote clear communication. This plan outlined all necessary details regarding how participants' personal information would be handled during the recruitment process, ensuring compliance with data privacy and protection laws. It also included the consent forms, which participants were required to complete and sign before participating. Therefore, focus group activities were not held until all consent forms were thoroughly completed and signed to maintain ethical and legal compliance. In doing this, we ensured that the collected data was trustworthy and responsibly managed, allowing effective contributions and successful focus groups to genuinely address real challenges and security requirements.

4.3.3 Run Focus Groups (Execution Stage)

We conducted the focus groups and discussions detailed in Table 4.2 to collect diverse and in-depth insights from professionals. The focus groups were scheduled to run virtually on Microsoft Teams. Each focus group took 45-60 minutes and included at least three participants. We facilitated the focus groups and ensured that all participants contributed and the discussions remained focused. In each focus group, we began with ice-breaker activities, followed by an explanation of the main objectives and how participants' feedback would significantly contribute to the development of a framework. The focus groups began with warm-up questions designed to help participants feel at ease, allowing them to share details about their roles, job responsibilities, and experience in cybersecurity. This approach effectively encouraged open dialogue while keeping the discussion focused on the prepared questions, establishing a clear tone for the conversation, and ensuring that participants remained on topic. Throughout the focus groups, all data, including video recordings, observations, and notes, were documented and stored on Microsoft Teams following the university's data policy.

4.3.4 Data Analysis (Post-Session Stage)

We conducted a qualitative analysis for the focus groups data using thematic analysis to ensure meaningful interpretation and reliable analysis for the key findings, while prioritizing unique insights and actionable points, and following the guidelines tailored in the field of software engineering and recommended by Braun et al. [202] and Cruzes et. al [205]. As planned, focus groups were recorded and stored in the university database using Microsoft Teams. We checked the recordings and their labeling to ensure accuracy of the data and quality of the audio. This step helped to prevent misinterpretation and ensure that data from different sessions remained distinct, maintaining the confidentiality and integrity of the session findings. Subsequently, we started the analysis process and created three top-level themes, indicating both data collection and analysis proceeded in parallel [408]. (1) the key security

Table 4.2: Participants Contributed to the Focus Groups - Demographic Details. (***P**: Participant, ***CX**: Cybersecurity experience in years)

Focus Group	ID	Current Role	Unit | Division	Domain	City	Highest Qualification	CX
FG1	P1	Security Engineer	Configuration Management | Vulnerabilities Assessment	Banks	Melbourne	Master's in Computer Engineering	6
	P2	Security Engineer	Configuration Management | Vulnerabilities Assessment	Banks	Melbourne	Bachelor's in Computer Science	5
	P3	Sr. Security Engineer	Configuration Management | Vulnerabilities Assessment	Banks	Melbourne	Bachelor's in Computer Science	5
FG2	P4	CEO/Start-up Founder	Cybersecurity Department	Cybersecurity	Melbourne	Bachelor's in Computer Science	10
	P5	Head of Dept.	Configuration Management | Vulnerabilities Assessment	Cybersecurity	Dubai	Bachelor's in Computer Science	6
	P6	Sr. Security Engineer	Configuration Management | Vulnerabilities Assessment	Cybersecurity	Dubai	Bachelor's degree in Computer Science	7
	P7	Security Engineer	Cybersecurity Dept.	Government	Dubai	Bachelor's degree in Computer Science	4
	P8	Security Engineer	Cybersecurity Dept.	Government	Dubai	Bachelor's degree in Computer Science	3
FG3	P9	Security Architect	Network & Infrastructure Security	Government/ E-Health	Sydney	Bachelor's degree in Computer Science	6
	P10	Security Engineer	Infrastructure & Network Security	Government/ E-Health	Sydney	Bachelor's degree in Computer Science	5
	P11	Sr. Security Engineer	Strategic Projects	Government	Canada	Bachelor's degree in Computer Science	8
Verify	Member Check (P4)	CEO/Start-up Founder	Cybersecurity Department	Cybersecurity	Melbourne	Bachelor's in Computer Science	10
	ITS	Six Subject Matter Experts (SMEs)	ITS Department	RMIT University	Melbourne		

controls that participants are committed to implementing and managing within their organizations to establish and maintain a strong cybersecurity posture. (2) the challenges and pitfalls they encountered while managing and implementing security controls throughout the various phases of application development and deployment. (3) the best practices and practical approaches they employed to mitigate security risks and address the challenges and issues they had encountered. The following steps were conducted during the thematic analysis. Figure 4.2 shows the application of the conceptualized thematic method on some of the session transcripts to identify the theme 'Compliance Audit'.

1. *Transcribing sessions*: The recorded conversations were transcribed verbatim, capturing only the verbal responses to support a thorough data assessment and in-depth analysis. Furthermore, the transcripts were reviewed to remove repetitions or any irrelevant words and sounds while ensuring that the context remained intact. Finally, they were cross-checked against the original recordings to ensure accuracy and minimize errors or biases.
2. *Extracting data*: Data analysis commenced with a thorough review of the imported transcripts to gain familiarity with the participants' responses and uncover concise narrations, valuable perceptions, and interpretations using descriptive key points from each session [203] [204] (see Figure 4.2.A).
3. *Coding data*: At this step, the initial codes were constructed. The focus groups primarily addressed "What" and "How" questions related to the management of security controls, with responses typically provided in clear, concise sentences rather than abstract statements. For each

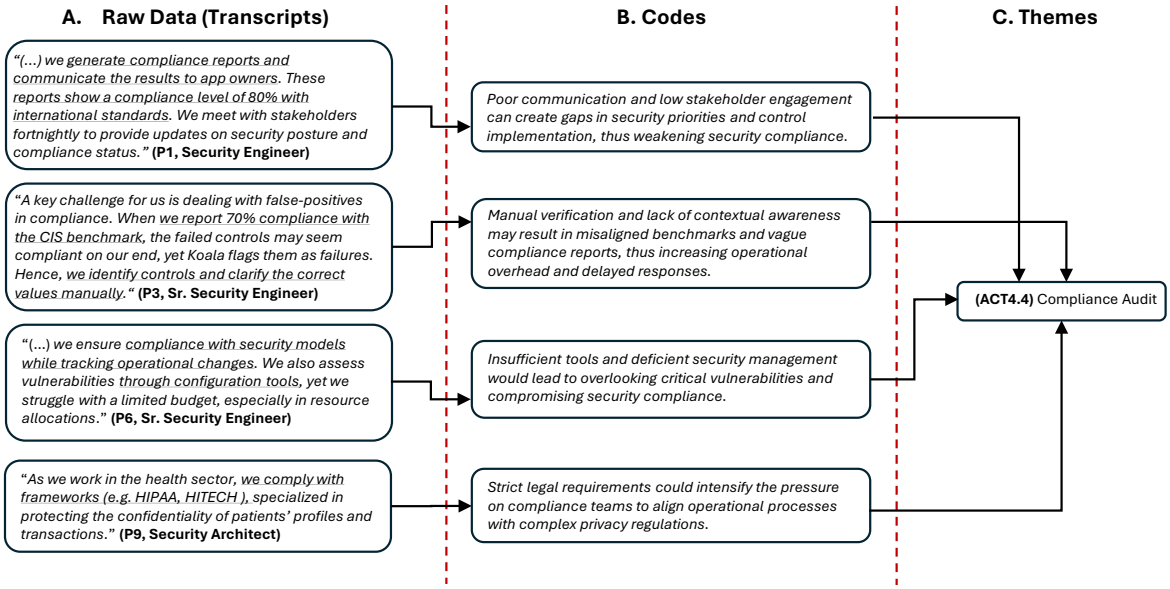

Figure 4.2: Applying thematic analysis on a sample of imported transcripts (E.g. Security Compliance and Adhering to Security Standards)

session transcript, we reviewed the raw data and combined the different initial codes generated from the sessions into potential codes (Figure 4.2.B)

4. *Translating codes into themes*: We created themes with appropriate names based on the generated codes in the previous step. This step also included eliminating overlapping or redundant themes, combining similar themes, or breaking down complex themes into sub-themes (see Figure 4.2.C).
5. *Evaluating the reliability of the synthesis*: Through this step, we first assessed the trustworthiness of the interpretations from which core themes emerged [205]. We investigated the extracted themes and established arguments in terms of credibility. For example, was the claimed issue widespread enough to be considered a common challenge for practitioners? Was the implemented solution or approach adequate in mitigating the impact of the identified problems?

All insights, perceptions, and feedback collected from focus group participants were provided to the co-authors for review. Through a negotiated agreement approach [206], they systematically discussed and resolved any conflicts concerning participant responses, submitted feedback, and interpretations to ensure a consistent and accurate representation of the findings.

4.3.5 Verify Initial Draft

After drafting the framework, we planned to verify it to ensure its robustness, effectiveness, and alignment with security objectives and organizational regulations using a member-checking process and a group discussion with six subject experts. We conducted a member check process to assess the credibility and practical relevance of the initial framework draft. This approach involved an in-depth discussion with Participant P4, who participated in the second focus group (FG2) in Table 4.2. The session facilitated a thorough evaluation of the framework from multiple perspectives, including alignment with security requirements and applicability within real-world organizational contexts. P4 offered valuable insights grounded in practical experience, particularly contributing to the assessment of security compliance and evaluating how well the framework's activities and practices align with recognized reg-

ulatory and industry standards, including NIST SP 800-53[20], ISO/IEC 27001[21], CIS[22], and GDPR[23].

Throughout this session, the focus was on emphasizing the core scope of the framework and ensuring that the proposed elements support the enhancement of security resilience throughout the full lifecycle of security controls. Further, the framework was reviewed in the context of key security domains such as access control, threat management, and incident response. They were assessed for their alignment with organizational objectives, risk strategies, and DevSecOps practices. The outcomes of this member checking session were highly constructive, confirming the relevance and effectiveness of the proposed framework. P4 also highlighted the coherence and usability of the framework, noting that navigation between its components was both efficient and professionally structured.

As part of the validation process, we conducted a group discussion with six subject experts from the Information Technology Services (ITS) department at a public university in Australia, as shown in Table 4.2. ITS provides a range of IT services and support, such as application support, computing facilities management and maintenance, project management and consulting services, to the staff and students in the university. During the discussion session, participants evaluated our framework against industry best practices and benchmark security standards to identify potential gaps, inefficiencies, and redundancies. The framework's scalability and effectiveness were assessed through simulations of security threats, real-world attack scenarios, and compliance violations. Furthermore, we conducted role-based exercises with the participants to assess usability and ensure that the framework integrates automated security, continuous monitoring, and risk-based testing.

The session yielded highly positive outcomes and the participants provided encouraging and constructive feedback. They highlighted that the framework is comprehensive and effectively covers all essential practices required to implement and validate security controls. Their observations indicated that the framework presents a well-integrated and practical approach to managing security controls in dynamic and regulated environments, thereby supporting its validity as a foundation for further refinement and implementation. However, they offered one recommendation and suggested a re-sequencing of the activities to improve the logical flow and strengthen the framework's clarity and practical value. Subsequently, their recommendations were prioritized and incorporated to refine the framework and strengthen the resilience to security throughout the entire lifecycle of security control.

4.4 Findings

This section presents a structured framework that encapsulates the complete lifecycle of security controls (Figure 4.3. The primary aim of this framework is to provide a systematic approach for software practitioners and security analysts to effectively manage security controls throughout the software development lifecycle (SDLC). By employing this framework, organizations can ensure that security controls are appropriately classified, designed, implemented, and validated, thereby meeting organizational security objectives and compliance requirements.

The framework comprises four distinct phases that represent the lifecycle of security controls: Identification/Classification, Assessment, Implementation, and Verification. Each phase comprises three core components: **inputs** (a list of artifacts required to initiate the phase), **activities** (the key tasks, activities, or practices carried out during the phase), and **outputs** (the deliverables or outcomes achieved upon completing the phase). The outputs generated in each phase operate as inputs for the subsequent

[20]National Institute of Standards and Technology
[21]International Organization for Standardization
[22]Critical Information Security
[23]General Data Protection Regulation

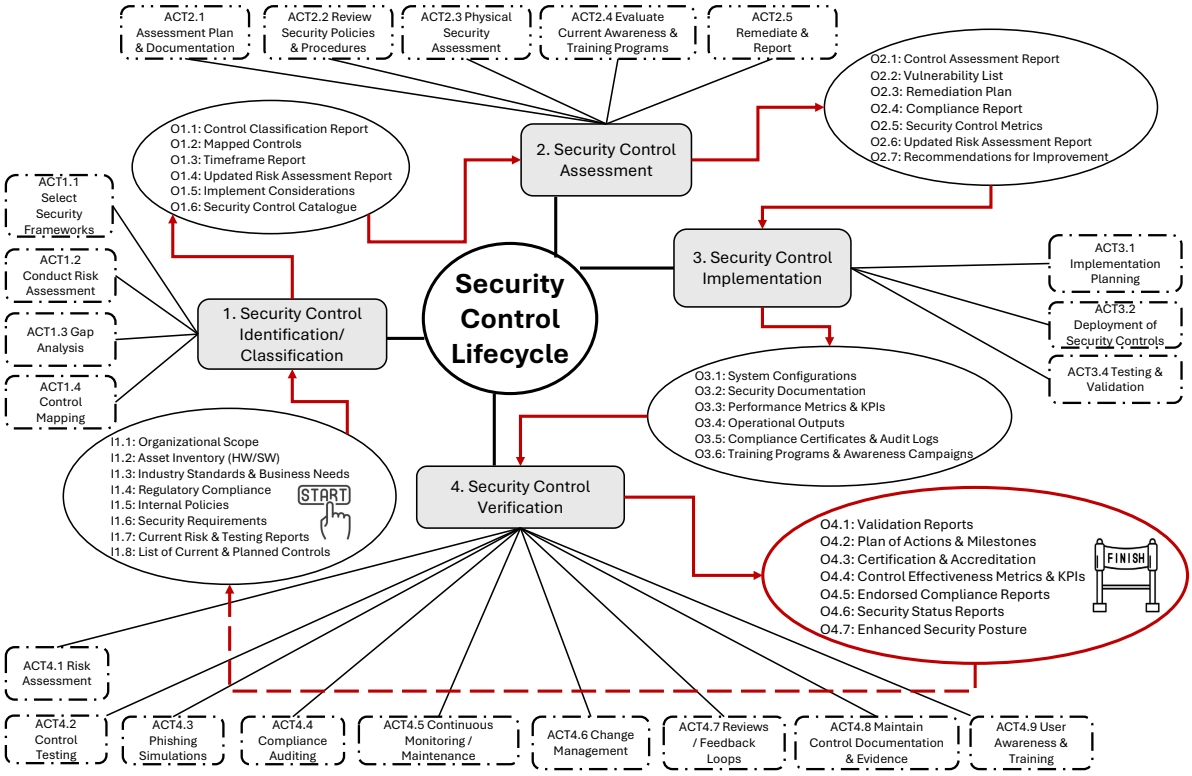

Figure 4.3: Overview of the Security Control Lifecycle (Classification, Assessment, Implementation, Verification), (***I**: Input, ***ACT**: Activity, ***O**: Output).

phase, supplemented by additional inputs unique to each phase. Within each phase, every activity relies on specific inputs to function effectively and produce a defined set of outputs.

4.4.1 Security Control Identification / Classification

Classifying security controls involves systematically organizing them based on specific criteria to ensure they effectively meet the organization's security requirements. This process helps define the type, purpose, and priority of each control, facilitating its appropriate implementation and management. By categorizing security controls, organizations can better assess their criticality and function, optimize resource allocation, and maintain compliance with security standards and regulatory requirements. This structured approach enhances the effectiveness of defense strategies and improves protection against cyber threats and malicious attacks, ultimately strengthening overall security posture.

4.4.1.1 Inputs

Our study identified the following inputs as essential for the effective identification and classification of security controls.

Organizational Scope. This artifact involves a comprehensive understanding of the security scope, including determining which areas of the organization the security controls will apply to (e.g., whether they are enterprise-wide, department-specific, or customized to individual requirements).

Asset Inventory (HW/SW) & Data. This involves creating an inventory of all assets, requiring protection and classifying the data according to its sensitivity and regulatory requirements (e.g., public, confidential, restricted). This specifies which hardware/software assets the controls will protect within the organization, including data, personal information, networks, software applications, hardware, or physical infrastructure such as servers.

Industry Standards & Business Needs. These are the guidelines outlined by regulatory bodies or industry groups to ensure consistency, quality, and safety within specific sectors, like technology or security. In contrast, business needs refer to the goals an organization must fulfill, to operate effectively and achieve its strategic objectives within a given sector, such as banking, telecommunications, or healthcare. These standards would shape the practices, strategies, and security controls necessary for success.

Regulatory Compliance. This artifact incorporates international standards that security controls must adhere to, such as GDPR[24], HIPAA[25], ISO 27001[26].

> *"There are many security frameworks and tools available in the market. Some engineers get confused and do not properly utilize the new tools and technologies. Unfortunately, they just wait to achieve a specific app milestone before considering security compliance. Hence, they fail to comply with crucial and emerging security frameworks."* **P9 (Security Architect)**

Internal Policies. They comprise rules, guidelines, and procedures that govern organizational operations and decision-making, ensuring alignment with the organization's goals, values, and legal obligations. Internal policies generally include security policies, privacy regulations, compliance standards, HR guidelines, risk management procedures, incident response protocols, and codes of conduct.

Security Requirements. These measures are implemented based on past incidents, such as system attacks and data breaches, and are designed to prevent similar events by addressing identified vulnerabilities.

Current Risk Assessment & Testing Reports. These reports are generated from previous audits and risk assessments, including test results and auditor comments.

List of Current Controls/Planned Controls. This document contains the authorized list of security controls prepared for implementation.

4.4.1.2 Activities

These activities ensure security controls are properly classified and aligned with the organization's security goals.

Select Security Frameworks. This involves selecting appropriate security frameworks and regulatory requirements (e.g., NIST [27], ISO 27001 [28], CIS [29] Controls) to ensure alignment with organizational needs.

> *"We develop our own framework and list of practices to establish the defense system for our organsation. We first apply the essential foundations that adhere to international standards such*

[24] General Data Protection Regulation
[25] Health Insurance Portability and Accountability Act
[26] International Organization for Standardization
[27] National Institute of Standards and Technology
[28] International Organization for Standardization
[29] Center for Internet Security

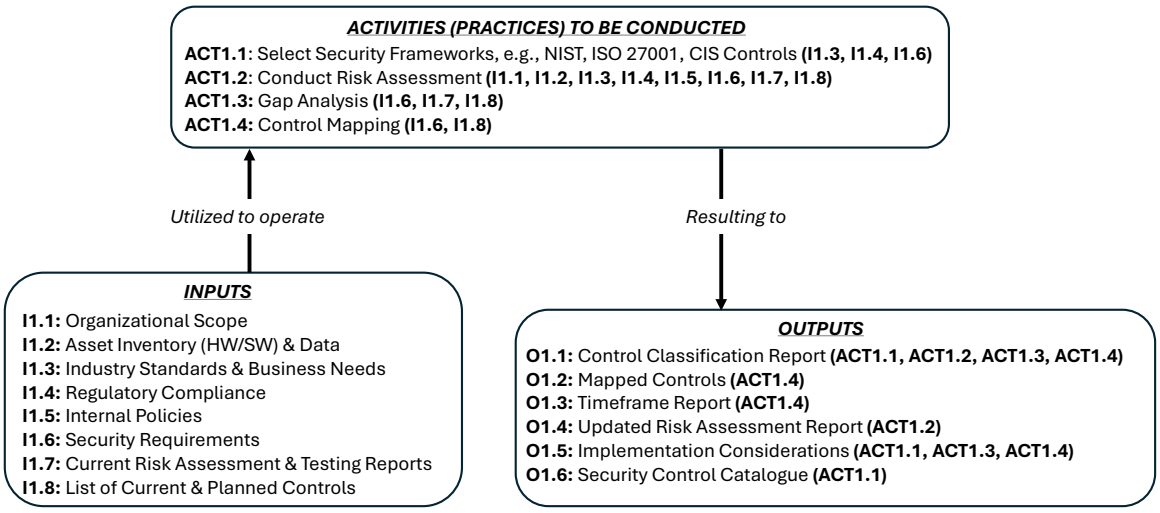

Figure 4.4: Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Identification / Classification**

> *as NIST, ISO, and CIS. Our cybersecurity division looks after security compliance and checks the certificate ensuring they are up to date within limited budget and resources."* **P4 (Cybersecurity Engineer)**

Conduct Risks Assessment. This activity is to conduct an accurate and effective risk assessment following the key steps of risk management: identification, analysis, evaluation, and treatment (monitoring). This involves assessing potential threats, vulnerabilities, and their impacts on the organization, and then aligning security controls with the identified risks. The process includes identifying areas where new controls are needed or existing controls require enhancement.

Gap Analysis. This step is crucial for identifying gaps where existing controls do not meet the security standards or requirements of external frameworks. During this process, security analysts will pinpoint controls that either partially fulfill the requirements or are completely missing.

Control Mapping. This activity is crucial in the domain of Governance, Risk, and Compliance (GRC), as it involves aligning existing security controls with relevant external standards, frameworks, or regulatory requirements. Security practitioners typically use tools like Spreadsheets or GRC platforms to document these mappings systematically. During this process, security controls are categorized into types such as preventive, detective, and corrective controls, or administrative, technical, and physical controls.

4.4.1.3 Outputs

This subsection outlines the results of the classification and identification activities.

Control Classification Report. This report documents key details about security controls, including their *type/category*, such as preventive (preventing incidents), detective (identifying incidents), corrective (mitigating impact), deterrent (discouraging attacks), recovery (restoring operations), and compensating (alternative measures when primary controls are unfeasible). It also outlines *functionality*, categorizing controls as administrative (policies and procedures), technical (hardware/software mechanisms), or physical (measures protecting infrastructure). Furthermore, the report specifies the *scope*

of the application where the controls are expected to operate, whether enterprise-wide, department-specific, or system-level, and defines *asset coverage*, identifying the resources protected, such as data, networks, applications, or physical infrastructure.

Mapped Security Controls. This encompasses a list of security controls mapped to identified risks and threats. It also highlights controls designed to address gaps, mitigate vulnerabilities, and ensure compliance with relevant standards and security frameworks.

Time frame Report. This artifact categorizes security controls based on their implementation urgency: immediate controls for addressing critical risks, short-term controls for deployment within a few months, and long-term controls integrated into strategic planning for sustained security enhancement.

Updated Risk Assessment Report. This document incorporates risk assessment results to identify necessary controls based on identified risks and vulnerabilities, threat modeling to understand the threats requiring mitigation, and an evaluation of potential impacts if a control fails or remains unimplemented.

Implementation Considerations. This includes mandatory requirements along with key considerations such as implementation to ensure clarity for stakeholders, maintenance costs, control complexity, effectiveness in mitigating identified risks, and ease of integration into existing processes.

Security Control Catalogue. This is a structured document that identifies and organizes security controls based on their adherence to organizational objectives and compliance requirements. It categorizes controls into domains and maps to specific goals in the Data Security Triad (confidentiality, access management, and system availability). Each control is detailed with its purpose, scope, implementation guidelines, and the regulatory standards they comply with, such as ISO 27001, NIST CSF, or GDPR. This catalogue also identifies the control ownership, effectiveness metrics, and validation procedures. It integrates periodic review and update processes, allowing organizations to adapt to evolving threats, regulatory changes, and operational requirements. Furthermore, this artifact encompasses all identified gaps, remediation plans, timelines, and evidence guidelines to ensure proactive security enhancements and regulatory compliance.

4.4.2 Security Control Assessment

The assessment process in the security control lifecycle involves verifying security controls before their actual implementation and full deployment. This step is crucial to ensure that security controls are properly designed, aligned with security requirements, and effective in mitigating identified risks. It also includes checking whether the controls are optimized, scalable, reliable, and effectively equipped to protect the organization against evolving cyber threats. Skipping this phase could lead to ineffective security controls, compliance violations, and potential breaches.

4.4.2.1 Inputs

The outcomes of the previous process (Section 4.4.1.3) will serve as input parameters for this process, supplemented by the following additional input parameters.

Scope of Assessment. This involves defining the assets to be inspected and assessed (systems, data, and infrastructure), establishing boundaries (inclusions and exclusions), and analyzing business processes that depend on security controls.

Threat Landscape. This includes information on emerging threats relevant to the organization's environment, current vulnerabilities, and a prioritized list of risks based on likelihood and impacts.

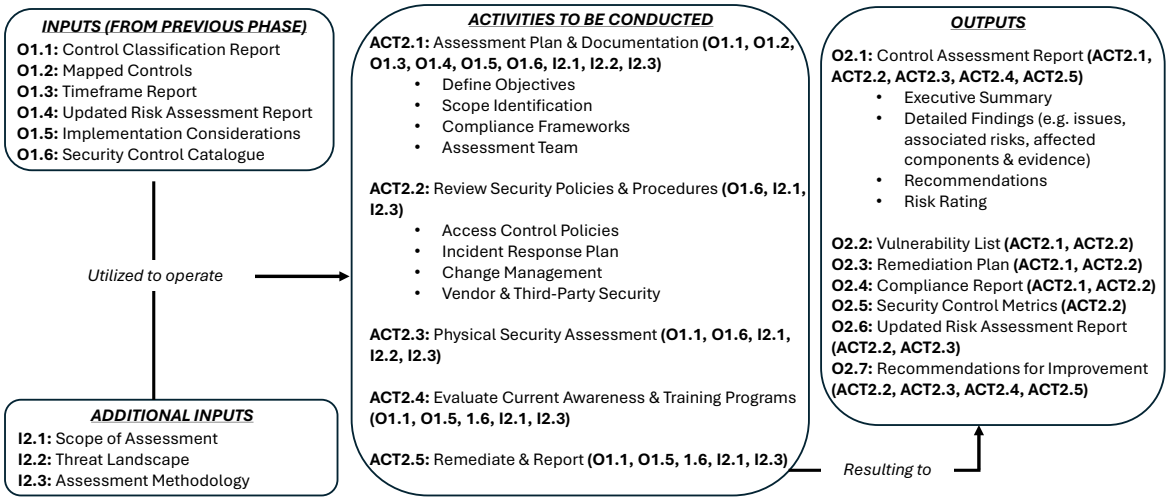

Figure 4.5: Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Assessment**

Assessment Methodology. This involves identifying the tools utilized for scanning and testing (e.g. vulnerability scanners, SIEMs), the assessment methods (interviews, reviews, technical walk-throughs), and the criteria (benchmarks or KPIs) used to measure control effectiveness.

> *"To check our security controls, we conduct a specific approach starting with adopting the CIS benchmarks, managing regular reviews, and providing assistance to users. We develop the tools to support configuration management focusing on operating systems such as Red Hat, Windows, etc. Later, all configuration settings are reviewed and compared against the CIS benchmarks before reports are submitted to the service owners."* **P1 (Cybersecurity Engineer)**

4.4.2.2 Activities

This section details the key activities involved in assessing security controls prior to their implementation.

Assessment Plan & Documentation. This procedure includes defining objectives, determining the scope, identifying relevant compliance frameworks, and allocating the team responsible for checking and assessing the controls.

Review Security Policies & Procedures. This includes inspecting security controls related to Access Control Policies, Incident Response Plans, Change Management, and controls associated with third-party systems.

> *"We develop security controls entirely from scratch by working closely with SMEs (Subject Matter Experts) and several vendors like Cisco, Palo Alto, etc. We provide important evidence and refer to crucial vendor documentation including hardening configuration settings and customizing guidelines on their websites."* **P2 (Security Engineer)**

Physical Security Assessment. This practice evaluates the validity of physical controls in preventing unauthorized access, data theft, and asset damage. It involves assessing security infrastructure, including access controls, surveillance systems, and environmental protection measures.

Evaluate Current Awareness & Training Programs. This involves assessing employees' security awareness through pre- and post-training quizzes, scenario-based assessments, and gathering feedback via user surveys and response forms.

Remediate & Report. In this procedure, remediation plans and training outcomes are documented for comparison. In addition, security controls and incidents will be compared before and after running the awareness sessions.

> *"One of the main OS issues (e.g. Red Hat Windows, Mac) is that we consistently need to remediate and scan cloud-based applications with IPS [30]. This requires agent-based scanning by the vendor, which could be just trickier and more complex."* **P6 (Senior Security Engineer)**

4.4.2.3 Outputs

This subsection outlines the results generated from the assessment process activities.

Control Assessment Report. This report outlines the assessment findings, starting with an executive summary that highlights key risks, recommended actions, and the overall security posture. It details identified vulnerabilities, including descriptions, potential risks, affected systems, and supporting evidence. In addition, the report offers actionable recommendations to mitigate risks, improve controls, and ensure compliance. All findings are prioritized based on severity and likelihood of exploitation, often using a risk matrix or scoring system.

Vulnerability List. This list provides a comprehensive inventory of all identified vulnerabilities, including technical details and CVE (Common Vulnerabilities and Exposures) identifiers. Vulnerabilities are classified by severity (e.g., critical, high, medium, low) and monitored for their remediation status, showing whether they have been resolved or are still under resolution.

Remediation Plan. This plan presents a structured list of action items, detailing required steps, assigned responsibilities, and deadlines for resolving identified issues, with a prioritized timeline to address critical and high-priority vulnerabilities first. It also outlines the resource allocation, including the personnel, tools, and budget required for effective remediation.

Compliance Report. This outcome is crucial as it evaluates the organization's security controls in relation to applicable regulations, standards, and internal policies. It highlights compliance gaps by identifying areas where controls fall short and provides recommendations for alignment, while also documenting audit readiness to ensure preparedness for both internal and external audits.

Security Control Metrics. This includes updated effectiveness metrics to measure the impact of controls on incident prevention and detection, along with key performance indicators (KPIs) to monitor control performance over time and baseline comparisons to assess progress against historical data or industry benchmarks.

Updated Risk Assessment Report. This involves an updated and comprehensive risk register documenting identified risks, their likelihood, impacts, and current mitigating controls. A risk treatment plan is included to outline mitigation strategies, corresponding action plans, and workarounds (e.g., transfer, acceptance, or avoidance). Furthermore, the report presents a residual risk analysis and evaluation of the remaining risks associated with the implementation phase, along with their potential impacts on the organization.

Recommendations for Improvement. This artifact suggests endorsements for strengthening existing security controls and improving essential processes, such as continuous monitoring and incident response management. In contrast, it highlights areas where additional training or awareness initiatives are needed to enhance user compliance with security policies.

[30] Intrusion prevention systems

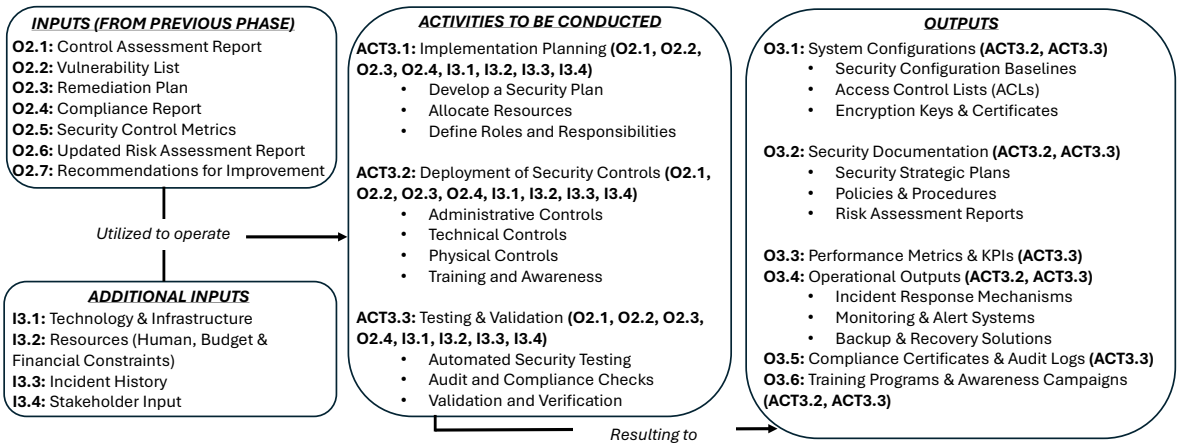

Figure 4.6: Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Implementation**

4.4.3 Security Control Implementation

This process refers to the implementation of security controls to mitigate risks and ensure the protection of organizational data and assets. It includes configuring and deploying technical solutions, establishing policies and procedures, and assigning responsibilities to relevant personnel. The implementation process also involves integrating security controls into existing systems to ensure that they are properly validated and maintained. Furthermore, this process requires documenting the implementation steps in a set of instructions and guidelines to provide adequate training and awareness to the organization's employees and individuals.

4.4.3.1 Inputs

The outcomes of the previous process 4.4.2.3 work as input parameters for this process, supplemented by the following additional input parameters.

Technology & Infrastructure. This outlines the tools, technologies, and resources available for implementing security controls.

> *"Because our organization is large, we create baselines and security standards where we would implement the fundamental settings as the minimum security requirements, specifying the tools and resources allocated to build security controls."* **P10 (Security Engineer)**

Resources (Human, Budget, Financial Constraints). This encompasses the expertise and skills of personnel responsible for implementing security controls, reinforced by continuous training and awareness programs to ensure compliance with security policies and regulations. It also includes budget allocations for security initiatives, financial considerations for control implementation, and cost-effectiveness assessments through Return on Investment (ROI) analysis.

Incident History. This includes the analysis of previous security incidents to identify recurring issues, data breaches, and areas for improvement. It also reports the lessons learned and insights gained from previous incidents to improve the effectiveness of security controls.

Stakeholder Inputs. This outlines the engagement and support gained from senior management and key stakeholders, along with the feedback received from end-users and other relevant parties about the usability and impacts of security controls.

"One of the main challenges we often encounter is communicating with stakeholders to obtain their approval on security controls. We make an effort to follow up with them and keep them informed, especially regarding cost increases and budget requirements for installing new technologies or training existing staff." **P9 (Security Architect)**

4.4.3.2 Activities

This section details the practices involved in implementing security controls after their assessment.

Implementation Planning. This involves developing a comprehensive security plan that outlines the deployment of selected security controls, including timelines, responsibilities, and resource requirements. It also ensures the allocation of necessary resources, such as personnel, budget, and tools, while defining clear roles and responsibilities for managing and executing security controls.

Deployment of Security Controls. This includes the implementation of technical measures such as firewalls, encryption algorithms, access controls, intrusion detection systems (IDS), and antivirus software. In this practice, administrative controls will be established through policies and procedures to govern security practices. In contrast, physical security measures, such as locks, surveillance cameras, and access control systems, are put in place to protect assets. Furthermore, essential training sessions and awareness programs are conducted to ensure employees understand their role in maintaining security.

Testing & Validation. This activity involves conducting automated security assessments, including penetration testing and vulnerability scanning, to validate control effectiveness and ensure they operate as intended. Additionally, it includes regular audits to confirm proper implementation and compliance with security standards and regulations.

"We do regular testing to confirm nothing will break. As we work in a bank and our team expands, numerous devices and operating systems have deployed their configurations. Because of this, we play the catch-up game by going through their settings and turning them off or locking things down to ensure compliance with security standards. We close ports that can be dangerous making sure they don't interfere with day-to-day activities." **P3 (Senior Cybersecurity Engineer)**

4.4.3.3 Outputs

The implementation of security controls produces both tangible and intangible outcomes that reflect their effectiveness and completeness. These results can be classified into several key categories.

System Configurations. These encompass configuration baselines aligned with security requirements, including updated Access Control Lists (ACLs) that define user and system permissions within the network. Further, they incorporate cryptographic measures, such as encryption keys and certificates, to ensure data protection.

Security Documentation. This artifact comprises updated policies, guidelines, and procedures that document the implemented controls, along with risk assessment reports detailing identified and mitigated risks. It also includes security plans that strategically outline the controls in place and their alignment with organizational objectives.

Performance Metrics & KPIs. These metrics include key performance indicators (KPIs) to measure the effectiveness of security controls, such as incident response time and the number of security breaches.

Operational Outputs. This document outlines the deployment of monitoring and alert systems to continuously detect suspicious activities, alongside incident response mechanisms for timely detection,

response, and recovery from security incidents. It also details backup and recovery solutions that ensure regular data backups and effective recovery strategies.

Compliance Certificates & Audit Logs. They include audit logs of system actions and changes, along with compliance certificates confirming adherence to standards, such as ISO 27001 [31], GDPR [32], or HIPAA [33].

Training Programs & Awareness Campaigns. They include security training sessions to ensure staff are well-versed in security protocols, along with initiatives to keep employees updated on emerging threats and best practices.

> *"One of our key investments is in educating, training and enhancing the skills of team members to effectively manage security controls, ensuring they stay up to date with the latest technologies."* **P5 (Head of Department)**

4.4.4 Security Control Verification

Validation in the security control lifecycle involves checking whether implemented security controls are functioning as intended and effectively mitigating risks. This process takes place after deployment and ensures that controls are properly integrated, comply with internal policies and industry standards, and deliver the desired security outcomes. It includes activities like audits, vulnerability assessments, penetration tests, and continuous monitoring to evaluate performance, identify gaps, and make essential adjustments. The goal is to maintain a strong security posture and ensure security resilience against emerging threats, which is why regular validation is essential.

4.4.4.1 Inputs

The results of the previous process 4.4.3.3 will serve as input parameters for this process, along with the following additional inputs.

Scope of Validation & Control Objectives. These inputs define the systems, networks, and data protected by security controls and necessitate validation.

Validation Criteria. This scale establishes success criteria for evaluating security controls along with their effectiveness, incorporating pass/fail benchmarks, risk thresholds, and approved key performance indicators (KPIs).

Resources. They encompass the personnel responsible for carrying out the validation process, such as internal audit teams or external consultants, along with the allocated budget and time necessary to complete the validation process.

Threat Model. This prototype represents the organization's threat landscape by outlining potential threats and attack vectors, along with risk assessment and vulnerability scans, confirming the capability of security controls to mitigate them.

> *"We enforce a set of core security controls tied to risk analysis and vulnerability management, use them to enforce endpoint and Software-as-a-Service (SaaS) controls, and regularly review the encryption keys linked to those controls."* **P7 (Security Engineer)**

[31] International Organization for Standardization
[32] General Data Protection Regulation
[33] Health Insurance Portability and Accountability Act

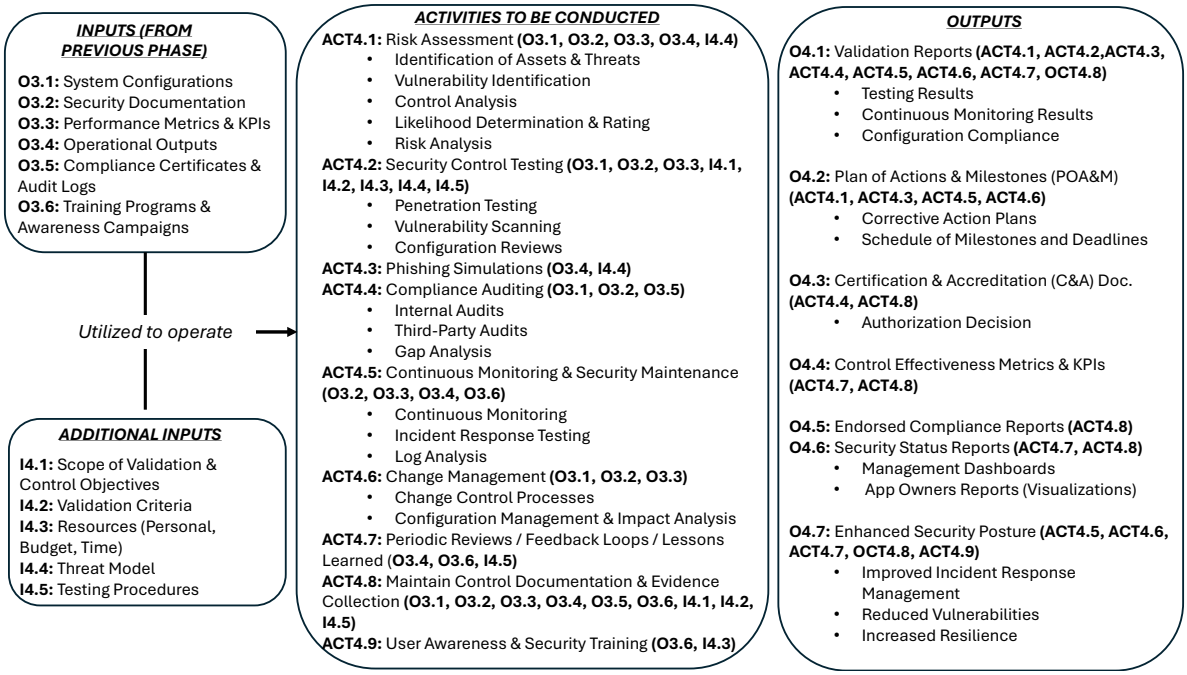

Figure 4.7: Major Components (Inputs (**I**), Activities (**ACT**), Outputs (**O**)) involved in **Security Control Verification**

Testing Procedures. These include test cases and scenarios used to validate security controls, including audit reviews and results from penetration testing and vulnerability scanning. Moreover, they detail the tools and methodologies employed, such as automated testing solutions and manual evaluation procedures.

4.4.4.2 Activities

This subsection details the practices involved in the verification process.

Risk Assessment. This activity includes identifying organizational assets and potential threats, assessing their likelihood and impact, and analyzing the identified risks to prioritize security controls for validation based on their criticality.

> *"During the risk assessment, we carefully evaluate the issue of multi-factor authentication, as we run different applications set up at various levels with different allocated budgets. As we move to the design phase, we develop an extensive plan based on the project's size."* **P9 (Security Architect)**

Security Control Testing. This critical practice includes key activities such as penetration testing to simulate real-world attacks and vulnerability scanning to assess security controls in spotting vulnerabilities and potential weaknesses.

> *"One of the major challenges we encounter during vulnerability scanning is the crowd-strike issue. This typically happens when peer reviewers provide inconsistent test results after conducting automation, compliance checks, or verification."* **P5 (Head of Security Department)**

Phishing Simulations. These tests will assess and improve employee awareness and response to cyber-attacks and malicious threats.

Compliance Auditing. This practice includes internal audits to ensure compliance with security policies and regulations, often complemented by independent third-party assessments. These audits perform gap analyses, assess control effectiveness, and benchmark security controls against industry standards to identify any deficiencies or inconsistencies.

Continuous Monitoring & Security Maintenance. This activity involves deploying Security Information and Event Management (SIEM) tools for real-time monitoring, anomaly detection, and security event tracking. In addition, security logs are reviewed and analyzed to assess control performance and verify their effectiveness in mitigating risks. Besides, a comprehensive incident plan is developed and frequently maintained to address security breaches and respond promptly to cyber incidents and malicious attacks. During this process, Patch management is carried out to ensure systems and software applications are consistently updated, keeping them secure and up to date.

Change Management. This process involves managing configuration settings and reviews to maintain control effectiveness, consistency, and adherence to security standards. It also includes impact analysis to assess the effects of changes on security controls and determine the need for further validation.

> *"We perform change management by aligning our CIS benchmarks with NIST standards, while focusing on configuration settings and the minimum security requirements for each infrastructure."*
> **P2 (Cybersecurity Engineer)**

Periodic Reviews / Feedback Loops / Lessons Learned. Throughout this practice, regular assessments are performed to evaluate the effectiveness of security controls, with adjustments made to address emerging threats and vulnerabilities. Following incidents, security practitioners gather insights to facilitate constructive feedback on incidents, audits, and monitoring activities, supporting continuous improvement. Subsequently, lessons-learned sessions are conducted to enhance security controls, validate processes, and adjust controls as needed to accommodate changes in the threat landscape, technologies, or business processes.

Maintain Control Documentation & Evidence Collection. Keeping comprehensive control documentation is crucial for outlining the purpose, implementation, configuration, and validation outcomes of security controls. To ensure security compliance and enable future assessments, all evidence of control performance (e.g. test results, audit findings, and monitoring reports) are collected, archived, and compiled into performance reports. All these reports will be shared periodically with stakeholders, offering valuable insights into the effectiveness of security controls and highlighting areas that may need further attention or enhancement.

User Awareness & Security Training. Provide ongoing training for employees on security policies, procedures, and best practices to enhance the human aspect of security controls.

4.4.4.3 Outputs

This subsection outlines the results obtained from the activities carried out during the verification process.

Validation Reports. These reports include comprehensive findings on the compliance of security controls with established policies, procedures, and standards. They document the results of continuous monitoring and ongoing tests, such as vulnerability scans, penetration tests, and functional assessments.

They aim to provide insights into long-term effectiveness, identify any deviations from expected performance, and confirm that security controls operate as intended. In addition, the Security Control Assessment (SCA) Report is included to provide overall assessments of the competency and efficiency of controls in mitigating identified risks, along with analysis of residual risks.

Plan of Actions & Milestones. This plan outlines detailed corrective action plans to address deficiencies or weaknesses identified during the verification process. It includes a timeline with clear milestones and deadlines for implementing corrective measures and action plans, ensuring the timely resolution of issues.

Certification and Accreditation (C&A) Documentation. This artifact includes the authorization decision, where authorized entities formally certify and confirm the adequacy of security controls to protect organizational data and systems, based on the verification results. It also involves the security authorization package, which comprehensively outlines and securely documents the verification outcomes, risk assessments, action plans, and authorization decisions.

Control Effectiveness Metrics & KPIs. They encompass security metrics and key performance indicators (KPIs) that quantitatively evaluate the efficiency and capability of controls in achieving security objectives, monitoring cyber trends, and identify areas for improvement.

Endorsed Compliance Reports. These logs serve as records for internal/external audits and verification activities. They also involve essential compliance documents that demonstrate adherence to international security standards and legal requirements.

Security Status Reports. These artifacts include management reports summarizing the organization's security posture, highlighting identified risks and the progress of corrective action plans. They also feature data dashboards and visualizations that provide real-time (or near-real-time) perceptions into security control effectiveness, enabling informed decision-making.

Enhanced Security Posture. This objective is achieved by reducing vulnerabilities and security gaps while significantly improving incident response management (IRM) for faster and more effective handling of security incidents. As a result, the organization's resilience and capabilities are strengthened to withstand and recover from cyber threats and attacks.

4.5 Discussion

The proposed framework provides a structured approach to managing and handling security controls in primary phases (classification, assessment, implementation, and verification). This section examines the framework's effectiveness, adaptability, and positive impact in overcoming challenges and obstacles within the Security Control Lifecycle, as well as across various organizational environments.

4.5.1 Analysis of Key Finding

Security controls are organized and categorized according to their functional responsibilities, main roles, and relevance based on risk. According to Section 4.4.1, the classification of security controls plays a vital role in enhancing an organization's security posture. We adopted a structured methodology and applied thematic analysis to systematically categorize security controls and prioritize them based on key factors such as organizational scope, asset inventory, regulatory compliance, and security requirements, as detailed in Subsection 4.4.1.1. Leveraging these inputs facilitates precise control classification, optimal resource allocation, and compliance with international standards and regulatory frameworks. Subsection 4.4.1.2 outlines key activities essential to this classification process, including risk management and security compliance, to strengthen overall defense strategies and ensure adher-

ence to international security standards such as NIST[34], ISO[35], and GDPR[36]. Conducting a gap analysis helps identify areas where security controls require implementation or improvement. Unlike traditional methods [409] [410], which typically rely on static lists of security controls [411], this framework incorporates dynamic risk analysis **(ACT1.2: Conduct Risk Assessment)** and growing business needs **(ACT1.4: Control Mapping)** in Figure 4.4, to enable organizations to conduct a proper identification and classification of security controls in response to evolving threats and malicious cyber attacks. In Subsection 4.4.1.3, various outputs are generated to finalize this process. Among them is **(O1.6: Security Control Catalogue)**, which offers comprehensive and up-to-date details on controls, including their purpose, scope, implementation guidelines, and compliance with relevant regulatory standards.

In the subsequent phase, security controls are assessed and checked against security policies, regulatory requirements, and industry best practices, as explained in Section 4.4.2. The framework leverages classification reports from the previous phase and integrates qualitative and quantitative metrics, along with key performance indicators (KPIs), to evaluate each control's effectiveness, scalability, and applicability before implementation. The activities enlisted in Subsection 4.4.2.2 enable organizations to measure the maturity of their controls over time before putting them into practice, ensuring scalable automation and feedback loops. Examples of those activities include **(ACT2.2: Review Security Policies & Documentation)** and **(ACT2.3: Physical Security Assessment)** in Figure 4.5, which offer risk-based evaluation and improve essential cognitive features like decision-making, problem-solving, and security reasoning. The assessment activity **(ACT2.4: Evaluate Current Awareness & Training Programs)** suggests situational awareness rather than solely focusing on regulatory compliance. It fosters a proactive approach to security, where awareness of real-time threats and an understanding of the broader security landscape enable individuals to adapt their controls effectively and mitigate potential threats.

As explained in Section 4.4.3, security controls are implemented methodically to establish check and balance in the organizational structure and infrastructure architecture to meet the organization security and industry regulations requirements, using the activities outlined in Section 4.4.3.2. These activities translate the results of the control assessment phase systematically into input parameters (Subsection 4.4.3.1), actionable implementation plans, and practical execution strategies (Subsection 4.4.3.3). Our framework supports the iterative implementation of security controls, addressing common challenges that organizations may face when trying to build security controls. These challenges could be due to complex IT environments, misalignment with business objectives, inflexibility of organizational business processes, resource limitations, and insufficient security awareness [412] [413] [414].

The verification phase ensures that the implemented controls work and operate as intended and remain effective over time, as shown in Section 4.4.4. The framework integrates adjustable and scalable verification practices that work according to the unique needs of an organization, regardless of its size or complexity. These practices are not rigid or one-size-fits-all; instead, they provide a flexible structure that allows small businesses to implement streamlined controls with minimal overhead, while also supporting the more complex, layered requirements of large enterprises. They encompass automated testing, periodic reviews, continuous monitoring, and feedback loops to maintain the ongoing relevance and effectiveness of security controls. Furthermore, the framework is aligned with widely

[34]National Institute of Standards and Technology
[35]The International Organization for Standardization
[36]General Data Protection Regulation

recognized security standards (e.g., NIST[37], ISO 27001[38], CIS[39]), ensuring its applicability across various industries, including finance, healthcare, government, and telecommunications. Unlike conventional, compliance-driven models described in [415] [416] [417], this framework emphasizes ongoing validation through real-time security analytics and feedback loops. This iterative process strengthens resilience and extensibility by allowing security practitioners to address security gaps proactively before they become vulnerabilities or more complex. However, they can customize and tailor the framework's practices to align with their specific security requirements, business objectives, risk profiles, and operational environments.

4.5.2 Implications to Practitioners

To identify the correct inputs for the security controls' classification and identification process as in Figure 4.4, identifying the asset inventory included in the security control lifecycle, including hardware, software components and applications, is paramount. Therefore, we emphasize the artifact **(I1.2 Asset Inventory (HW/SW) & Data)** in Subsection 4.4.1.1. By evaluating the inventory size, assets, systems, and software applications of an organization, security practitioners can strategically determine where security controls should be established. In addition, early identification of assets and components that require immediate security attention enables software engineers to perform precise workload assessments and develop accurate budget estimates, including costs, resources, and timelines.

Risk management is a fundamental pillar of a robust security framework, as it allows practitioners to identify, assess, and mitigate potential threats and vulnerabilities systematically. Therefore, we incorporated a dedicated practice **(ACT1.2 Conduct Risk Assessment)** to conduct risk assessment practices recognizing their significant role during the identification and classification of security controls. As illustrated in Figure 4.4, performing a thorough risk assessment serves as a confirmation that security controls are focused on the most critical risks and are effectively aligned with organizational objectives and risk frameworks. Moreover, risk assessment helps practitioners assess potential threats, determine vulnerabilities, and understand their potential impacts. Consequently, they can identify areas where new security controls need to be implemented or those that require enhancement, ultimately improving the overall security posture.

By effectively integrating risk management, security practitioners build proactive security controls rather than reactive ones, ensuring their compliance with security standards and regulatory requirements. Also, they confirm the appropriate controls are in place to mitigate the identified risks and potential security breaches. For this reason, we have incorporated all the risk outcomes and assessment results into a comprehensive risk report **(O1.4: Updated Risk Assessment Report)**. This artifact ensures proper version control for past and current risk reports and maintains accuracy, traceability, and consistency in risk assessments. Eventually, maintaining this documentation will provide a structured approach to prioritizing cyber initiatives and optimizing resource allocation, thus ensuring continuous security improvements. Additionally, this procedure enhances governance, strategic planning, and informed decision-making.

As we recognize the essential need, for security practitioners to continuously review security documents, international guidelines, policies, and strategies throughout the security control assessment for various critical reasons, we emphasized this step in the **(ACT2.2: Review Security Policies & Documentation)** activity, as depicted in Figure4.5. This step involves reviewing and verifying organizational access controls, multi-factor authentication (MFA) mechanisms, incident response plans,

[37]National Institute of Standards and Technology
[38]The International Organization for Standardization
[39]Center for Internet Security

and remediable workarounds. For example, an organization's access controls define user authentication and authorization requirements, specifying that only authorized personnel can access sensitive financial data. Those personnel must authenticate via multi-factor authentication (MFA) before gaining access.

It is vital for security practitioners to document and utilize past experiences, leveraging lessons learned from previous applications and attacks to strengthen their security strategies and defenses, as presented by **(I3.3: Incident History)** in Figure 4.6. Conversely, they create comprehensive incident response plans (IRPs) to define procedures resulting from the control implementation process, ensuring an effective response to attacks and security breaches as shown by **(O3.4: Operational Outputs)** in Figure 4.6. They detail the steps to take if malware and malicious attacks are detected, such as isolating the infected systems, notifying the security team, and initiating forensic analysis to understand the scope of the attack [418].

Additionally, practitioners must adhere to the change management policies in **(O3.2: Security Documentation)**, which define the security procedures, strategies and policies for system implementation and application change tracking. All updates, whether hardware or software, undergo review, testing in staging environments, and approval by the change control board before deployment to production, ensuring no unintended security vulnerabilities are introduced. For this reason, we specified this practice by **(ACT4.6: Change Management)** in Figure 4.7. Regarding collaboration with vendors on system updates, third-party security policies define the security standards required for vendors handling sensitive information. Typically, they require third-party providers to encrypt data at rest, in transit, and undergo regular security audits to ensure compliance with security standards and organizational regulations. Therefore, we specifically incorporated this practice by **(ACT4.4: Compliance Auditing)** including internal audits, third-party audits, and gap analysis. All these rules, policies, and guidelines for encryption are typically documented in security agreements with third parties and vendors in **(O4.3: Certification & Accreditation (C&A) / Doc. Authorization Decision)** and **(O4.6: Security Status Reports)** in Figure 4.7.

4.5.3 Implications to Researchers

During the development of our framework, we recognize the important role of automation throughout the security control implementation and verification processes, as demonstrated by **(ACT3.3: Testing and Validation)** in Figure 4.6, and **(ACT4.2: Security Control Testing)** and **(ACT4.5: Continuous Monitoring & Security Maintenance)** in Figure 4.7. For several key reasons, practitioners should always include automated testing when implementing controls. Implementing the practices outlined in our framework ensures that security controls are efficient, consistent, scalable, and continuously evaluated, minimizing human errors and inconsistencies. For example, we focused on applying automation to key practices, understanding that this enables organizations to efficiently test a large number of controls across complex environments, which would be time-consuming if done manually [419] [420]. Moreover, automation quickly identifies vulnerabilities, misconfigurations, and non-compliance issues, enabling proactive remediation, continuous security improvement, and regulatory compliance with international standards and prevalent security frameworks (e.g., NIST[40], ISO 27001[41]) [421] [422].

As organizations increasingly integrate automation into their security practices, researchers are encouraged to explore key aspects of this transformation. In particular, more research is needed to address three fundamental questions: **(What, When, and How)** to apply automation in security frameworks,

[40] National Institute of Standards and Technology
[41] International Organization for Standardization

particularly within modern methodologies like DevSecOps or emerging environments like AI and zero-trust models.

What to Automate? Researchers should investigate which security practices, processes, and controls are best suited for automation. This includes identifying areas where automation enhances efficiency, accuracy, and resilience while determining tasks that may still require human intervention. For instance, one paper examined how various types and levels of automation impact operational performance and workload [423]. It highlighted the importance of aligning automation with cognitive resource demands, which results in applying auditory alerts and improved outcomes. Another paper that debated on automation is the multivocal literature review (MLR) referred by [424]. This study analyzed formal/gray literature and presented critical decisions about 'when and what' to automate in software testing. It also categorized key influencing factors into groups and offered practical checklists for industry use, highlighting the necessity for more structured and empirical approaches to support decision-making.

When to Automate? Understanding the optimal time for automation is essential. Security researchers should also explore the factors that influence when organizations should implement automation, such as risk assessments, compliance requirements, and maturity level. Maturity levels represent the development stages that evaluate an organization's ability to manage, improve, and maintain its IT processes, from informal practices to standardized, data-driven, and continuously evolving applications and systems. As an example, security professionals conducted case studies to inspect the accuracy of security maturity level assessments based on ISO/IEC 27002 [42] controls and COBIT[43] maturity levels [425]. The findings revealed that many experts struggle with accurate assessments, often overestimating their performance. They also highlighted specific mechanisms to support and enhance assessment reliability in practice.

How to Automate? The methodology and best techniques to integrate automation into security workflows require careful consideration. Researchers should study best practices, step-by-step implementation strategies, and guidelines that guide organizations in applying automation effectively. One such paper discussed the evolving boundary between human and machine tasks, emphasizing the role of Hybrid Intelligence (HI) in combining human strengths with AI (Artificial Intelligence) capabilities [426]. It highlighted process mining as a crucial tool for identifying which tasks to automate and for effectively managing workflows shared between humans and software robots in Business Process Management (BPM). Another example includes a survey that examined AI methods developed over the last 15 years to aid in conducting systematic literature reviews [427]. The survey outlined the tasks that can be automated, along with the algorithms and tools used. It also offers historical views of how AI has evolved to assist in streamlining and enhancing the SLR process while highlighting the continuing role of human input.

Although research has explored automation methodologies, there remains significant potential for further investigation. In particular, researchers could further conduct and delve into a more in-depth analysis by developing comprehensive guidelines and best practices for optimizing automation processes and conducting the best and most efficient methods, ensuring greater efficiency while minimizing costs, time, and resource expenditures.

On the other hand, automation can be resource-intensive and costly, necessitating strategic planning for budget allocation, including human resources, tools, and advanced software updates. Moreover, automation requires time; therefore, before implementing automation, time should be considered as a factor, not just cost. Consequently, future research should also address cost-benefit analyses, helping

[42] International Organization for Standardization | International Electrotechnical Commission

[43] Control Objectives for Information and Related Technology

organizations determine how to balance automation investments with their security objectives. By investigating these areas, researchers can provide valuable insights and actionable knowledge to support security practitioners in making informed decisions about automation within evolving security methodologies like cloud networks and DevSecOps or integrating with AI functions.

As security awareness plays a crucial role in both the implementation and verification process of security controls, **(O3.6: Training Programs & Awareness Campaigns)** in Figure 4.6 and **(ACT4.9: User Awareness & Security Training)** in Figure 4.7, cyber resilience has become a critical and evolving concept in the field of cybersecurity. [428]. It is the ability of an organization to continuously deliver the intended outcome and deliverables despite disruptive events or cyber-attacks [429]. Cyber resilience extends beyond attack prevention, ensuring organizations can quickly recover and maintain operational continuity in the event of security breaches [430] [431]. Given its growing relevance, researchers are recommended to explore best practices for integrating cyber resilience into organizational strategies and security processes. They should also investigate the most effective methods for teaching cyber resilience to staff, emphasizing its importance in building organizational capacity to respond to incidents. In particular, incident response management **(ACT4.5: Continuous Monitoring & Security Maintenance)** in Figure 4.7 greatly benefits from cyber resilience, as it tests the ability of employees to perform under pressure and evaluate their decision-making in times of crises and malicious attacks. Therefore, researchers should examine how to simulate high-pressure scenarios to assess and improve employees' capabilities in real-world scenarios and stressful situations, ensuring that their response strategies are robust and effective. By studying the application of cyber resilience, security researchers can provide valuable insights and crucial observations about how organizations can better prepare their workforce for incidents, improve recovery strategies, and enhance overall cyber resilience.

4.5.4 The Benefits of our Framework

Unlike traditional compliance-focused frameworks (e.g. ISO/IEC 27001[44] [432] [433], HIPAA[45] [434], PCI DSS[46] [435] [436], GDPR[47] [437] [438], NIST SP 800-53[48] [439] [440], SOX[49] [441], COBIT[50] [442] [443]), we designed our framework using a systematic and **risk-centric** approach to manage security controls and prioritize risk-driven practices and decision-making. In addition, it is well-established to be **comprehensive** and ensure that all the security controls and essential practices are covered while effectively managing the inputs and requirements in each phase. The outputs are presented in a systematic hierarchy, which allows them to be utilized as input parameters for subsequent processes, ensuring a seamless flow throughout the security lifecycle. On the other hand, this framework incorporates the feature of **Operational Integration** for aligning security controls with business objectives in a structured manner, ensuring that security is embedded within operational workflows rather than acting as a standalone requirement. Moreover, it is **adaptable** as it is meant to be deployed in the IT industry to support software engineers in building security controls and conducting security practices efficiently, generating consistent and actionable outputs.

The presented framework is **scalable** as is able to incorporate inputs and activities as necessary. When it became apparent that extra parameters would enhance the effectiveness of the process, they

[44] International Organization for Standardization | The International Electrotechnical Commission
[45] Health Insurance Portability and Accountability Act
[46] Payment Card Industry Data Security Standard
[47] General Data Protection Regulation
[48] National Institute of Standards and Technology | Special Publication
[49] Sarbanes-Oxley Act
[50] Control Objectives for Information and Related Technologies

were included, further proving the framework's adaptability and **thoroughness**. Furthermore, it is **flexible** and can be customized to meet the specific needs of organizations, such as security requirements, business priorities, and international standards. This ensures its relevance and effectiveness across various industries and environments. In addition, this framework is considered as an approach for preparing organizations for DevSecOps implementation and promoting **continuous improvement** effectively. It builds the fundamental groundwork for adopting automation in security processes and integrating security controls within emerging technologies and new trends, such as cloud networks, AI methods, and zero-trust models. Additionally, the iterative verification mechanism enables organizations to continuously consider **feedback loops** in refining and enhancing existing security controls in a way that would certainly improve overall security posture and cyber resilience over time.

4.5.5 Comparison with Existing Security Models and Standards

In comparison to international security standards (e.g., NIST SP 800-53[51], ISO 27001[52], and CIS[53]), our framework stands out due to its flexibility, comprehensiveness, adaptability, and risk-driven approach. Its ability to evolve and incorporate emerging needs and standards makes it a powerful tool for organizations seeking to improve their security posture while aligning with industry best practices and global security frameworks. While the other security models mentioned in Section 4.2, focus on specific aspects of security, such as risk management or incident response, our framework integrates all activities associated with the security control lifecycle, ensuring a holistic and continuous process from planning to execution. This unique feature allows it to effectively leverage security controls across all phases, providing a robust structure that enhances overall security posture.

In contrast to traditional models such as Ellenberg's framework [397], Qudus's framework [375], the model developed by Youngin et al.'s [398], Kanaan et al.'s framework [399], Loncar et al.'s model [400], and the model proposed by Al-Safwani et al. [333], which may treat security controls in isolation or as discrete activities, this framework integrates security controls and practices into a unified and systematic approach. It not only manages the implementation and verification of security measures, but it also ensures the continuous maintenance, monitoring, and enhancement of security controls, adapting to evolving threats and organizational requirements.

Another key distinction is its ability to use the inputs and outputs across each phase of the security control lifecycle. The systematic approach ensures that the outputs of one phase seamlessly serve as the inputs for the next, maintaining a dynamic, adaptive security environment. This integration and flow of information contribute to a more efficient and effective security management system compared to more fragmented models. In contrast, other frameworks may lack the flexibility to cater to diverse security needs. Further, our framework is developed to be highly customizable and scalable. It can be tailored to meet specific business needs, aligned with industry standards, and adapted to regional regulations, making it more versatile than many alternative models. This level of adaptability makes it a valuable tool for organizations seeking to up-level their security posture or implement new security methodologies (e.g. **DevSecOps**) that align with their unique challenges and objectives.

In conclusion, our framework offers a more comprehensive, integrated, and adaptable approach to security control implementation and management than other models, delivering key benefits in streamlining processes, enhancing security compliance, and boosting efficiency and cyber resilience.

[51] National Institute of Standards and Technology
[52] International Organization for Standardization
[53] Center for Internet Security

4.6 Threats to Validity

This section summarizes the threats to our study design and the findings and strategies used to address those threats.

4.6.1 Internal validity

Internal validity refers to the extent to which the framework's development process and evaluation accurately reflect its functionality and effectiveness in managing the security control lifecycle. Potential threats include:

Bias in Expert Input. The framework was designed based on insights, perceptions, and feedback received from software practitioners, security analysts, and subject matter experts (SMEs). However, their perspectives and interpretations may introduce bias, as their cybersecurity experiences may not fully capture the diverse range of security challenges and obstacles encountered across different organizational environments or industries.

Focus Group Limitations. Although the conducted focus groups provided valuable perceptions and qualitative insights, the subjective nature of discussions may have shaped the final framework structure, potentially overlooking certain security concerns or prioritizing specific aspects over others. To mitigate bias in expert input and focus group limitations, we incorporated diverse perspectives from a broad range of industry professionals, security practitioners, and organizational stakeholders. In this study, we were keen to collect insights and perceptions from experts across multiple sectors and conducted structured focus groups and interviews to validate the findings.

Lack of Empirical Validation. The framework is currently conceptual and built upon theoretical foundations. However, it has not undergone extensive empirical testing or practical implementation in real-world scenarios and environments. We believe, its maturity, practical effectiveness, and adaptability to dynamic security threats require further validation through implementation studies, case studies, simulations, and peer reviews.

Potential Overfitting to Specific Scenarios. The framework may be more aligned with specific industries or coordinated with certain use cases, security standards, or regulatory requirements. This could result in limiting its applicability and feasibility across all sectors without further modifications.

Potential Threats in Designing Focus Group Questions. The way the questions were structured may lead participants toward a particular response, potentially reinforcing existing assumptions rather than encouraging open-ended discussion. In addition, ambiguous questions can limit the depth and precision of responses, causing participants to respond based on perceived expectations rather than their real experiences. To minimize this threat, we ensured that all questions were neutral, open-ended, and clearly defined. As a team of researchers, we consulted together to review the wording and structure of the questions before the focus group began.

Author's Influence/Bias While Conducting Focus Groups. Since we facilitated the focus groups, there was a potential risk that personal perspectives and biases could have unintentionally influenced the discussions. This could manifest in the follow-up questions or the prioritization of certain viewpoints over others. Our role as researchers may have introduced a power dynamic that could have influenced participants' willingness to express dissenting or alternative perspectives. To address this, we followed a neutral facilitation approach and ensured that personal opinions or favorable viewpoints were not expressed. We also used a structured moderation guide to ensure consistency in the way discussions were conducted across different focus groups [444] [445]. During the focus groups and interviews enlisted in Table 4.2, we fostered an inclusive environment by encouraging diverse perspectives and emphasizing confidentiality, ensuring that participants felt comfortable sharing honest insights. Furthermore,

all session contents (recordings and notes) were recorded and transcribed carefully to ensure that all perspectives were accurately captured and analyzed impartially.

Analysis of Collected Data. A significant threat during data analysis is confirmation bias, where we might unintentionally interpret or highlight findings that align with our expectations while overlooking contradictory evidence [446]. Furthermore, subjectivity in coding qualitative data may lead to inconsistencies in theme identification and data categorization [447]. To mitigate these threats, we employed the thematic analysis method and iteratively reviewed and analyzed the collected data. Moreover, we conducted member checking by sharing preliminary findings with key stakeholders to validate whether the interpretations accurately reflected their perspectives.

4.6.2 External validity

External validity ensures, to what extent the framework and its findings can be perceived and generalized to a broader range of organizations, industries, and security environments. Possible threats include:

Generalizability across Organizations. Although we developed this framework to be comprehensive, inclusive, and adaptable, its capabilities and effectiveness may vary based on an organization's cyber maturity, availability of skilled resources, and regulatory landscapes.

Scalability and Customization Challenges. Although the framework is designed to be flexible, scalable, and customizable, its actual adaptability depends on how well organizations can utilize and integrate with current controls, security policies, DevSecOps pipelines, and automation capabilities. However, some organizations may have the expertise to effectively use this framework or possess the capability to customize it as needed.

Evolving Threat Landscapes. Cyber threats and attack vectors are constantly evolving and advancing at a rapid pace. While this framework incorporates best practices and security strategies, it may require continuous updates and refreshers to remain effective in addressing security risks and emerging attacks.

Industry-Specific Constraints. Organizations typically have highly strict security rules and stringent compliance requirements in certain industries, such as finance or telecoms. The framework may require further refinements or sector-specific modifications to meet specialized business needs.

4.7 Conclusion

In conclusion, this chapter presents a comprehensive security framework designed to provide clear guidelines for the implementation and verification of security controls. It can be deployed in the IT industry to effectively assist security practitioners throughout the entire security control lifecycle, thus empowering security improvement and overall cyber posture. Our framework was developed through a collaborative process involving software practitioners, security analysts, and other subject matter experts (SMEs). It combines theoretical knowledge with practical operational experience, focusing on security compliance, minimizing vulnerabilities, and optimizing secure system deployments. It aims to assist organizations in implementing and validating security controls in real-world scenarios. Incorporating diverse perspectives and insights guarantees that the framework is both resilient and flexible, effectively addressing key challenges encountered in the development and implementation of security controls, such as resource limitations, knowledge gaps, and evolving threats.

The framework encompasses all essential security controls and practices, plus it emphasizes the most critical and trending aspects of DevSecOps and security automation. More importantly, every

element and component within this framework is scalable and adaptable, allowing customization based on practitioners' needs, organizational regulations, security standards, industry requirements, and geographic considerations. Its comprehensive nature makes it applicable across various contexts, ensuring that organizations can adopt a proactive and systematic approach to security control management without compromising agility or innovation.

In the following chapter (Chapter 5), continuous assessment was applied, and the framework was validated through a member-checking process and a focused group discussion involving six subject matter experts. By engaging those experts (Table 4.2), we ensured the credibility, relevance, practical value, and that the proposed framework (Figure 4.3) aligns with both security requirements and business objectives [448]. As a result, the framework has been rigorously reviewed and validated in the next chapter (Chapter 5, to confirm its ability in supporting security practitioners in addressing key challenges, managing resource limitations, navigating complex compliance requirements, bridging knowledge gaps, and maintaining resilience in the face of an evolving cyber threat landscape.

Chapter 5

Framework Verification

This chapter has been submitted to the IEEE TrustCom conference and has been accepted for presentation.

M. Sinan, M. Shahin, I. Gondal, Validation of a Governance Framework Supporting Security Controls across Emerging Systems, the 24th IEEE International Conference on Trust, Security and Privacy in Computing and Communications in China, 2025.

As discussed in the previous chapter 4, and given the critical importance of the seamless implementation of security controls in safeguarding organizational assets, ensuring regulatory compliance, and maintaining operational resilience, the need for such a robust security framework (Figure 4.3), was particularly evident in DevSecOps environments. To validate the framework's applicability, empirical sessions and structured focus groups with subject matter experts (SMEs) and experienced security practitioners were conducted using real-world use cases. The results and findings confirmed its alignment with international security standards and industry regulations such as NIST SP 800-53 [1] and ISO 27001[2]. Participants endorsed its comprehensiveness, traceability, and automation readiness, affirming its value in both traditional and agile development contexts. The feedback provided by participants contributed to enhancements that strengthened the framework's practicality and ease of use.

5.1 Introduction

The effective management of security controls throughout their lifecycle is critical to ensuring that organizations maintain a robust and adaptable security posture [449]. Security threats and malicious attacks are constantly evolving, making static or one-time implementations of security controls neither adequate nor sufficient to address the evolving threat landscape [450] [451]. Instead, security controls must be continuously classified, assessed, implemented, and validated to ensure they remain suitable and effective in addressing emerging risks and compliance requirements. Managing security controls throughout their entire lifecycle enables organizations to systematically address vulnerabilities, adapt to changes, and ensure compliance with security standards, regulatory requirements, and industry best practices [452].

[1] National Institute of Standards and Technology
[2] International Organization for Standardization

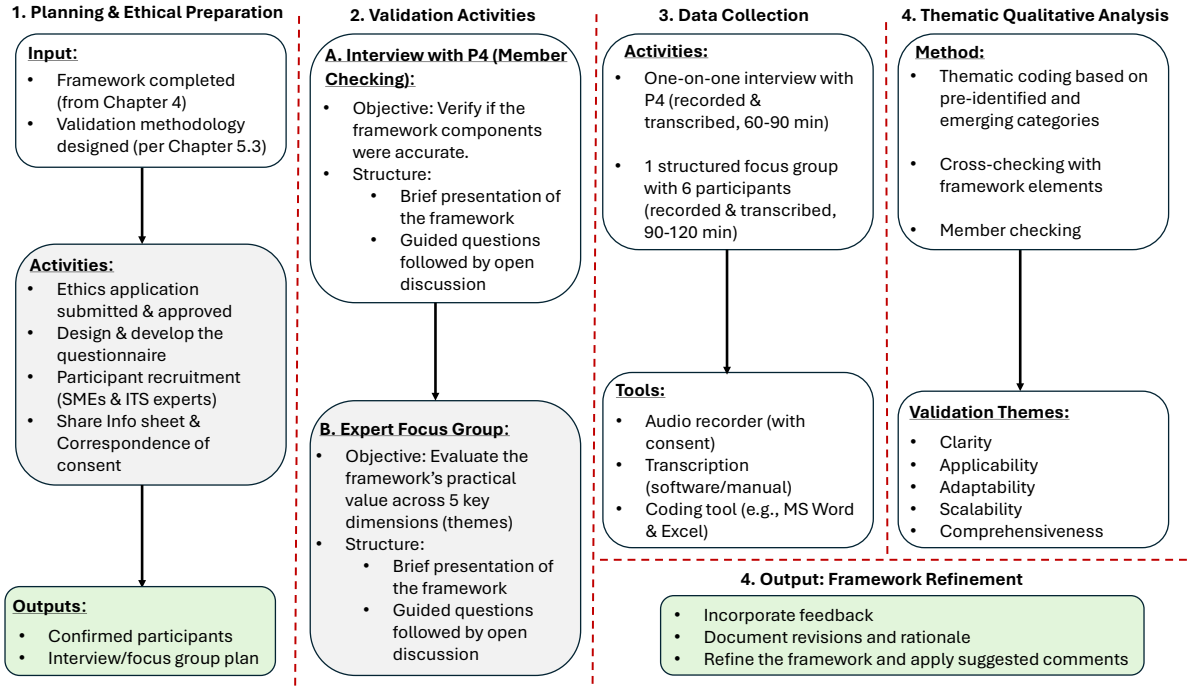

Figure 5.1: Methodology for Verifying the Proposed Framework

Managing security controls has become increasingly critical and challenging in modern IT and software engineering environments [453]. However, organizations continue to face significant challenges in managing security controls, as they must navigate complex, evolving cyber threats while ensuring proper classification, assessment, implementation, and validation of these controls to maintain a robust security posture [454] [455]. On the other side, current approaches and security strategies tend to focus on isolated phases of control management, leaving significant gaps and vulnerabilities in traceability, consistency, and assurance across the entire lifecycle [456] [457]. To overcome these challenges, a comprehensive approach to managing security controls is essential. This can be effectively achieved through the development of a structured framework that governs security controls across all phases, aligning with organizational objectives, compliance requirements, security risks, and the evolving threat landscape [458] [459]. In response to this need, we developed a comprehensive framework to manage security controls holistically across their lifecycle (Figure 4.3 in Chapter 4). The framework systematically addresses key stages, including classifying controls, assessing their applicability and effectiveness, implementing controls within agile environments, and frequently validating them to ensure efficiency and continuous improvement.

This chapter focuses specifically on the verification and validation of the framework proposed in Figure 4.3 in Chapter 4, recognizing its significance and applicability within the fields of software engineering and cybersecurity. In the discipline of software engineering, and particularly when proposing a new security framework, it is essential to thoroughly verify and validate the framework before promoting its adoption within the IT industry. Security practitioners must have confidence that the framework is fit for purpose, practically applicable, and capable of delivering the intended outcomes before they begin to adapt and leverage it in real-world settings. For this reason, we conducted this study to thoroughly evaluate the framework's design, structure, and hands-on applicability to ensure it functions seamlessly and contributes to improving security control management practices across organizations.

5.2 Methodology for Framework Validation

To verify the proposed security control governance framework in Figure 4.3 (Chapter 4), we employed a qualitative validation methodology, as detailed in Figure 5.2. This approach focused on collecting expert feedback and insights to assess the framework's clarity, applicability, relevance to security controls, and thoroughness within real-world IT environments [460] [461]. The following sections outline the qualitative data analysis and the procedures undertaken to ensure the reliability and validity of our framework. In accordance with sections 3.3 and 3.3.2 in Chapter 3, this process received formal approval from the university's ethics committee to include validation focus groups, ensuring full compliance with institutional and academic standards for responsible research conduct. All validation activities were conducted following ethical research guidelines. Before the sessions, participants and subject matter experts (SMEs) were provided with an information sheet describing the framework, main objective, role, and how it would be deployed and used in the IT industry.

5.2.1 Member Checking (Individual Interview)

Our initial step in verifying and validating the framework involved engaging a participant who previously contributed to one of the original focus groups involved in the framework's development (P4 in Table 4.2, Chapter 4). We carried out a member check with P4 to confirm the authenticity of the interpreted insights and ensure the credibility of the framework, as indicated in Table 5.1. It is important to highlight that Participant P4 possessed a strong track record in the IT industry, with extensive hands-on experience in security governance in general, and in security controls in particular. During the session, we meticulously validated and confirmed that the core concepts of the framework, artifacts, interpretations, and key security practices were fully aligned with the participant's understanding and professional experience. This one-to-one discussion played a significant role in identifying any potential misrepresentations or oversights in the framework's design, especially as it was assessed against existing benchmarks and frameworks that Participant P4 is currently applying in real-world practices.

Table 5.1: Participants Contributed to member checking and focus groups - Demographic Details. (**CX**: Cybersecurity experience in years)

Verification Tool	Current Role	Unit | Division	Domain	City	Highest Qualification	CX
Member Check	(P4) CEO Start-up Founder	Cybersecurity Dept.	Cybersecurity	Melbourne	Bachelor's in Computer Science	10
Focus Group	Six Subject Matter Experts (SMEs)	ITS Dept.	RMIT University	Melbourne	Bachelor's and Master's degrees in Computer Science	6-10

5.2.2 Expert Focus Group Discussion

A structured focus group was conducted with six experts from the Information Technology Services (ITS) department at a public university in Australia. This department provides a wide range of IT services and support to the university community, including help-desk assistance, consulting, and project management. All participants had extensive experience in IT governance and security controls, facilitating operational management and effective use of ICT[3] activities. The session was structured to collect critical feedback on the real-world applicability, adaptability, and efficacy of the framework in

[3]Information and Communications Technology

managing security controls in different IT environments. First, we started the discussion by presenting the fundamental components of the framework along with its objectives and main features. Later, the session was guided by a set of predefined questions aligned with the framework's objectives, while actionable insights emerged through open and constructive dialogue. The participants collaboratively reviewed the framework and examined its associated artifacts, including input parameters, core activities, sub-activities, and output parameters, offering valuable insights and constructive suggestions for refinement.

5.2.3 Qualitative Data Analysis

Qualitative analysis in software engineering provides rich and contextual insights that help to better understand developer experiences, organizational needs, and work processes [462]. It truly enables the exploration of complex phenomena, such as organizational structures, application dynamics, and team interactions, which are often overlooked by quantitative methods [463]. By incorporating tools like interviews and focus groups, qualitative analysis ensures that software design is user-oriented and fits within real-world environments [405]. The data collected from both the individual member checking interview and the expert focus group discussion mentioned in Sections 5.2.1 and 5.2.2, were analyzed using a thematic and qualitative analysis approach [464]. All sessions were audio-recorded (with participant consent) and transcribed verbatim (word-for-word) to ensure accuracy. The transcripts were carefully reviewed and analyzed to identify recurring patterns and feedback concerning the framework's structure, practicality, and its alignment with real-world security practices.

Participant perceptions and key insights were carefully categorized under themes (main category/perspective) for which the framework would be verified, such as **clarity** (is it structured and easy to interpret? would the stakeholders understand and apply its components effectively?) [465] [466], **applicability** (is it suitable for diverse operational environments?) [467], **adaptability** (does it allow seamless integration with different processes and emerging technologies, (e.g. AI[4], ML[5], and ZTA[6]) [468], **scalability** (does it enable the organization to effectively expand or adjust its security controls in line with growth, complexity, and evolving attacks or risk landscapes) [469] [470], and **comprehensiveness** (does the framework address all critical aspects or types of security controls, from governance to technical controls, ensuring thorough and smooth coverage throughout the entire organization) [471] [472]. Some sample questions are outlined in Table 5.2. To ensure a reliable analysis process, we iteratively applied codes and identified key themes, while simultaneously comparing and cross-checking the framework against the aforementioned perspectives.

A thematic analysis of the focus group discussions revealed a set of key themes related to the proposed security framework, such as scalability, comprehensiveness, and practical usability, as illustrated in Figure 5.2. Participants generally agreed that the framework was scalable across different organizational sizes and technological environments, including both cloud-native and traditional infrastructures. They also affirmed the emphasis on user training and awareness, and how the framework covered the critical phases of the security control lifecycle. In terms of usability, participants highlighted the ease of integrating the framework into existing DevSecOps practices. These insights collectively confirm that the framework is both scalable and largely comprehensive, while also scalable enough to identify areas for further enhancement and include more security practices.

[4]Artificial Intelligence
[5]Machine Learning
[6]Zero Trust Architectures

Table 5.2: Sample Questions (aligned with themes)

Theme	Sample Questions
Clarity	- Is the framework structure clear and easy to interpret? - Are the artifacts intuitively organized?
Applicability	- Can this framework be adopted in your IT environment? - Does it match typical governance workflows?
Adaptability	- Could this framework integrate with emerging tech (e.g. AI, ZTA)? - How flexible is it?
Scalability	- Can this be applied in both small and large organizations? - What might limit its scalability?
Comprehensiveness	- Does it address all relevant areas of control (governance, technical, operational)?

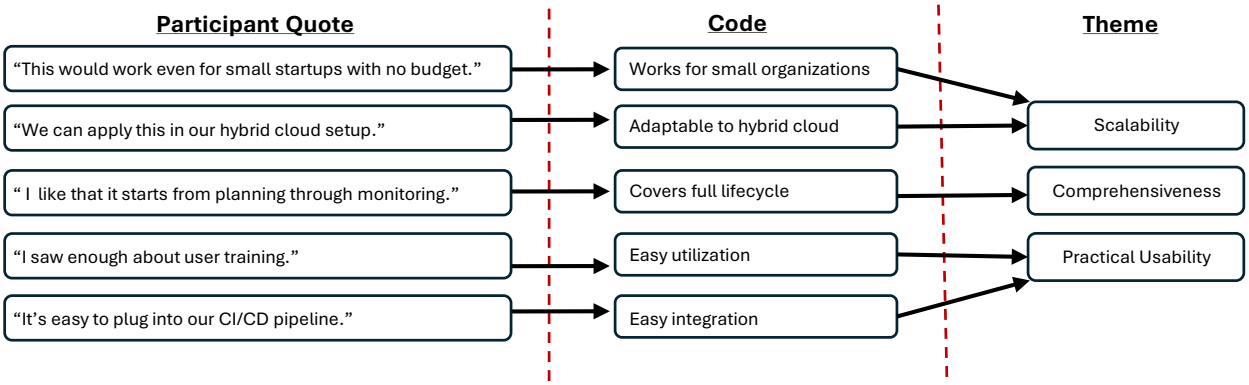

Figure 5.2: Mapping of Participant Quotes to Codes and Emergent Themes Identified Through Thematic Analysis

5.3 Results and Findings

This section outlines the feedback and participant perceptions obtained from the verification activities, comprising a one-on-one member checking interview and a focus group discussion with six ITS department experts (Section 5.2). It emphasizes the key aspects and outcomes of the framework's validation, along with participants' perceptions, constructive feedback, and suggestions for improvement and further refinement. Overall, the feedback was highly positive, with the framework perceived as relevant, practical, and applicable, reinforcing confidence in its robustness and potential usefulness across various IT environments. The following findings emerged from the qualitative analysis:

1. **Clarity and Comprehensiveness**. The participants appreciated the framework's clarity in defining the artifacts and essential activities of control classification, assessment, implementation, and verification. They noted that the step-by-step structure makes the framework easy to understand, adopt, and implement. They also highlighted its comprehensiveness and how it addresses both technical and governance aspects of security control management.
2. **Relevance and Practical Applicability**. Participants consistently affirmed that the framework is highly relevant to current security practices and IT governance. They noted that the structure effectively reflects real-world processes for managing and governing security controls within

complex and dynamic IT environments. The framework was viewed as both practical and ready to implement, particularly for organizations seeking to align their security controls with global security standards, business needs, and regulatory requirements.

3. **Adaptability to Modern Security Contexts**. Participants emphasized that the presented framework can be customized for various organizational contexts and industry settings. This flexibility was widely recognized as a significant strength, particularly in the context of rapidly changing threat landscapes and regulatory requirements.
4. **Validation of Governance Focus**. Participants commended how the framework (in Figure 4.3, Chapter 4) is governance-oriented, particularly the focus on continuous monitoring, traceability, and auditability. The integration between the core components and governance elements was very clear and seen as an essential link to ensure accountability and long-term sustainability.
5. **Suggestions for Improvement**. Although the overall feedback was positive, the following suggestions were made for enhancing the framework.
   a) The focus group session (Section 5.2.2), suggested to change the order of some of the activities involved in the security control implementation phase.
   b) The Second suggestion was to simplify the terminology in some areas to ensure understanding for less technical stakeholders.

   We have given due consideration to both suggestions, and they have been comprehensively addressed and incorporated into the framework.

6. **Overall Perception**. Both validation activities reached a clear consensus that the framework is robust, well-structured, and fit for purpose. Participants expressed confidence in its ability to support effective security control governance and recommended its utility in both academic (supporting researchers) and operational settings (assisting security practitioners in implementing and handling security controls in their organizations).

5.4 Discussion

The results of this verification process greatly support the robustness, relevance, and practical utility of our governance framework. Based on the insights obtained from both the one-on-one member checking and the expert focus group discussion, the feedback endorsed the framework's alignment with international security standards and essential security practices, such as NIST[7], ISO[8], GDPR[9]. A key point of consensus among participants was the framework's real-world applicability in IT environments, particularly in the context of DevSecOps and agile-driven organizations. Its feasibility and adaptability were emphasized as notable strengths, thereby giving the ability to navigate through evolving threat landscapes and manage dynamic regulatory IT expectations. Moreover, this flexibility further enhances its potential for broader applicability across diverse organizational contexts.

Another significant outcome was the affirmation of the framework's alignment with existing security standards and compliance frameworks. Participants perceived it as complementing, rather than conflicting with, the existing security frameworks and governance models. This significantly increases its potential for adoption and seamless integration of controls within existing structures, without the need for major organizational disruption or redevelopment of security controls from the ground up. Moreover, the validation process yielded constructive feedback that provided meaningful suggestions

[7]National Institute of Standards and Technology
[8]International Organization for Standardization
[9]General Data Protection Regulation

for further refinement. These included minor changes (like re-ordering or sequencing the activities), to ensure clarity and consider scalability for organizations of varying sizes. This positive feedback noticeably contributed to continuous improvement and informed the next iteration of the framework. On the other side, the consistency of feedback across both validation methods strengthens the reliability of these findings. The combination of individual and group-based verification sessions ensured a breadth of perspectives and minimized bias. This approach certainly added extra precision and validity to the validation process, in addition to increasing confidence in the framework's design and value. In summary, the discussion affirms that the governance framework is both theoretically sound and practically viable. While further testing in practical organizational environments was recommended to assess long-term impact and adaptability, the initial validation provided a strong foundation for its application and future development.

5.5 Conclusion

This chapter demonstrates how the proposed framework (outlined in Chapter 4) was rigorously verified to confirm it is theoretically robust and practically viable for integrating security controls in real-world agile and DevSecOps environments. The framework was evaluated for its relevance and applicability using systematic validation methods, such as member checking and focus groups with subject matter experts who confirmed its alignment with essential practices, compliance with governance requirements, and adaptability across diverse organizational contexts and business needs. In conclusion, this process underscored the framework's practical value in managing security controls and highlighted key strengths (e.g., clarity, flexibility, effectiveness). Further, the findings demonstrated strong support for the framework, with participants offering constructive feedback to further enhance its practical applicability. There was a clear consensus that the framework effectively bridges the gap between fast-paced software delivery and security compliance, representing a timely and valuable contribution to cybersecurity governance, particularly within the context of security controls and DevSecOps environments.

Chapter 6

Conclusion and Future Work

This thesis aimed to explore the progressive and critical challenges of managing security controls in fast-paced and automated DevSecOps environments. As software development lifecycles evolve toward automation and continuous integration, traditional and conventional security approaches often fall short. Our research addressed those gaps and inspected how security controls should be systematically embedded, managed, and governed throughout DevSecOps pipelines, in tandem with maintaining a robust and seamless integration for security controls within agile development environments. The findings underscore the complexity of managing security controls in automated and fast-paced DevSecOps environments. They also highlight the importance of effective and seamless implementation of security controls as a critical factor in achieving a more resilient security posture.

6.1 Summary of Findings and Key Contributions

This thesis accomplished its main objectives through a systematic approach, with its key contributions collectively bridging the gap between theoretical insights, practical applications, and the strategic implementation of security controls. The first contribution is presented in the systematic literature review (SLR) in Chapter 2, which was conducted to examine the theoretical foundations and critically synthesize perspectives from the existing literature. It primarily aimed to build a fragmented landscape and conceptual knowledge, identifying recurring challenges, associated solutions, and research gaps related to the integration of security controls within DevSecOps and continuous practices. During the SLR execution, numerous issues and critical challenges were identified and emphasized, including limited integration across toolchains, insufficient traceability, poor visibility, ambiguous ownership of controls, and misalignment with agile and automated pipelines. Conversely, the SLR also highlighted best practices, emerging methodologies, and evolving technologies aimed at addressing the reported challenges, including automated control enforcement, security compliance, and continuous compliance mechanisms. Ultimately, the review revealed a significant research gap in the area of security control management and traditional governance models, particularly concerning those tailored for DevSecOps and capable of supporting the continuous management of security controls.

The second contribution, represented in a practitioner-focused survey, was conducted to capture real-world practices and insights, gather empirical evidence, and investigate how security practitioners handle and manage security controls in various industries, including finance, telecommunications, insurance, and government. The survey focused on bridging the gap between theory and practice through a targeted practitioner survey, as detailed in Chapter 3. It received 118 anonymous responses, providing diverse perspectives on how security controls are genuinely perceived, classified, implemented, and

validated in DevSecOps environments. This empirical component was designed to capture real-world experiences from security practitioners, including analysts, designers, and DevSecOps engineers. The survey aimed to understand how security controls are currently managed, what tools and processes are used, and what practical challenges security analysts encounter in agile environments. While participants demonstrated a clear understanding of the importance of security control management, the findings nonetheless revealed significant inconsistencies in the implementation and maintenance of these controls within real-world projects and complex operational environments. Many participants identified critical challenges, including the absence of centralized control documentation, difficulties in sustaining control ownership across DevOps teams, and insufficient support for continuous control validation. These insights reinforced several of the thesis findings and affirmed the practical relevance of the issues previously identified in the literature.

The third and main contribution of this thesis is the development of a governance framework designed to handle the integration and implementation of security controls across the full DevOps lifecycle, as presented in Chapter 4. The framework directly addresses the feedback, challenges, and concerns identified through focus groups and interviews (Table 4.2), offering a structured and scalable approach to assist security practitioners in the effective implementation and management of security controls. It supports the seamless and automated management of security controls, guiding their classification, implementation, and validation. Each phase is designed to be iterative and tightly integrated with DevOps workflows, allowing organizations to embed security without creating bottlenecks. Moreover, the presented framework bridges theoretical insights **(obtained from the SLR)** with actionable practice **(obtained from the survey)**, emphasizing continuous monitoring, automation, and traceability to improve accountability and sustain long-term compliance with internal regulations and external security standards. It also promotes alignment with continuous integration practices and the automation-driven nature of DevSecOps pipelines. This approach extends beyond the technical implementation of security controls to encompass broader governance frameworks and organizational considerations across the entire security control lifecycle. For instance, it ensures that security practices are strategically aligned with business objectives while upholding compliance with international standards and regulatory mandates, including NIST[1], ISO[2], GDPR[3], and HIPAA[4]. By aligning with both technical and organizational needs, this governance framework contributes to closing the gap between strategic governance and operational execution. It offers a practical blueprint for organizations seeking to mature their DevSecOps practices and ensure security is treated as a shared responsibility throughout the development process.

The framework in Figure 4.3, representing the ultimate goal of this thesis, was subjected to a comprehensive verification and validation process to ensure its scalability, reliability, and practical applicability in supporting security controls and addressing recurring challenges, as detailed in Chapter 5. Its validity and relevance were established through multiple qualitative validation and thematic analysis methods, including expert interviews, focus group discussions, and member checking. The evaluation outcomes collectively affirmed the framework's applicability in real-world contexts and its adaptability to the diverse needs of organizations across various sectors.

[1]National Institute of Standards and Technology
[2]International Organization for Standardization
[3]General Data Protection Regulation
[4]Health Insurance Portability and Accountability Act

6.2 Implications

6.2.1 Implications for Industry Practice

From a practical perspective, this research responds to one of the critical gaps in existing security landscapes; the absence of a systematic approach to embed and integrate security into agile sprints and DevSecOps environments. In today's fast-paced development cycles, many organizations struggle to integrate security controls without disrupting workflow velocity. The governance framework, introduced in Chapter 4, can be adopted and leveraged as a clear and practical guide for those who seek to align security controls with the dynamic nature of agile sprints and continuous deployment pipelines without compromising speed or responsiveness, thus improving the overall security posture.

On the other side, software practitioners and security analysts can utilize this framework as a strategic planning and operational tool to plan and continuously improve essential security practices (e.g., risk management, threat modeling, vulnerability management, etc). It enables them to implement, refine, and map security controls systematically with existing practices throughout the software development lifecycle. This is attributed to its flexible and scalable architecture, which enhances the ownership and traceability of security controls on one side, and promotes effective collaboration and communication among DevSecOps teams (development, operations, and security) on the other side.

Furthermore, the integration of governance and automation within the framework is critical to bridge the gap between security governance and DevOps workflows. This would address the dual imperatives of DevSecOps and promote a model in which security is supported by automation and handled as a shared responsibility across DevSecOps teams. This framework enables software practitioners to achieve technical efficiency while ensuring alignment with compliance requirements and organizational regulations. This balanced approach equips organizations to navigate complex compliance landscapes (e.g., ISO 27001[5], NIST[6], or industry-specific regulations) without slowing down innovation. For those industries that operate in highly regulated or high-risk sectors (e.g., finance, healthcare, or telecoms), the framework offers an opportunity to mature DevSecOps practices and ensure security is not an afterthought, but a core enabler of resilient and trustworthy software delivery.

6.2.2 Implications for Researchers

This work also contributes to the academic body of knowledge by synthesizing fragmented insights into a cohesive understanding of how security controls operate within modern software development environments, particularly in the context of DevSecOps. The proposed framework (Chapter 4) offers a structured approach that integrates security controls seamlessly into agile and DevSecOps pipelines. This area has often been treated in isolation or with limited practical depth. This study consolidates both theoretical knowledge and real-world practices, and offer a holistic perspective for examining the intricate balance between rapid software development and effective security governance.

The taxonomy of challenges and solutions, developed through a rigorous literature review (Chapter 2), presents a refined classification that researchers can use as a reference point for comparative studies, theory building, or further refinement. Combined with the empirical insights gathered through the survey (Chapter 3), this work establishes a solid empirical basis for understanding current industry practices, perceptions, and gaps in the implementation of security controls in DevSecOps pipelines. Such grounded insights are particularly valuable in a rapidly evolving field where academic models often struggle to keep pace with industry transformation.

[5]The International Organization for Standardization
[6]The National Institute of Standards and Technology

Moreover, this thesis highlights the importance of mixed-method research in cybersecurity and software engineering studies. Combining literature synthesis with empirical data, it exemplifies a methodology that enhances both relevance and rigor. Future researchers are encouraged to adopt the proposed framework to test its applicability in various organizational contexts or to extend it by incorporating emerging technologies such as AI-driven security tools or compliance automation platforms. Ultimately, this research helps bridge the gap between theoretical models and the practical realities faced by development teams, fostering a more dynamic and responsive academic dialogue in the field of secure software development.

6.3 Limitations

While this research provides a strong foundation for understanding and supporting the integration of security controls within DevSecOps environments, it is not without limitations. Although the survey was conducted and enriched by participants from various professional backgrounds, the participation was limited to individuals with internet access and a foundational understanding of cybersecurity terminology and jargon. This inherently excludes perspectives from non-English speakers or business stakeholders who work in regions with limited digital access, potentially narrowing the global applicability of the findings. Furthermore, the survey analysis included many sample sizes that are sufficient for exploratory purposes; nevertheless, it may not fully capture the diversity of practices between industries and organizational sizes.

Another limitation lies in the scope of empirical validation (Chapter 5). The practical implementation of the framework has not been tested in extended fields and sectors. The absence of continued case studies in real-world DevSecOps environments means that the long-term efficacy and adaptability of the framework remain to be observed. Therefore, including such case studies in future research would certainly enable a deeper understanding of how the framework evolves under real-world and operational pressures, and within different cultural organizations or regulatory contexts.

Lastly, this study focuses primarily on the conceptual and structural aspects of integrating security controls and does not delve into the technical tooling or automation mechanisms that could enhance its implementation. As such, the framework (Chapter 4) remains at a strategic level, offering guidance rather than prescriptive technical solutions. Future work could explore the development of associate tools, templates, or plugins for CI/CD platforms to support automated governance, as well as the integration of artificial intelligence (AI) and machine learning (ML) techniques to enhance the responsiveness, adaptability, and predictive capabilities of security controls in DevSecOps pipelines. These additions would help bridge the gap between conceptual frameworks and operational deployment, further increasing the framework's practical value.

6.4 Future Research Directions

6.4.1 Enhancing the proposed framework

While this thesis provides a comprehensive foundation for the implementation and management of security controls, it simultaneously highlights several promising directions for future research. Although the proposed framework (Figure 4.3 in Chapter 4) makes a significant contribution to the field, further refinement is intended to enhance its practicality and broaden its applicability in real-world environments. By acknowledging and addressing the threats identified in Section 4.6, the following strategies are proposed to enhance the framework's overall effectiveness and resilience:

- Conduct empirical validation through case studies, pilot implementations, and real-world scenarios is essential to elevate the security maturity of the framework. This approach will significantly demonstrate its practical applicability and ensure it remains vital and relevant in addressing sector-specific challenges.
- Expand the scope of expert input by organizing more advanced focus groups that incorporate a diverse range of security practitioners from various organizational contexts. Collaborating closely with business stakeholders will allow the framework to be tailored and iteratively refined based on their feedback and specific regulatory requirements. Moreover, it expands the framework's adaptability to meet the unique demands of different industries, such as healthcare, finance, telecommunications, and governmental sectors.
- Leverage continuous updates to incorporate the framework and keep in line with emerging security technologies and evolving regulatory changes.

6.4.2 Automation in DevSecOps

Given the increasing prevalence of automation in DevSecOps, future research could investigate automation more extensively. With automation becoming a core aspect of modern security practices, integrating automated security controls effectively will enhance the framework's efficiency and scalability. Further, researchers should explore the integration of security controls within emerging technologies (e.g., security orchestration, machine learning (ML), artificial intelligence (AI)-driven threat modeling, and zero-trust models to improve threat detection and response capabilities, allowing the framework to stay vital and ahead of emerging risks. , along with the integration of security controls

6.4.3 Cultural and socio-organizational perspectives

On the other side, a more in-depth investigation is required into the cultural and organizational factors that impact the effective adoption of security governance frameworks within agile environments. Future research could examine the interplay between DevSecOps roles, team structures, and compliance requirements. Such investigations would certainly contribute to the development of more comprehensive models for secure software delivery, addressing both technical and socio-organizational perspectives.

6.5 Final Reflections

In conclusion, this thesis offers a timely and practical response to the growing demand for seamless and effective integration of security controls. It further explores the challenges and obstacles associated with the management and implementation of security controls, with a particular focus on the automation and continuous integration of critical security practices within DevSecOps and agile software development environments. The SLR (Chapter 2) offered a comprehensive overview of the current state of knowledge, while the online survey (Chapter 3) gathered direct input from software practitioners. The synthesis of findings and expert insights collectively informed the development and validation of the governance framework (Chapters 4 and 5). By seamlessly integrating theoretical analysis with practical insights and developing a validated framework tailored to the IT industry, this thesis makes a significant contribution to both the advancement of academic research and the practical implementation of security controls within dynamic, agile DevSecOps environments. It equips security practitioners

with practical guidance and establishes the foundation for future innovation in the integration of security controls within DevSecOps practices.

Bibliography

[1] Innovify, "What is devops and how it works?," *Innovify*, 2022. x, 5

[2] G. Kim, J. Humble, P. Debois, and J. Willis, *The DevOps Handbook: How to create world-classy Agility, Reliability and Security in IT organisations*. IT Revolution, 2021. xii, 12, 18

[3] M. Sinan, "Survey questions available at," in *Survey Questions available at*, 2024. xii, 63

[4] M. I. Ononiwu, O. C. Onwuzulike, and K. Shitu, "The role of digital business transformation in enhancing organizational agility," *World Journal of Advanced Research and Reviews*, vol. 23, no. 3, pp. 285–308, 2024. 2

[5] S. Hyrynsalmi, "Cloud-based integration platforms: exploring the challenges and opportunities," *LUT University*, 2024. 2

[6] S. Jones, Z. Irani, U. Sivarajah, and P. E. Love, "Risks and rewards of cloud computing in the uk public sector: A reflection on three organisational case studies," *Information systems frontiers*, vol. 21, pp. 359–382, 2019. 2

[7] S. Saeed, S. A. Altamimi, N. A. Alkayyal, E. Alshehri, and D. A. Alabbad, "Digital transformation and cybersecurity challenges for businesses resilience: Issues and recommendations," *Sensors*, vol. 23, no. 15, p. 6666, 2023. 2

[8] H. Haelterman, "Hard, soft or situational controls? bridging the gap between security, compliance and internal control," *Security Journal*, vol. 33, no. 4, pp. 636–656, 2020. 2

[9] I. Tikanmäki, J. Savolainen, and H. Ruoslahti, "The role of standards in enhancing cybersecurity and business continuity management for organizations," *Information & Security*, vol. 55, no. 1, pp. 63–78, 2024. 2

[10] R. Steen, O. J. Haug, and R. Patriarca, "Business continuity and resilience management: A conceptual framework," *Journal of Contingencies and Crisis Management*, vol. 32, no. 1, p. e12501, 2024. 2

[11] A. Shukla and P. K. Suri, "Importance of implementing effective cyber security controls for active cyber security risk management," in *Flexibility, Resilience and Sustainability*, pp. 325–336, Springer, 2024. 2

[12] R. K. Goutam, *Cybersecurity Fundamentals: Understand the Role of Cybersecurity, Its Importance and Modern Techniques Used by Cybersecurity Professionals (English Edition)*. BPB Publications, 2021. 2

[13] O. M. C. Osazuwa, O. Mitchell, and C. Osazuwa, "Confidentiality; integrity, and availability in network systems: A review of related literature," *International Journal of Innovative Science and Research Technology*, vol. 8, no. 12, pp. 1946–1953, 2023. 2

[14] D. G. Hiza and P. Chogo, "Assessment of ict infrastructure security vulnerabilities based on confidentiality, integrity, and availability of information," *IAA Digital Repository*, 2021. 2

[15] T. Aksoy and L. Aksoy, "Increasing importance of internal control in the light of global developments, national and international standards and regulations," *Sayıştay Dergisi*, vol. 1, pp. 9–40, 2020. 2

[16] S. Duggineni, "Impact of controls on data integrity and information systems," *Science and Technology*, vol. 13, no. 2, pp. 29–35, 2023. 2, 58

[17] V. Viegas and O. Kuyucu, *IT Security Controls*, vol. 193. Springer, 2022. 2, 49, 93

[18] R. Pompon, "Administrative controls," in *IT Security Risk Control Management: An Audit Preparation Plan*, pp. 153–163, Springer, 2016. 2

[19] K. Renaud and J. Ophoff, "A cyber situational awareness model to predict the implementation of cyber security controls and precautions by smes," *Organizational Cybersecurity Journal: Practice, Process and People*, vol. 1, no. 1, pp. 24–46, 2021. 2, 82

[20] X. Liu, J. Yu, W. Lv, D. Yu, Y. Wang, and Y. Wu, "Network security situation: From awareness to awareness-control," *Journal of Network and Computer Applications*, vol. 139, pp. 15–30, 2019. 2

[21] R. K. Mahmood, A. I. Mahameed, N. Q. Lateef, H. M. Jasim, A. D. Radhi, S. R. Ahmed, and P. Tupe-Waghmare, "Optimizing network security with machine learning and multi-factor authentication for enhanced intrusion detection," *Journal of Robotics and Control (JRC)*, vol. 5, no. 5, pp. 1502–1524, 2024. 3

[22] S. Garg, S. S. Negi, *et al.*, "Advanced cloud enabled security firewall," *Jaypee University of Information Technology Waknaghat*, 2024. 3

[23] F. I. Salih, H. B. Abas, A. Azizan, and S. M. Daud, "Enhancement of physical security control for data centre and perimeter in banking: A case study of central bank of sudan (cbos)," *Open International Journal of Informatics (OIJI)*, pp. 67–84, 2018. 3

[24] A. U. Nabi, M. Ahmed, and A. Abro, "An overview of firewall types, technologies, and functionalities," *International Journal of Computing and Related Technologies*, vol. 3, no. 1, pp. 10–16, 2022. 3

[25] A. Mishra, Y. I. Alzoubi, A. Q. Gill, and M. J. Anwar, "Cybersecurity enterprises policies: A comparative study," *Sensors*, vol. 22, no. 2, p. 538, 2022. 3

[26] S. Bauer, E. W. Bernroider, and K. Chudzikowski, "Prevention is better than cure! designing information security awareness programs to overcome users' non-compliance with information security policies in banks," *computers & security*, vol. 68, pp. 145–159, 2017. 3

[27] I.-C. Donca, O. P. Stan, M. Misaros, D. Gota, and L. Miclea, "Method for continuous integration and deployment using a pipeline generator for agile software projects," *Sensors*, vol. 22, no. 12, p. 4637, 2022. 4

[28] S. Arachchi and I. Perera, "Continuous integration and continuous delivery pipeline automation for agile software project management," in *2018 Moratuwa Engineering Research Conference (MERCon)*, pp. 156–161, IEEE, 2018. 4

[29] H. van Merode, *Continuous Integration (CI) and Continuous Delivery (CD): a practical guide to designing and developing pipelines*. Springer, 2023. 4

[30] Z. Wadhams, A. M. Reinhold, and C. Izurieta, "Automating static code analysis through ci/cd pipeline integration," in *2024 IEEE International Conference on Software Analysis, Evolution and Reengineering-Companion (SANER-C)*, pp. 119–125, IEEE, 2024. 4

[31] N. S. P. K. Yadati, "Integrating dynamic security testing tools into ci/cd pipelines: A continuous security testing case study," *International Journal of Science and Research (IJSR*, 2021. 4

[32] M. A. Aljohani and S. S. Alqahtani, "A unified framework for automating software security analysis in devsecops," in *A Unified Framework for Automating Software Security Analysis in DevSecOps*, 2023 International Conference on Smart Computing and Application (ICSCA), pp. 1–6, IEEE, 2023. 4, 26

[33] M. Nalini, B. Mahalakshmi, N. Khandelwal, N. Pai, and L. Sharan, "Ci/cd pipeline with vulnerability mitigation," in *2023 International Conference on Recent Advances in Science and Engineering Technology (ICRASET)*, pp. 1–6, IEEE, 2023. 4

[34] I. Qabajeh, F. Thabtah, and F. Chiclana, "A recent review of conventional vs. automated cybersecurity anti-phishing techniques," *Computer Science Review*, vol. 29, pp. 44–55, 2018. 4

[35] S. Pargaonkar, "Advancements in security testing: A comprehensive review of methodologies and emerging trends in software quality engineering," *International Journal of Science and Research (IJSR)*, vol. 12, no. 9, pp. 61–66, 2023. 4

[36] M. Alenezi and S. Almuairfi, "Security risks in the software development lifecycle," *International Journal of Recent Technology and Engineering*, vol. 8, no. 3, pp. 7048–7055, 2019. 4

[37] O. O. Abiona, O. J. Oladapo, O. T. Modupe, O. C. Oyeniran, A. O. Adewusi, and A. M. Komolafe, "The emergence and importance of devsecops: Integrating and reviewing security practices within the devops pipeline," *World Journal of Advanced Engineering Technology and Sciences*, vol. 11, no. 2, pp. 127–133, 2024. 4, 6

[38] X. Sun, Y. Cheng, X. Qu, and H. Li, "Design and implementation of security test pipeline based on devsecops," in *2021 IEEE 4th Advanced Information Management, Communicates, Electronic and Automation Control Conference (IMCEC)*, vol. 4, pp. 532–535, IEEE, 2021. 4

[39] O. B. Abiola and O. G. Olufemi, "An enhanced cicd pipeline: A devsecops approach," *International Journal of Computer Applications*, vol. 184, no. 48, 2023. 4

[40] M. Sánchez-Gordón and R. Colomo-Palacios, "Security as culture: a systematic literature review of devsecops," in *Security as culture: a systematic literature review of DevSecOps*, Proceedings of the IEEE/ACM 42nd International Conference on Software Engineering Workshops, pp. 266–269, 2020. 4, 20, 21, 51

[41] X. Zhou, R. Mao, H. Zhang, Q. Dai, H. Huang, H. Shen, J. Li, and G. Rong, "Revisit security in the era of devops: An evidence-based inquiry into devsecops industry," *IET Software*, vol. 17, no. 4, pp. 435–454, 2023. 4, 18, 25, 96

[42] N. Islavath, "" shifting security left: Integrating devops with secure development practices," *J Artif Intell Mach Learn & Data Sci 2020*, vol. 1, no. 1, pp. 1368–1371, 2020. 4

[43] R. Dachepally, "Devsecops: Shifting security left with automated scanning tools," *IJAIDR-Journal of Advances in Developmental Research*, vol. 16, no. 1, 2025. 4

[44] T. Rangnau, R. v. Buijtenen, F. Fransen, and F. Turkmen, "Continuous security testing: A case study on integrating dynamic security testing tools in ci/cd pipelines," in *2020 IEEE 24th International Enterprise Distributed Object Computing Conference (EDOC)*, pp. 145–154, IEEE, 2020. 4

[45] P. Bajpai and A. Lewis, "Secure development workflows in ci/cd pipelines," in *2022 IEEE Secure Development Conference (SecDev)*, pp. 65–66, IEEE, 2022. 4

[46] A. JAHIĆ and N. BUZAĐIJA, "Devops methodology in modern software development," *Quantum Journal of Engineering, Science and Technology*, vol. 4, no. 1, pp. 1–11, 2023. 4

[47] P. Narang and P. Mittal, "Performance assessment of traditional software development methodologies and devops automation culture," *Engineering, Technology & Applied Science Research*, vol. 12, no. 6, pp. 9726–9731, 2022. 4

[48] T. H.-C. Hsu, *Practical security automation and testing: tools and techniques for automated security scanning and testing in devsecops*. Packt Publishing Ltd, 2019. 4

[49] S. Chittala, "Securing devops pipelines: Automating security in devsecops frameworks," *JOURNAL OF RECENT TRENDS IN COMPUTER SCIENCE AND ENGINEERING (JRTCSE)*, vol. 12, no. 5, pp. 31–44, 2024. 4

[50] X. Zhao, T. Clear, and R. Lal, "Identifying the primary dimensions of devsecops: A multi-vocal literature review," *Journal of Systems and Software*, p. 112063, 2024. 5

[51] N. Tomas, J. Li, and H. Huang, "An empirical study on culture, automation, measurement, and sharing of devsecops," in *2019 International Conference on Cyber Security and Protection of Digital Services (Cyber Security)*, pp. 1–8, IEEE, 2019. 5

[52] N. Sohrabi Safa, C. Maple, T. Watson, and S. Furnell, "Information security collaboration formation in organisations," *IET Information Security*, vol. 12, no. 3, pp. 238–245, 2018. 5

[53] F. Lombardi and A. Fanton, "From devops to devsecops is not enough. cyberdevops: an extreme shifting-left architecture to bring cybersecurity within software security lifecycle pipeline," *Software Quality Journal*, vol. 31, no. 2, pp. 619–654, 2023. 5, 12, 26

[54] R. N. Rajapakse, M. Zahedi, M. A. Babar, and H. Shen, "Challenges and solutions when adopting devsecops: A systematic review," *Information and software technology*, vol. 141, p. 106700, 2022. 5, 19, 20, 21, 51

[55] A. Mahida, "A review on continuous integration and continuous deployment (ci/cd) for machine learning," *International journal of science and research*, vol. 10, no. 3, pp. 1967–1970, 2021. 5

[56] J.-H. Park, S.-C. Park, and H.-Y. Youm, "A proposal for a zero-trust-based multi-level security model and its security controls.," *Applied Sciences (2076-3417)*, vol. 15, no. 2, 2025. 5

[57] S. M. Saleh, N. Madhavji, and J. Steinbacher, "Blockchain for securing ci/cd pipeline: A review on tools, frameworks, and challenges," in *2024 7th Conference on Cloud and Internet of Things (CIoT)*, pp. 1–5, IEEE, 2024. 5

[58] D. S. D'Onofrio, M. L. Fusco, and H. Zhong, "Ci/cd pipeline and devsecops integration for security and load testing," tech. rep., Sandia National Lab.(SNL-NM), Albuquerque, NM (United States), 2023. 5

[59] R. C. Thota, "Cloud-native devsecops: Integrating security automation into ci/cd pipelines," *INTERNATIONAL JOURNAL OF INNOVATIVE RESEARCH AND CREATIVE TECHNOLOGY*, vol. 10, no. 6, pp. 1–19, 2024. 5

[60] S. Tatineni, "Compliance and audit challenges in devops: a security perspective," *International Research Journal of Modernization in Engineering Technology and Science*, vol. 5, no. 10, pp. 1306–1316, 2023. 5

[61] T. H.-C. Hsu, *Hands-On Security in DevOps: Ensure continuous security, deployment, and delivery with DevSecOps*. Packt Publishing Ltd, 2018. 6

[62] C. Colliander, "Challenges of devsecops," *English. Master's thesis. University of Helsinki, Faculty of Science. url: http://hdl. handle. net/10138/342887*, 2022. 6, 22

[63] E. McCoy, "Cybersecurity real-world applications for the software development life cycle," *Land Forces Academy Review*, vol. 30, no. 1, pp. 148–161, 2025. 6

[64] M. Sinan, M. Shahin, and I. Gondal, "Integrating security controls in devsecops: Challenges, solutions, and future research directions," *Journal of Software: Evolution and Process*, vol. 37, no. 6, p. e70029, 2025. 10

[65] M. Sinan, M. Shahin, and I. Gondal, "Implementing and integrating security controls: A practitioners' perspective," *Computers & Security*, p. 104516, 2025. 10, 55

[66] B. S. Farroha and D. L. Farroha, "A framework for managing mission needs, compliance, and trust in the devops environment," in *A framework for managing mission needs, compliance, and trust in the DevOps environment*, 2014 IEEE Military Communications Conference, pp. 288–293, IEEE, 2014. 12

[67] L.-J. Zhang, J. Zhang, and H. Cai, "End-to-end services delivery platform and methodology," *Services Computing*, pp. 310–329, 2007. 12

[68] S. Radack, "The system development life cycle (sdlc)," tech. rep., National Institute of Standards and Technology, 2009. 12

[69] S. Alajrami, A. Romanovsky, and B. Gallina, "Software development in the post-pc era: towards software development as a service," in *Software development in the post-PC era: towards software development as a service*, Product-Focused Software Process Improvement: 17th International Conference, PROFES 2016, Trondheim, Norway, November 22-24, 2016, Proceedings 17, pp. 662–671, Springer, 2016. 12

[70] E. C. Burkard, "Usability testing within a Devsecops environment," in *Usability testing within a Devsecops environment*, 2020 Integrated Communications Navigation and Surveillance Conference (ICNS), pp. 1C1–1, IEEE, 2020. 12

[71] H. Myrbakken and R. Colomo-Palacios, "DevSecOps: A multivocal literature review," tech. rep., SpringerLink, 2017. 12, 18

[72] V. Mohan and L. B. Othmane, "DevSecOps: Is it a marketing buzzword?-mapping research on security in DevOps," in *DevSecOps: Is it a marketing buzzword?-mapping research on security in DevOps*, 2016 11th international conference on availability, reliability and security (ARES), pp. 542–547, IEEE, 2016. 12

[73] Akujobi and J. Chukwukamneleanya, "A model for measuring improvement of security in continuous integration pipelines: Metrics & four-axis maturity driven DevSecOps (MFAM)," tech. rep., UNIVERSITY OF TWENTE, 2021. 12

[74] L. Prates, J. Faustino, M. Silva, and R. Pereira, "Devsecops metrics," in *Devsecops metrics*, Information Systems: Research, Development, Applications, Education: 12th SIGSAND/PLAIS EuroSymposium 2019, Gdansk, Poland, September 19, 2019, Proceedings 12, pp. 77–90, Springer, 2019. 12

[75] A. ULLAH and R. LAI, "Modeling business goal for business/it alignment using requirements engineering," *Journal of Computer Engineer Systems*, 2015. 12

[76] A. Sharma and P. K. Misra, "Aspects of enhancing security in software development life cycle," *Advances in Computational Sciences and Technology*, vol. 10, no. 2, pp. 203–210, 2017. 12

[77] R. A. Khan, M. A. Akbar, S. Rafi, A. O. Almagrabi, and M. Alzahrani, "Evaluation of requirement engineering best practices for secure software development in gsd: an ism analysis," *Journal of Software: Evolution and Process*, vol. 36, no. 5, p. e2594, 2024. 13, 82

[78] J. Zhou, "Devsecops: Integrating security in devops for financial applications," *Future And Fintech, The: Abcdi And Beyond*, p. 423, 2022. 13

[79] S. I. Governance and P. F. in Large Organizations, "From Information Governance to IT governance: An overview of issues and frameworks for large organizations," *IGI Global*, 2019. 13

[80] D. Verslegers, "Challenges and opportunities for security assurance in DevOps," *Strategic Approaches to Digital Platform Security Assurance*, 2021. 13

[81] Y. Kurii and I. Opirskyy, "Analysis and comparison of the nist sp 800-53 and iso/iec 27001: 2013," *NIST Spec. Publ*, vol. 800, no. 53, p. 10, 2022. 13

[82] H. Susanto and M. N. Almunawar, *Information security management systems: a novel framework and software as a tool for compliance with information security standard*. Apple Academic Press, 2018. 13

[83] A. Bicaku, M. Tauber, and J. Delsing, "Security standard compliance and continuous verification for industrial internet of things," *International Journal of Distributed Sensor Networks*, vol. 16, no. 6, p. 1550147720922731, 2020. 13

[84] M. Alicea and I. Alsmadi, "Misconfiguration in firewalls and network access controls: Literature review," *Future Internet*, vol. 13, no. 11, p. 283, 2021. 13

[85] J. A. RUÍZ-TAPIA, S. RUÍZ-VALDÉS, I. d. R. CRUZ-SOLÍS, and F. H. ALCÁNTARA-CRUZ, "Administrative audit tool as support for the iso 27001 standard towards managing the quality of information in smses, 2021.," *Journal of Business & SMEs*, vol. 8, no. 21, 2022. 13

[86] M. Butavicius, K. Parsons, M. Lillie, A. McCormac, M. Pattinson, and D. Calic, "When believing in technology leads to poor cyber security: Development of a trust in technical controls scale," *Computers & Security*, vol. 98, p. 102020, 2020. 14

[87] R. Makri, P. Karaivazoglou, A. Kyritsis, M. Skitsas, N. Koutras, J. Valera, and J. M. Sanchez, "Modern innovative detectors of physical threats for critical infrastructures," *CYBER-PHYSICAL THREAT INTELLIGENCE FOR CRITICAL INFRASTRUCTURES SECURITY*, p. 397, 2020. 14

[88] L. Collins, "Computer and information security handbook (second edition)," in *Computer and Information Security Handbook (Second Edition)* (J. R. Vacca, ed.), pp. 1015–1021, Boston: Morgan Kaufmann, second edition ed., 2013. 14

[89] B. Alluhaybi, M. S. Alrahhal, A. Alzhrani, and V. Thayananthan, "A survey: agent-based software technology under the eyes of cyber security, security controls, attacks and challenges," *International Journal of Advanced Computer Science and Applications (IJACSA)*, vol. 10, no. 8, 2019. 14

[90] S. Maksuti, A. Bicaku, M. Zsilak, I. Ivkic, B. Péceli, G. Singler, K. Kovács, M. Tauber, and J. Delsing, "Automated and secure onboarding for system of systems," *IEEE Access*, vol. 9, pp. 111095–111113, 2021. 14

[91] K. Kaur, I. Gupta, A. K. Singh, *et al.*, "A comparative evaluation of data leakage/loss prevention systems (dlps)," in *A comparative evaluation of data leakage/loss prevention systems (DLPS)*, Proc. 4th Int. Conf. Computer Science & Information Technology (CS & IT-CSCP), pp. 87–95, 2017. 14

[92] S. O. Olabanji, O. O. Olaniyi, C. S. Adigwe, O. J. Okunleye, and T. O. Oladoyinbo, "Ai for identity and access management (iam) in the cloud: Exploring the potential of artificial intelligence to improve user authentication, authorization, and access control within cloud-based systems," *Authorization, and Access Control within Cloud-Based Systems (January 25, 2024)*, 2024. 14

[93] A. Arfeen, S. Ahmed, M. A. Khan, and S. F. A. Jafri, "Endpoint detection & response: A malware identification solution," in *Endpoint detection & response: A malware identification solution*, 2021 International Conference on Cyber Warfare and Security (ICCWS), pp. 1–8, IEEE, 2021. 14

[94] F. G. Siji and O. P. Uche, "An improved model for comparing different endpoint detection and response tools for mitigating insider threat," *Indian J. Eng.*, vol. 20, no. 53, pp. 1–13, 2023. 14

[95] M. L. Hale and R. F. Gamble, "Semantic hierarchies for extracting, modeling, and connecting compliance requirements in information security control standards," *Requirements Engineering*, vol. 24, pp. 365–402, 2019. 14

[96] M. Parker, B. Partridge, E. Svetcov, and A. J. Taylor, "Managing third-party risk: Framework details for risk management in medical technology," in *Advanced Health Technology*, pp. 213–252, Productivity Press, 2023. 14

[97] K. Ryanto and V. Tundjungsari, "Standardization of information security management in the banking sector using the iso 27001: 2022 framework," *Journal La Multiapp*, vol. 5, no. 4, pp. 361–379, 2024. 15

[98] C. Colabuono, D. Wiemer, M. V. Marabello, D. Lofù, M. Pappalardo, P. Bogacki, A. Dziech, J. Derkacz, L. A. G. Sanchez, E. Konieczna, *et al.*, "Approach to sector-specific cybersecurity schemes: Key elements and security problem definition," in *Approach to Sector-Specific Cybersecurity Schemes: Key Elements and Security Problem Definition*, International Conference on Multimedia Communications, Services and Security, pp. 104–117, Springer, 2022. 15

[99] M. Malatji, "Management of enterprise cyber security: A review of iso/iec 27001: 2022," in *Management of enterprise cyber security: A review of ISO/IEC 27001: 2022*, 2023 International conference on cyber management and engineering (CyMaEn), pp. 117–122, IEEE, 2023. 15

[100] S. Watkins, "Iso/iec 27001: 2022: An introduction to information security and the isms standard," *torossa*, 2022. 15

[101] V. Mohan, L. ben Othmane, and A. Kres, "Bp: Security concerns and best practices for automation of software deployment processes: An industrial case study," *IEEE Xplore*, 2018. 15, 49

[102] S. V. Deshmukh, D. S. Ahire, N. N. Chavan, N. D. Bharambe, and Akshay.R.Jain, "Implementing devsecops pipeline for an enterprise organization," *Springer Nature Link*, 2021. 15

[103] M. Fowler, *Refactoring: Improving the Design of Existing Code*. Addison-Wesley Professional, 2018. 15

[104] M. Kaya, S. Conley, Z. S. Othman, and A. Varol, "Effective software refactoring process," in *Effective software refactoring process*, 2018 6th International Symposium on Digital Forensic and Security (ISDFS), pp. 1–6, IEEE, 2018. 15

[105] R. Saint-Germain *et al.*, "Information security management best practice based on iso/iec 17799," *INFORMATION MANAGEMENT JOURNAL-PRAIRIE VILLAGE-*, vol. 39, no. 4, p. 60, 2005. 15

[106] K. Cormican, "Integrated enterprise risk management: From process to best practice," *Modern Economy*, vol. 2014, 2014. 15

[107] M. Trnka, A. S. Abdelfattah, A. Shrestha, M. Coffey, and T. Cerny, "Systematic review of authentication and authorization advancements for the internet of things," *Sensors*, vol. 22, no. 4, p. 1361, 2022. 15

[108] R. S. Kale, J. Hase, S. Deshmukh, S. N. Ajani, P. K. Agrawal, and C. S. Khandelwal, "Ensuring data confidentiality and integrity in edge computing environments: A security and privacy perspective," *Journal of Discrete Mathematical Sciences and Cryptography*, vol. 27, pp. 421–430, 2024. 16

[109] P. Sirohi, A. Agarwal, and S. Tyagi, "A comprehensive study on security attacks on ssl/tls protocol," in *A comprehensive study on security attacks on SSL/TLS protocol*, 2016 2nd international conference on next generation computing technologies (NGCT), pp. 893–898, IEEE, 2016. 16

[110] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, "Security information and event management (siem): analysis, trends, and usage in critical infrastructures," *Sensors*, vol. 21, no. 14, p. 4759, 2021. 16

[111] P. Sharma, "Enforcing network security policies in the context of the nist cybersecurity framework and its legal implications," *Network Security*, vol. 2024, no. 7, pp. 22–27, 2024. 16

[112] T. Stefaniuk, "Training in shaping employee information security awareness," *Entrepreneurship and Sustainability Issues*, vol. 7, no. 3, p. 1832, 2020. 16, 48

[113] U. Hamza, N. L. Abdullah, and S. M. Syed-Mohamad, "Devops adoption guidelines, challenges and benefits: A systematic literature review," *Journal of Advanced Research in Applied Sciences and Engineering Technology*, pp. 114–136, 2024. 17

[114] J. Faustino, D. Adriano, R. Amaro, R. Pereira, and M. M. da Silva, "Devops benefits: A systematic literature review," *Software: Practice and Experience*, vol. 52, no. 9, pp. 1905–1926, 2022. 17

[115] F. El Aouni, K. Moumane, A. Idri, M. Najib, and S. U. Jan, "A systematic literature review on agile, cloud, and devops integration: Challenges, benefits," *Information and Software Technology*, p. 107569, 2024. 17

[116] I. S. Committee *et al.*, "Ieee standard for devops: Building reliable and secure systems including application build, package, and deployment: Ieee standard 2675-2021," *IEEE*, 2021. 17

[117] K. Neharika and R. G. Lennon, "Investigations into secure iac practices," in *Investigations into Secure IaC Practices*, Proceedings of Seventh International Congress on Information and Communication Technology: ICICT 2022, London, Volume 2, pp. 289–303, Springer, 2022. 17

[118] C. Blundo, S. Cimato, and L. Siniscalchi, "Managing constraints in role based access control," *IEEE Access*, vol. 8, pp. 140497–140511, 2020. 17

[119] S. M. Mohammad, "Continuous integration and automation," *International Journal of Creative Research Thoughts (IJCRT), ISSN*, pp. 2320–2882, 2016. 17

[120] L. E. Lwakatare, P. Kuvaja, and M. Oivo, "Relationship of devops to agile, lean and continuous deployment: A multivocal literature review study," in *Relationship of devops to agile, lean and continuous deployment: A multivocal literature review study*, Product-Focused Software Process Improvement: 17th International Conference, PROFES 2016, Trondheim, Norway, November 22-24, 2016, Proceedings 17, pp. 399–415, Springer, 2016. 17

[121] Y. Fan, X. Wang, T. Funk, I. Rashid, B. Herman, N. Bompoti, M. S. Mahmud, M. Chrysochoou, M. Yang, T. M. Vadas, *et al.*, "A critical review for real-time continuous soil monitoring: Advantages, challenges, and perspectives," *Environmental Science & Technology*, vol. 56, no. 19, pp. 13546–13564, 2022. 18

[122] A. Sen, "Devops, devsecops, aiops-paradigms to it operations," in *Evolving Technologies for Computing, Communication and Smart World: Proceedings of ETCCS 2020*, pp. 211–221, Springer, 2021. 18

[123] R. Mao, H. Zhang, Q. Dai, H. Huang, G. Rong, H. Shen, L. Chen, and K. Lu, "Preliminary findings about DevSecOps from grey literature," in *Preliminary findings about DevSecOps from grey literature*, 2020 IEEE 20th International Conference on Software Quality, Reliability and Security (QRS), pp. 450–457, IEEE, 2020. 18

[124] H. Adkins, B. Beyer, P. Blankinship, P. Lewandowski, A. Oprea, and A. Stubblefield, *Building Secure & Reliable Systems-Best Practices for Designing, Implementing and Maintaining Systems*. O'Reilly Media, Inc., 2020. 18

[125] L. Wehenkel and M. Pavella, "Decision tree approach to power systems security assessment," *International Journal of Electrical Power and Energy Systems*, vol. 15, no. 1, pp. 13–36, 1993. 18

[126] M. Zaydi and B. Nassereddine, "DevSecOps practices for an agile and secure it service management," *Journal of Management Information and Decision Sciences*, vol. 23, no. 2, 2020. 18

[127] M. Hadi and H. Bahşi, "Making the shift from DevOps to DevSecOps at distribution technologies GMBH," *TAL TECH*, 2019. 18

[128] Y. Bobbert and M. Chtepen, "Research findings in the domain of CI/CD and DevOps on security compliance," *IGI Publisher of Timely Knowledge*, 2021. 18

[129] H. Fujita, A. Selamat, and S. Omatu, *Knowledge Innovation Through Intellignet Software Methodologies, Tools and Techniques*. IOS Press, 2020. 18

[130] S. Dupont, G. Ginis, M. Malacario, C. Porretti, N. Maunero, C. Ponsard, and P. Massonet, "Incremental common criteria certification processes using DevSecOps practices," tech. rep., IEEE Publisher, 2021. 18

[131] E. Sermpezis, "Integration of security in the devops methodology," *ieeexplore*, 2024. 18

[132] C. A. Cois, J. Yankel, and A. Connell, "Modern DevOps: Optimizing software development through effective system interactions," in *Modern DevOps: Optimizing software development through effective system interactions*, 2014 IEEE international professional communication conference (IPCC), pp. 1–7, IEEE, 2014. 18

[133] D. W. Hallock, "Devsecops in practice," *CrossTalk*, 2022. 18

[134] Y. Zhang, B. Vasilescu, H. Wang, and V. Filkov, "One size does not fit all: an empirical study of containerized continuous deployment workflows," in *One size does not fit all: an empirical study of containerized continuous deployment workflows*, Proceedings of the 2018 26th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering, pp. 295–306, 2018. 19

[135] T. Detofeno, A. Malucelli, and S. Reinehr, "Priortd: a method for prioritization technical debt," in *PriorTD: a method for prioritization technical debt*, Proceedings of the XXXVI Brazilian Symposium on Software Engineering, pp. 230–240, 2022. 19

[136] G. Park, "The changing wind of data privacy law: A comparative study of the european union's general data protection regulation and the 2018 california consumer privacy act," *UC Irvine L. Rev.*, vol. 10, p. 1455, 2019. 19

[137] N. Lamponen, "Implementation of secure workflow for devops from best practices viewpoint," *LUT University*, 2021. 19

[138] G. G. Claps, R. B. Svensson, and A. Aurum, "On the journey to continuous deployment: Technical and social challenges along the way," *Information and Software technology*, vol. 57, pp. 21–31, 2015. 19

[139] J. Humble and J. Molesky, "Why enterprises must adopt DevOps to enable continuous delivery," *Cutter IT Journal*, vol. 24, p. 6, 2011. 19, 20

[140] H. Dhaduk, "DevOps lifecycle: 7 phases explained in detail with examples," *SIMFORM*, 2022. 19

[141] E. Ntentos, "Supporting architecture evolution in microservice-based systems and infrastructure-as-code based deployments," *Wien University*, 2023. 19

[142] A. Wiedemann, M. Wiesche, H. Gewald, and H. Krcmar, "Understanding how DevOps aligns development and operations: a tripartite model of intra-it alignment," *European Journal of Information Systems*, vol. 29, no. 5, pp. 458–473, 2020. 20

[143] B. Fitzgerald and K.-J. Stol, "Continuous software engineering: A roadmap and agenda," *Journal of Systems and Software*, vol. 123, pp. 176–189, 2017. 20

[144] M. Hvardand and C.-P. Ricardo, "Devsecops: A multivocal literature review," in *DevSecOps: A Multivocal Literature Review*, pp. 17–29, Springer International Publishing, 2017. 20, 21

[145] S. Rafi, W. Yu, M. A. Akbar, A. Alsanad, and A. Gumaei, "Multicriteria based decision making of devops data quality assessment challenges using fuzzy topsis," *IEEE Access*, vol. 8, pp. 46958–46980, 2020. 20, 21

[146] S. Rafi, W. Yu, M. A. Akbar, A. Alsanad, and A. Gumaei, "Prioritization based taxonomy of devops security challenges using promethee," *IEEE Access*, vol. 8, pp. 105426–105446, 2020. 20, 21, 26

[147] M. A. Akbar, K. Smolander, S. Mahmood, and A. Alsanad, "Toward successful devsecops in software development organizations: A decision-making framework," *Information and Software Technology*, vol. 147, p. 106894, 2022. 20, 21, 26

[148] X. Ramaj, M. Sánchez-Gordón, V. Gkioulos, S. Chockalingam, and R. Colomo-Palacios, "Holding on to compliance while adopting devsecops: An slr," *Electronics*, vol. 11, no. 22, p. 3707, 2022. 20, 21, 52

[149] M. Chiari, M. De Pascalis, and M. Pradella, "Static analysis of infrastructure as code: a survey," in *Static analysis of infrastructure as code: a survey*, 2022 IEEE 19th International Conference on Software Architecture Companion (ICSA-C), pp. 218–225, IEEE, 2022. 20, 21, 52

[150] F. M. Erich, C. Amrit, and M. Daneva, "A qualitative study of devops usage in practice," *Journal of software: Evolution and Process*, vol. 29, no. 6, p. e1885, 2017. 20

[151] B. A. Kitchenham, T. Dyba, and M. Jorgensen, "Evidence-based software engineering," in *Evidence-based software engineering*, Proceedings. 26th International Conference on Software Engineering, pp. 273–281, IEEE, 2004. 22

[152] W. Ding, P. Liang, A. Tang, and H. Van Vliet, "Knowledge-based approaches in software documentation: A systematic literature review," *Information and Software Technology*, vol. 56, no. 6, pp. 545–567, 2014. 22

[153] S. Keele *et al.*, "Guidelines for performing systematic literature reviews in software engineering," 2007. 22

[154] T. Bikis, "Safe and devsecops in governmental organizations: A case study for benefits and challenges," 2022. 22

[155] R. Desai and T. Nisha, "Best practices for ensuring security in devops: A case study approach," *Journal of Physics: Conference Series*, vol. 1964, no. 4, p. 042045, 2021. 22

[156] H. Zhang, M. A. Babar, and P. Tell, "Identifying relevant studies in software engineering," *Information and Software Technology*, vol. 53, no. 6, pp. 625–637, 2011. 22

[157] L. Chen, M. A. Babar, and H. Zhang, "Towards an evidence-based understanding of electronic data sources," in *Towards an evidence-based understanding of electronic data sources*, 14th International conference on evaluation and assessment in software engineering (EASE), pp. 1–4, 2010. 23

[158] T. Dybå and T. Dingsøyr, "Empirical studies of agile software development: A systematic review," *Information and software technology*, vol. 50, no. 9-10, pp. 833–859, 2008. 24, 52

[159] C. Wohlin, "Guidelines for snowballing in systematic literature studies and a replication in software engineering," in *Guidelines for snowballing in systematic literature studies and a replication in software engineering*, Proceedings of the 18th international conference on evaluation and assessment in software engineering, pp. 1–10, 2014. 25, 52

[160] I. Koren, F. Rinker, K. Meixner, J. Matevska, and J. Walter, "Challenges and opportunities of devops in cyber-physical production systems engineering," in *Challenges and Opportunities of DevOps in Cyber-Physical Production Systems Engineering*, 2023 IEEE 6th International Conference on Industrial Cyber-Physical Systems (ICPS), pp. 1–6, IEEE, 2023. 25, 96

[161] M. Senapathi, J. Buchan, and H. Osman, "Devops capabilities, practices, and challenges: Insights from a case study," in *DevOps capabilities, practices, and challenges: Insights from a case study*, Proceedings of the 22nd International Conference on Evaluation and Assessment in Software Engineering 2018, pp. 57–67, 2018. 25, 96

[162] N. Beigi-Mohammadi, M. Litoiu, M. Emami-Taba, L. Tahvildari, M. Fokaefs, E. Merlo, and I. V. Onut, "A devops framework for quality-driven self-protection in web software systems," in *A DevOps framework for quality-driven self-protection in Web software systems*, Proceedings of the 28th Annual International Conference on Computer Science and Software Engineering, IBM Corp, pp. 270–274, 2018. 25, 96

[163] S. Rafi, W. Yu, and M. A. Akbar, "Towards a hypothetical framework to secure devops adoption: Grounded theory approach," in *Towards a hypothetical framework to secure DevOps adoption: Grounded theory approach*, Proceedings of the 24th International Conference on Evaluation and Assessment in Software Engineering, pp. 457–462, 2020. 25, 96

[164] R. Filepp, C. Adam, M. Hernandez, M. Vukovic, N. Anerousis, and G. Q. Zhang, "Continuous compliance: Experiences, challenges, and opportunities," in *Continuous compliance: Experiences, challenges, and opportunities*, 2018 IEEE World Congress on Services (SERVICES), pp. 31–32, IEEE, 2018. 26

[165] R. Namal Rajapakse, M. Zahedi, and M. A. Babar, "An empirical analysis of practitioners' perspectives on security tool integration into devops," *arXiv e-prints*, pp. arXiv–2107, 2021. 26

[166] R. Kumar and R. Goyal, "Modeling continuous security: A conceptual model for automated devsecops using open-source software over cloud (adoc)," *Computers & Security*, vol. 97, p. 101967, 2020. 26

[167] Z. Ahmed and S. C. Francis, "Integrating security with devsecops: Techniques and challenges," in *Integrating security with devsecops: Techniques and challenges*, 2019 International Conference on Digitization (ICD), pp. 178–182, IEEE, 2019. 26

[168] A. Qumer Gill, A. Loumish, I. Riyat, and S. Han, "Devops for information management systems," *VINE Journal of Information and Knowledge Management Systems*, vol. 48, no. 1, pp. 122–139, 2018. 26

[169] M. Efendi, T. Raharjo, and A. Suhanto, "Devsecops approach in software development case study: Public company logistic agency," in *DevSecOps Approach in Software Development Case Study: Public Company Logistic Agency*, 2021 International Conference on Informatics, Multimedia, Cyber and Information System (ICIMCIS, pp. 96–101, IEEE, 2021. 26

[170] J. R. Michener and A. T. Clager, "Mitigating an oxymoron: compliance in a devops environments," in *Mitigating an oxymoron: compliance in a DevOps environments*, vol. 1 of *2016 IEEE 40th Annual Computer Software and Applications Conference (COMPSAC)*, pp. 396–398, IEEE, 2016. 26

[171] G. Liu, B. Huang, Z. Liang, M. Qin, H. Zhou, and Z. Li, "Microservices: architecture, container, and challenges," in *Microservices: architecture, container, and challenges*, 2020 IEEE 20th international conference on software quality, reliability and security companion (QRS-C), pp. 629–635, IEEE, 2020. 26

[172] B. Fitzgerald and K.-J. Stol, "Continuous software engineering and beyond: trends and challenges," in *Continuous software engineering and beyond: trends and challenges*, Proceedings of the 1st International Workshop on rapid continuous software engineering, pp. 1–9, 2014. 26

[173] V. Mohan, L. ben Othmane, and A. Kres, "Bp: Security concerns and best practices for automation of software deployment processes: An industrial case study," in *BP: Security concerns and best practices for automation of software deployment processes: An industrial case study*, 2018 IEEE Cybersecurity Development (SecDev), pp. 21–28, IEEE, 2018. 26

[174] M. Voggenreiter and U. Schöpp, "Using a semantic knowledge base to improve the management of security reports in industrial devops projects," in *Using a semantic knowledge base to improve the management of security reports in industrial DevOps projects*, Proceedings of the 44th International Conference on Software Engineering: Software Engineering in Practice, pp. 309–310, 2022. 26

[175] J. Alonso, R. Piliszek, and M. Cankar, "Embracing iac through the devsecops philosophy: Concepts, challenges, and a reference framework," *IEEE Software*, vol. 40, no. 1, pp. 56–62, 2022. 26

[176] J. A. Morales, T. P. Scanlon, A. Volkmann, J. Yankel, and H. Yasar, "Security impacts of sub-optimal devsecops implementations in a highly regulated environment," in *Security impacts of sub-optimal DevSecOps implementations in a highly regulated environment*, Proceedings of the 15th International Conference on Availability, Reliability and Security, pp. 1–8, 2020. 26

[177] S. Throner, H. Hütter, N. Sänger, M. Schneider, S. Hanselmann, P. Petrovic, and S. Abeck, "An advanced devops environment for microservice-based applications," in *An advanced DevOps environment for microservice-based applications*, 2021 IEEE International Conference on Service-Oriented System Engineering (SOSE), pp. 134–143, IEEE, 2021. 26

[178] M. Shahin, M. A. Babar, M. Zahedi, and L. Zhu, "Beyond continuous delivery: an empirical investigation of continuous deployment challenges," in *Beyond continuous delivery: an empirical investigation of continuous deployment challenges*, 2017 ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM), pp. 111–120, IEEE, 2017. 26

[179] H. Kang, M. Le, and S. Tao, "Container and microservice driven design for cloud infrastructure devops," in *Container and microservice driven design for cloud infrastructure devops*, 2016 IEEE International Conference on Cloud Engineering (IC2E), pp. 202–211, IEEE, 2016. 26

[180] C. Parnin, E. Helms, C. Atlee, H. Boughton, M. Ghattas, A. Glover, J. Holman, J. Micco, B. Murphy, T. Savor, *et al.*, "The top 10 adages in continuous deployment," *IEEE Software*, vol. 34, no. 3, pp. 86–95, 2017. 26

[181] L. Chen, "Continuous delivery: Huge benefits, but challenges too," *IEEE software*, vol. 32, no. 2, pp. 50–54, 2015. 26

[182] P. Stöckle, I. Pruteanu, B. Grobauer, and A. Pretschner, "Hardening with scapolite: A devops-based approach for improved authoring and testing of security-configuration guides in large-scale organizations," in *Hardening with Scapolite: A DevOps-Based Approach for Improved Authoring and Testing of Security-Configuration Guides in Large-Scale Organizations*, Proceedings of the Twelfth ACM Conference on Data and Application Security and Privacy, pp. 137–142, 2022. 26

[183] A. Saboor, M. F. Hassan, R. Akbar, E. Susanto, S. N. Mehmood Shah, M. A. Siddiqui, and S. A. Magsi, "Root-of-trust for continuous integration and continuous deployment pipeline in cloud computing.," *Computers, Materials & Continua*, vol. 73, no. 2, 2022. 26

[184] T. Okubo and H. Kaiya, "Efficient secure devops using process mining and attack defense trees," *Procedia Computer Science*, vol. 207, pp. 446–455, 2022. 26

[185] I. A. Tøndel and G. Brataas, "Securescale: Exploring synergies between security and scalability in software development and operation," in *SecureScale: Exploring Synergies between Security and Scalability in Software Development and Operation*, Proceedings of the 2022 European Interdisciplinary Cybersecurity Conference, pp. 36–41, 2022. 26

[186] A. Dalvi, "Cloud infrastructure self service delivery system using infrastructure as code," in *Cloud Infrastructure Self Service Delivery System using Infrastructure as Code*, 2022 International Conference on Computing, Communication, and Intelligent Systems (ICCCIS), pp. 1–6, IEEE, 2022. 26

[187] T. Nisha and A. Khandebharad, "Migration from devops to devsecops: A complete migration framework, challenges, and evaluation," *International Journal of Cloud Applications and Computing (IJCAC)*, vol. 12, no. 1, pp. 1–15, 2022. 26

[188] J. Cusick, A. Avritzer, A. Tse, and A. Janes, "Automated dependability assessment in devops environments," in *Automated Dependability Assessment in DevOps Environments*, 2022 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW), pp. 93–98, IEEE, 2022. 26

[189] A. Avritzer, "Challenges and approaches for the assessment of micro-service architecture deployment alternatives in devops: A tutorial presented at icsa 2020," in *Challenges and approaches for the assessment of micro-service architecture deployment alternatives in devops: A tutorial presented at icsa 2020*, 2020 IEEE International Conference on Software Architecture Companion (ICSA-C), pp. 1–2, IEEE, 2020. 26

[190] S. Carturan and D. Goya, "Major challenges of systems-of-systems with cloud and devops–a financial experience report," in *Major Challenges of Systems-of-Systems with Cloud and DevOps–a financial experience report*, 2019 IEEE/ACM 7th International Workshop on Software Engineering for Systems-of-Systems (SESoS) and 13th Workshop on Distributed Software Development, Software Ecosystems and Systems-of-Systems (WDES), pp. 10–17, IEEE, 2019. 26

[191] M. Staples, L. Zhu, and J. Grundy, "Continuous validation for data analytics systems," in *Continuous validation for data analytics systems*, Proceedings of the 38th International Conference on Software Engineering Companion, pp. 769–772, 2016. 26

[192] L. Liu, D. Xie, Y. Cheng, and G. Li, "Architecture scheme of devops for cross network and multiple environment collaboration," in *Architecture Scheme of DevOps for Cross Network and Multiple Environment Collaboration*, Proceedings of the 5th International Conference on Computer Science and Application Engineering, pp. 1–5, 2021. 26

[193] M. Khanam, S. Rafi, and M. A. Akbar, "Understandings of ethics in devops teams: A preliminary investigation," in *Understandings of Ethics in DevOps Teams: A Preliminary Investigation*, Proceedings of the 27th International Conference on Evaluation and Assessment in Software Engineering, pp. 394–397, 2023. 26

[194] G. Casale, C. Chesta, P. Deussen, E. Di Nitto, P. Gouvas, S. Koussouris, V. Stankovski, A. Symeonidis, V. Vlassiou, A. Zafeiropoulos, *et al.*, "Current and future challenges of software engineering for services and applications," *Procedia computer science*, vol. 97, pp. 34–42, 2016. 26

[195] J. Díaz, J. E. Pérez, M. A. Lopez-Peña, G. A. Mena, and A. Yagüe, "Self-service cybersecurity monitoring as enabler for devsecops," *Ieee Access*, vol. 7, pp. 100283–100295, 2019. 26

[196] M. Alawneh and I. M. Abbadi, "Expanding devsecops practices and clarifying the concepts within kubernetes ecosystem," in *Expanding DevSecOps Practices and Clarifying the Concepts within Kubernetes Ecosystem*, 2022 Ninth International Conference on Software Defined Systems (SDS), pp. 1–7, IEEE, 2022. 26

[197] A. Sadovykh, G. Widforss, D. Truscan, E. P. Enoiu, W. Mallouli, R. Iglesias, A. Bagnto, and O. Hendel, "Veridevops: Automated protection and prevention to meet security requirements in devops," in *Veridevops: Automated protection and prevention to meet security requirements in devops*, 2021 Design, Automation & Test in Europe Conference & Exhibition (DATE), pp. 1330–1333, IEEE, 2021. 26

[198] A. Valani, "Rethinking secure devops threat modeling: The need for a dual velocity approach," in *Rethinking secure DevOps threat modeling: The need for a dual velocity approach*, 2018 IEEE Cybersecurity Development (SecDev), pp. 136–136, IEEE, 2018. 27

[199] V. Garousi, M. Felderer, and M. V. Mäntylä, "Guidelines for including grey literature and conducting multivocal literature reviews in software engineering," *Information and software technology*, vol. 106, pp. 101–121, 2019. 27

[200] B. A. Kitchenham, "Systematic review in software engineering: where we are and where we should be going," in *Systematic review in software engineering: where we are and where we should be going*, Proceedings of the 2nd international workshop on Evidential assessment of software technologies, pp. 1–2, 2012. 27

[201] M. I. Alhojailan, "Thematic analysis: a critical review ofits process and evaluation," in *Thematic analysis: a critical review ofits process and evaluation*, WEI international European academic conference proceedings, Zagreb, Croatia, Citeseer, 2012. 27

[202] V. Braun and V. Clarke, "Using thematic analysis in psychology," *Qualitative research in psychology*, vol. 3, no. 2, pp. 77–101, 2006. 27, 98

[203] A. G. Tuckett, "Applying thematic analysis theory to practice: A researcher's experience," *Contemporary nurse*, vol. 19, no. 1-2, pp. 75–87, 2005. 27, 99

[204] R. Jabbari, N. bin Ali, K. Petersen, and B. Tanveer, "Towards a benefits dependency network for devops based on a systematic literature review," *Journal of Software: Evolution and Process*, vol. 30, no. 11, p. e1957, 2018. 27, 99

[205] D. S. Cruzes and T. Dyba, "Recommended steps for thematic synthesis in software engineering," in *Recommended steps for thematic synthesis in software engineering*, 2011 international symposium on empirical software engineering and measurement, pp. 275–284, IEEE, 2011. 27, 98, 100

[206] J. L. Campbell, C. Quincy, J. Osserman, and O. K. Pedersen, "Coding in-depth semistructured interviews: Problems of unitization and intercoder reliability and agreement," *Sociological methods & research*, vol. 42, no. 3, pp. 294–320, 2013. 27, 28, 100

[207] V. Diamantopoulou, A. Tsohou, and M. Karyda, "From iso/iec 27002: 2013 information security controls to personal data protection controls: guidelines for gdpr compliance," in *From ISO/IEC 27002: 2013 information security controls to personal data protection controls: guidelines for GDPR compliance*, Computer Security: ESORICS 2019 International Workshops, CyberICPS, SECPRE, SPOSE, and ADIoT, Luxembourg City, Luxembourg, September 26–27, 2019 Revised Selected Papers 5, pp. 238–257, Springer, 2020. 28

[208] K. Singh and P. Best, "Auditing during a pandemic–can continuous controls monitoring (ccm) address challenges facing internal audit departments?," *Pacific Accounting Review*, vol. 35, no. 5, pp. 727–745, 2023. 46

[209] C. Barria, D. Cordero, L. Galeazzi, and A. Acuña, "Proposal of a multi-standard model for measuring maturity business levels with reference to information security standards and controls," in *Intelligent Methods in Computing, Communications and Control: Proceedings of the 8th International Conference on Computers Communications and Control (ICCCC) 2020 8*, pp. 121–132, Springer, 2021. 46

[210] A. Rajamäki, "Industrial control systems' integrations to operation technology and information technology security operation center," *Jamaki*, 2021. 46

[211] B. Gallina, T. Y. Olesen, E. Parajdi, and M. Aarup, "A knowledge management strategy for seamless compliance with the machinery regulation," in *A knowledge management strategy for seamless compliance with the machinery regulation*, European Conference on Software Process Improvement, pp. 220–234, Springer, 2023. 47

[212] A. J. Apeh, A. O. Hassan, O. O. Oyewole, O. G. Fakeyede, P. A. Okeleke, and O. R. Adaramodu, "Grc strategies in modern cloud infrastructures: a review of compliance challenges," *Computer Science & IT Research Journal*, vol. 4, no. 2, pp. 111–125, 2023. 47

[213] K. R. Gade, "Data governance in the cloud: Challenges and opportunities," *MZ Computing Journal*, vol. 4, no. 1, 2023. 47

[214] L. Maria Bruma, "Using cloud control matrix to evaluate trust in cloud providers," in *Proceedings of the 2021 10th International Conference on Software and Computer Applications*, pp. 273–278, 2021. 47

[215] S. K. Sahu, "Security standards and best practices," in *Building Secure PHP Applications: A Comprehensive Guide to Protecting Your Web Applications from Threats*, pp. 249–313, Springer, 2024. 47

[216] A. van Belkum, T. T. Bachmann, G. Lüdke, J. G. Lisby, G. Kahlmeter, A. Mohess, K. Becker, J. P. Hays, N. Woodford, K. Mitsakakis, *et al.*, "Developmental roadmap for antimicrobial susceptibility testing systems," *Nature Reviews Microbiology*, vol. 17, no. 1, pp. 51–62, 2019. 47

[217] Y.-H. Tung, S.-C. Lo, J.-F. Shih, and H.-F. Lin, "An integrated security testing framework for secure software development life cycle," in *An integrated security testing framework for secure software development life cycle*, 2016 18th Asia-Pacific Network Operations and Management Symposium (APNOMS), pp. 1–4, IEEE, 2016. 47

[218] M. A. Umar and C. Zhanfang, "A study of automated software testing: Automation tools and frameworks," *International Journal of Computer Science Engineering (IJCSE)*, vol. 6, no. 217-225, pp. 47–48, 2019. 47

[219] R. Akhilesh, O. Bills, N. Chilamkurti, and M. J. M. Chowdhury, "Automated penetration testing framework for smart-home-based iot devices," *Future Internet*, vol. 14, no. 10, p. 276, 2022. 48

[220] V. Garousi, N. Joy, and A. B. Keleş, "Ai-powered test automation tools: A systematic review and empirical evaluation," *arXiv preprint arXiv:2409.00411*, 2024. 48

[221] M. M. Al-Daeef, N. Basir, and M. M. Saudi, "Security awareness training: A review," in *Security awareness training: A review*, vol. 1 of *Proceedings of the world congress on engineering*, pp. 5–7, 2017. 48

[222] F. Abu-Amara, R. Almansoori, S. Alharbi, M. Alharbi, and A. Alshehhi, "A novel seta-based gamification framework to raise cybersecurity awareness," *International Journal of Information Technology*, vol. 13, no. 6, pp. 2371–2380, 2021. 48

[223] S. Gulati, A. Tyagi, and P. K. Goel, "Security automation and orchestration in the cloud," in *Analyzing and Mitigating Security Risks in Cloud Computing*, pp. 24–47, IGI Global, 2024. 49

[224] J. Kinyua and L. Awuah, "Ai/ml in security orchestration, automation and response: Future research directions.," *Intelligent Automation & Soft Computing*, vol. 28, no. 2, 2021. 49

[225] S. M. Mohammad and L. Surya, "Security automation in information technology," *International journal of creative research thoughts (IJCRT)–Volume*, vol. 6, 2018. 49

[226] N. M. Yungaicela-Naula, C. Vargas-Rosales, J. A. Pérez-Díaz, and M. Zareei, "Towards security automation in software defined networks," *Computer Communications*, vol. 183, pp. 64–82, 2022. 49

[227] E. Casalicchio and S. Iannucci, "The state-of-the-art in container technologies: Application, orchestration and security," *Concurrency and Computation: Practice and Experience*, vol. 32, no. 17, p. e5668, 2020. 49

[228] K. A. Torkura, M. I. Sukmana, F. Cheng, and C. Meinel, "Cloudstrike: Chaos engineering for security and resiliency in cloud infrastructure," *IEEE Access*, vol. 8, pp. 123044–123060, 2020. 49

[229] R. Cioffi, M. Travaglioni, G. Piscitelli, A. Petrillo, and F. De Felice, "Artificial intelligence and machine learning applications in smart production: Progress, trends, and directions," *Sustainability*, vol. 12, no. 2, p. 492, 2020. 49

[230] M. Soori, B. Arezoo, and R. Dastres, "Artificial intelligence, machine learning and deep learning in advanced robotics, a review," *Cognitive Robotics*, vol. 3, pp. 54–70, 2023. 49

[231] M. M. Taye, "Understanding of machine learning with deep learning: architectures, workflow, applications and future directions," *Computers*, vol. 12, no. 5, p. 91, 2023. 49

[232] C. Kielland, "Information security performance evaluation: Building a security metrics library and visualization dashboard," Master's thesis, UNIVERSITY OF OSLO, 2023. 49

[233] C. Onwubiko and A. Onwubiko, "Cyber kpi for return on security investment," in *Cyber KPI for return on security investment*, 2019 International Conference on Cyber Situational Awareness, Data Analytics And Assessment (Cyber SA), pp. 1–8, IEEE, 2019. 49

[234] M. Gschwandtner, L. Demetz, M. Gander, and R. Maier, "Integrating threat intelligence to enhance an organization's information security management," in *Integrating threat intelligence to enhance an organization's information security management*, Proceedings of the 13th International Conference on Availability, Reliability and Security, pp. 1–8, 2018. 50

[235] S. Sultan, I. Ahmad, and T. Dimitriou, "Container security: Issues, challenges, and the road ahead," *IEEE access*, vol. 7, pp. 52976–52996, 2019. 50

[236] C. Stach and B. Mitschang, "The secure data container: An approach to harmonize data sharing with information security," in *The secure data container: An approach to harmonize data sharing with information security*, vol. 1 of *2016 17th IEEE International Conference on Mobile Data Management (MDM)*, pp. 292–297, IEEE, 2016. 50

[237] B. Tak, C. Isci, S. Duri, N. Bila, S. Nadgowda, and J. Doran, "Understanding security implications of using containers in the cloud," in *Understanding security implications of using containers in the cloud*, 2017 USENIX Annual Technical Conference (USENIX ATC 17), pp. 313–319, 2017. 50

[238] E. L. Vargas, J. Hejderup, M. Kechagia, M. Bruntink, and G. Gousios, "Enabling real-time feedback in software engineering," in *Enabling real-time feedback in software engineering*, Proceedings of the 40th International Conference on Software Engineering: New Ideas and Emerging Results, pp. 21–24, 2018. 50

[239] G. Moser, R. Vallon, M. Bernhart, and T. Grechenig, "Teaching software quality assurance with gamification and continuous feedback techniques," in *Teaching software quality assurance with gamification and continuous feedback techniques*, 2021 IEEE Global Engineering Education Conference (EDUCON), pp. 505–509, IEEE, 2021. 50

[240] A. Dawoud, S. Finster, N. Coppik, and V. Ashiwal, "Better left shift security! framework for secure software development," in *Better Left Shift Security! Framework for Secure Software Development*, 2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), pp. 642–649, IEEE, 2024. 51

[241] D. Gonzalez, P. P. Perez, and M. Mirakhorli, "Barriers to shift-left security: The unique pain points of writing automated tests involving security controls," in *Barriers to shift-left security: The unique pain points of writing automated tests involving security controls*, Proceedings of the 15th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM), pp. 1–12, 2021. 51

[242] M.-A. Storey, N. A. Ernst, C. Williams, and E. Kalliamvakou, "The who, what, how of software engineering research: a socio-technical framework," *Empirical Software Engineering*, vol. 25, pp. 4097–4129, 2020. 51

[243] B. Turnheim and B. K. Sovacool, "Exploring the role of failure in socio-technical transitions research," *Environmental Innovation and Societal Transitions*, vol. 37, pp. 267–289, 2020. 51

[244] M. Sánchez-Gordón and R. Colomo-Palacios, "Characterizing devops culture: a systematic literature review," in *Characterizing DevOps culture: a systematic literature review*, Software Process Improvement and Capability Determination: 18th International Conference, SPICE 2018, Thessaloniki, Greece, October 9–10, 2018, Proceedings 18, pp. 3–15, Springer, 2018. 51

[245] S. Kanungo, "Security challenges and solutions in multi-cloud environments," *Stochastic Modelling and Computational Sciences*, vol. 3, no. 2, pp. 139–146, 2023. 51

[246] T. E. Lander Jr, "Multi-cloud architecture attacks through application programming interfaces," *Mississippi State University - Theses and Dissertations*, 2024. 51

[247] B. Desai and K. Patil, "Demystifying the complexity of multi-cloud networking," *Asian American Research Letters Journal*, vol. 1, no. 4, 2024. 51

[248] N. Shinde and P. Kulkarni, "Cyber incident response and planning: a flexible approach," *Computer Fraud & Security*, vol. 2021, no. 1, pp. 14–19, 2021. 51

[249] N. A. Z. Farok and M. F. Zolkipli, "Incident response planning and procedures," *Borneo International Journal eISSN 2636-9826*, vol. 7, no. 2, pp. 69–76, 2024. 51

[250] M. Ricks, "Building capability and community through cyber-incident response exercises," *Journal of Business Continuity & Emergency Planning*, vol. 18, no. 1, pp. 49–58, 2024. 51

[251] X. Zhou, Y. Jin, H. Zhang, S. Li, and X. Huang, "A map of threats to validity of systematic literature reviews in software engineering," in *A map of threats to validity of systematic literature reviews in software engineering*, 2016 23rd Asia-Pacific Software Engineering Conference (APSEC), pp. 153–160, IEEE, 2016. 52

[252] M. Unterkalmsteiner, T. Gorschek, A. M. Islam, C. K. Cheng, R. B. Permadi, and R. Feldt, "Evaluation and measurement of software process improvement—a systematic literature review," *IEEE Transactions on Software Engineering*, vol. 38, no. 2, pp. 398–424, 2011. 52

[253] D. HIZA, *Assessig the Significance of Cia Triad Security Model in Establishing ICT Security Controls in The Public Sector.* PhD thesis, Institute of Accountancy Arusha (IAA), 2022. 56

[254] A. Onumo, I. Ullah-Awan, and A. Cullen, "Assessing the moderating effect of security technologies on employees compliance with cybersecurity control procedures," *ACM Transactions on Management Information Systems (TMIS)*, vol. 12, no. 2, pp. 1–29, 2021. 56

[255] I. Bongiovanni, K. Renaud, H. Brydon, R. Blignaut, and A. Cavallo, "A quantification mechanism for assessing adherence to information security governance guidelines," *Information & Computer Security*, vol. 30, no. 4, pp. 517–548, 2022. 56

[256] H. Raza, J. Baptista, and P. Constantinides, "Conceptualizing the role of is security compliance in projects of digital transformation: Tensions and shifts between prevention and response modes.," in *ICIS*, pp. 1–100, 2019. 56

[257] F. Rahimian, A. Bajaj, and W. Bradley, "Estimation of deficiency risk and prioritization of information security controls: A data-centric approach," *International Journal of Accounting Information Systems*, vol. 20, pp. 38–64, 2016. 56

[258] M. Alshar'e, "Cyber security framework selection: Comparision of nist and iso27001," *Applied computing Journal*, pp. 245–255, 2023. 56

[259] G. B. White and N. Sjelin, "The nist cybersecurity framework," in *Research Anthology on Business Aspects of Cybersecurity*, pp. 39–55, IGI Global, 2022. 56

[260] S. Paz, "Cybersecurity standards and frameworks," *IEEE Technology and Engineering Management Society Body of Knowledge (TEMSBOK)*, pp. 397–416, 2023. 56

[261] G. D. P. R. GDPR, "General data protection regulation," *URL: https://gdpr-info. eu/[accessed 2020-11-21]*, 2018. 56

[262] I. Rauf, T. Lopez, H. Sharp, M. Petre, T. Tun, M. Levine, J. Towse, D. van der Linden, A. Rashid, and B. Nuseibeh, "Influences of developers' perspectives on their engagement with security in code," in *Proceedings of the 15th International Conference on Cooperative and Human Aspects of Software Engineering*, pp. 86–95, 2022. 56

[263] A. Parker and I. Brown, "Skills requirements for cyber security professionals: a content analysis of job descriptions in south africa," in *Information Security: 17th International Conference, ISSA 2018, Pretoria, South Africa, August 15–16, 2018, Revised Selected Papers 17*, pp. 176–192, Springer, 2019. 56

[264] S. Furnell, "The cybersecurity workforce and skills," *Computers & Security*, vol. 100, p. 102080, 2021. 56

[265] U. D. Ani, N. Daniel, F. Oladipo, and S. E. Adewumi, "Securing industrial control system environments: the missing piece," *Journal of Cyber Security Technology*, vol. 2, no. 3-4, pp. 131–163, 2018. 56

[266] K. Mazur, B. Ksiezopolski, and Z. Kotulski, "The robust measurement method for security metrics generation," *The Computer Journal*, vol. 58, no. 10, pp. 2280–2296, 2015. 56

[267] E. Bergström, M. Lundgren, and Å. Ericson, "Revisiting information security risk management challenges: a practice perspective," *Information & Computer Security*, vol. 27, no. 3, pp. 358–372, 2019. 56

[268] S. Abraham and I. Chengalur-Smith, "Evaluating the effectiveness of learner controlled information security training," *Computers & Security*, vol. 87, p. 101586, 2019. 56

[269] A. Kudriavtseva and O. Gadyatskaya, "You cannot improve what you do not measure: A triangulation study of software security metrics," in *Proceedings of the 39th ACM/SIGAPP Symposium on Applied Computing*, pp. 1223–1232, 2024. 57

[270] R. K. Jha, "Cybersecurity and confidentiality in smart grid for enhancing sustainability and reliability," *Recent Research Reviews Journal*, vol. 2, no. 2, pp. 215–241, 2023. 58

[271] M. P. Singh, S. Sural, J. Vaidya, and V. Atluri, "Managing attribute-based access control policies in a unified framework using data warehousing and in-memory database," *Computers & security*, vol. 86, pp. 183–205, 2019. 58

[272] O. Alsaadoun, "A cybersecurity prospective on industry 4.0: Enabler role of identity and access management," in *International Petroleum Technology Conference*, p. D031S058R001, IPTC, 2019. 58

[273] M. Žgela and I. Penga, "Security information and event management–capabilities, challenges and event analysis in the complex it system," in *Central European Conference on Information and Intelligent Systems*, pp. 259–266, Faculty of Organization and Informatics Varazdin, 2019. 58

[274] W. Stallings, *Effective cybersecurity: a guide to using best practices and standards*. Addison-Wesley Professional, 2018. 58

[275] M. Alshaikh, S. B. Maynard, and A. Ahmad, "Security education, training, and awareness: Incorporating a social marketing approach for behavioural change," in *International Information Security Conference*, pp. 81–95, Springer, 2020. 58

[276] H. Kim, K. Lee, and J. Lim, "A study on the impact analysis of security flaws between security controls: An empirical analysis of k-isms using case-control study," *KSII Transactions on Internet and Information Systems (TIIS)*, vol. 11, no. 9, pp. 4588–4608, 2017. 58

[277] S. U. Syed, "Evaluating the effectiveness of cyber security regulations," *'Governors State University'*, 2023. 58

[278] A. S. George, T. Baskar, and P. B. Srikaanth, "Cyber threats to critical infrastructure: assessing vulnerabilities across key sectors," *Partners Universal International Innovation Journal*, vol. 2, no. 1, pp. 51–75, 2024. 58

[279] M. Tripathi and A. Mukhopadhyay, "Financial loss due to a data privacy breach: An empirical analysis," *Journal of Organizational Computing and Electronic Commerce*, vol. 30, no. 4, pp. 381–400, 2020. 58

[280] I. Agrafiotis, J. R. Nurse, M. Goldsmith, S. Creese, and D. Upton, "A taxonomy of cyber-harms: Defining the impacts of cyber-attacks and understanding how they propagate," *Journal of Cybersecurity*, vol. 4, no. 1, p. tyy006, 2018. 58

[281] S.-A. Shaikha and T. K. Singhalb, "Study on the various intellectual property management strategies used and implemented by ict firms for business intelligence," *Journal of Intelligence Studies in Business*, vol. 9, no. 2, 2019. 59

[282] S. Kausar, A. R. Leghari, and E. Iftikhar, "Analysis of the cyber security challenges and solutions," *Journal of Positive School Psychology*, vol. 7, no. 1, pp. 163–171, 2023. 59

[283] T. Stafford, G. Deitz, and Y. Li, "The role of internal audit and user training in information security policy compliance," *Managerial Auditing Journal*, vol. 33, no. 4, pp. 410–424, 2018. 59

[284] L. Almeida and A. Respício, "Decision support for selecting information security controls," *Journal of Decision Systems*, vol. 27, no. sup1, pp. 173–180, 2018. 59

[285] H. Khajouei, M. Kazemi, and S. H. Moosavirad, "Ranking information security controls by using fuzzy analytic hierarchy process," *Information Systems and e-Business Management*, vol. 15, pp. 1–19, 2017. 59

[286] S. Bettaieb, S. Y. Shin, M. Sabetzadeh, L. Briand, G. Nou, and M. Garceau, "Decision support for security-control identification using machine learning," in *International Working Conference on Requirements Engineering: Foundation for Software Quality*, pp. 3–20, Springer, 2019. 59

[287] E. J. W. Endro Joko Wibowo and K. R. Kalamullah Ramli, "Impact of implementation of information security risk management and security controls on cyber security maturity (a case study at data management applications of xyz institute)," *Jurnal Sistem Informasi (Journal of Information System)*, vol. 18, no. 2, pp. 1–17, 2022. 60

[288] R. Hamed, "The role of internal control systems in ensuring financial performance sustainability," *Sustainability*, vol. 15, no. 13, p. 10206, 2023. 60

[289] M. Angelini, S. Bonomi, C. Ciccotelli, and A. Palma, "Toward a context-aware methodology for information security governance assessment validation," in *Cyber-Physical Security for Critical Infrastructures Protection* (H. Abie, S. Ranise, L. Verderame, E. Cambiaso, R. Ugarelli, G. Giunta, I. Praça, and F. Battisti, eds.), (Cham), pp. 171–187, Springer International Publishing, 2021. 60

[290] Y. V. Papazov, "Cybersecurity metrics," *NATO Science and Technology Organization (STO)*, pp. 1–18, 2019. 60

[291] S. Bettaieb, S. Y. Shin, M. Sabetzadeh, L. C. Briand, M. Garceau, and A. Meyers, "Using machine learning to assist with the selection of security controls during security assessment," *Empirical Software Engineering*, vol. 25, pp. 2550–2582, 2020. 60

[292] A. A. Jillepalli, F. T. Sheldon, D. C. de Leon, M. Haney, and R. K. Abercrombie, "Security management of cyber physical control systems using nist sp 800-82r2," in *2017 13th International Wireless Communications and Mobile Computing Conference (IWCMC)*, pp. 1864–1870, IEEE, 2017. 60

[293] S. Mishra, N. Tripathy, B. K. Mishra, and C. Mahanty, "Analysis of security issues in cloud environment," *Security designs for the cloud, Iot, and social networking*, pp. 19–41, 2019. 60

[294] A. Habbal, M. K. Ali, and M. A. Abuzaraida, "Artificial intelligence trust, risk and security management (ai trism): Frameworks, applications, challenges and future research directions," *Expert Systems with Applications*, vol. 240, p. 122442, 2024. 61

[295] W. Huang and J. Li, "Robustness and security of ai models deployed in cloud environments: Challenges and solutions," *Asian American Research Letters Journal*, vol. 1, no. 2, 2024. 61

[296] S. Rangaraju, S. Ness, and R. Dharmalingam, "Incorporating ai-driven strategies in devsecops for robust cloud security," *International Journal of Innovative Science and Research Technology*, vol. 8, no. 23592365, pp. 10–5281, 2023. 61

[297] S. R. Sudharsanam, D. Venkatachalam, and D. Paul, "Securing ai/ml operations in multi-cloud environments: Best practices for data privacy, model integrity, and regulatory compliance," *Journal of Science & Technology*, vol. 3, no. 4, pp. 52–87, 2022. 61

[298] K. A. Cochran, "Securing the cloud: A comprehensive guide to cloud security," in *Cybersecurity Essentials: Practical Tools for Today's Digital Defenders*, pp. 327–363, Springer, 2024. 61

[299] H. Loukasmäki, "Cyber incident response in public cloud: implications of modern cloud computing characteristics for cyber incident response," *THESEUS*, 2023. 61

[300] M. Jhaveri and V. Parmar, "Cloud security information & event management," *GIS Science journal*, vol. 10, no. 3, 2023. 61

[301] S. Achar, "Enterprise saas workloads on new-generation infrastructure-as-code (iac) on multi-cloud platforms," *Global Disclosure of Economics and Business*, vol. 10, no. 2, pp. 55–74, 2021. 61

[302] P. Assunção, "A zero trust approach to network security," in *Proceedings of the Digital Privacy and Security Conference*, vol. 2019, p. 1, Porto Protugal, 2019. 62

[303] S. Ghasemshirazi, G. Shirvani, and M. A. Alipour, "Zero trust: Applications, challenges, and opportunities," *arXiv preprint arXiv:2309.03582*, 2023. 62

[304] C. Itodo and M. Ozer, "Multivocal literature review on zero-trust security implementation," *Computers & Security*, p. 103827, 2024. 62

[305] S. Das, B. Wang, A. Kim, and L. J. Camp, "Mfa is a necessary chore!: Exploring user mental models of multi-factor authentication technologies.," in *HICSS*, pp. 1–10, 2020. 62

[306] S. Das, B. Wang, Z. Tingle, and L. J. Camp, "Evaluating user perception of multi-factor authentication: A systematic review," *arXiv preprint arXiv:1908.05901*, 2019. 62

[307] M. Neelakandhan, G. Ramprakash, and M. Gaidhani, "Achieving least privilege at cloud scale with cloud infrastructure entitlements management," *Cyber Security: A Peer-Reviewed Journal*, vol. 5, no. 3, pp. 227–236, 2022. 62

[308] M. Shaik, L. Gudala, and A. K. R. Sadhu, "Leveraging artificial intelligence for enhanced identity and access management within zero trust security architectures: A focus on user behavior analytics and adaptive authentication," *Australian Journal of Machine Learning Research & Applications*, vol. 3, no. 2, pp. 1–31, 2023. 62

[309] M. Thangavelu, V. Krishnaswamy, and M. Sharma, "Impact of comprehensive information security awareness and cognitive characteristics on security incident management–an empirical study," *Computers & Security*, vol. 109, p. 102401, 2021. 62

[310] B. A. Kitchenham and S. L. Pfleeger, "Personal opinion surveys," in *Guide to advanced empirical software engineering*, pp. 63–92, Springer, 2008. 62, 65

[311] U. Kaila and L. Nyman, "Information security best practices: First steps for startups and smes," *Technology innovation management review*, vol. 8, no. 11, pp. 32–42, 2018. 81

[312] F. E. Abdulrasool and S. J. Turnbull, "Exploring security, risk, and compliance driven it governance model for universities: applied research based on the cobit framework," *International Journal of Electronic Banking*, vol. 2, no. 3, pp. 237–265, 2020. 81

[313] W. C. Lin and D. Saebeler, "Risk-based v. compliance-based utility cybersecurity-a false dichotomy," *Energy LJ*, vol. 40, p. 243, 2019. 81

[314] M. Syafrizal, S. R. Selamat, and N. A. Zakaria, "Analysis of cybersecurity standard and framework components," *International Journal of Communication Networks and Information Security*, vol. 12, no. 3, pp. 417–432, 2020. 81

[315] B. Krumay, E. W. Bernroider, and R. Walser, "Evaluation of cybersecurity management controls and metrics of critical infrastructures: A literature review considering the nist cybersecurity framework," in *Secure IT Systems: 23rd Nordic Conference, NordSec 2018, Oslo, Norway, November 28-30, 2018, Proceedings 23*, pp. 369–384, Springer, 2018. 81

[316] M. A. C. Dizon and A. Meehan, "Technical principles and protocols of encryption and their significance and effects on technology regulation," *Information & Communications Technology Law*, pp. 1–27, 2024. 82

[317] J.-P. Aumasson, *Serious cryptography: a practical introduction to modern encryption*. No Starch Press, Inc, 2024. 82

[318] D. Lazar, H. Chen, X. Wang, and N. Zeldovich, "Why does cryptographic software fail? a case study and open problems," in *Proceedings of 5th Asia-Pacific Workshop on Systems*, pp. 1–7, 2014. 82

[319] J. Joy and S. Devaraju, "Ensuring secure cloud data sharing through blockchain-based auditing for authentication and fuzzy identity-based proxy re-encryption for access control," *Library Progress International*, vol. 44, no. 1s, pp. 134–146, 2024. 82

[320] R. A. Khan, S. U. Khan, H. U. Khan, and M. Ilyas, "Systematic mapping study on security approaches in secure software engineering," *Ieee Access*, vol. 9, pp. 19139–19160, 2021. 82

[321] F. Ekundayo, I. Atoyebi, A. Soyele, and E. Ogunwobi, "Predictive analytics for cyber threat intelligence in fintech using big data and machine learning," *Int J Res Publ Rev*, vol. 5, no. 11, pp. 1–15, 2024. 82

[322] K. R. Gade, "The role of data modeling in enhancing data quality and security in fintech companies," *Journal of Computing and Information Technology*, vol. 3, no. 1, 2023. 82

[323] L. Hertteli, "Improving it administration security by using security controls based on security frameworks," Master's thesis, JAMK University of Applied Sciences, 2022. 82

[324] V. Bandari, "Enterprise data security measures: a comparative review of effectiveness and risks across different industries and organization types," *International Journal of Business Intelligence and Big Data Analytics*, vol. 6, no. 1, pp. 1–11, 2023. 83

[325] D. Kelley and E. Moyle, *Practical Cybersecurity Architecture: A guide to creating and implementing robust designs for cybersecurity architects*. Packt Publishing Ltd, 2023. 83

[326] O. Hosam, R. Abousamra, M. Hassouna, and R. Azzawi, "Security analysis and planning for enterprise networks: Incorporating modern security design principles," in *Industry 4.0 Key Technological Advances and Design Principles in Engineering, Education, Business, and Social Applications*, pp. 85–117, CRC Press, 2024. 83

[327] M. Evans, Y. He, L. Maglaras, and H. Janicke, "Heart-is: A novel technique for evaluating human error-related information security incidents," *Computers & Security*, vol. 80, pp. 74–89, 2019. 83

[328] E. Weishäupl, E. Yasasin, and G. Schryen, "Information security investments: An exploratory multiple case study on decision-making, evaluation and learning," *Computers & Security*, vol. 77, pp. 807–823, 2018. 83

[329] S. Rizvi, J. Ryoo, J. Kissell, W. Aiken, and Y. Liu, "A security evaluation framework for cloud security auditing," *The Journal of Supercomputing*, vol. 74, pp. 5774–5796, 2018. 83

[330] L. Frazer, "Does internal control improve the attestation function and by extension assurance services? a practical approach," *Journal of Accounting and Finance*, vol. 20, no. 1, 2020. 84

[331] R. A. Khan, S. U. Khan, M. Alzahrani, and M. Ilyas, "Security assurance model of software development for global software development vendors," *Ieee Access*, vol. 10, pp. 58458–58487, 2022. 84

[332] R. A. Khan, S. U. Khan, H. U. Khan, and M. Ilyas, "Systematic literature review on security risks and its practices in secure software development," *ieee Access*, vol. 10, pp. 5456–5481, 2022. 84

[333] N. Al-Safwani, Y. Fazea, and H. Ibrahim, "Iscp: In-depth model for selecting critical security controls," *Computers & Security*, vol. 77, pp. 565–577, 2018. 84, 95, 119

[334] O. Elazhary, C. Werner, Z. S. Li, D. Lowlind, N. A. Ernst, and M.-A. Storey, "Uncovering the benefits and challenges of continuous integration practices," *IEEE Transactions on Software Engineering*, vol. 48, no. 7, pp. 2570–2583, 2021. 84

[335] C. Carthern, W. Wilson, and N. Rivera, "Advanced troubleshooting," in *Cisco Networks: Engineers' Handbook of Routing, Switching, and Security with IOS, NX-OS, and ASA*, pp. 631–704, Springer, 2021. 85

[336] A. Liveretos and I. Draganov, "Identity & access management (iam) and customer iam (ciam): A pulse survey of several global corporations over their current usage and exploitation of automated iam and ciam solutions," *International Journal of Computers*, vol. 7, 2022. 85

[337] R. Lukanta, Y. Asnar, and A. I. Kistijantoro, "A vulnerability scanning tool for session management vulnerabilities," in *2014 International conference on data and software engineering (ICODSE)*, pp. 1–6, IEEE, 2014. 85

[338] M. Kuppinger, "Cloud user and access management," *KuppingerCole Leadership Compass Report*, vol. 70969, 2014. 85

[339] I. Indu, P. R. Anand, and V. Bhaskar, "Identity and access management in cloud environment: Mechanisms and challenges," *Engineering science and technology, an international journal*, vol. 21, no. 4, pp. 574–588, 2018. 85

[340] R. Kazmi, D. N. Jawawi, R. Mohamad, and I. Ghani, "Effective regression test case selection: A systematic literature review," *ACM Computing Surveys (CSUR)*, vol. 50, no. 2, pp. 1–32, 2017. 86

[341] P. Centonze, "Security and privacy frameworks for access control big data systems.," *Computers, Materials & Continua*, vol. 59, no. 2, 2019. 86

[342] S. Alghaithi, A. Alkaabi, H. Al Hamadi, N. A. Al-Dmour, and T. M. Ghazal, "A study of risk management frameworks and security testing for secure software systems," in *2022 International Conference on Electrical, Computer, Communications and Mechatronics Engineering (ICECCME)*, pp. 1–4, IEEE, 2022. 86

[343] D. Votipka, K. R. Fulton, J. Parker, M. Hou, M. L. Mazurek, and M. Hicks, "Understanding security mistakes developers make: Qualitative analysis from build it, break it, fix it," in *29th USENIX Security Symposium (USENIX Security 20)*, pp. 109–126, 2020. 87

[344] G. E. Matt and T. D. Cook, "Threats to the validity of generalized inferences from research syntheses," *The handbook of research synthesis and meta-analysis*, pp. 489–516, 2019. 87

[345] A. N. Ghazi, K. Petersen, S. S. V. R. Reddy, and H. Nekkanti, "Survey research in software engineering: Problems and mitigation strategies," *IEEE Access*, vol. 7, pp. 24703–24718, 2018. 87

[346] I. Krumpal, "Social desirability bias and context in sensitive surveys," in *Encyclopedia of quality of life and well-being research*, pp. 6527–6532, Springer, 2024. 87

[347] P. Spoletini and R. M. Parizi, "Bias-aware guidelines and fairness-preserving taxonomy in software engineering education," in *2018 IEEE Frontiers in Education Conference (FIE)*, pp. 1–4, IEEE, 2018. 87

[348] C. C. S. Kam and J. P. Meyer, "How careless responding and acquiescence response bias can influence construct dimensionality: The case of job satisfaction," *Organizational research methods*, vol. 18, no. 3, pp. 512–541, 2015. 87

[349] M. J. McClendon, "Acquiescence and recency response-order effects in interview surveys," *Sociological Methods & Research*, vol. 20, no. 1, pp. 60–103, 1991. 87

[350] P. G. Curran, "Methods for the detection of carelessly invalid responses in survey data," *Journal of Experimental Social Psychology*, vol. 66, pp. 4–19, 2016. 87

[351] J. S. Molléri, K. Petersen, and E. Mendes, "An empirically evaluated checklist for surveys in software engineering," *Information and Software Technology*, vol. 119, p. 106240, 2020. 88

[352] J. Liu, Z. Shen, Y. He, X. Zhang, R. Xu, H. Yu, and P. Cui, "Towards out-of-distribution generalization: A survey," *arXiv preprint arXiv:2108.13624*, 2021. 88

[353] E. W. Tsang, "Generalizing from research findings: The merits of case studies," *International Journal of Management Reviews*, vol. 16, no. 4, pp. 369–383, 2014. 88

[354] M. J. Barratt, J. A. Ferris, and S. Lenton, "Hidden populations, online purposive sampling, and external validity: Taking off the blindfold," *Field methods*, vol. 27, no. 1, pp. 3–21, 2015. 88

[355] N. P. Appelbaum, S. A. Santen, S. Vota, L. Wingfield, R. Sabo, and N. Yaghmour, "Threats to reliability and validity with resident wellness surveying efforts," *Journal of Graduate Medical Education*, vol. 11, no. 5, pp. 543–549, 2019. 88

[356] B. P. Eddy, N. Wilde, N. A. Cooper, B. Mishra, V. S. Gamboa, K. M. Shah, A. M. Deleon, and N. A. Shields, "A pilot study on introducing continuous integration and delivery into undergraduate software engineering courses," in *2017 ieee 30th conference on software engineering education and training (csee&t)*, pp. 47–56, IEEE, 2017. 88

[357] J. S. Molléri, K. Petersen, and E. Mendes, "Survey guidelines in software engineering: An annotated review," in *Proceedings of the 10th ACM/IEEE international symposium on empirical software engineering and measurement*, pp. 1–6, 2016. 88

[358] A. I. Jony and S. A. Hamim, "Navigating the cyber threat landscape: A comprehensive analysis of attacks and security in the digital age," *Journal of Information Technology and Cyber Security*, vol. 1, no. 2, pp. 53–67, 2023. 92

[359] Ö. Aslan, S. S. Aktuğ, M. Ozkan-Okay, A. A. Yilmaz, and E. Akin, "A comprehensive review of cyber security vulnerabilities, threats, attacks, and solutions," *Electronics*, vol. 12, no. 6, p. 1333, 2023. 92

[360] S. Mishra, M. A. Alowaidi, and S. K. Sharma, "Impact of security standards and policies on the credibility of e-government," *Journal of Ambient Intelligence and Humanized Computing*, pp. 1–12, 2021. 92

[361] N. AllahRakha, "Cybersecurity regulations for protection and safeguarding digital assets (data) in today's worlds," *Lex Scientia Law Review*, vol. 8, no. 1, pp. 405–432, 2024. 92

[362] C. Tayaksi, E. Ada, Y. Kazancoglu, and M. Sagnak, "The financial impacts of information systems security breaches on publicly traded companies: reactions of different sectors," *Journal of Enterprise Information Management*, vol. 35, no. 2, pp. 650–668, 2022. 92

[363] R. D. Banker and C. Feng, "The impact of information security breach incidents on cio turnover," *Journal of Information Systems*, vol. 33, no. 3, pp. 309–329, 2019. 92

[364] L. Almeida and A. Respício, "Decision support for selecting information security controls," *Journal of Decision Systems*, vol. 27, no. sup1, pp. 173–180, 2018. 92

[365] M. Lehto, "Cyber-attacks against critical infrastructure," in *Cyber security: Critical infrastructure protection*, pp. 3–42, Springer, 2022. 92

[366] C. Asbaş and Ş. Tuzlukaya, "Cyberattack and cyberwarfare strategies for businesses," in *Conflict Management in Digital Business*, pp. 303–328, Emerald Publishing Limited, 2022. 92

[367] G. Stamenkov, "Cloud service models, business continuity and disaster recovery plans, and responsibilities," *International Journal of Organizational Analysis*, vol. 33, no. 3, pp. 437–451, 2025. 92

[368] R. Nayak, U. Ghugar, P. Gupta, S. Dash, and N. Gupta, "Data privacy and compliance in information security," *Securing the Digital Frontier: Threats and Advanced Techniques in Security and Forensics*, pp. 17–33, 2025. 92

[369] A. Noah, L. Moon, and A. John, "The consequences of non-compliance with data protection regulations on business analytics," *Tech.*, 2024. 92

[370] M. Ebute, "Continuous monitoring and assessment mechanisms in cybersecurity: Best practices for sustained protection of critical assets," *Available at SSRN 4912624*, 2024. 92

[371] D. Moon and J. P. Krahel, "Continuous risk monitoring and assessment: New component of continuous assurance," *Journal of Emerging Technologies in Accounting*, vol. 17, no. 2, pp. 173–200, 2020. 92

[372] D. Ajish, "The significance of artificial intelligence in zero trust technologies: a comprehensive," *Journal of Electrical Systems and Information Technology*, 2024. 92

[373] R. M. Czekster, "Continuous risk assessment in secure devops," *arXiv preprint arXiv:2409.03405*, 2024. 92

[374] H. O. Bello, C. Idemudia, and T. V. Iyelolu, "Navigating financial compliance in small and medium-sized enterprises (smes): overcoming challenges and implementing effective solutions," *World Journal of Advanced Research and Reviews*, vol. 23, no. 1, pp. 042–055, 2024. 92

[375] L. Qudus, "Cybersecurity governance: Strengthening policy frameworks to address global cybercrime and data privacy challenges," *International Journal of Science and Research Archive*, 2025. 92, 94, 119

[376] E. D. Knapp, *Industrial Network Security: Securing critical infrastructure networks for smart grid, SCADA, and other Industrial Control Systems*. Elsevier, 2024. 93

[377] J. M. Borky, T. H. Bradley, J. M. Borky, and T. H. Bradley, "Protecting information with cybersecurity," *Effective model-based systems engineering*, pp. 345–404, 2019. 93

[378] M. R. Rahman and L. Williams, "An investigation of security controls and mitre att\&ck techniques," *arXiv preprint arXiv:2211.06500*, 2022. 93

[379] N. B. Lucila Jr, "Securing user experience: A survey on information security controls in a higher education institution," *International Journal of Information Security (IJIS)*, vol. 3, no. 1, pp. 33–46, 2024. 93

[380] D. Tykholaz, R. Banakh, L. Mychuda, A. Piskozub, and R. Kyrychok, "Incident response with aws detective controls," *Cybersecurity Providing in Information and Telecommunication Systems II 2024*, vol. 3826, pp. 190–197, 2024. 93

[381] P. Y. Lartey, Y. Kong, F. B. M. Bah, R. J. Santosh, and I. A. Gumah, "Determinants of internal control compliance in public organizations; using preventive, detective, corrective and directive controls," *International Journal of Public Administration*, vol. 43, no. 8, pp. 711–723, 2020. 93

[382] S. Pochu and S. R. Kathram, "Integrating security requirements into software development: A comprehensive approach to secure software design," *Journal for Multidisciplinary Research*, vol. 1, no. 03, pp. 60–76, 2024. 93

[383] S. Reddy and S. R. Kathram, "Secure by design: Embedding security protocols in the software quality assurance lifecycle," *Journal of Multidisciplinary Research (JOMR)*, vol. 8, no. 01, pp. 38–50, 2022. 93

[384] V. Viegas and O. Kuyucu, "International security standards," in *IT Security Controls: A Guide to Corporate Standards and Frameworks*, pp. 17–65, Springer, 2022. 93

[385] S.-F. Wen and B. Katt, "A quantitative security evaluation and analysis model for web applications based on owasp application security verification standard," *Computers & Security*, vol. 135, p. 103532, 2023. 93

[386] S. W. A. Hamdani, H. Abbas, A. R. Janjua, W. B. Shahid, M. F. Amjad, J. Malik, M. H. Murtaza, M. Atiquzzaman, and A. W. Khan, "Cybersecurity standards in the context of operating system: Practical aspects, analysis, and comparisons," *ACM Computing Surveys (CSUR)*, vol. 54, no. 3, pp. 1–36, 2021. 93

[387] Z. Sun, J. Zhang, H. Yang, and J. Li, "Research on the effectiveness analysis of information security controls," in *2020 IEEE 4th Information Technology, Networking, Electronic and Automation Control Conference (ITNEC)*, vol. 1, pp. 894–897, 2020. 93

[388] D. J. Edwards, *Security Policies and Procedures*, ch. 7, pp. 413–434. Berkeley, CA: Apress, 2024. 93

[389] D. Landoll, "The security risk assessment handbook: A complete guide for performing security risk assessments (3rd ed.)," in *The Security Risk Assessment Handbook: A Complete Guide for Performing Security Risk Assessments (3rd ed.)*, pp. 1–555, 2021. 93

[390] L. Johnson, *Security controls evaluation, testing, and assessment handbook*. Academic Press, 2019. 93

[391] C. Schmitz, M. Schmid, D. Harborth, and S. Pape, "Maturity level assessments of information security controls: An empirical analysis of practitioners assessment capabilities," *Computers & Security*, vol. 108, p. 102306, 2021. 94

[392] D. Schlette, M. Caselli, and G. Pernul, "A comparative study on cyber threat intelligence: The security incident response perspective," *IEEE Communications Surveys & Tutorials*, vol. 23, no. 4, pp. 2525–2556, 2021. 94

[393] A. Staves, T. Anderson, H. Balderstone, B. Green, A. Gouglidis, and D. Hutchison, "A cyber incident response and recovery framework to support operators of industrial control systems," *International Journal of Critical Infrastructure Protection*, vol. 37, p. 100505, 2022. 94

[394] U. Patel, "The role of next-generation firewalls in modern network security: A comprehensive analysis," *INTERNATIONAL JOURNAL OF ADVANCED RESEARCH IN ENGINEERING AND TECHNOLOGY (IJARET)*, vol. 15, p. 135–154, Aug. 2024. 94

[395] K. Coulibaly, "An overview of intrusion detection and prevention systems," *arXiv*, 2020. 94

[396] P. Thanapat and C. Gamon, "Vulnerability assessment analysis in open source code management within business environments," *Idea: Future Research*, vol. 1, p. 58–65, Jul. 2023. 94

[397] G. Ellenberg, "A framework for implementing effective security controls in cloud computing environments," *Journal ID*, vol. 9471, p. 1297, 2021. 94, 119

[398] Y. You, J. Lee, J. Oh, and K. Lee, "A review of cyber security controls from an ics perspective," in *2018 International Conference on Platform Technology and Service (PlatCon)*, pp. 1–6, IEEE, 2018. 94, 119

[399] A. Kanaan, A. AL-Hawamleh, M. Aloun, A. Alorfi, and M. Abdalwahab Alrawashdeh, "Fortifying organizational cyber resilience: an integrated framework for business continuity and growth amidst escalating threat landscapes," *International Journal of Computing and Digital Systems*, vol. 16, no. 1, pp. 1–13, 2024. 94, 119

[400] K. Loncar, J. Redzepagic, and V. Dakic, "Secure coding guidelines and standards.," *Annals of DAAAM & Proceedings*, vol. 35, 2024. 95, 119

[401] M. Bach-Nutman, "Understanding the top 10 owasp vulnerabilities," *arXiv preprint arXiv:2012.09960*, 2020. 95

[402] M. Willberg, "Web application security testing with owasp top 10 framework," *THESEUS*, 2019. 95

[403] L. M. Restrepo-Tamayo and G. P. Gasca-Hurtado, "Gamified focus group for empirical research in software engineering: A case study," in *European Conference on Software Process Improvement*, pp. 59–71, Springer, 2023. 95

[404] J. Kontio, J. Bragge, and L. Lehtola, "The focus group method as an empirical tool in software engineering," in *Guide to advanced empirical software engineering*, pp. 93–116, Springer, 2008. 95, 96

[405] L. von Kurnatowski, A. Meinecke, and A. Rieger, "Towards using focus groups to identify software developer's interests regarding their development process," in *2022 IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER)*, pp. 1266–1269, IEEE, 2022. 95, 126

[406] L. Llerena, N. Rodríguez, J. W. Castro, and S. T. Acuña, "Adoption of the focus groups technique in the open source software development process," in *Human-Computer Interaction. User Interface Design, Development and Multimodality: 19th International Conference, HCI International 2017, Vancouver, BC, Canada, July 9-14, 2017, Proceedings, Part I 19*, pp. 325–340, Springer, 2017. 95

[407] J. Kontio, L. Lehtola, and J. Bragge, "Using the focus group method in software engineering: obtaining practitioner and user experiences," in *Proceedings. 2004 International Symposium on Empirical Software Engineering, 2004. ISESE'04.*, pp. 271–280, IEEE, 2004. 96

[408] C. B. Seaman, "Qualitative methods in empirical studies of software engineering," *IEEE Transactions on software engineering*, vol. 25, no. 4, pp. 557–572, 1999. 98

[409] B. Dong and X. Wang, "Comparison deep learning method to traditional methods using for network intrusion detection," in *2016 8th IEEE international conference on communication software and networks (ICCSN)*, pp. 581–585, IEEE, 2016. 114

[410] S. Almuhammadi and M. Alsaleh, "Information security maturity model for nist cyber security framework," *Computer Science & Information Technology (CS & IT)*, vol. 7, no. 3, pp. 51–62, 2017. 114

[411] F. J. González, E. Aguirre-Anaya, M. Salinas-Rosales, and A. Miyaji, "Identification of static and dynamic security controls using machine learning," *Computación y Sistemas*, vol. 27, no. 2, pp. 581–592, 2023. 114

[412] T. Sobb, B. Turnbull, and N. Moustafa, "Supply chain 4.0: A survey of cyber security challenges, solutions and future directions," *Electronics*, vol. 9, no. 11, p. 1864, 2020. 114

[413] G. Beuchelt, "Information technology security management," in *Computer and Information Security Handbook*, pp. 475–508, Elsevier, 2025. 114

[414] G. Culot, F. Fattori, M. Podrecca, and M. Sartor, "Addressing industry 4.0 cybersecurity challenges," *IEEE Engineering Management Review*, vol. 47, no. 3, pp. 79–86, 2019. 114

[415] R. Sonani and V. Govindarajan, "Cloud integrated governance driven reinforcement framework for ethical and legal compliance in ai based regulatory enforcement," *Journal of Selected Topics in Academic Research*, vol. 1, no. 1, 2025. 115

[416] M. Lee, H. Kwon, and H. Yoon, "Compliance-driven cybersecurity planning based on formalized attack patterns for instrumentation and control systems of nuclear power plants," *Security and Communication Networks*, vol. 2022, no. 1, p. 4714899, 2022. 115

[417] V. Kalocsai, "How to redesign business processes in a compliance-driven way," *Eindhoven University of Technology*, 2019. 115

[418] T. Bollé, E. Casey, and M. Jacquet, "The role of evaluations in reaching decisions using automated systems supporting forensic analysis," *Forensic Science International: Digital Investigation*, vol. 34, p. 301016, 2020. 116

[419] K. Aiyenitaju, "The role of automation in devops: A study of tools and best practices," *THE SEUS*, 2024. 116

[420] D. Xin, E. Y. Wu, D. J.-L. Lee, N. Salehi, and A. Parameswaran, "Whither automl? understanding the role of automation in machine learning workflows," in *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems*, pp. 1–16, 2021. 116

[421] C. Van der Velden, C. Bil, and X. Xu, "Adaptable methodology for automation application development," *Advanced Engineering Informatics*, vol. 26, no. 2, pp. 231–250, 2012. 116

[422] D. Ajiga, P. A. Okeleke, S. O. Folorunsho, and C. Ezeigweneme, "The role of software automation in improving industrial operations and efficiency," *International Journal of Engineering Research Updates*, vol. 7, no. 1, pp. 22–35, 2024. 116

[423] G. S. Taylor, L. E. Reinerman-Jones, J. L. Szalma, M. Mouloua, and P. A. Hancock, "What to automate: Addressing the multidimensionality of cognitive resources through system design," *Journal of Cognitive Engineering and Decision Making*, vol. 7, no. 4, pp. 311–329, 2013. 117

[424] V. Garousi and M. V. Mäntylä, "When and what to automate in software testing? a multi-vocal literature review," *Information and Software Technology*, vol. 76, pp. 92–117, 2016. 117

[425] C. Schmitz, M. Schmid, D. Harborth, and S. Pape, "Maturity level assessments of information security controls: An empirical analysis of practitioners assessment capabilities," *Computers & Security*, vol. 108, p. 102306, 2021. 117

[426] W. M. Van Der Aalst, "Hybrid intelligence: to automate or not to automate, that is the question," *International Journal of Information Systems and Project Management*, vol. 9, no. 2, pp. 5–20, 2021. 117

[427] J. de la Torre-López, A. Ramírez, and J. R. Romero, "Artificial intelligence to automate the systematic review of scientific literature," *Computing*, vol. 105, no. 10, pp. 2171–2194, 2023. 117

[428] S. M. Alhidaifi, M. R. Asghar, and I. S. Ansari, "A survey on cyber resilience: Key strategies, research challenges, and future directions," *ACM computing surveys*, vol. 56, no. 8, pp. 1–48, 2024. 118

[429] M. Segovia-Ferreira, J. Rubio-Hernan, A. Cavalli, and J. Garcia-Alfaro, "A survey on cyber-resilience approaches for cyber-physical systems," *ACM Computing Surveys*, vol. 56, no. 8, pp. 1–37, 2024. 118

[430] S. Petrenko, *Cyber resilience*. River Publishers, 2022. 118

[431] G. Brennan, K. Joiner, and E. Sitnikova, "Architectural choices for cyber resilience," *Australian Journal of Multi-Disciplinary Engineering*, vol. 15, no. 1, pp. 68–74, 2019. 118

[432] F. Kitsios, E. Chatzidimitriou, and M. Kamariotou, "The iso/iec 27001 information security management standard: how to extract value from data in the it sector," *Sustainability*, vol. 15, no. 7, p. 5828, 2023. 118

[433] W. Soliman and A. Ojalainen, "Conflict resolution in an iso/iec 27001 standard implementation: a contradiction management perspective," in *Proceedings of the 56thAnnual Hawaii International Conference on System Sciences*, pp. 1–10, University of Hawai'i at Manoa, 2023. 118

[434] T. Ghattas, *Exploring the Limitations of HIPAA in the 21st Century*. PhD thesis, CALIFORNIA STATE UNIVERSITY, NORTHRIDGE, 2020. 118

[435] J. L. Mutyaba, *Factors that Influence PCI DSS Noncompliance by Small and Medium-Size Merchants in the Hospitality Industry*. Capella University, 2023. 118

[436] S. Chippagiri and A. Ramesh, "Pci dss: A critical analysis of implementation, effectiveness, and legislative impact in payment card security," *International Journal of Scientific Research in Computer Science, Engineering and Information Technology*, 2025. 118

[437] Y. Smirnova and V. Travieso-Morales, "Understanding challenges of gdpr implementation in business enterprises: a systematic literature review," *International Journal of Law and Management*, vol. 66, no. 3, pp. 326–344, 2024. 118

[438] A. Aseri, "The implication of the european union's general data protection regulation (gdpr) on the global data privacy," *Journal of Theoretical and Applied Information Technology*, vol. 98, no. 04, 2020. 118

[439] A. Luthfi *et al.*, "Comparison study of nist sp 800-86 and iso/iec 27037 standards as a framework for digital forensic evidence analysis," *Journal of Information Systems and Informatics*, vol. 6, no. 2, pp. 701–718, 2024. 118

[440] L. O. Mailloux, P. M. Beach, and M. T. Span, "Examination of security design principles from nist sp 800-160," in *2018 Annual IEEE International Systems Conference (SysCon)*, pp. 1–8, IEEE, 2018. 118

[441] A. Sy, "Analysing some issues with sox," *International Journal of Auditing Technology*, vol. 1, no. 1, pp. 18–25, 2013. 118

[442] D. Utomo, M. Wijaya, S. Suzanna, E. Efendi, and N. T. M. Sagala, "Leveraging cobit 2019 to implement it governance in sme context: A case study of higher education in campus a," *CommIT (Communication and Information Technology) Journal*, vol. 16, no. 2, pp. 129–141, 2022. 118

[443] M. Rubino *et al.*, "A comparison of the main erm frameworks: how limitations and weaknesses can be overcome implementing it governance," *International Journal of Business and Management*, vol. 13, no. 12, pp. 203–214, 2018. 118

[444] A. M. Prosser, L. N. Heung, L. Blackwood, S. O'Neill, J. W. Bolderdijk, and T. Kurz, "'talk amongst yourselves': designing and evaluating a novel remotely-moderated focus group methodology for exploring group talk," *Qualitative Research in Psychology*, vol. 21, no. 1, pp. 1–43, 2024. 120

[445] S. Mishra and R. Ramesh, "A software solution to facilitate moderation, observation and analysis in a focused group interview (fgi)," in *2013 IEEE Fifth International Conference on Technology for Education (t4e 2013)*, pp. 9–12, IEEE, 2013. 120

[446] I. Salman, B. Turhan, and S. Vegas, "A controlled experiment on time pressure and confirmation bias in functional software testing," *Empirical Software Engineering*, vol. 24, pp. 1727–1761, 2019. 121

[447] B. McSweeney, "Fooling ourselves and others: confirmation bias and the trustworthiness of qualitative research–part 1 (the threats)," *Journal of Organizational Change Management*, vol. 34, no. 5, pp. 1063–1075, 2021. 121

[448] T. O. Abrahams, O. A. Farayola, O. O. Amoo, B. S. Ayinla, F. Osasona, and A. Atadoga, "Continuous improvement in information security: A review of lessons from superannuation cybersecurity uplift programs," *International Journal of Science and Research Archive*, vol. 11, no. 1, pp. 1327–1337, 2024. 122

[449] F. Jimmy, "Cloud security posture management: tools and techniques," *Journal of Knowledge Learning and Science Technology ISSN: 2959-6386 (online)*, vol. 2, no. 3, 2023. 123

[450] S. Sharma, S. S. Agrawal, and S. A. Kumar, "Unlocking cybersecurity horizons: Exploring cutting-edge technologies, strategies, and trends in the dynamic cyber threat landscape," in *2024 International Conference on Intelligent Computing and Emerging Communication Technologies (ICEC)*, pp. 1–6, IEEE, 2024. 123

[451] A. Goni, M. U. F. Jahangir, and R. R. Chowdhury, "A study on cyber security: Analyzing current threats, navigating complexities, and implementing prevention strategies," *International Journal of Research and Scientific Innovation*, vol. 10, no. 12, pp. 507–522, 2024. 123

[452] A. Folorunso, V. Mohammed, I. Wada, and B. Samuel, "The impact of iso security standards on enhancing cybersecurity posture in organizations," *World Journal of Advanced Research and Reviews*, vol. 24, no. 1, pp. 2582–2595, 2024. 123

[453] M. Otieno, D. Odera, and J. E. Ounza, "Theory and practice in secure software development lifecycle: A comprehensive survey," *World Journal of Advanced Research and Reviews*, vol. 18, no. 3, pp. 053–078, 2023. 124

[454] M. R. Rahman, B. Wroblewski, M. Tamanna, I. Rahman, A. Anufryienak, and L. Williams, "Towards a taxonomy of challenges in security control implementation," in *2024 Annual Computer Security Applications Conference (ACSAC)*, pp. 61–75, IEEE, 2024. 124

[455] N. M. Mohammed, M. Niazi, M. Alshayeb, and S. Mahmood, "Exploring software security approaches in software development lifecycle: A systematic mapping study," *Computer Standards & Interfaces*, vol. 50, pp. 107–115, 2017. 124

[456] R. Shu, P. Wang, S. A. Gorski III, B. Andow, A. Nadkarni, L. Deshotels, J. Gionta, W. Enck, and X. Gu, "A study of security isolation techniques," *ACM Computing Surveys (CSUR)*, vol. 49, no. 3, pp. 1–37, 2016. 124

[457] M. Alwaheidi, *A Data-Driven Threat Modelling Language for Ensuring Cyber Security Assurance*. PhD thesis, University of East London, 2024. 124

[458] M. Nicho, "A process model for implementing information systems security governance," *Information & Computer Security*, vol. 26, no. 1, pp. 10–38, 2018. 124

[459] A. Joseph *et al.*, "A holistic framework for unifying data security and management in modern enterprises," *International Journal of Social and Business Sciences*, vol. 17, no. 10, pp. 602–609, 2023. 124

[460] R. Prikladnicki, A. Boden, G. Avram, C. R. de Souza, and V. Wulf, "Data collection in global software engineering research: learning from past experience," *Empirical Software Engineering*, vol. 19, pp. 822–856, 2014. 125

[461] P. E. Strandberg, E. P. Enoiu, W. Afzal, D. Sundmark, and R. Feldt, "Information flow in software testing–an interview study with embedded software engineering practitioners," *IEEE Access*, vol. 7, pp. 46434–46453, 2019. 125

[462] C. Treude, "Qualitative data analysis in software engineering: Techniques and teaching insights," in *Handbook on Teaching Empirical Software Engineering*, pp. 155–176, Springer, 2024. 126

[463] K. Goseva-Popstojanova, T. Kyanko, and N. Nkwocha, "Benefits and challenges of model-based software engineering: Lessons learned based on qualitative and quantitative findings," in *2019 IEEE 30th International Symposium on Software Reliability Engineering (ISSRE)*, pp. 413–423, IEEE, 2019. 126

[464] M. E. Kiger and L. Varpio, "Thematic analysis of qualitative data: Amee guide no. 131," *Medical teacher*, vol. 42, no. 8, pp. 846–854, 2020. 126

[465] P. Lenberg and R. Feldt, "Psychological safety and norm clarity in software engineering teams," in *Proceedings of the 11th international workshop on cooperative and human aspects of software engineering*, pp. 79–86, 2018. 126

[466] A. Taghavi and C. Woo, "The role clarity framework to improve requirements gathering," *ACM Transactions on Management Information Systems (TMIS)*, vol. 8, no. 2-3, pp. 1–16, 2017. 126

[467] N. Luburić, G. Sladić, and B. Milosavljević, "Applicability issues in security requirements engineering for agile development," in *Proceedings/8 th International conference on applied internet and information technologies*, vol. 8, pp. II–VII, "St Kliment Ohridski" University-Bitola, Faculty of Information and . . . , 2018. 126

[468] K. M. Adams and K. M. Adams, "Adaptability, flexibility, modifiability and scalability, and robustness," *Nonfunctional Requirements in Systems Analysis and Design*, pp. 169–182, 2015. 126

[469] D. Ajiga, P. A. Okeleke, S. O. Folorunsho, and C. Ezeigweneme, "Methodologies for developing scalable software frameworks that support growing business needs," *Int. J. Manag. Entrep. Res*, vol. 6, pp. 2661–2683, 2024. 126

[470] D. Pflüger, M. Mehl, J. Valentin, F. Lindner, D. Pfander, S. Wagner, D. Graziotin, and Y. Wang, "The scalability-efficiency/maintainability-portability trade-off in simulation software engineering: Examples and a preliminary systematic literature review," in *2016 Fourth International Workshop on Software Engineering for High Performance Computing in Computational Science and Engineering (SE-HPCCSE)*, pp. 26–34, IEEE, 2016. 126

[471] S. Karunaratne and D. Dharmarathna, "A review of comprehensiveness, user-friendliness, and contribution for sustainable design of whole building environmental life cycle assessment software tools," *Building and Environment*, vol. 212, p. 108784, 2022. 126

[472] S. Hu, B. Hua, and Y. Wang, "Comprehensiveness, automation and lifecycle: A new perspective for rust security," in *2022 IEEE 22nd International Conference on Software Quality, Reliability and Security (QRS)*, pp. 982–991, IEEE, 2022. 126

Appendix A

List of Publications

- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Integrating Security Controls in DevSecOps: Challenges, Solutions, and Future Research Directions*", Journal of Software: Evolution and Process, 2025.
- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Implementing and Integrating Security Controls: A Practitioners' Perspective*", Computers & Security, 2025 (**SCImago-Q1**).
- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Towards Resilient Security: A Structured Framework for Security Control Lifecycle Management*", International Journal of Information Security, 2025 (*Under Review*).
- **Maysa Sinan**, Mojtaba Shahin, Iqbal Gondal, "*Validation of a Governance Framework Supporting Security Controls across Emerging Systems*", The IEEE TrustCom (24th IEEE International Conference on Trust, Security and Privacy in Computing and Communications) in China, 2025.

Appendix B

Survey Instrument

What was the purpose of conducting the survey?

This survey was undertaken as part of Maysa Sinan (PhD Research Program - RMIT), with the supervision of Prof Iqbal Gondal, and Dr Mojtaba Shahin ((School of Computing Technologies – RMIT). The aim of this research project was to investigate the challenges and issues related to security controls within the adoption and implementation of DevSecOps practices. The research aims to identify the current state of DevSecOps and the challenges that have been experienced by security analysts and practitioners and identified in the literature. You are invited to participate in this research project because you are either a security analyst or practitioner in an organization that operates cybersecurity and utilizes security controls as safeguards to regulate software systems and products.

What did participation involve?

Participation involved completing an anonymous questionnaire with primarily 'yes' - 'no', or 'select a box' answers, and some Likert scale answers (strongly agree – strongly disagree) that will take approximately 20 minutes of your time. Questions will include:

- What industry is your company in? (Select one)
- What is your job title? (Select one)
- Are you involved with identifying and managing security controls for cybersecurity related?
- practices and activities within your organization? (Select one)

• Your participation in this research project is entirely voluntary. If you agree to participate you do not have to complete any question(s) you are uncomfortable answering. Your decision to participate or not participate will in no way impact upon your current or future relationship with your company or RMIT or associated external organization. If you do agree to participate you can withdraw from the research project before commencing or completing the online questionnaire without comment or penalty. Any information already obtained that can be linked to you will be destroyed. However, as the questionnaire is anonymous once it has been submitted it will not be possible to withdraw. You will be able to review your responses before submitting and save a copy of your responses after submitting the survey. A partially completed survey, i.e., one where the participant does not click to submit, will not be considered

What are the possible benfits for you if you take the survey?

It is expected that this research project will benefit you directly through enabling you to have a better understanding of how cybersecurity controls are being implemented and managed in your organization, along with a new learning on DevSecOps practices. Any research papers drawn from the research, when available, will be made available online when published.

What are the possible risks for you if you take the survey?

There are no risks beyond normal day-to-day living associated with your participation in this research project.

What about privacy and confidentiality?

All comments and responses are anonymous i.e., it will not be possible to identify you at any stage of the research, because personal identifying information is not sought in any of the responses. Any data collected as part of this research project will be stored securely as per RMIT Management of research data policy. Data will be stored for a minimum of 5 years and can be disclosed if it is to protect you or others from harm, if specifically required by law, or if a regulatory or monitoring body such as the ethics committee requests it.

How do you give consent to participate in the survey?

The submission of the completed survey is accepted as an indication of your consent to participate in this research project. A partially completed survey, i.e., one where the participant does not click to submit, will not be considered.

Contact the Research Team

- **Principal Researcher**: Maysa Sinan, PhD Research Student
- **Associate Researcher**: Professor Iqbal Gondal
- **Associate Researcher**: Dr. Mojtaba Shahin
  School of Computing Technologies, RMIT University.

General Information on DevSecOps

DevSecOps (Development, Security and Operations) can be defined as a trendy paradigm in the Cybersecurity industry, comprising a set of principles and practices that integrate and embed advanced security measures within the DevOps (Development and Operations) pipelines. The main goal of DevSecOps is to ensure that security controls and essential measures are well-considered, managed at early stages in the Software Development Lifecycle (SDLC), and never handled as a bottleneck or a separate burden. DevSecOps promotes effective collaboration between all team members from different departments, with the aim of creating a culture of shared responsibility for security where every involved engineer/developer takes ownership of security concerns along with his/her software code.

Security Controls are measures established to protect organizational data, information systems, and software assets from risks and being exploited by security threats. These controls can be defined as the

fundamental safeguards by which the company can handle and mitigate various types of security threats and vulnerabilities. Through the integration of security controls into every stage of the development pipeline, the organization can reduce security risks, respond to malicious cyber-attacks quickly, spot vulnerabilities earlier before they get hard or costly to fix, and deliver more secure software to end-users. It is important to learn how to manage security controls during the adoption of DevSecOps practices and embedding security at the early stages of the Software Development Lifecycle (SDLC).

Demographic Questions:

Q1) Which industry do you work in? (Select one)

1. Governmental sector
2. Learning and Education
3. Financial sector and banks
4. Legal advisors and consulting
5. Insurance organizations
6. Healthcare and social assistance
7. Marketing and advertising
8. IT Consulting companies
9. Cybersecurity companies
10. Other (please specify)

Q2) What is your job title? (Select one)

1. CEO / Managing Director / President
2. Director / Vice President
3. Manager / Supervisor / Project Manager
4. Technology Consultant
5. Security Practitioner (e.g., Security Engineer, Security Architect, Security Analyst)
6. Software Engineer / Designer / Developer
7. DevOps Engineer
8. Other (please specify)

Q3) How many years have you been in your current role?

1. Less than a year
2. 1-3 years
3. 3-5 years
4. 5-8 years
5. 8-15 years
6. More than 15 years

Q4) What certifications do you hold in Cybersecurity? (Select all that apply)

1. Computer Emergency Response Team (CERT)
2. CompTIA Advanced Security Practitioner (CASP+)
3. Chief Information Security Officer (CISO)
4. Certified Ethical Hacker (CEH)

5. Certified in the Governance of Enterprise IT (CGEIT)
6. Cybersecurity and Infrastructure Security Agency (CISA) or equivalent
7. Certified Information Security Manager (CISM) or equivalent
8. Certificate in Information Security Management Principles (CISMP) or equivalent
9. Certified Information Systems Security Professional (CISSP) or equivalent
10. Certified in Risk and Information Systems Control® (CRISC®) or equivalent
11. Cybersecurity Practitioner (CSXP) or equivalent
12. GIAC Certified Penetration Tester (GPEN) or equivalent
13. GIAC Security Essentials Certification (GSEC) or equivalent
14. Network+ or equivalent
15. Offensive Security Certified Professional certification (OSCP) or equivalent
16. Security+ or equivalent
17. Systems Security Certified Practitioner (SSCP) or equivalent
18. Other (please specify, separate with commas)

Survey Questionnaire

Q5) Has your organization put in place security controls and measurements to monitor security breaches? If yes, then how? (Select all that apply)

1. In-house identified security controls
2. Outsourced controls implemented through a third party or service provider
3. No security controls are in place
4. Other (please specify)

Q6) Which departments in your organization manage and monitor security controls? (Select all that apply)

1. Incident Response (IR) Department
2. Risk Management
3. Compliance and Governance Department
4. Identity and Access Management (IDAM)
5. Security Operations Center (SOC)
6. Middle management and business owners
7. Executive leadership (Board of Directors)
8. Legal department
9. IT Security team
10. Not sure / can't disclose
11. Other (please specify)

Q7) Security controls are categorized into several types: administrative, technical, physical, human, detective, and corrective controls. Which of the following administrative security controls do you employ in your organization? (Select all that apply)

1. Policies and Procedures: Establish security policies and guidelines to govern how employees should handle data and access systems.

2. Security Awareness Training: Educate employees about security practices and their responsibilities for safeguarding data and organizational assets.
3. Access Control Management: Manage access requests to systems and data through account provisioning, deprovisioning, and user access reviews.
4. Incident Response Management: Develop plans and remediation workarounds to respond to security incidents and breaches.
5. Others (Specify)

Q8) Which of the following technical security controls do you employ in your organization? (Select all that apply)

1. Authentication: Verify the identity of users who try to access systems and resources using passwords or multi-factor authentication (MFA) mechanisms.
2. Firewalls: Implement security devices to filter network traffic, and control incoming and outgoing traffic with the aim of preventing unauthorized access.
3. Encryption: Protect organizational data by transferring it into unreadable formats that can only be decrypted by authorized logins.
4. Intrusion Detection and Prevention Systems (IDS/IPS): Monitor network traffic for suspicious activities and take action to block and/or alert potential threats.
5. Antivirus and Anti-malware Software: Scan for malicious software and remove once found in the systems.
6. Patch Management: Ensure that software and systems are kept up to date with the latest security patches and updates.
7. Vulnerability Scanning: Identify and assess vulnerabilities in systems and applications.
8. Security Information and Event Management (SIEM): Collect and analyze login files to detect security incidents.
9. Access Control Lists (ACLs): Configure permissions and restrictions on files and directories.
10. Others (Specify)

Q9) Which of the following physical security controls do you employ in your organization? (Select all that apply)

1. Biometric Access Systems: Use fingerprint or retina scans for physical access control.
2. Surveillance Systems: Employ cameras and monitoring equipment to monitor and record physical access.
3. Environmental Controls: Maintain safe physical environments to protect your hardware, such as temperature and humidity control, fire suppression, and backup power systems.
4. Others (Specify)

Q10) Which of the following human security controls do you employ in your organization? (Select all that apply)

1. Background Checks and Screening: Ensure that individuals who are hired for positions with access to sensitive information undergo security checks.
2. User Training and Awareness Programs: Educate employees about security practices, trendy methods, and the importance of their roles in maintaining security.

3. User Account Management: Properly manage user accounts including provisioning, deprovisioning, and enforcing password policies.
4. Others (Specify)

Q11) Which of the following detective security controls do you employ in your organization? (Select all that apply)

1. Log and Audit Trail Analysis: Review logs and audit trails to detect unauthorized activities.
2. Intrusion Detection Systems (IDS): Monitor for signs of unauthorized access or attacks.
3. Others (Specify)

Q12) Which of the following corrective security controls do you employ in your organization? (Select all that apply)

1. Maintain the CIA (Confidentiality, Integrity, Availability) Triad: Establish specific controls to maintain the security principles for data and information systems.
2. Risk Management Plan: Implement security controls based on risk plans and solid assessments following the security needs of your organization.
3. Incident Response Plans: Execute remediation plans and procedures that respond to security incidents and data breaches.
4. Recovery Procedures and Backups: Implement strategies to recover organizational data and create secure backups for systems in case of data loss, breaches, or system compromise.
5. Others (Specify)

Q13) During the process of identifying security controls, which of the following points you were considered? (Select all that apply)

1. Provide meaningful descriptions of controls to ensure they are understood and verified for effectiveness.
2. Specify clear ownerships and specific managers assigned to execute security controls.
3. Determine the place of execution; whether to be executed offsite or by a third party.
4. Specify the occurrence parameters (runtime triggers) for security controls.
5. Indicate the key inputs (parameters) for each security control.
6. Perform essential security practices, such as, risk management, vendor actions/controls, projects/business initiatives, and regulatory/structural changes.
7. Other (please specify).

Q14) When does your organization execute security controls?

1. At requirement phase
2. At design time
3. At runt timw
4. Other (Specify)

Q15) How often are security controls performed?

1. Monthly
2. Quarterly
3. Semi-yearly
4. Yearly
5. Other (Specify)

Q16) The 'trigger runtime' refers to the instance when a specific event or condition occurs resulting in initiating security control to execute. What is the trigger runtime in your organization?

1. Automation Process: A trigger runtime points to the time when a pre-defined event occurs, for example, a form submitted, a change detected, or an email received.
2. Event-Driven Program: A trigger runtime happens with a specific event, such as, a button clicked by a user, or a message placed in the queue.
3. Database Systems: The trigger is initially invoked by a set of actions that are automatically executed in response to a database event like system updates.
4. Cloud Services: Triggers are predefined to execute once a file is uploaded into clouds or serverless architectures.
5. IoT (Internet of Things): Trigger runtimes are associated with sensor readings, for example, the thermostat triggers heating systems whenever the temperature falls below a certain threshold.
6. Other (Specify).

Q17) Verifying security controls is an essential aspect of maintaining security in the organization. This process involves ensuring that controls are thoroughly integrated and implemented to protect and safeguard organizational assets against evolving threats and vulnerabilities. Is there a regular validation process implemented on security controls in your organization?

1. Yes (Go to Question 14)
2. No (Go to Question 17)

Q18) How often are the controls validated in your organization?

1. Monthly
2. Quarterly
3. Semi-yearly
4. Yearly

Q19) Who performs the auditing/validation process on security controls in your organization?

1. In-house administrative department that manages security controls in your origination.
2. Client Services Centre, e.g., helpdesk or technical support divisions.
3. Self-auditing in each department (division)
4. Other (please specify)

Q20) Which of the following tasks are carried out during the validation process? (Select all that apply)

1. Understand the scope, main objective and expected outcome of each control in alignment with the organization's security policies.
2. Review all documentation related to security controls including procedures, standards, and guidelines in accordance with regulatory requirements of the industry.
3. Keep all security documentation up to date and version controlled.
4. Review the implementation of each control including configuration checks, access control lists, and network diagrams.
5. Carry out vulnerability assessment, code management and penetration tests to determine weaknesses and areas of malfunctions.
6. Revise the effectiveness of Incident Response (IR) plan.
7. Develop remediation workarounds to address issues and respond to vulnerabilities.
8. Ensure all users are aware of cybersecurity and always compliant with security policies.
9. Ensure that security controls comply with security standards and align with the regulatory requirements in the industry (e.g., GDPR, HIPAA, ISO 27001).
10. Apply continuous monitoring to track the performance of controls through security information and event management (SIEM) and intrusion detection systems (IDS).
11. Enforce continuous improvement and use the feedback received after each validation.
12. Generate reports that summarize the results of the validation process and share the findings with managers and other stakeholders.
13. Other (specify)

Q21) Which user groups have the biggest influence on your security controls or pose the largest risk to your security controls? (Select up to 3)

1. Privileged business users
2. Privileged IT users /admins
3. Business partners
4. Regular employees
5. Contractors / service providers / temporary consultants
6. Executive managers
7. Other IT staff
8. Not sure
9. Other (please specify)

Q22) What are your plans to handle evolving security controls in the next 12 months? (Select all that apply)

1. Implement additional security controls and measurements.
2. Use security software programs from independent outsourced vendors.
3. Increase security awareness and improve IT staff capabilities through SETA (security education training) to become security experts and self-assess internal controls.
4. Partner with managed service providers who will provide the out-sourced security analysts.
5. Partner with current vendors and expand new contracts to assist in managing security controls.
6. Increase headcount and recruit new staff specialized in cybersecurity.

7. No change
8. Not sure
9. Other (please specify)

Q23) Which Cybersecurity regulations and privacy laws does your organization comply with? (Select all that apply)

1. Data Availability and Transparency Act 2022
2. Australian Cyber Security Centre (ACSC) Manual
3. Payment Card Industry Data Security Standard (PCI DSS)
4. Federal Information Security Management Act (FISMA)
5. Sarbanes-Oxley Act (SOX) Act
6. Baseline Security Analyzer (BSA)
7. Personal Information Protection and Electronic Documents Act (PIPEDA)
8. Health Insurance Portability and Accountability Act (HIPAA)
9. General Data Protection Regulation (GDPR)
10. Other (please specify)
11. Not sure

Q24) Which of the following practices have helped in improving the effectiveness of controls in your organization? (Select all that apply)

1. Execute penetration testing and vulnerability scanning to ensure the effect of controls in detecting vulnerabilities.
2. Be ready with solid Incident Response (IR) plans to demonstrate that controls simulate incidents properly.
3. Carry out intrusion detection and network security monitoring to uncover suspicious activities and anomalies.
4. Manage User Awareness Training to improve security competences in identifying and reporting attacks.
5. Apply regular reviews and audit access controls like authentication mechanisms and user access permissions to ensure only authorized users have access.
6. Apply firewall rules and network segmentation to control the traffic.
7. Conduct Security Information and Event Management (SIEM) analysis to provide valuable insights into security incidents.
8. Run/Monitor patch management to assure the proper execution of security patches.
9. Conduct regular compliance audits to verify that controls align with regulatory requirements and industry standards, e.g., ISO 27001, GDPR, HIPAA.
10. Engage in red team exercises where ethical hackers attempt to breach controls to address vulnerabilities.
11. Use Incident Response (IR) metrics like Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR). E.g., low MTTD/MTTR values indicate the efficiency of controls.
12. Track security metrics and key performance indicators (KPIs) like incident reduction rates and false positives/negatives.
13. Conduct security audits and regular assessments to identify areas where controls may need refinement.

14. Perform post-incident analysis after the occurrence of attacks to decide lessons learned.
15. Generate security control validation reports and share the results with managers and stakeholders.

Q25) Considering DevSecOps environment in your organization, how do you manage security controls? (Select all that apply)

1. Partner with managed service providers who provide cybersecurity resources
2. Train and/or certify current IT staff
3. Look at different (security-as-service) providers to outsource 24x7 monitoring facilities
4. Hire a new staff specialized in firewalls and cloud security
5. Use advanced security software from an independent software vendor
6. Not sure
7. Other (please specify)

Q26) Which security practices have you utilized during the implementation of DevSecOps? (Select all that apply)

1. Continuous Planning
2. Automated Deployment
3. Continuous Delivery
4. Security Continuous Integration (SCI)
5. Feedback iterative loops between Dev,Sec,Ops
6. Automated Testing
7. Automated Monitoring
8. Continuous Vulnerability Assessment and Remediation
9. Threat Intelligence and Investigation
10. Compliance Monitoring
11. SETA (Security, Education, Training, Awareness) methods
12. Other (please specify)

Appendix C

Guide on Conducting the Focus Groups

General Information

We conducted focus groups to gather in-depth insights and valuable data from the subject matter experts. First, we started by identifying the main goals and what exactly we want to get from those focus groups. Later, we came up with a data management plan to outline exactly how we will carry out the focus groups. Then, we developed the questions that will be asked in the sessions and attached mandatory documentation. Our human ethics application got approved by the Research Integrity Committee to run the focus groups and reach out to security practitioners. We allocated the participants into groups and got their consent forms signed off, later we did the logistics setup including the time slots that ranged between 60 to 75 minutes for each session allowing in-depth discussions without overwhelming the participants. Also, a quick test on Microsoft Teams was carried out to ensure the recording will work properly.

During the Focus Group, we began with an introduction about our research study explaining the objective of the session and assuring its confidentiality course. We started with direct questions to get participants comfortable, asking them about their roles, job responsibilities and years of experience in cyber security. We then used open-ended questions to encourage and facilitate the discussion, following up with related issues and challenges of integrating and implementing security controls within their organsations. We were keen to ensure all participants have the opportunity to speak and avoid injecting bias opinions into discussions. After checking the recorded sessions, we started to transcribe the sessions for easier analysis, and utilized thematic analysts to thoroughly Investigate received Feedback and look for recurring insights and divergent views about security controls.

General Questions on Security Controls

Q1) Which security controls do you consider fundamental in your organization?
Q2) How did you choose them?
Q3) How do you ensure security controls are properly and consistently applied?
Q4) Do you apply same security controls across all phases (design, development and deployment) in the SDLC? Do you have a separate list for each phase?
Q5) Can I perceive the list of your controls per phase?

Questions on Tools and Technologies

Q6) Which tools and technologies are you currently using to implement security controls?
Q7) What criteria do you use to select the tools for implementing security controls?

Questions on Current Practices and Challenges

Q8) Do you have a list of best practices that helped in building and integrating security controls?
Q9) What issues did you encounter while building security controls?
Q10) How did you mitigate those issues/challenges?
Q11) Did you have all the resources and frameworks needed to do your best work?
Q12) Can you mention some of them as an example?
Q13) What did you specifically learn from past projects to ensure the same mistakes don't arise in the future?

Questions on Security Control Validation

Q14) Do you carry out a regular process to validate implemented security controls, whether for the purpose of improving them or addressing new vulnerabilities?
Q15) What metrics do you use to measure the effectiveness of implemented security controls?
Q16) How do you follow up with stakeholders and team members to keep them in the loop and ensure they work in adherence with security controls?

Questions on Monitoring security controls for Regulatory and Security Compliance

Q17) How do you monitor and track implemented security controls to ensure they comply with security standards and regulatory requirements?
Q18) Do you have any concerns about aligning with NIST standards and other national regulations?

Questions on Directions and Future Opportunities

Q19) What future plans do you have to improve security controls in your organisations?
Q20) What is your vision for security controls in case you decide to adopt DevOps practices over the next few years?

Questions on Security Training and Culture

Q21) What training programs and/or resources do you provide your teams to ensure they are aware of compliance with security controls?
Q22) What is your strategy to foster a culture of security within your development and operation (DevOps) teams?

Questions on DevSecOps Methodology

Q23) What is your current understanding of DevSecOps practices?
Q24) Can you describe your experience with implementing DevSecOps practices in your organization?
Q25) How do you perceive the important role of DevSecOps in enhancing the implementation of security controls?
Q26) What tools and technologies do you recommend for integrating security controls into the DevOps

pipelines?
Q27) How do you envision the new role of DevSecOps engineer?

Questions on Team Collaboration and Communication

Q28) How has the adoption of DevSecOps methodology affected the collaboration between development, operations, and security teams in your organisation?
Q29) What communication channels/tools do you find effective to ensure security controls are integrated properly throughout the DevSecOps lifecycle?

Appendix D

Approved Human Ethics Application

Presented below is the ethics approval letter issued by the Human Research Ethics Committee, authorizing the conduct of the study, the distribution of surveys, facilitation of focus groups, and communication with practitioners and subject matter experts.

STEM College
College Human Ethics Advisory Network (CHEAN)
Email: humanethics@rmit.edu.au
Tel: [61 3] 9925 4620

Notice of Approval

Date:	**25 September 2023**
Project number:	25665
Project title:	*Challenges related to security controls during the adoption of DevSecOps*
Risk classification:	**Negligible/Low**
Principal investigator:	Professor Iqbal Gondal
Status:	**Approved**
Approval period:	From: **25/09/2023** To: **31/03/2025**

The above application has been approved by the RMIT University CHEAN as it meets the requirements of the *National Statement on Ethical Conduct in Human Research* (NHMRC, 2007).

Terms of approval:

1. **Responsibilities of principal investigator**
   It is the responsibility of the above principal investigator to ensure that all other investigators and staff on a project are aware of the terms of approval and to ensure that the project is conducted as approved by CHEAN. Approval is valid only whilst the principal investigator holds a position at RMIT University.
2. **Amendments**
   Approval must be sought from CHEAN to amend any aspect of a project. To apply for an amendment, submit a request for amendment form, via the Research Ethics Platform. Amendments must not be implemented without first gaining approval from CHEAN.
3. **Adverse events**
   You should notify the CHEAN immediately (within 24 hours) of any serious or unanticipated adverse effects of their research on participants, and unforeseen events that might affect the ethical acceptability of the project.
4. **Annual reports**
   Continued approval of this project is dependent on the submission of an annual report. Annual reports must be submitted by the anniversary of approval of the project for each full year of the project. If the project is of less than 12 months duration, then a final report only is required.

5. **Final report**
   A final report must be provided within six months of the end of the project. The CHEAN must be notified if the project is discontinued before the expected date of completion.
6. **Monitoring**
   Projects may be subject to an audit or any other form of monitoring by the CHEAN at any time.
7. **Retention and storage of data**
   The investigator is responsible for the storage and retention of original data according to the requirements of the *Australian Code for the Responsible Conduct of Research* (R22) and relevant RMIT policies.
8. **Special conditions of approval**
   Approved on condition that approval is sought and received from the NT Department of Education before research commences. Please provide this approval to the RMIT Human Ethics team once received.

In any future correspondence please quote the project number and project title above.

Yours faithfully,

Dr Lauren Saling
Chair, STEM College Human Ethics Advisory Network

Cc Student Investigator/s: Mrs Maysa Sinan
Other Investigator/s: Lecturer Mojtaba Shahin

Appendix E

List of Abbreviations / Acronyms

ACP	Access Control Policies
ACT	Activity
AES	Advanced Encryption Standard
AHP	Analytical Hierarchy Process
AI	Artificial Intelligence
AI Ops	Artificial Intelligence for IT Operations
API	Application Programming Interface
APM	Application Performance Management
APRA CPS	Australian Prudential Regulation Authority | Control Performance Standard
APTs	Advanced Persistent Threats
ASCA	Application Systems Control and Audit
AST	Automated Security Testing
CAPEC	Common Attack Pattern Enumeration and Classification
CCIE	Cisco Certified Internetwork Expert
CCM	Continuous Compliance Monitoring
CCPS	Cyber-Physical Production Systems
CCTV	Closed-Circuit Television
CD	Continuous Delivery
CDE	Common Data Environment
CEH	Certified Ethical Hackers
CFP	Calls for papers
CGEIT	Certified in the Governance of Enterprise IT
CH	Challenge
CI	Continuous Integration
CIA	Confidentiality, Integrity, Availability
CISM	Certified Information Security Manager
CIS	Critical Security Controls
CISA	Infrastructure Security Agency
CISO	Chief Information Security Officer
CISSP	Certified Information Systems Security Professional
COBIT	Control Objectives for Information and Related Technologies

Appendix F

CSE	Canary Sandbox Environment
CSES	Cyberspace Security Econometrics System
CSF	Cyber Security Framework
CSPM	Cloud Security Posture Management
CTA	Call to Action
CVE	Common Vulnerabilities and Exposures
DAST	Dynamic Application Security Testing
DevOps	Development, Operations
DevSecOps	Development, Security, Operations
DLP	Data Loss Prevention
DMP	Data Management Plan
DREAD	Damage, Reproducibility, Exploitability, Affected users, and Discoverability
EBSE	Evidence-Based Software Engineering
EBs	Ethical Barriers
ECC	Elliptic Curve Cryptography
EFs	Ethical Factors
EDR	Endpoint Detection and Response
FG	Focus Group
GCSP	Geneva Center for Security Policy
GDPR	General Data Protection Regulation
GRC	Governance, Risk, and Compliance
HIPAA	Health Insurance Portability and Accountability Act
HW	Hardware
IaC	infrastructure-as-code
IAM	Identity and Access Management
ICS	Industrial Control Systems
IDs	Identifiers
IDS	Intrusion Detection Systems
IEC	International Electrotechnical Commission
IEM	IaC Execution Manager
ISC2	International Information System Security Certification Consortium
ISMS	Information Security Management System

Appendix G

ISO/IEC	International Organization for Standardization/International Electrotechnical Commission
IoT	Internet of Things
IP	Intellectual Property
IPS	Intrusion Prevention Systems
IR	Incident Response
IRM	Incident Response Management
ISA	Instruction Set Architecture
ISCP	Information Security Control Prioritization
KB	Knowledge Base
MBE	Model-Based Engineering
MFA	Multi-Factor Authentication
ML	Machine Learning
MLR	Multivocal Literature Review
MFA	Multi-Factor Authentication
MTTD	Mean-Time-to-Detect
MTTR	Mean-Time-to-Respond
NFR	non-functional requirements
NID	Network Intrusion Detection
NIST CSF	National Institute of Standards and Technology | Cybersecurity Framework
NIST SP	National Institute of Standards and Technology | Special Publication
NLP	Natural Language Processing
OWASP	Open Web Application Security Projects
P (Chapter 2)	Paper
P (Chapters 4, 5)	Participant
PCI DSS	Payment Card Industry Data Security Standard
QA	Quality Assurance
R&D	Research and Development
RBAC	Role-Based Access Control
ROI	Return on Investment
RQ	Research Question
RSA	Rivest-Shamir-Adleman
SaC	Security-as-code

Appendix H

SAST	Static Application Security Testing
SACP	Security Content Automation Protocols
SCI	Security Continuous Integration
SCA	Security Control Assessment
SDaaS	Software Development as a Service
SEI CERT	The Software Engineering Institute | Computer Emergency Response Team
SETA	Security Education Training Awareness
SIEM	Security Information & Event Management
SLN	Solution
SLR	Systematic Literature Review
SMB	Small and medium-sized businesses
SMEs	Subject Matter Experts
SMSE	Security Management Systems Enterprises
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center
SoS	Systems of Systems
SOX	Sarbanes-Oxley Act
SRA	Security Risk Assessment
SRB	Security Review Board
SREs	Site Reliability Engineers
SSL	Secure Sockets Layer
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service (DoS), and Elevation of privilege
SW	Software
TGT	Trusted Computing Groups
TCT	Trusted Computing Technologies
TLS	Transport Layer Security
TOPSIS	Technique for Order Preference by Similarity to Ideal Solution
VPN	Virtual Private Networks
XCCDF	Extensible Configuration Checklist Description Format
ZTA	Zero Trust Architecture